Elko County Information Operations Policy Manual

Abstract / Executive Summary

Abstract

The Elko County Information Operations Policy Manual (maintained as the master *Policy_Manual.lyx* file) is the designated Authoritative System of Record for all governance controls, including the departmental security and service management standards defined herein. It establishes the mandatory frameworks required to ensure consistency, accountability, and compliance with applicable laws, regulations, and industry standards across the County's technology landscape.

Executive Summary

The policies contained herein are administratively mandatory and align the Department's strategic objectives with statutory requirements and industry control frameworks.

Compliance Alignment & Order of Precedence

The controls in this manual align with the following frameworks, listed in order of authority:

1. **State Law**: Nevada Revised Statutes (NRS), including Chapter 239 (Public Records), Chapter 205 (Computer Crimes), Chapter 603A (Security of Personal Information), and other applicable provisions.
2. **Administrative Regulation**: Nevada Administrative Code (NAC).
3. **Records Retention**: Nevada Local Government Records Management Program and mandatory retention schedules (Local Records Disposal Authority) under NRS 239.125.
4. **Law Enforcement Compliance**: FBI CJIS Security Policy Version 6.0.
5. **Security Controls**: NIST SP 800-53 Revision 5 (Security and Privacy Controls for Information Systems and Organizations).
6. **Strategic Risk**: NIST Cybersecurity Framework (CSF) 2.0.
7. **Risk Management**: NIST SP 800-37 Revision 2 (Risk Management Framework).
8. **Incident Response**: NIST SP 800-61 Revision 3 (Computer Security Incident Handling Guide).
9. **Governance**: COBIT 2019 (Governance and Management Objectives).
10. **Service Management**: ITIL v4 (Service Value System and Practices).

Additional Frameworks Referenced: NIST SP 800-181 Revision 1 (NICE Workforce Framework for Cybersecurity) and SFIA 9 (Skills Framework for the Information Age) are referenced for workforce role alignment under **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework) and do not participate in the authority resolution hierarchy above.

Authority and Scope

This manual, alongside the procedural library maintained in the System of Engagement, serves as the primary reference for governance, operational decision-making, audit defense, and interdepartmental service level agreements.

Compliance with these policies is mandatory for:

1. All Elko County Information Operations personnel.

2. All County employees, contractors, and vendors who access, administer, or support County information systems, infrastructure, or data governed by the Information Operations Department.

Deviations from these policies shall be managed through the formal exception management framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

Contents

1 Governance and Strategic Framework **1**
1.01 Department Mission and Strategic Objectives . . . 2
1.02 Code of Ethics and Professional Conduct . . . 4
1.03 Standard Operating Ethos . . . 7
1.04 Policy and Documentation Formatting Standards . . . 11
1.05 Policy Review and Update Procedures . . . 22
1.06 IT Governance and Oversight Structure . . . 26
1.07 Workforce Roles, Responsibilities, and Competency Framework . . . 29
1.08 Delegation of Authority and Decision Rights . . . 34
1.09 Risk Management Policy . . . 40
1.10 IT Financial Management and Procurement Policy . . . 46
1.11 Data Governance and Classification Policy . . . 50
1.12 IT Asset Management Policy . . . 56
1.13 Supply Chain Risk Management (SCRM) and Vendor Governance . . . 62
1.14 Stakeholder Engagement and Communications Policy . . . 67

2 Information Security **71**
2.01 Acceptable Use of Information Technology Resources Policy . . . 72
2.02 Personnel Security and Background Screening Policy . . . 75
2.03 Security Awareness and Training Policy . . . 78
2.04 Access Control Policy . . . 81
2.05 Identification and Authentication Policy . . . 86
2.06 Privacy and Data Protection Policy . . . 90
2.07 System and Communications Protection Policy . . . 93
2.08 System Integrity and Malware Protection Policy . . . 97
2.09 Vulnerability and Patch Management Policy . . . 101
2.10 Secure Configuration Baselines and Hardening Policy . . . 105
2.11 Audit Logging and Monitoring Policy . . . 109
2.12 Media Protection and Sanitization Policy . . . 113
2.13 Physical Security and Environmental Controls Policy . . . 117
2.14 Mobile Device and Remote Access Policy . . . 121
2.15 System Development and Secure Software Lifecycle Policy . . . 126

3 Service Management and Operations **131**
3.01 Service Catalog and SLA Policy . . . 132
3.02 Service Level Management and Metrics Reporting . . . 137
3.03 End-User Communication Standards . . . 143
3.04 Service Delivery Feedback and Grievance Policy . . . 147
3.05 Service Request Fulfillment Policy . . . 152
3.06 Operational Incident Management Policy . . . 159
3.07 Problem Management Policy . . . 167
3.08 Service Configuration Management (CMDB) Policy . . . 174
3.09 Change Management Policy . . . 180
3.10 Release and Deployment Policy . . . 186
3.11 Capacity and Availability Management Policy . . . 190
3.12 Monitoring and Event Management Policy . . . 194
3.13 Knowledge Management Policy . . . 199
3.14 IT Project Management Policy . . . 203
3.15 Service Continuity and Contingency Planning Policy . . . 210

3.16 Service Improvement and Continual Improvement Plan . . . 217
3.17 System Maintenance and Vendor Repairs . . . 222

4 Incident Response **228**
4.01 Incident Response Policy Overview . . . 229
4.02 Identification and Reporting Procedures . . . 238
4.03 Containment Strategy and Playbooks . . . 247
4.04 Eradication Procedures and Scenario Guides . . . 255
4.05 Recovery Operations and Restoration Prioritization . . . 264
4.06 Communication Protocols and Partner Integration . . . 265
4.07 Postmortem Review and Lessons Learned . . . 266
4.08 Incident Response Roles and Contact Directory . . . 267

5 Compliance and Oversight **268**
5.01 Policy Implementation, Enforcement, and Legal Alignment . . . 269
5.02 Internal Audits, Self-Assessment, and Control Testing . . . 279
5.03 Compliance Monitoring and Corrective Action . . . 285
5.04 Performance Metrics and Operational KPIs . . . 291
5.05 Security Control Assessment and Authorization . . . 297
5.06 Vendor Compliance and Third-Party Assurance . . . 301
5.07 Annual Policy Review and Maturity Scoring . . . 310

6 Appendices **317**
6.01 Glossary and Definitions . . . 318
6.02 Policy Matrix . . . 319
6.03 Workforce Roles STAK Matrix . . . 323
6.04 Revision History and Version Control . . . 330

1. Governance and Strategic Framework

1.01 Department Mission and Strategic Objectives

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy defines the mission and strategic objectives of the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel and informs the development, execution, and evaluation of all policies, procedures, and services maintained by the Department. It serves as the strategic anchor point for departmental planning, service delivery, policy enforcement, and cross-departmental coordination.

3. Roles and Responsibilities

- **IT Director**:
  - Shall define, approve, and update the Department mission and strategic objectives to ensure alignment with County goals, in accordance with the review cadence established in **Policy 1.05** (Policy Review and Update Procedures).
  - Shall ensure that all policy development and procedural guidance explicitly maps to the Department's mission.
- **All Information Operations Personnel**:
  - Shall uphold the Department mission and contribute to the realization of strategic objectives through their daily actions, decisions, and participation in governance and risk-management activities.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel.

- **Assessment**: Strategic alignment shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with justification and approved by the IT Director in accordance with the exception management framework defined in **Policy 5.01** and **Policy 1.08** (Delegation of Authority and Decision Rights). Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment

- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NRS 242.171 (Responsibilities of Office/Director)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- NIST CSF 2.0: GV.OC-01 (Organizational Context)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-11 (Mission and Business Process Definition)
- COBIT 2019: EDM01 (Ensure Governance Framework Setting and Maintenance)

6. Policy Statement

6.1 Mission Statement

The mission of the Elko County Information Operations Department is to establish and enforce clear, comprehensive standards for technology and information management, ensuring secure, compliant, and efficient operations across all County departments while actively informing the County's cybersecurity and privacy risk management approach.

6.2 Strategic Objectives

The Department shall achieve and maintain the following strategic objectives:

- **Standardization**: The Department shall establish and maintain clear guidelines for the secure, responsible use of County information systems and technology resources.
- **Enforcement**: The Department shall apply approved standards consistently and impartially, fostering a culture of operational accountability and technical discipline.
- **Risk Management**: The Department shall identify, assess, and mitigate risks across systems, departments, and workflows to reduce systemic vulnerabilities and support the County's cybersecurity risk management strategy.
- **Service Enablement**: The Department shall design and support infrastructure that delivers reliability, continuity, and interoperability across County operations.
- **Decision Support**: The Department shall streamline and automate processes to reduce manual burden and shall provide accurate, current, and well-governed data to County leadership.
- **Policy Leadership**: The Department shall act as the central authority for information governance, security, and service management within Elko County, maintaining a coherent governance framework aligned with applicable laws, regulations, and control frameworks.

1.02 Code of Ethics and Professional Conduct

Effective: July 01, 2026 Version: 2.2

1. Purpose

This policy establishes the mandatory standard of professional conduct for all personnel within the Elko County Information Operations Department.

2. Scope

This policy applies to all Elko County Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, interns, and volunteers who access County IT systems or data.

3. Roles and Responsibilities

- **IT Director**:
  - Shall conduct an annual review of this policy and adjudicate ethical conflicts that cannot be resolved at the staff level.
  - Shall approve or deny exceptions to this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **All Information Operations Personnel**:
  - Shall read, acknowledge, and adhere to this policy and the professional standards adopted in Section 6.1.
  - Shall report suspected criminal conduct, Criminal Justice Information (CJI) misuse, or active threats to County systems or data to the IT Director immediately upon discovery.
  - Shall report all other known or suspected violations of this policy to the IT Director within one (1) business day of discovery.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel and all other personnel within the scope defined in Section 2.

- **Assessment**: Adherence to the standards of conduct defined in this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures). All Information Operations Personnel shall acknowledge this policy upon hire and annually thereafter in accordance with the acknowledgment program defined in **Policy 5.01**.
- **Enforcement**: Non-compliance with this policy shall be addressed through the corrective action framework defined in **Policy 5.01**. Violations involving misuse of CJIS data or County assets may result in criminal referral under NRS 205 (Computer Crimes) and applicable federal law.
- **Exceptions**: Exceptions to the standards of conduct defined in this policy shall follow the exception management framework established in **Policy 5.01** Section 6.6. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205 (Computer Crimes)
- NRS 281A (Ethics in Government)
- ACM: Code of Ethics and Professional Conduct

Framework Alignment:

- CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PS-1 (Personnel Security Policy and Procedures)
- NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions)
- COBIT 2019: APO01.02 (Manage Ethical and Professional Behavior)

6. Policy Statement

Public trust in the administration of government technology requires that all personnel maintain the highest standards of professional conduct and integrity. All directives in this policy apply to all personnel within the scope defined in Section 2. Where a directive applies to a narrower audience, the specific role is identified.

6.1 Adoption of Professional Standards

Elko County Information Operations formally adopts the ACM Code of Ethics and Professional Conduct as the baseline for professional behavior. Personnel shall uphold the principles of contributing to human well-being, avoiding harm, and respecting privacy. Where the ACM Code and County or Department policy conflict, applicable State and Federal law shall take precedence, followed by County and Department policy.

6.2 Professional Conduct and Culture

- **Respect in Communication**: Mocking, belittling, or dismissive comments regarding end-users, colleagues, or other departments—whether verbal, written, or in digital chats—is prohibited. Operational frustration does not justify unprofessional conduct.
- **User-Centered Service**: Personnel shall respond to service requests and inquiries from County staff in a professional and courteous manner. Dismissive or condescending responses to end-user communications are prohibited.
- **Representation**: Personnel shall not express personal opinions as official County positions in any public forum or media channel unless explicitly authorized by the County Manager or IT Director.
- **Compliance with Personnel Policies**: Personnel shall comply with the Elko County Personnel Policies and applicable Collective Bargaining Agreements in addition to this policy.

6.3 Integrity and Conflict of Interest

- **Zero-Gift Policy**: Personnel are strictly prohibited from accepting any gifts, gratuities, meals, entertainment, or favors from current or prospective technology vendors, regardless of monetary value. This includes standard industry courtesies such as vendor-paid business lunches or promotional items.
  - **Rationale**: This standard is intentionally stricter than the minimum requirements of NRS 281A (Ethics in Government) to eliminate ambiguity and protect personnel from even the appearance of impropriety.
- **Vendor Interaction**: When meeting with vendors over a meal, personnel shall pay for their own share or expense it through official County channels if applicable. The vendor is never permitted to pay.
- **Truthfulness**: Personnel shall be honest in all professional reporting. Falsifying logs, obscuring errors, or misrepresenting the status of a project or system is a violation of this policy.

6.4 Stewardship of Information and Assets

- **Confidentiality**: Personnel shall protect sensitive data (PII, PHI, CJIS) in accordance with **Policy 1.11** (Data Governance and Classification Policy). Curiosity is not a valid reason for accessing data; access is permitted only for specific business duties.
- **Zero Tolerance for Misuse**: The use of County IT assets for harassment, illegal activity, or personal financial gain is strictly prohibited.

1.03 Standard Operating Ethos

Effective: July 01, 2026 Version: 2.0

1. Purpose

This policy defines the internal culture, operational mindset, and behavioral expectations of the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, and volunteers. It governs the cultural and professional baseline for Department interactions, decision-making, and conflict resolution.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the final authority on matters of operational conduct and Department culture.
  - Shall maintain this policy as the governing standard for Department conduct and professional expectations.
  - Shall define and document operational delegations and escalation paths in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Assistant IT Director**:
  - Shall reinforce the standards defined in this policy through active mentorship and shall model the operational ethos in daily operations.
- **All Information Operations Personnel**:
  - Shall operate in strict alignment with this ethos, modeling professional discipline, initiative, and leadership at every level.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Adherence to this policy shall be evaluated through individual performance reviews, incident post-mortem analysis examining adherence to escalation and documentation standards per **Policy 4.01** (Incident Response Policy Overview), supervisor observations, and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance with this policy may result in corrective actions as defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment), including coaching, supervisory feedback, or formal performance management. Failure to complete required policy acknowledgments under Section 6.5 constitutes non-compliance enforceable under this section.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework in **Policy 5.01** §6.6. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 281A (Ethics in Government)
- CJIS Security Policy v6.0: Section 5.1.1.4 (Management Control Agreements)

Framework Alignment:

- NIST CSF 2.0: GV.SC-01 (Cybersecurity Supply Chain Risk Management)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- COBIT 2019: APO01.01 (Design the management system for enterprise I&T)
- COBIT 2019: APO07.01 (Maintain adequate and appropriate staffing)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

This policy serves as the unifying ethos that aligns individual conduct with the organizational mission — defining how the Department leads, operates, and serves. The standards established here complement the ethical obligations defined in **Policy 1.02** (Code of Ethics and Professional Conduct) and operationalize the professional discipline required to sustain the Department's governance, security, and service delivery mission.

6.1 Operational Authority and Autonomy

The Information Operations Department shall maintain operational authority over the administration, security, architecture, and configuration of all Elko County information systems, infrastructure, and technology assets placed under the governance of the Information Operations Department as defined in **Policy 1.06** (IT Governance and Oversight Structure).

- **Unified Authority**: To support compliance with the strict connectivity and security requirements of the CJIS Security Policy Section 5.1.1.4 (Management Control Agreements), Elko County has adopted a unified governance structure for shared infrastructure. Under this structure, the IT Director retains final decision-making authority over all technical controls and risk mitigation strategies across the enterprise, subject to the statutory management control authority of Criminal Justice Agencies (CJA) over CJIS data policy.
- **Independence**: While administratively reporting to County Management, the Department's operational decisions shall be driven by technical standards, security mandates, and risk assessments. Political pressure or external influence shall not supersede mandatory security controls, engineering

standards, or the ethical obligations established under NRS 281A. Technical decisions shall be made in accordance with the delegation framework defined in **Policy 1.08**.

6.2 Chain of Command and Escalation

The chain of command is a mechanism for accountability and risk management. All Information Operations Personnel shall utilize the chain of command to ensure decisions are made at the appropriate authority level.

- **Act Decisively**: All Information Operations Personnel shall execute duties with precision within their assigned scope of authority.
- **Escalate with Purpose**: All Information Operations Personnel shall escalate issues to their direct supervisor within one (1) business day when operational risk, legal constraints, or policy ambiguity exceed their defined authority or expertise. During active incidents, personnel shall escalate in accordance with the incident response escalation procedures defined in **Policy 4.01**.
- **Unified Direction**: Once a decision is made by the designated authority, all Information Operations Personnel shall implement that decision promptly. Concerns about implementation shall be raised through the escalation process defined in **Policy 1.08** without impeding execution unless a safety or legal issue is identified.

6.3 Leadership and Crisis Management

Leadership within the Information Operations Department is defined by consistency, clarity, and accountability.

- **Communicate with Precision**: The IT Director and Assistant IT Director shall issue instructions and status reports that are clear, specific, and actionable. All Information Operations Personnel shall confirm understanding of critical directives before execution.
- **Decide Based on Standards**: The IT Director and Assistant IT Director shall base operational decisions on data, policy, and formal risk assessment. Political pressure, personal sentiment, or external influence shall not supersede technical standards or mandatory security controls.
- **Accountability**: The IT Director and Assistant IT Director shall acknowledge errors transparently and shall document lessons learned within five (5) business days of incident closure. The IT Director shall ensure remediation actions are tracked to completion in the Department's system of record.
- **Crisis Discipline**: During major incidents, all Information Operations Personnel shall adhere to the incident response protocols defined in **Policy 4.01**. The IT Director and Assistant IT Director shall provide clear, evidence-based direction to maintain operational discipline and shall participate in formal post-incident reviews to document lessons learned.

6.4 Operational Discipline

Operational discipline is the foundation of the Department's credibility. All Information Operations Personnel shall execute duties according to the following standards:

- **Own the Scope**: All Information Operations Personnel shall fully own tasks within their job role. If a task falls outside their scope, they shall escalate it with clear context and documentation rather than ignoring it.
- **Document as Standard**: All Information Operations Personnel shall document operational actions, changes, and decisions in accordance with the documentation requirements established in **Policy 5.01** §6.1 (Documentation as Standard).
- **Prioritize Based on Risk**: All Information Operations Personnel shall assess urgency based on impact to County operations and security, not solely on the volume of the request.

- **Resolve or Escalate**: All Information Operations Personnel shall actively move every ticket or work order toward resolution or escalate it to the appropriate tier with sufficient context for action. No ticket or work order shall remain without a documented status update beyond the timeframes established in the applicable service level targets.

6.5 Policy Acknowledgment

All Information Operations Personnel shall acknowledge receipt and understanding of this policy upon hire, upon any substantive revision, and annually thereafter. The IT Director shall ensure acknowledgments are documented and maintained in accordance with **Policy 2.03** (Security Awareness and Training Policy).

1.04 Policy and Documentation Formatting Standards

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the mandatory formatting, structural, and stylistic standards governing all policies, procedures, and official documentation maintained by the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel responsible for drafting, editing, approving, or maintaining any document that is part of the Information Operations Policy Manual or supporting procedural library.

- **In Scope**:
  - Policy documents within the Information Operations Policy Manual.
  - Standard Operating Procedures (SOPs) maintained in the System of Engagement (Redmine).
  - Playbooks maintained as governed Knowledge Base artifacts in the System of Engagement (Redmine).
- **Out of Scope**:
  - Informal working documents, drafts in progress, and internal correspondence not intended for publication in the Policy Manual or procedural library.

3. Roles and Responsibilities

- **IT Director**:
  - Shall maintain this policy and serve as the final authority on formatting standards, style determinations, and exception approvals.
  - Shall return documents found to be non-compliant to the author for revision prior to publication.
- **All Information Operations Personnel**:
  - Shall apply the structural, grammatical, and stylistic standards defined in this policy when drafting, editing, or maintaining any document within scope.
  - Shall verify cross-reference accuracy and citation completeness prior to submitting a document for review.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel engaged in documentation tasks.

- **Assessment**: Adherence to formatting and style standards shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).

- **Enforcement**: The IT Director shall return documents found to be non-compliant to the author for revision prior to publication. Repeated non-compliance may be escalated under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Exceptions**: Exceptions to formatting standards shall be documented with justification and approved in writing by the IT Director. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix 6.01: Glossary and Definitions
- NRS 239.010 (Applicability and Public Records)

Framework Alignment:

- COBIT 2019: APO01.01 (Design the management system for enterprise I&T)
- COBIT 2019: APO01.09 (Define and communicate policies and procedures)
- ITIL v4: Knowledge Management Practice

6. Policy Statement

6.1 Source of Truth and Document Authority

The **Elko County Information Operations Policy Manual** (maintained as the master *Policy_Manual.lyx* file) is the designated **Authoritative System of Record** for all governance controls.

- **Master Repository**: The LyX source file constitutes the legally authoritative master record.
  - **Public Records Status**: Designation of an "authoritative" copy is for version control only and does not alter public records status, retention obligations, or disclosure requirements applicable to records in any medium under NRS 239.010.
- **Operational Interface (System of Engagement)**: The Departmental Knowledge Base (Redmine) serves as the accessible operational interface for day-to-day reference.
- **Synchronization**: Content published in Redmine shall be sourced directly from the LyX master. In the event of a discrepancy, the LyX master record (and its compiled PDF) takes precedence.

6.2 Policy Document Structure

All policies within the Information Operations Policy Manual shall adhere to the following six-section structure, presented in this exact order. No sections shall be omitted, reordered, or renamed.

1. **Purpose**: A concise statement defining what the policy governs.
2. **Scope**: Defines who and what the policy applies to, and what it does not.
3. **Roles and Responsibilities**: Identifies specific roles tasked with execution or oversight.

4. **Compliance and Exceptions**: Defines assessment mechanisms, enforcement authority, and the exception process.
5. **References**: Citations of upstream frameworks and internal cross-references that are directly cited in the body of the policy.
6. **Policy Statement**: The core directives, organized into subsections.

Subsections within the Policy Statement shall use decimal notation (e.g., 6.1, 6.2). Nesting beyond two levels (e.g., 6.1.1) is prohibited.

6.3 Purpose Section Template

The Purpose section shall consist of one (1) sentence, or two (2) sentences at maximum. It shall answer a single question: what does this policy govern?

- **Opening Construction**: Every Purpose statement shall open with the construction "This policy [verb]s..." using a direct, present-tense verb (e.g., "This policy establishes...," "This policy defines...," "This policy governs...").
- **Prohibited Constructions**: The preamble "The purpose of this policy is to..." is prohibited. Introductory filler, risk justification, and framework alignment rationale shall not appear in the Purpose section.
- **Rationale Placement**: Context that explains why the policy matters, what risk it addresses, or how it aligns with external frameworks shall be placed in the opening paragraph of Section 6 (Policy Statement) or in the Policy Matrix appendix.

6.4 Scope Section Template

The Scope section shall open with a single universal applicability statement using the construction "This policy applies to [who/what]."

When boundary clarification is required, the Scope section shall use the following labeled subsections, formatted as bolded bullet labels with sub-bullets:

- **In Scope**: Capitalized noun phrases identifying what the policy governs. Each item shall appear as a sub-bullet beneath the label and consist of a standalone noun phrase with a terminal period. No policy pointers are required, as the governed items reside within this policy.
- **Out of Scope**: Capitalized noun phrases identifying what the policy does not govern. Each item shall appear as a sub-bullet beneath the label, followed by a colon and the routing pointer to the governing policy. Format: "[Topic]: **Policy [X.XX]**."

Not every policy requires both In Scope and Out of Scope subsections. Simple policies where the applicability sentence is sufficient may omit them. However, when boundaries are drawn, they shall be drawn with labels and sub-bullets, not with narrative prose.

Cross-references within the Scope section shall use the routing pointer format prescribed above. The first-use parenthetical title convention defined in Section 6.9 applies to prose references in Sections 3, 4, and 6; it does not apply to Scope section routing pointers.

Exclusion: The Scope section shall not contain directives, compliance language, or enforcement statements. Those belong in Section 4.

6.5 Roles and Responsibilities Section Template

The Roles and Responsibilities section shall identify every role with accountability under the policy. Roles shall be listed in descending order of authority (e.g., IT Director, County Manager, Assistant IT Director, then operational roles, then external stakeholders).

Each role shall be formatted as follows:

- The role title shall appear as a bolded bullet item followed by a colon. No text shall follow the colon on the role title line.
- Each distinct obligation shall appear as a sub-bullet beneath the role, opening with the word "Shall" and containing exactly one (1) directive.
- Obligations shall not be chained together in a single comma-separated sentence. Each auditable obligation requires its own sub-bullet.

Role Identity Requirement: Every role listed in Section 3 shall correspond to a defined position in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework), an established County institutional title (e.g., County Manager, Board of County Commissioners), or a defined group with a clear membership boundary (e.g., "All Information Operations Personnel," "All County Personnel," "Department Heads"). Descriptive activity labels (e.g., "Policy Authors," "Approving Authorities," "System Owners") shall not be used as role identifiers in Section 3. If a responsibility applies to any person performing a given activity, it shall be assigned to the defined role or group that performs that activity.

The Roles and Responsibilities section shall focus on ownership of outcomes, not step-by-step procedures. Procedural detail belongs in Section 6.

6.6 Compliance and Exceptions Section Template

The Compliance and Exceptions section shall open with a single sentence establishing the mandatory nature of the policy (e.g., "Compliance with this policy is mandatory for all Information Operations personnel involved in [relevant activity].").

The section shall contain the following three (3) mandatory labeled bullet items, in this order:

- **Assessment**: Identifies how and when compliance with this policy is evaluated.
- **Enforcement**: Identifies the consequences of non-compliance and the authority that enforces the policy.
- **Exceptions**: Defines the process for requesting deviations. Shall state that oral exceptions are not valid.

Additional labeled bullets may be included when the policy warrants them. The following are the governed set of optional labels:

- **Constructive Notice**: For policies where publication constitutes notice.
- **Emergency Deviations**: For policies with time-critical override procedures.
- **Sanctions**: For policies with specific disciplinary consequences beyond the standard enforcement framework.
- **Universal Applicability**: For policies that apply regardless of location or work status.
- **Mandatory Compliance**: For policies that apply without exception to all personnel classes.

No other labels shall be introduced without IT Director approval and incorporation into this governing list. The Compliance and Exceptions section shall not use numbered subsections (e.g., 4.1, 4.2); it shall use the flat bolded-bullet-label structure defined above.

6.7 References Section Template

The References section is the legal and framework audit trail. It shall be formatted as a flat list of citation line items with no narrative prose. The section shall be divided into two (2) labeled subsections: Cited References and Framework Alignment.

Cited References: This subsection contains citations that are directly referenced by number or identifier in the body of the policy (Sections 1 through 4 and Section 6). A policy or framework that is not cited in the body text shall not appear in this subsection. Conversely, any policy or framework cited by number in the body text shall have a corresponding entry in this subsection. Cited References are load-bearing — they support specific directives, cross-references, or compliance statements within the policy.

Framework Alignment: This subsection contains framework mappings that establish where the policy sits in the broader governance landscape, regardless of whether they are explicitly cited in the body text. Framework Alignment entries support traceability, feed the Policy Matrix (Appendix 6.02), and make governance alignment visible at the policy level. A framework reference that is directly cited in the body text shall appear under Cited References, not Framework Alignment.

Default Placement:

- The following categories shall default to Cited References unless they are not cited in the body text:
  - ECIO Policies.
  - ECIO Appendices.
  - NRS.
  - NAC.
  - LRDA.
  - CJIS.
  - NIST CSF.
  - NIST SP.
- The following categories shall default to Framework Alignment unless they are directly cited by identifier in the body text:
  - COBIT 2019.
  - ITIL v4.

A COBIT or ITIL reference that is directly invoked by identifier in the body text shall be promoted to Cited References.

Ordering: Within each subsection, citations shall follow the categorical sequence and sub-ordering rules defined in Section 6.11 of this policy.

Formatting Rules:

- Each citation shall be a distinct, individual line item. Citations shall not be grouped on a single line.
- Reference line items shall not end with a terminal period. They are citations, not sentences.
- Internal ECIO policy and appendix references shall not be bolded in either subsection. All citation line items shall receive uniform formatting to avoid visually privileging internal references over upstream frameworks.
- Internal ECIO policy and appendix references shall use LyX cross-reference insets (CommandInset ref) to maintain link integrity. They shall not be manually typed.

Citation Syntax: Citation formatting for each framework category is defined in Section 6.11 of this policy.

6.8 Policy Statement Section Template

The Policy Statement is the operational core of the policy, containing the auditable controls and directives.

- **Framing Preamble**: When a policy requires contextual framing — risk justification, framework alignment rationale, or dual-audience explanation — that context shall appear as an opening paragraph or paragraphs before Section 6.1 begins, or as the opening content of Section 6.1 itself.
- **Subsection Organization**: Content shall be organized into labeled subsections (6.1, 6.2, etc.) grouped by operational sub-domain.
- **One Directive Per Item**: Each numbered or bulleted item within the Policy Statement shall contain exactly one (1) directive or requirement. Blended rules that combine multiple obligations in a single item are prohibited.

6.9 Compliance Language Standards

To ensure clear enforceability during audits, the following terminology definitions apply to all policy documents within the Information Operations Policy Manual.

- **"Shall" or "Must"**: Indicates a mandatory requirement. Non-compliance is auditable and enforceable.
- **"Should"**: Indicates a recommended best practice. Deviations from "Should" requirements shall be documented in writing and approved by the IT Director or Policy Owner prior to implementation. Justifications shall be retained for audit.
- **"May"**: Indicates a permissible or discretionary action.

Anchoring Requirement: Every directive shall be anchored to a specific, capitalized role. Orphaned directives (e.g., "Logs shall be reviewed weekly" with no identified role) are prohibited. The correct form is "The Systems Administrator shall review logs weekly."

Prohibited Language: The following terms and phrases are prohibited in Section 6 (Policy Statement) of any policy. Authors shall map the intended obligation to "Shall," "Should," or "May" with an explicit role anchor.

- "expected to"
- "responsible for"
- "as needed"
- "where possible"
- "where feasible"
- "is not feasible" / "not feasible" / "technically feasible"
- "as appropriate"
- "in a timely manner / “timely”
- “reasonable”
- "when practical" / "where practical"
- "if necessary"
- "attempt to"
- "strive to"
- "best effort"
- "strongly encouraged"

6.10 Universal Style and Grammar Standards

The following style and grammar rules apply to all text within the Information Operations Policy Manual.

- **Voice and Tense**: All policy text shall use present-tense, active voice (e.g., "The IT Director reviews logs" rather than "Logs are reviewed by the IT Director"). Passive constructions are permitted only when the acting role is genuinely irrelevant or unknown.
- **Time and Quantity Syntax**: All deadlines, timeframes, and quantities shall be written as the number in words followed immediately by the numerical digit in parentheses (e.g., "five (5) business days," "twenty-four (24) hours," "ninety (90) calendar days"). Neither the word nor the digit shall appear alone.
- **Institutional Capitalization**: The following shall always be capitalized: proper nouns, official job titles (e.g., "IT Director," "Systems Administrator"), institutional concepts (e.g., "County," "Department," "Information Operations Department"), defined terms from the Glossary (**Appendix 6.01**), and named policy constructs (e.g., "Incident Commander," "Hard Fork," "Operational Handback").
- **Acronym Protocol**: The first instance of a technical term or organizational name within each policy shall be fully spelled out, followed by its abbreviation in parentheses (e.g., "Criminal Justice Information Services (CJIS)"). Subsequent references within the same policy may use the abbreviation alone. Acronym definitions do not carry across policies; each policy shall define its own terms on first use. Standard terms defined in the Glossary (**Appendix 6.01**) are exempt from the first-use requirement only when the policy explicitly states reliance on the Glossary.
- **Oxford Comma**: The Oxford comma is mandatory in all lists (e.g., "systems, services, and infrastructure").
- **Official Systems Terminology**: Software and platforms referenced in policy documents shall be cited by their governance function label only (e.g., "System of Engagement," "Authoritative System of Record," "Endpoint Protection Platform," "Productivity Suite"). Vendor and product names shall not appear in policy text. Product-specific names, configurations, and implementation details belong in operational documentation maintained in the System of Engagement.
- **Policy Numbering**: Policy numbers shall follow a strictly padded two-digit decimal system within each chapter (e.g., Policy 1.01, Policy 2.05, Policy 3.14). Single-digit policy numbers (e.g., Policy 1.1) are prohibited.

6.11 Cross-Reference, Citation, and Bold Standards

Cross-Reference Syntax: Internal references to other policies shall use the following rules:

- Every reference shall use the singular construction "Policy [X.XX]" (e.g., "Policy 2.04"). The word "Policy" shall appear before every number, even when citing multiple policies in sequence (e.g., "Policy 3.03 and Policy 3.04," never "Policies 3.03 and 3.04").
- The first reference to an internal policy within each policy shall include the parenthetical title immediately after the cross-reference (e.g., "Policy 1.08 (Delegation of Authority and Decision Rights)"). The parenthetical title shall not be bolded; bold applies only to the cross-reference itself. All subsequent references within the same policy shall use the short form only (e.g., "Policy 1.08").
- Every in-body cross-reference (Sections 1 through 4 and Section 6) shall be bolded and implemented as a LyX cross-reference inset (CommandInset ref) to maintain link integrity. Manually typed policy numbers are prohibited in the body of any policy.
- Cross-references within Section 5 (References) shall not be bolded, consistent with the uniform citation formatting rule in Section 6.7. They shall still use LyX cross-reference insets.
- Directional phrases such as "see below," "see above," "as described later," and hard-coded page numbers are prohibited. All internal references shall use absolute numerical pointers (e.g., "Policy 2.04" or "Section 6.2").

External Framework First-Use Syntax: The first reference to an external framework citation within each policy shall include the full citation with parenthetical topic (e.g., "NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)"). Subsequent references within the same policy may use the short form (e.g., "NIST SP 800-53 IR-4" or the control identifier alone if context is unambiguous).

Reference Citation Syntax: Citations within Section 5 (References) shall follow the formatting defined below for each framework category. These formats apply uniformly within both the Cited References and Framework Alignment subsections.

- Internal Policies: ECIO Policy [Number]: [Policy Title]
- Internal Appendices: ECIO Appendix [Number]: [Appendix Title]
- NRS: NRS [Chapter].[Section] ([Short Topic Description])
- NAC: NAC [Chapter].[Section] ([Short Topic Description])
- LRDA: LRDA [LRDA Number] ([Record Series Title])
- CJIS: CJIS Security Policy v[Version]: Section [ID] ([Topic])
- NIST CSF: NIST CSF [Version]: [Function].[Category]-[ID] ([Title])
- NIST SP: NIST SP [Number] Rev. [Revision]: [Control ID] ([Control Title])
- COBIT 2019: COBIT 2019: [Process ID] ([Process Name])
- ITIL v4: ITIL v4: [Practice Name]

Reference Sub-Ordering Within Categories: The following ordering rules apply within each subsection (Cited References and Framework Alignment) independently. Citations shall not be interleaved across subsections.

1. **ECIO Policies**: Sorted numerically by Policy Number in ascending order.
2. **ECIO Appendices**: Sorted numerically by Appendix Number in ascending order.
3. **State of Nevada**: Grouped by authority in the sequence NRS, NAC, then LRDA. Within each group, sorted numerically by Chapter, Schedule Number, or LRDA Number.
4. **CJIS**: Sorted alphanumerically by Section or Control Family identifier.
5. **NIST CSF**: Sorted by Core Function sequence (GV, ID, PR, DE, RS, RC), then alphanumerically by Category and Subcategory identifier.
6. **NIST SP**: Sorted numerically by Publication Number (e.g., SP 800-37 precedes SP 800-53), then alphanumerically by Control Identifier.
7. **COBIT 2019**: Sorted alphanumerically by Core Model Objective or Domain identifier.
8. **ITIL v4**: Sorted alphabetically by Practice name.
9. **Other Frameworks**: Sorted alphabetically by issuing authority, then publication title.

This ordering establishes structural consistency and does not alter the legal hierarchy of authority established in the Manual Executive Summary.

Bold Usage: Bold formatting is a navigational and structural tool, not an emphasis tool. Bold shall be reserved for the following uses only:

- **Internal Cross-References**: Bolded on every instance in the policy body (Sections 1 through 4 and Section 6). Not bolded in Section 5 (References).
- **Glossary-Defined Terms**: Bolded on first use within each policy only. Not linked to the Glossary; the bold treatment serves as a visual flag that the term carries a specific defined meaning. The criteria for Glossary inclusion are defined in Section 6.14.

- **Structural Labels**: Role titles in Section 3, compliance labels in Section 4, In Scope and Out of Scope labels in Section 2, and contextual clarifier tags (defined in Section 6.12). Bolded by virtue of their structural position.

Bold shall not be applied to external framework references (CJIS, NIST, COBIT control IDs), numerical values, parenthetical titles accompanying cross-references, or general emphasis within prose.

6.12 List and Structural Formatting Standards

Terminal Periods: Every bulleted and sub-bulleted list item shall end with a terminal period, regardless of whether the item is a full sentence or a fragment.

- **Exception**: Citation line items in Section 5 (References) shall not end with a terminal period.

Bulleted Lists vs. Numbered Lists: Bulleted lists (Itemize) shall be used for unordered collections of items. Numbered lists (Enumerate) shall be used only when the items represent an ordered sequence where position is meaningful (e.g., a workflow, a hierarchy of precedence). Numbered lists shall not be used solely for the purpose of counting items.

Sub-Bullets: Nested list items shall use the LyX begin_deeper environment (rendered as indented sub-bullets). Nesting beyond two levels is prohibited.

Bold Label Formatting: When a bold label is used to identify a bullet item, a paragraph-level directive, or a topic block within a subsection, the label shall always be followed by a colon, never a period. The colon signals that the label identifies the content that follows. Bold labels followed by periods are prohibited.

Contextual Clarifiers: When a directive requires boundary-setting, explanation, or qualification, the clarifying statement shall be separated from the primary directive using a bolded tag followed by a colon, placed on a new line or as a sub-bullet. The following tags constitute the governed vocabulary of permitted contextual clarifiers:

- **Constraint**: Defines a hard limitation or boundary condition on the directive.
- **Rationale**: Provides the justification for a requirement that may not be self-evident.
- **Exception**: Identifies a specific, defined circumstance under which the directive does not apply.
- **Exclusion**: Carves out a specific item, group, or system from the scope of the directive.
- **Clarification**: Resolves a potential ambiguity in the directive's application.

No other contextual clarifier tags shall be introduced without IT Director approval and incorporation into this governed list.

6.13 Visual and Typography Standards

Typography, spacing, and layout are controlled programmatically by the LyX document class (book) and the master preamble to ensure absolute consistency.

- **Manual Overrides**: Authors shall not use manual formatting commands (e.g., forcing font sizes, manual line breaks, or changing margins) within the LyX editor.
- **Images and Diagrams**: Workflow diagrams may be included when necessary. They shall be inserted as standard LyX "Floats" with a caption and created in a format that renders clearly in grayscale (PDF).
- **Term Definitions**: Policies shall not redefine standard terms already defined in the central Glossary (**Appendix 6.01**). If a policy requires a term that does not yet appear in the Glossary and meets the inclusion criteria defined in Section 6.14, the IT Director shall approve the term for addition to **Appendix 6.01** prior to or concurrent with publication of the policy.

6.14 Glossary Governance and Term Criteria

The Glossary (**Appendix 6.01**) is the authoritative repository for defined terms used within the Information Operations Policy Manual. The IT Director shall maintain the Glossary and approve all additions, modifications, and removals.

Inclusion Criteria: A term warrants a Glossary entry if it meets any of the following conditions:

- The term is coined by the ECIO Policy Manual and has no standard external definition (e.g., "Hard Fork," "Operational Handback").
- The term is a standard industry or framework term that the manual uses with a specific institutional meaning that narrows, modifies, or contextualizes the common definition (e.g., "Incident Commander" as scoped by the ECIO framework).
- The term is an acronym or abbreviation whose expansion is not obvious to the intended audience of the manual.

Exclusion Criteria: The following shall not receive Glossary entries:

- Plain-language terms used in their ordinary, commonly understood sense (e.g., "server," "firewall," "email").
- Terms whose meaning is fully self-evident to a competent IT professional without further definition.
- External framework terms (e.g., NIST control names, COBIT process identifiers) that are used in their standard published meaning without institutional modification. These terms are defined by their issuing authority and do not require local redefinition.

Bold Treatment: Terms that appear in the Glossary shall be bolded on first use within each policy, as defined in Section 6.11. Glossary terms shall not be hyperlinked to **Appendix 6.01**; the bold treatment serves as the visual indicator that the term carries a defined meaning.

Maintenance Cadence: The Glossary shall be reviewed as part of each annual policy review cycle defined in **Policy 1.05**. Terms that are no longer referenced by any active policy shall be candidates for removal.

6.15 Procedural Document Formatting

Standard Operating Procedures (SOPs) are distinct from policies and are maintained as tickets or wiki entries in the System of Engagement (Redmine).

- **Taxonomy**: The Subject Line shall clearly identify the task. The Category field shall correspond to the ticket taxonomy.
- **Linkage**: The procedure shall link to at least one (1) work order or policy that triggered the documentation. Informational documentation is exempt from this requirement.
- **Ownership**: Each SOP shall identify the owning role that shall keep the procedure current.
- **Required Body Elements**:
  - **Prerequisites**: Required roles, permissions, or system states.
  - **Quick Guide**: A condensed summary for experienced technicians.
  - **Step-by-Step**: A detailed, narrative walkthrough.
  - **Outputs**: Artifacts or logs generated by the procedure.

6.16 Playbook Formatting

Playbooks are scenario-based operational artifacts that govern decision-making and technical execution during defined incident or operational scenarios. They are distinct from SOPs in that they present branching

decision logic rather than linear procedural steps. Playbooks are maintained as governed Knowledge Base artifacts in the System of Engagement (Redmine).

Each playbook shall include the following structural elements:

- **Subject Line**: Shall identify the scenario type and governing policy (e.g., "Chapter 4 Playbook — Category B: Malicious Code Activity | Governed by **Policy 4.03** (Containment Strategy and Playbooks)").
- **Version and Effective Date**: Shall be maintained in the document header and updated upon each revision.
- **Governing Policy Reference**: Shall cite the policy that mandates the playbook's existence and defines its content requirements.
- **Owning Role**: Shall identify the role that shall maintain the playbook and initiate reviews.
- **Required Content Sections**: As defined by the governing policy for each playbook type.

Review cadence and content requirements for each playbook class are defined in the governing policy. Playbook versioning and Knowledge Base artifact governance are subject to **Policy 3.13** (Knowledge Management Policy).

1.05 Policy Review and Update Procedures

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to define the lifecycle, cadence, responsibilities, and mechanisms for reviewing, updating, and reauthorizing official IT policies within the Elko County Information Operations Department. Its goal is to ensure all policies remain current, enforceable, and aligned with legal, operational, and institutional realities.

2. Scope

This policy applies to all formal Information Technology policies governed by the Elko County Information Operations Department (the "Policy Manual"). It does not apply to draft procedures, working documents, or informal guidance.

3. Roles and Responsibilities

- **IT Director**: Shall oversee annual reviews, approve internal revisions, and issue emergency changes when operational integrity is at risk. Shall ensure review records are available for audit.
- **County Manager**: Grants final approval for standard policy updates, governance changes, and formal exceptions.
- **County Commission**: Approves policies requiring legal ratification, funding appropriation, or significant changes to County governance structure.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all activities related to the development, review, approval, retirement, and maintenance of IT policies.

- **Assessment**: Completion and timeliness of required policy reviews and resanctions shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to conduct required reviews, resanctions, or tracker updates in accordance with this policy may be treated as non-compliance and escalated under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Emergency Deviations**: Deviations from standard review timelines shall be documented and approved by the IT Director, including justification and a revised review date.
- **Exceptions**: Exceptions to this policy shall be justified in writing and approved by the County Manager in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights) and documented in accordance with **Policy 1.04**.

5. References

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

- ECIO Appendix 6.04: Revision History and Version Control
- CJIS Security Policy v6.0: Section 5.1.1.6 (Policy and Procedures)
- NIST CSF 2.0: GV.PO-02 (Policy Review)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership)
- COBIT 2019: MEA01 (Monitor, Evaluate and Assess Performance and Conformance)
- COBIT 2019: MEA03 (Monitor, Evaluate and Assess Compliance with External Requirements)

6. Policy Statement

6.1 Review Cadence

To ensure continued relevance and compliance, all policies shall undergo the following review cycles:

- **Annual Internal Review**: The IT Director or designated Policy Owners shall conduct an annual internal review of each policy to evaluate compliance, technical accuracy, and workforce awareness. This review supports **NIST SP 800-53 Rev. 5 PM-1** and **PM-2** and **CJIS Security Policy v6.0 Section 5.1.1.6** by ensuring program leadership actively evaluates and maintains the policy framework.
- **Biennial Resanction**: The IT Director shall coordinate biennial resanction of the Policy Manual with the County Manager and, where required, the County Commission. This resanction reaffirms institutional support, risk tolerance, and funding alignment for the IT governance framework.
- **Ad Hoc Reviews**: Policy Owners shall initiate ad hoc reviews when triggered by:
  - Regulatory or legal changes (e.g., FBI CJIS Security Policy updates).
  - Internal or external audit findings.
  - Major incidents or critical system events requiring post-mortem policy adjustment.
  - Significant organizational changes (e.g., departmental mergers or new mandates).
  - Significant technology changes (e.g., new platforms, major infrastructure shifts).

6.2 Policy Lifecycle and Change Control

Updates to the Policy Manual shall follow this strict change control workflow:

1. **Identification**: The reviewer or Policy Owner shall identify needed revisions based on the criteria in Section 6.1.
2. **Drafting**: Draft updates shall be prepared in accordance with the formatting standards in Policy 1.04 and the version control requirements in **Appendix 6.04**.
3. **Approval**:
   - The IT Director shall approve technical and operational changes that do not alter governance structures or budget authority.
   - The County Manager shall approve changes that affect governance constructs, decision rights, or risk appetite, and shall escalate to the County Commission when legal ratification or additional appropriation is required.
4. **Notification**:
   - The IT Director shall notify all affected personnel of every approved policy change within five (5) business days. Notification shall include an effective date, a summary of changes, and a link to the authoritative policy record.

- All personnel whose duties are impacted by the change shall complete a documented acknowledgement (electronic or written) within **ten (10) business days** of notice. Failure to acknowledge does not delay the effective date and constitutes noncompliance.

5. **Publication**:
   - The policy version shall be incremented in accordance with **Appendix 6.04**.
   - The new version shall be committed to the Authoritative System of Record (LyX/PDF) and synchronized to the System of Engagement (Redmine).
   - The previous version shall be marked "Obsolete" and archived in accordance with **Appendix 6.04** and applicable retention schedules.
6. **Retirement**: Policies deemed no longer necessary must be formally retired. The retirement process requires the same approval level as the policy's original creation. Retired policies are removed from active circulation but retained in the archive in accordance with **Appendix 6.04** and applicable retention schedules for legal defensibility.

6.3 Emergency Policy Changes

The IT Director may issue temporary policy amendments ("Technical Directives") when standard policies obstruct legal compliance, operational integrity, or incident response.

- **Permissible Scenarios**:
  - A CJIS, HIPAA, or statutory compliance deadline requiring immediate action.
  - Response to a zero-day vulnerability or active threat.
  - Critical failure affecting escalation, access control, or procedures.
- **Constraints**:
  - Must be documented immediately in the Policy Review Tracker.
  - Must include justification, scope, and a specific expiration date.
  - Emergency Deviations established through Technical Directives are subject to the same documentation and exception requirements defined in Section 4.
- **Automatic Expiration**: Emergency policies expire after **90 calendar days**. Upon expiration, the Technical Directive shall either be (a) incorporated into a formally approved policy revision following the process in Section 6.2, or (b) explicitly rescinded and documented in the Policy Review Tracker. The same or substantially similar emergency policy shall not be re-issued within twelve (12) months of expiration without formal adoption through the standard approval process.
- **Limitation**: Emergency powers may not be used to alter budget authority or core governance roles defined in **Policy 1.06**.

6.4 Policy Review Tracker

All policy review and update activity shall be recorded in the Departmental Knowledge Base (Redmine). Policy Owners shall ensure that review and update records for their assigned policies are created and maintained, and the IT Director shall ensure these records are available to support internal audits and the maturity scoring process defined in **Policy 5.07**. Required metadata for every update includes:

- Policy ID and Title
- Last Review Date and Next Scheduled Review Date
- Responsible Reviewer or Policy Owner
- Review Status (Compliant/Revision Needed/Obsolete)

- Associated Work Order or Ticket Reference Link
- Reference to any applicable audit finding, incident report, or regulatory change.

1.06 IT Governance and Oversight Structure

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy defines the structure and authority through which Information Technology (IT) governance is established, maintained, and executed within Elko County. It articulates the formal relationships, decision rights, and operational responsibilities required to ensure effective oversight, strategic alignment, and accountability for Information Operations.

2. Scope

This policy applies to all Elko County departments, elected officials, appointed leadership, and employees who interact with, procure, or rely on Information Operations services. It governs the mechanisms by which IT decisions are made, funded, and overseen.

3. Roles and Responsibilities

- **Board of County Commissioners**: Shall provide strategic vision, ratify County-wide policy, and exercise final budgetary authority for IT capital investments.
- **County Manager**: Shall provide operational oversight of County administration, approve administrative policies, and arbitrate conflicts between the Information Operations Department and other County entities.
- **IT Director**: Shall serve as the primary governance authority for technical standards, security controls, and infrastructure operations, consistent with the delegation framework defined in **Policy 1.08**.
- **Department Heads**: Shall define business requirements, participate in governance processes as requested, and comply with established IT standards and procedures.

Decision-making authority for specific governance and operational actions shall follow the delegation framework defined in **Policy 1.08** (Delegation of Authority and Decision Rights).

4. Compliance and Exceptions

Adherence to this policy is mandatory. Circumvention of IT governance (e.g., "Shadow IT," unauthorized procurement, or unauthorized system changes) is a violation of this policy.

- **Risk Recording**: Confirmed instances of Shadow IT or unauthorized procurement shall be documented as governance violations and evaluated under **Policy 1.09** (Risk Management Policy) in addition to being addressed through corrective actions as defined in **Policy 5.01**.
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Exceptions**: Exceptions regarding decision rights must be documented and approved by the County Manager in consultation with the IT Director in accordance with **Policy 1.08**.

5. References

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.08: Delegation of Authority and Decision Rights

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- NRS 244 (Counties: Government)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section 5.1.1.4 (Management Control Agreements)
- NIST CSF 2.0: GV.OC-02 (Stakeholder Expectations)
- NIST CSF 2.0: GV.RR-01 (Leadership Accountability)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-3 (Information System Resources)
- COBIT 2019: EDM01 (Ensure Governance Framework Setting and Maintenance)

6. Policy Statement

6.1 Delegated Governance Framework

Elko County hereby establishes a delegated governance model for IT oversight. While strategic direction and budget appropriation are established by the Board of County Commissioners, the execution of technical strategy is delegated to the Information Operations Department in accordance with the decision rights defined in **Policy 1.08**.

- **Program Leadership (NIST PM-2)**: The IT Director serves as the designated senior official with responsibility and authority to coordinate, develop, implement, and maintain the County's information security program, consistent with NIST SP 800-53 PM-2.
- **Central Authority**: The Information Operations Department is designated as the sole authoritative source for all IT-related governance policy, technical standards, and architecture coordination across County departments.
- **Operational Independence**: To ensure security and stability, the Information Operations Department shall operate with the autonomy required to enforce compliance standards, as defined in **Policy 1.03**.

6.2 Policy and Enforcement Authority

The IT Director holds the delegated authority to develop IT policy, enforce technical standards, and manage operational decisions.

- **Binding Nature**: The Information Operations Department shall enforce all formally adopted IT policies and technical standards across all Elko County departments, systems, and personnel.
- **CJIS Management Control**: Consistent with **CJIS Security Policy Section 5.1.1.4** and applicable Management Control Agreements, the Criminal Justice Agency (CJA) retains management control over criminal justice functions and CJI. Within that framework, the IT Director (or designated CJIS Information Security Officer), acting as the CJA's technical agent, shall exercise exclusive administrative control over the configuration, security, and management of hardware, software, and firmware that transmit or store CJI on County-managed infrastructure, regardless of the user department.

6.3 Access and Change Governance

To maintain the integrity of the County network, specific decision rights are reserved exclusively for Information Operations leadership:

- **Access Control**: The granting, modification, and revocation of logical access privileges to County information systems and physical access to IT-controlled facilities (e.g., data centers, server rooms, network closets) shall fall under the operational authority of the IT Director, implemented in accordance with **Policy 2.04** (Access Control Policy) and **Policy 2.02** (Personnel Security and Background Screening Policy). For systems processing CJI, access decisions shall further comply with CJIS Security Policy and applicable Management Control Agreements.
- **Change Control**: Changes affecting cross-departmental services, core infrastructure, or security baselines must be reviewed and approved by the IT Director and processed in accordance with **Policy 3.09** (Change Management Policy). Significant changes affecting County-wide operations may require County Manager notification or approval in accordance with **Policy 1.08**.

6.4 Interdepartmental Dependencies and Obligations

Effective governance requires strict coordination between control functions. The following dependencies are mandatory:

- **Human Services** (HR): HR serves as the authoritative source for personnel status. HR shall provide notification to IT—through the designated HR information system or service desk process—regarding onboarding, termination, or role changes to ensure secure access control (See **Policy 2.02**).
- **Fiscal Affairs**: Fiscal Affairs governs financial processing for technology purchases. Fiscal Affairs shall collaborate with IT to ensure all technology procurement aligns with the governance standards defined in **Policy 1.10** and supply chain risk criteria in **Policy 1.13**, and shall reject non-compliant requisitions.

1.07 Workforce Roles, Responsibilities, and Competency Framework

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to define the internal organizational structure, operational scope, behavioral expectations, and advancement pathways for all personnel within the Elko County Information Operations Department. It establishes a formal hierarchy of authority, accountability, and technical competency aligned with industry frameworks to ensure the consistent delivery of technology services and the security of County information assets.

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, trainees, contractors, and temporary workers. It governs internal role design, authority delegation, support escalation, and professional development expectations.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the department head and senior technical authority, responsible for strategic alignment, governance oversight, and final competency adjudication.
- **Assistant IT Director**: Shall serve as the operational executive, responsible for day-to-day service delivery, workforce development, and ensuring role clarity among staff.
- **Supervisors and Leads**: Shall enforce role boundaries, validate competency mastery, ensure position descriptions incorporate STAK-defined skills, and conduct performance evaluations against the standards defined in this policy.
- **All Personnel**: Shall act strictly within the scope of their assigned role and authority, shall not perform duties reserved for higher tiers without documented delegation in accordance with **Policy 1.08**, and shall maintain the competencies defined for their role in **Appendix 6.03**.

4. Compliance and Exceptions

Personnel shall act only within the scope of their assigned role and technical authorization level. Any temporary delegation of authority or acting capacity must be documented in accordance with **Policy 1.08** (Delegation of Authority).

- **Assessment**: Role alignment and competency mastery shall be assessed annually during performance reviews.
- **Acknowledgment**: All personnel shall acknowledge receipt and understanding of this policy and their assigned role definition upon hire, upon role change, and annually thereafter.
- **Enforcement**: Failure to adhere to assigned role boundaries, Tier restrictions, or competency requirements may be treated as non-compliance and escalated under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Exceptions**: Exceptions to the role structure or minimum competency requirements must be reviewed and approved in writing by the IT Director.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Appendix 6.03: Workforce Roles STAK Matrix
- NRS 242.171 (Responsibilities of Office/Director)
- CJIS Security Policy v6.0: Section PS-3 (Personnel Screening)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: AT-1 (Awareness and Training Policy and Procedures)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: PM-13 (Security and Privacy Workforce)
- NIST SP 800-53 Rev. 5: PS-1 (Personnel Security Policy and Procedures)
- NIST SP 800-53 Rev. 5: PS-4 (Personnel Termination)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- NIST SP 800-53 Rev. 5: PS-9 (Position Descriptions)
- NIST SP 800-181 Rev. 1: (NICE Workforce Framework for Cybersecurity)
- COBIT 2019: APO07 (Manage Human Resources)
- ITIL v4: Workforce and Talent Management Practice
- SFIA 9: (Skills Framework for the Information Age)

6. Policy Statement

6.1 Role Tier Structure & Security Clearance

The Information Operations Department is organized into hierarchical role tiers to ensure operational clarity, escalation discipline, and professional development. Role tiers L0–L5 correspond directly to the roles defined in **Appendix 6.03** (Workforce Roles STAK Matrix).

- **Security Screening Requirements**: Assignment of any individual, including contractors and temporary personnel, to a role above "Trainee" is contingent upon the successful adjudication of background screening required for that tier as defined in **Policy 2.02** (Personnel Security).
  - **Rescreening**: Personnel with access to Criminal Justice Information (CJI) shall undergo rescreening at least once every five (5) years in accordance with **CJIS Security Policy Section 5.12**.
  - **Advancement**: Advancement between tiers shall require verification that the individual's background screening adjudication remains current and appropriate for the target tier's access level.
  - **Competency Maintenance and Privileged Access Eligibility**: Assignment to Tier L3 (Administrator) and above is contingent upon maintaining the current, valid role requirements designated as mandatory in **Appendix 6.03** (Workforce Roles STAK Matrix) and the Departmental Career Ladder, including any required certifications and renewals where specified. A lapse in a mandatory requirement (e.g., expiration, revocation, or failure to maintain renewal status) shall

result in the immediate suspension of administrative privileges and removal from unsupervised Tier L3+ duties. The individual shall be temporarily reassigned to Tier L2 duties (Support Specialist) or lower until the requirement is reinstated or a written exception is approved by the IT Director in accordance with **Policy 1.08**. All suspensions, exceptions, and reinstatements shall be documented in the Department's system of record and managed under the corrective action framework in **Policy 5.01**.

- **Tier Definitions**:
  - **Director Level (Tier L5)**: Provides strategic leadership, governance, and oversight. Focus is on Strategy and Risk. Aligns with NICE OV-EXL-001 / SFIA Levels 6-7.
  - **Assistant Director Level (Tier L4)**: Manages operations and workforce development. Focus is on Operations and Governance. Aligns with NICE OV-MGT-001 / SFIA Levels 5-6.
  - **Administrator Level (Tier L3)**: Manages critical infrastructure, security controls, and engineering. Focus is on Stability and Security. Aligns with NICE OM-ADM-001 (Systems) & OM-NET-001 (Network) / SFIA Levels 4-5.
  - **Support Specialist Level (Tier L2)**: Provides Tier 1 support and resolution. Focus is on Service and Resolution. Aligns with NICE OM-STS-001 / SFIA Level 3.
  - **Administrative Assistant Level (Tier L1)**: Provides triage and logistics. Focus is on Process and Logistics. Aligns with SFIA Level 2.
  - **IT Trainee Level (Tier L0)**: Focus is on Learning and Assimilation. Aligns with SFIA Level 1.

6.2 Role Definitions and Duties

The following roles define the operational and governance structure of the Information Operations Department. Formal County position descriptions shall align with these definitions and with the STAK competencies in Appendix 6.03.

- **IT Director**: The IT Director is the senior technology authority, reporting to the County Manager. The Director shall:
  - **Strategic Planning**: Develop and drive IT strategy aligned with Elko County's statutory duties and public service objectives.
  - **Governance**: Establish and maintain the Information Operations Policy Manual, ensuring compliance with Federal, State, and Local mandates.
  - **Security Leadership**: Serve as the designated Chief Information Security Officer (CISO) function, holding ultimate accountability for the County's cybersecurity posture.
  - **Financial Management**: Manage the departmental budget, capital improvement plans (CIP), and procurement contracts.
- **Assistant IT Director**: The Assistant IT Director serves as the operational executive and deputizes for the Director. The Assistant Director shall:
  - **Operations Management**: Oversee daily IT service delivery, ensuring adherence to Service Level Agreements (SLAs).
  - **Workforce Development**: Manage staffing, performance evaluations, and the execution of the training program.
  - **Project Governance**: Lead the IT project portfolio to ensure initiatives are delivered on time, within scope, and on budget.
  - **Deputization**: Assume decision-making authority in the Director's absence only to the extent formally delegated under **Policy 1.08**.

- **Systems Administrator**: The Systems Administrator manages server infrastructure, identity, and data integrity. The Systems Administrator shall:
  - **Server Management**: Provision, harden, and maintain physical and virtual server infrastructure (Windows/UNIX).
  - **Identity Management**: Manage Active Directory, Group Policy, and role-based access control (RBAC) in accordance with **Policy 2.04**.
  - **Data Integrity**: Manage backups, disaster recovery replication, and database security (SQL) to ensure data availability and confidentiality.
  - **Patch Management**: Execute the vulnerability management program for server endpoints.
- **Network Administrator**: The Network Administrator manages connectivity, boundary defenses, and transport infrastructure. The Network Administrator shall:
  - **Network Architecture**: Design and maintain LAN/WAN/Wireless topologies to ensure high availability and fault tolerance.
  - **Boundary Defense**: Configure firewalls, VPNs, and intrusion detection systems (IDS/IPS) to protect the network perimeter.
  - **Traffic Analysis**: Monitor network flow and performance metrics to identify anomalies or capacity bottlenecks.
  - **Physical Infrastructure**: Manage structured cabling, switching infrastructure, and environmental controls in network closets.
- **Support Specialist**: Support Specialists serve as the primary interface for end-user assistance and resolution. Support Specialists shall:
  - **Incident Resolution**: Diagnose and resolve Tier 1 hardware and software issues for end-users via the service desk.
  - **Deployment**: Configure and install new endpoints, peripherals, and software in accordance with standard baselines.
  - **User Guidance**: Educate users on approved software configurations and best practices.
  - **Escalation**: Accurately document and escalate unresolved issues to Administrators with complete diagnostic data.
- **Administrative Assistant**: The Administrative Assistant manages departmental front-end operations and logistics. The Administrative Assistant shall:
  - **Access Triage**: Validate visitor credentials, issue visitor badges, and manage physical access logs in compliance with physical security policies.
  - **Credential Support**: Perform verified password resets (non-privileged accounts only) and initial ticket intake/classification under documented procedures.
  - **Coordination**: Manage departmental procurement receiving, phone routing, and scheduling logistics.
  - **Documentation Support**: Assist with formatting and distributing IT communications in accordance with **Policy 1.04**.
- **IT Trainee**: Trainees operate under a structured development program. Trainees shall:
  - **Mentorship Rotation**: Participate in mandatory rotations across Support and Infrastructure domains.
  - **Certification**: Obtain CompTIA A+ and Network+ certifications (or Director-approved equivalents) within **twelve (12) months** of hire date.

  - **Operational Discipline**: Demonstrate cultural alignment, professional communication, and adherence to the Code of Ethics (**Policy 1.02**).
  - **CJIS Restriction**: Trainees shall not be assigned duties involving access to Criminal Justice Information (CJI) or CJIS-connected systems until all required CJIS personnel security screening defined in **Policy 2.02** has been successfully adjudicated.

6.3 Advancement Pathways

Advancement within the Department is meritocratic, earned through demonstrated competency mastery, certification acquisition, and cultural adherence. Tenure alone shall not constitute grounds for promotion.

- **Criteria**: Advancement decisions shall consider both technical competency and security compliance history (e.g., adherence to policies, absence of unresolved disciplinary actions).
- **Pathways**: Specific criteria for advancement from Trainee, Support Specialist, and Administrator roles are defined in the Departmental Career Ladder and aligned with the STAK Matrix.

6.4 Competency and Skills Framework (STAK)

To ensure objective evaluation of personnel, the Department utilizes a **Skills, Tasks, Abilities, and Knowledge (STAK)** framework.

- **Definition**: Specific STAK requirements for each role are defined in **Appendix 6.03**.
- **Alignment**: These competencies are mapped to the **NICE Workforce Framework for Cybersecurity** and **SFIA 9**.
- **Evaluation**: Performance reviews shall explicitly reference the STAK matrix to identify skill gaps and assign remedial training.
- **Training**: The Director shall ensure that personnel with security-relevant duties complete role-based cybersecurity training at onboarding and at least annually thereafter, consistent with the competencies defined in **Appendix 6.03** and **Policy 2.03**.

1.08 Delegation of Authority and Decision Rights

Effective: July 01, 2026 Version: 1.3

1. Purpose

This policy defines the structure, scope, and limitations of decision-making authority within the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel and to any County official, department, or entity interacting with the Information Operations Department in a managerial, technical, or support capacity.

3. Roles and Responsibilities

- **IT Director**:
  - Shall hold primary operational and decision-making authority over technical services, cybersecurity, and infrastructure.
  - Shall delegate administrative and operational authority as defined in Section 6 of this policy.
  - Shall maintain the Separation of Duties Matrix and review it at least annually.
- **County Manager**:
  - Shall hold administrative oversight of the IT Director, including performance evaluation and policy ratification.
  - Shall not exercise operational authority over security controls.
  - Shall serve as the mediation authority for conflicts between administrative and operational authority as defined in Section 6.4.
- **Assistant IT Director**:
  - Shall hold standing delegated operational authority as defined in Section 6.2.
  - Shall serve as the primary operational decision-maker in the IT Director's absence, within the bounds of the standing written Delegation of Authority Order.
- **Human Resources (HR)**:
  - Shall provide official onboarding and offboarding notifications as defined in Section 6.5.
  - Shall not direct or influence technical decisions or access control timelines.
- **Fiscal Affairs**:
  - Shall oversee budgetary and procurement processes.
  - Shall not prescribe technical standards or override IT design decisions.
- **All Information Operations Personnel**:
  - Shall operate strictly within their designated role and authority as defined by department policy.
  - Shall not assume authority beyond their assigned role without formal, written delegation.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel and County officials exercising authority over or within the Information Operations Department.

- **Assessment**: Compliance with delegation requirements shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and through the annual review of delegation records and the Separation of Duties Matrix required under Section 6 of this policy.
- **Enforcement**: The IT Director shall treat unauthorized assumption of authority, failure to document delegations, or exercise of authority beyond a delegation's defined scope as non-compliance and may initiate corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with written justification, approved in accordance with **Policy 5.01**, and processed as follows. Oral exceptions are not valid.
  - **Operational Exceptions**: Exceptions to operational delegation shall be approved in writing by the IT Director.
  - **Governance Exceptions**: Exceptions regarding decision rights or chain of command shall be approved by the County Manager in consultation with the IT Director. Governance exceptions shall not grant operational authority, alter security baselines, or authorize deviation from mandatory security controls. Governance exceptions shall not modify incident declaration authority, Incident Commander designation criteria, or operational decision rights during incident response as defined in **Policy 4.01** (Incident Response Policy Overview).
  - **Stand-in Restriction**: During the IT Director's absence, exceptions that would expand the authority of an acting administrative stand-in shall be deferred until the IT Director's return or escalated to the Board of County Commissioners.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- CJIS Security Policy v6.0: Section AC-6(7) (Least Privilege — Review of User Privileges)
- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: AC-6 (Least Privilege)

Framework Alignment:

- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: AC-1 (Access Control Policy and Procedures)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- COBIT 2019: APO01.04 (Define roles, responsibilities, and authorities)

- COBIT 2019: APO01.05 (Define target capability)
- COBIT 2019: DSS06.03 (Manage roles, responsibilities, access privileges, and levels of authority)

6. Policy Statement

This policy formalizes how decision-making power — both operational and administrative — is assigned, delegated, and exercised within the Information Operations Department. The separation of administrative and operational authority is designed to preserve continuity, accountability, and appropriate oversight across the Information Technology function while ensuring that mandatory security controls are never subordinated to administrative convenience.

6.1 Authority Classification

Authority within the Information Operations Department is classified into two distinct categories to satisfy NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties):

- **Administrative Authority**: Managerial oversight functions including personnel management, timekeeping, budget approval, and policy ratification.
- **Operational Authority**: Technical decision-making functions including infrastructure management, cybersecurity configuration, technical standards, and service design.
- **Constraint**: Dual authority (the ability to exercise both administrative and operational functions) resides inherently with the IT Director and may only be granted to others through explicit, written delegation (including the standing delegation defined in Section 6.2).
- **Clarification**: Mandatory security controls — defined as all requirements stipulated by the CJIS Security Policy, Nevada Revised Statutes, and County-adopted security baselines — shall not be subject to override by administrative stand-ins. The IT Director shall ensure that mandatory security controls are maintained regardless of personnel changes or delegations.
- **CJIS Management Control**: For systems processing, storing, or transmitting Criminal Justice Information (CJI), decision rights are subject to the applicable CJIS Management Control Agreement and shall not be overridden by administrative stand-ins.

6.2 Delegation Rules and Limitations

- **Formal Documentation**: The IT Director shall delegate operational authority only to technically qualified personnel (Tier L3 or higher per **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework)) and shall document each delegation in writing. The IT Director shall define the scope, conditions, and duration in the delegation record.
- **Annual Review**: The IT Director shall review delegated authority and privileged access assignments at least annually to validate continued business need, consistent with CJIS Security Policy v6.0: Section AC-6(7) (Least Privilege — Review of User Privileges).
- **Retention**: The IT Director shall retain delegation records in the Department's designated system of record in accordance with NRS 239.125 and the Nevada Local Government Records Management Program.
- **Standing Delegation**: The Assistant IT Director holds standing delegated operational authority and is authorized to exercise administrative functions in the IT Director's absence only within the bounds of a standing written Delegation of Authority Order, reviewed annually. The Assistant IT Director shall exercise only those administrative functions explicitly delegated in writing by the IT Director. Authority not expressly granted is reserved to the IT Director.
  - **Scope of Administrative Authority**: Authority is limited to routine operational administration (e.g., timecard approvals, workflow coordination, internal purchasing). It does not include authority for HR disciplinary actions, terminations, or ratification of the Countywide IT budget.

  - **Lapse**: Failure to complete the annual review of the standing Delegation of Authority Order shall not automatically revoke the standing delegation, but shall constitute non-compliance subject to remediation under **Policy 5.01**. The IT Director shall complete the overdue review within ten (10) business days of discovery, and the delegation record shall be flagged as review-past-due in the Department's system of record until remediation is complete.

- **Directed Deputization**: The IT Director may designate any Tier L3+ IT Department personnel to exercise specific operational authority on the IT Director's behalf for a defined scope and duration. Directed Deputization is limited to operational functions — including work order management, priority retasking, and representation in meetings — and shall not include administrative authority as defined in Section 6.1. The IT Director shall document the designation in writing, specifying the scope of authority granted, the duration, and any constraints. Directed Deputization does not displace the Assistant IT Director from their current role, modify their standing delegation, or alter the chain of delegation established in this policy. The IT Director retains authority to rescind any Directed Deputization at any time. Directed Deputization shall not include: policy exception approval, formal risk acceptance, incident declaration authority (unless separately authorized under **Policy 4.01**), access approval for the delegate's own account, or any function prohibited by the Separation of Duties Matrix maintained under Section 6.6.
- **Emergency Operational Authority**: During declared cybersecurity incidents (per **Policy 4.01**), all operational authority transfers immediately and exclusively to the designated Incident Commander.
  - **Declaration Authority**: Authority to declare a cybersecurity incident resides with the IT Director, Assistant IT Director, or designated technical lead as defined in **Policy 4.01**.
  - **Incident Commander Qualification — Designated Appointment**: The IT Director may designate any IT Department staff member as Incident Commander for a specific incident. Designation shall be made at the time it becomes effective and documented in the incident record. No tier-level prerequisite applies to a designated appointment. The IT Director retains authority to rescind any designation and resume the Incident Commander role at any time.
  - **Incident Commander Qualification — Emergency Declaration Authority**: When both the IT Director and the Assistant IT Director are genuinely unavailable, authority to declare a cybersecurity incident and serve as Incident Commander shall be limited to Tier L3+ IT Department personnel identified in writing by the IT Director. The IT Director shall maintain this list and review it at least annually. In all cases, the Incident Commander shall be an IT Department staff member. Personnel serving in a non-technical administrative or acting capacity are not eligible to serve as Incident Commander under either path.
  - **Non-Interference**: Administrative stand-ins shall not intervene in, delay, or countermand operational directives issued by the Incident Commander.
  - **Emergency Procurement**: Emergency operational actions and procurement necessary to maintain or restore mandated security controls shall not be delayed for administrative convenience; unresolved funding disputes shall be escalated to the Board of County Commissioners without pausing required containment actions. The Incident Commander is authorized to initiate emergency procurement using County emergency procedures with after-the-fact ratification.
  - **Fiscal Duty**: Fiscal Affairs and Purchasing shall process Incident Commander emergency procurement requests using applicable emergency procedures without delaying required containment or mandated control restoration. Fiscal Affairs and Purchasing shall document all actions and approvals in the incident record.
  - **Constraint**: Administrative funding authority shall not be exercised to delay, suspend, or condition execution of incident containment actions or mandated security control implementation.
- **Administrative Stand-ins**: Non-technical leadership (e.g., County Manager) acting as a stand-in during leadership absence may fulfill administrative duties (e.g., communications coordination, staffing logistics, budget routing) but shall not:

  - Issue operational directives, service restoration sequencing instructions, or countermand technical decisions.
  - Authorize changes to security baselines, firewall rules, or access configurations.
  - Approve risk acceptance for mandatory security controls.
  - Modify patch deployment schedules or vulnerability remediation priorities.

6.3 Interdepartmental Boundaries

To preserve operational integrity and separation of duties, the following boundaries shall apply:

- **Human Resources (HR)**:
  - HR may enforce administrative actions (e.g., terminations) and shall provide official notifications per Section 6.5.
  - HR shall not influence how access revocation is performed, dictate tools, or establish technical response timelines without IT Director approval.
- **Fiscal Affairs**: Fiscal Affairs may control budgetary limits but shall not mandate hardware standards or compel the reduction of mandatory security controls due to cost without a formal risk acceptance documented in the Risk Register maintained under **Policy 1.09** (Risk Management Policy) and signed by the IT Director.
- **System Access Restrictions**: To enforce separation of duties (AC-5), non-IT personnel serving as administrative stand-ins shall not be granted administrative access to Information Operations systems (e.g., Active Directory, firewalls), including "break-glass" accounts, or physical access to secure server environments without IT escort.
  - **Facilities Access**: Facilities and custodial access provisioning for server rooms/network closets shall be controlled by Information Operations access lists; emergency entry by non-IT personnel shall require IT escort or the Incident Commander's written authorization.

6.4 Revocation and Escalation

- **Revocability**: The IT Director may revoke any delegated authority at any time.
- **Conflict Resolution**: The IT Director or the party identifying the conflict shall formally escalate disputes between administrative and operational authority to the County Manager for mediation.
- **Mediation Constraints**: Mediation shall occur on an expedited basis and begin within one (1) business day of escalation. Mediation may address priorities and resources but shall not authorize deviation from mandatory security controls or security baselines. The IT Director or Incident Commander shall ensure that operational containment and mandated control implementation continue during mediation.
- **Impartiality**: If the County Manager is serving as the administrative stand-in and is a party to the conflict, the IT Director shall escalate the matter to the Board of County Commissioners to ensure impartial review.

6.5 Delegated Notification Authority

The Information Operations Department designates Human Resources as the authoritative originator of official onboarding and offboarding notifications. This delegation is procedural — HR is authorized to initiate the process — but does not convey control over access implementation, technical execution timing, or operational response, which remain with the IT Director and designated IT personnel. When HR is unavailable and an urgent separation requires immediate action, the County Manager or other legally authorized official may initiate the notification directly to the Information Operations Department. The IT Director shall treat

such notifications as valid and shall document the source and circumstances in the Department's system of record.

- **Timelines**: HR shall provide:
  - **Onboarding notifications**: At least three (3) business days prior to the start date.
  - **Offboarding notifications**: Immediately upon determination of separation (no later than close of business on the decision date).
- **Accountability**: The IT Director shall document notification delays that result in access control violations and report them to the County Manager. The delaying party bears accountability for the resulting compliance gap.

6.6 Separation of Specific Duties

The IT Director shall enforce the following separation of duties requirements to satisfy NIST SP 800-53 AC-5 (Separation of Duties):

- **Access Approval vs. Access Provisioning**: Personnel authorized to approve access requests shall not be the same personnel who implement the access in the directory service, except where automated provisioning systems enforced by policy are utilized. Automated systems must enforce approval workflows and maintain immutable audit trails.
- **Security Administration vs. Audit Logging**: Personnel with administrative control over security baselines (e.g., firewall rules) shall not have the ability to modify or delete audit logs that record their actions. Security logs must be forwarded to a repository where security administrators hold read-only or append-only privileges.
- **Development vs. Production**: Personnel shall not have unmonitored administrative access to both development and production environments for the same system.
- **Change Approval vs. Change Implementation**: Personnel authorized to approve significant changes to security baselines (e.g., firewall policy, Group Policy, endpoint protection) shall not be the same personnel who implement those changes, except where emergency procedures are invoked and subsequently reviewed.
- **Separation Matrix**: The IT Director shall maintain a documented Separation of Duties Matrix identifying specific incompatible duties, including but not limited to: (a) system administration vs. audit log review; (b) access provisioning vs. access approval. The IT Director shall review this matrix annually.
- **Delegation Constraint**: Delegation shall not permit any individual to both request and approve access, approve access for themselves, or combine access approval with access provisioning, in accordance with separation of duties (AC-5) and least privilege (AC-6).

The IT Director shall document separation-of-duties role assignments and corresponding privileged access authorizations in the Department's access control matrix and shall enforce them through role-based access control (RBAC). The IT Director shall review the access control matrix at least annually and upon significant role or staffing changes. When the IT Director determines that staffing constraints require a single individual to perform otherwise incompatible duties, the IT Director shall implement compensating controls (e.g., independent after-the-fact review within one (1) business day, immutable logging, or secondary approval via workflow) and shall document the exception.

1.09 Risk Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the formal governance structure, methodology, and responsibilities for managing information technology risk within Elko County. It mandates a lifecycle approach to identifying, assessing, responding to, and monitoring risks that threaten the confidentiality, integrity, and availability of County information systems. This policy serves as the authority for risk-based decision-making, resource prioritization, and the formal acceptance of operational risk.

2. Scope

This policy applies to all information systems, infrastructure, data, personnel, and third-party vendors managed by or on behalf of the Elko County Information Operations Department. It governs strategic, operational, compliance, and technical risk throughout the system development lifecycle (SDLC)

3. Roles and Responsibilities

- **IT Director**: Shall serve as the **Chief Information Security Officer (CISO)** and the designated **Authorizing Official (AO)** for Elko County, responsible for issuing risk-based authorization decisions for all County information systems. Shall define the County's risk tolerance by reviewing and approving the **Risk Management Strategy** annually. Shall sign all **Risk Acceptance Memos**. In the Director's absence, the Assistant IT Director (Acting) may sign risk acceptances that are time-bounded (not to exceed 30 days) and shall be ratified in writing by the IT Director within five (5) business days of return. This temporary delegation is a specific limitation for risk acceptance decisions and does not expand delegation beyond the standing authority defined in **Policy 1.08**. Shall review and formally approve System Security Categorizations.
- **Assistant IT Director**: Shall serve as the **Risk Program Owner** and coordinate RMF evidence across systems. Shall execute the Risk Management program and maintain the centralized **Risk Register**. Shall develop and maintain a formal, standalone Risk Management Strategy document that defines organizational risk tolerance, mitigation approaches, and review frequency (**NIST PM-9**). Shall oversee the execution of risk assessments and vulnerability scans. Shall validate that risk mitigation strategies and Plans of Action and Milestones (POA&Ms) are effective and updated.
- **System Owners (Department Heads/Elected Officials)**: Shall be accountable for the security and privacy of the information systems they own. Shall support the categorization of their systems and participate in risk assessments. Shall concur with Risk Acceptance Memos for their systems, acknowledging the operational risk being accepted.
- **Administrators (Network & Systems)**: Shall conduct technical risk assessments and vulnerability scans. Shall implement required risk mitigation controls and remediate vulnerabilities within mandated timelines. Shall report changes in system architecture that may alter the risk profile to the Assistant IT Director immediately.
- **All Department Personnel**: Shall submit identified vulnerabilities, control gaps, or potential threats to the Assistant IT Director for inclusion in the Risk Register. Shall report active threats, anomalous system behavior, or suspected breaches immediately via the channels defined in **Policy 4.02** (Identification and Reporting Procedures). Shall adhere to risk mitigation procedures and security controls defined in this manual.

4. Compliance and Exceptions

- **Mandatory Compliance**: Adherence to this policy is mandatory. Failure to identify, report, or remediate risks according to these standards constitutes a violation of County governance and may result in disciplinary action.
- **Acknowledgment**:
  - **Personnel**: All Department personnel shall acknowledge receipt of this policy upon hire, upon substantive revision, and annually thereafter. Acknowledgment records shall be maintained in accordance with **Policy 2.03** (Security Awareness and Training Policy).
  - **Vendors**: Vendors and contractors shall acknowledge adherence through contractual agreements and the vendor governance process defined in **Policy 1.13**.
- **Records Retention**: Risk Assessment Reports, Risk Acceptance Memos, and POA&Ms are County records. They shall be retained in accordance with **NRS 239.125** and **NAC 239.155** under the applicable **Nevada Local Government Records Retention Schedule** series, including:
  - **IT Security Evaluations**
  - **IT Security Plans**
  - **IT Security Reviews, Reports and Logs**
- **Exceptions and Deviations**: Any deviation from this policy, including the decision to accept a "High" or "Critical" risk without mitigation, must be documented in a formal **Risk Acceptance Memo**, signed by the IT Director (or authorized Acting IT Director) and the System Owner, and logged in the Risk Register.
  - **Authorization Package**: Risk Acceptance Memos shall become part of the system's **Authorization Package** (along with the System Security Plan, Security Assessment Report, and POA&M).
  - **Template**: Exceptions shall be documented using the standard **Risk Acceptance Memo Template** located in.
  - **Memo Requirements**: Risk Acceptance Memos must include, at a minimum: scope of the exception, business justification, compensating controls, expiration/review date, residual risk statement, and System Owner concurrence.
  - **Decision Rights**: System Owner concurrence constitutes acknowledgement of operational/business impact and acceptance of residual operational risk. AO approval constitutes the authorization decision and acceptance of residual security risk on behalf of the County.
  - **Automatic Expiration**: All risk acceptances shall automatically expire on the stated expiration date. Expired acceptances shall be treated as unauthorized deviations until renewed in writing.
  - **Ongoing Monitoring**: Accepted risks shall remain documented in the applicable assessment records and shall be monitored for changes in likelihood, impact, or exposure until closed.
  - **Prohibition**: Risk acceptance shall not authorize noncompliance with CJIS Security Policy requirements, statutory requirements, or other mandatory security controls.
  - **Governance Boundary**: Risk Acceptance Memos document residual risk after required controls are implemented. Requests to deviate from decision rights or the chain of command are governance exceptions governed by **Policy 1.08**.
  - **Administrative Stand-ins**: Non-technical administrative stand-ins (as defined in **Policy 1.08**) are prohibited from approving risk acceptance for mandatory security controls.

5. References

- ECIO Policy 1.01: Department Mission and Strategic Objectives

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action Policy
- ECIO Policy 5.05: Security Control Assessment and Authorization
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section RA-1 (Risk Assessment Policy and Procedures)
- CJIS Security Policy v6.0: Section RA-2 (Security Categorization)
- CJIS Security Policy v6.0: Section RA-3 (Risk Assessment)
- CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning)
- CJIS Security Policy v6.0: Section RA-7 (Risk Response)
- CJIS Security Policy v6.0: Section RA-9 (Supply Chain Risk Assessment)
- NIST CSF 2.0: GV.RM-01 (Risk Management Strategy)
- NIST CSF 2.0: GV.RM-02 (Risk Appetite)
- NIST CSF 2.0: GV.RM-04 (Risk Register)
- NIST CSF 2.0: GV.RM-06 (Risk Monitoring)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Management)
- NIST CSF 2.0: ID.RA-02 (Threat Intelligence)
- NIST CSF 2.0: ID.RA-03 (Internal/External Threats)
- NIST CSF 2.0: ID.RA-04 (Risk Impacts)
- NIST CSF 2.0: ID.RA-05 (Risk Threats)
- NIST CSF 2.0: ID.RA-06 (Risk Responses)
- NIST SP 800-30 Rev. 1: (Guide for Conducting Risk Assessments)
- NIST SP 800-37 Rev. 2: (Risk Management Framework)
- NIST SP 800-53 Rev. 5: PM-9 (Risk Management Strategy)
- NIST SP 800-53 Rev. 5: RA-1 (Risk Assessment Policy and Procedures)
- NIST SP 800-53 Rev. 5: RA-2 (Security Categorization)
- NIST SP 800-53 Rev. 5: RA-3 (Risk Assessment)
- NIST SP 800-53 Rev. 5: RA-5 (Vulnerability Monitoring and Scanning)
- NIST SP 800-53 Rev. 5: RA-7 (Risk Response)
- NIST SP 800-53 Rev. 5: RA-9 (Supply Chain Risk Assessment)

- NIST SP 800-137: (Information Security Continuous Monitoring (ISCM))
- COBIT 2019: APO12 (Manage Risk)
- COBIT 2019: EDM03 (Ensure Risk Optimization)

6. Policy Statement

6.1 Risk Management Framework (RMF) Adoption

The Information Operations Department adopts the NIST Risk Management Framework (RMF) as the strategic methodology for managing system lifecycles. All County information systems shall move through the RMF stages: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor.

- **Risk Management Strategy**: The Assistant IT Director shall maintain a documented Risk Management Strategy that defines risk appetite/tolerance, prioritization criteria, management decision rules for selecting risk responses, scoring methodology, reporting thresholds, and review cadence; the IT Director shall approve it at least annually (**NIST PM-9**).
- **Continuous Monitoring**: Operational risk management shall align with the NIST Cybersecurity Framework (CSF) 2.0 functions. Risk monitoring shall be integrated into the Department's Continuous Monitoring program, and outputs shall be recorded as evidence in the Risk Register and/or control assessment records. The program shall explicitly track:
  - **Effectiveness**: Monitoring ensuring security controls are operating as intended.
  - **Compliance**: Monitoring ensuring adherence to CJIS, HIPAA, PCI, and County policy.
  - **Change**: Monitoring identifying changes to systems or environments that alter the risk profile.

6.2 Security Categorization (FIPS 199)

All County information systems must be categorized based on the potential impact of a loss of confidentiality, integrity, or availability.

- **Authorizing Official Approval**: The IT Director (AO) shall review and formally approve the security categorization of all information systems (**NIST RA-2**).
- **Documentation**: Security categorization results and rationale shall be documented in the **System Security Plan (SSP)** or equivalent system security documentation.
- **Criminal Justice Information (CJI)**: As a County baseline, all systems processing, storing, or transmitting CJI shall be categorized, at a minimum, as **Moderate Impact** and shall implement CJIS-required controls and County controls commensurate with that impact level.
- **Categorization Review**: Security categorizations must be reviewed annually or following any significant system change.

6.3 Risk Assessment Methodology

Risk assessments must identify threats, vulnerabilities, likelihood, and impact specific to the system environment. Assessments shall utilize the standardized scoring criteria. Assessments shall explicitly consider supply chain risks in accordance with **Policy 1.13**.

- **Assessment Cadence**:
  - **Quarterly Review**: All risk assessments shall be reviewed at least **Quarterly**. "Review" is defined as risk register reconciliation, status validation, and treatment progress confirmation.
  - **Annual Update**: Formal risk assessment updates (re-scoring and threat refresh) shall be performed at least **Annually** for non-critical systems.

  - **CJI/Critical Update**: Formal risk assessment updates shall be performed at least **Quarterly** for CJI and Critical Systems (**CJIS RA-3**).
- **Event-Driven Reviews**: A risk assessment update shall be initiated within five (5) business days following any security incident, material system change, significant control failure, or confirmed vulnerability affecting County systems (**NIST RA-3**).
- **Policy Review**: This policy shall be reviewed at least annually in accordance with **Policy 1.05** and updated as necessary to reflect changes in the risk environment.
- **Threat Intelligence**: The process shall incorporate cyber threat intelligence received from external information-sharing forums (e.g., MS-ISAC, FBI InfraGard) (**NIST ID.RA-02**).

6.4 Vulnerability Monitoring and Remediation Standards

The Department shall employ automated tools to scan for vulnerabilities in information systems and hosted applications. Operational patching procedures and specific tool configurations shall be maintained in accordance with **Policy 2.09** (Vulnerability and Patch Management Policy).

- **Scope**: Scans shall cover internal assets, external perimeter assets, and web applications. Privileged vulnerability scans shall require explicit authorization.
- **Scanning Frequency**: Vulnerability scans shall be performed at least Monthly (County Baseline) and whenever new vulnerabilities potentially affecting the system are identified and reported, including following major configuration changes and critical exploit advisories (**CJIS RA-5**).
- **Remediation Timelines**: To manage technical risk, the Department shall adhere to the following strict remediation timelines. Severity ratings shall be based on the County-approved scoring standard (e.g., CVSS base score or vendor severity, whichever is higher), as defined in **Policy 2.09** and **Appendix** .
  - **Critical Severity**: Remediate within **15 days**.
  - **High Severity**: Remediate within **30 days**.
  - **Medium Severity**: Remediate within **60 days**.
  - **Low Severity**: Remediate within **90 days**.
- **Enforcement**: When remediation will exceed the timelines above, the Administrator shall document the item in a POA&M and submit a **Risk Acceptance Memo** before the remediation deadline expires. This memo must include **compensating controls** to mitigate risk during the exposure window and a defined expiration date.

6.5 Risk Response Strategies

Upon identification of a risk, the Department must select one of the following response strategies (**NIST RA-7**):

- **Mitigate**: Apply controls (patches, configuration changes, and physical barriers) to reduce risk to an acceptable level.
- **Accept**: Formally acknowledge the risk. Risk acceptance requires written justification, System Owner concurrence, and approval by the IT Director.
- **Transfer**: Shift liability to a third party (e.g., cyber insurance, managed service contracts). Vendor risk transfer shall be managed in accordance with **Policy 1.13**.
- **Avoid**: Discontinue the activity, system, or vendor relationship causing the risk.

6.6 Criticality Analysis

The Department shall identify critical system components and functions by performing a criticality analysis at the planning, design, and implementation stages (**NIST RA-9**).

- **High Value Assets (HVAs)**: Systems designated as "Critical" or "High Value" in the **Disaster Recovery Plan** or **System Security Plan (SSP)** shall be prioritized for advanced protection measures and continuity planning.

6.7 Risk Register and Reporting

The Assistant IT Director shall maintain a centralized Risk Register tracking all identified risks.

- **System of Record**: The Risk Register shall be maintained in the Department's designated **System of Record** (e.g., Redmine or secured GRC platform) with strict role-based access controls.
- **Sensitive Security Information**: The Risk Register and supporting evidence shall be treated as sensitive security documentation; access shall be restricted to authorized personnel on a need-to-know basis, and disclosures shall be managed in accordance with County policy and CJIS requirements.
- **Minimum Data Fields**: The Risk Register shall contain, at a minimum: Risk ID, Date Identified, System/Asset, System Owner, CJI Indicator (Y/N), Risk Category, CVE/CVSS (if applicable), Inherent/Residual Score, Control Mapping, Treatment Strategy, POA&M Linkage, Status, Due Date, and Acceptance Authority.
- **POA&M Updates**: Plans of Action and Milestones (POA&Ms) for unremediated risks shall be updated at least every **six (6) months**.
- **Risk-Based Frequency**: For CJI systems, Critical systems, and any risk rated "High" or "Critical," POA&Ms shall be reviewed and updated at least **Quarterly**.
- **Reporting**: A summary of the County's risk posture, including all accepted "High" risks, shall be reported to the County Manager annually by the IT Director.

1.10 IT Financial Management and Procurement Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory governance and internal controls for the financial stewardship and procurement of Elko County technology resources. This policy enforces a strict separation between **Technical Authority** (validation of need, compatibility, lifecycle impact, inventory integration, and security) and **Financial Authority** (budget verification and lawful purchasing execution). This separation is required to prevent unauthorized technology acquisition ("Shadow IT"), ensure value realization, and maintain full auditability of public funds in accordance with Nevada Revised Statutes.

2. Scope

This policy applies to all technology-related financial transactions conducted by any Elko County entity, department, or elected office, regardless of funding source or purchasing mechanism. This includes, but is not limited to:

- Hardware, software, and infrastructure procurement.
- Cloud services (SaaS, IaaS, PaaS), subscriptions, renewals, and auto-renewals.
- Consulting, support, and managed service contracts.
- Technology purchases made via Departmental Purchase Cards (P-Cards), regardless of the funding source.
- Grant-funded technology acquisitions and renewals.

3. Roles and Responsibilities

- **IT Director**
  - **Technical Approval**: Shall act as technical authority and shall approve technical specifications, security requirements, and lifecycle/architecture impact for all technology purchases prior to the obligation of funds, execution of purchasing actions, or acceptance of contract terms.
  - **Vendor Governance**: Shall serve as the primary owner for County IT vendor technical standards, security requirements, and technical dispute escalation activities delegated to the Information Operations Department.
  - **Delegation**: Shall designate technical approvers only through **Policy 1.08** (Delegation of Authority) and shall ensure such delegations are documented.
- **Assistant IT Director**
  - **Workflow Execution**: Shall execute day-to-day procurement workflow tasks (e.g., requisitions, tracking, receiving coordination) as directed by the IT Director.
  - **Audit Readiness**: Shall maintain procurement tracking artifacts required for audit and reconciliation, including the linkage of purchases to requisitions, receiving records, work orders/tickets, project codes, and inventory/CMDB entries.
- **Fiscal Affairs (Financial Authority)**
  - **Verification**: Shall verify budget availability and execute purchasing and payment activities in accordance with applicable County procurement rules and NRS 332.

  - **Gatekeeper Function**: Shall not process technology invoices, reimbursements, or payment requests that lack documented Technical Approval from the IT Director or a formally delegated technical approver.

- **Department Heads / Elected Offices**
  - **Requirement Definition**: Shall define business requirements and coordinate with the Information Operations Department for technology needs.
  - **Restriction**: Shall not negotiate with technology vendors, authorize technology procurement, or accept/execute technology contract terms (including click-through terms, EULAs, MSAs, SOWs, renewals, or auto-renewals) without Information Operations Department review and documented Technical Approval.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all County technology procurement and technology-related financial activity.

- **Assessment**: Compliance shall be assessed through procurement review activities, audit support activities, and the annual policy review process defined in**Policy5.07**.
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Exceptions**:
  - **Emergency Procurement**: Purchases immediately necessary to protect life, safety, or critical infrastructure may proceed without prior Technical Approval only when delay would materially increase harm. Such procurements shall be reported to the IT Director and Fiscal Affairs within twenty-four (24) hours and shall undergo post-incident technical review, inventory/CMDB capture, and documentation for audit.
  - **Standing Exceptions**: Standing or permanent exceptions to this policy shall be documented with justification and approved in accordance with **Policy 1.08**.

5. References

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy5.07: Annual Policy Review and Maturity Scoring
- NRS 332 (Purchasing: Local Governments)
- CJIS Security Policy v6.0: Section 5.1.1.5 (Private Contractor User Agreements)
- CJIS Security Policy v6.0: Section Appendix H (CJIS Security Addendum / Certification)
- NIST CSF 2.0: GV.RR-03 (Resource Allocation)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)

- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: PM-3 (Information Security and Privacy Resources)
- NIST SP 800-53 Rev. 5: SA-2 (Allocation of Resources)
- NIST SP 800-53 Rev. 5: SA-4 (Acquisition Process)
- NIST SP 800-53 Rev. 5: SR-3 (Supply Chain Controls and Processes)
- COBIT 2019: APO06.01 (Manage Finance and Accounting)

6. Policy Statement

6.1 The Technical–Fiscal Handshake

Elko County shall employ a mandatory two-step validation for all technology spending:

- **Technical Approval (Information Operations Department)**: Validation that the request meets County standards. Technical Approval shall be valid only when recorded as a distinct approval status within the Department's designated System of Record (CMDB/Service Desk). Email correspondence or verbal assent shall not constitute Technical Approval.
- **Financial Approval (Fiscal Affairs)**: Validates budget availability and ensures purchasing actions comply with applicable procurement requirements (including competitive bidding thresholds and required documentation).
- **Restrictions**:
  - A budget line item does not constitute authorization to procure.
  - Fiscal Affairs shall not process payment without documented Technical Approval.
  - The Information Operations Department shall not integrate, support, or onboard technology resources that were acquired without documented Technical Approval.

6.2 Procurement Controls and "Shadow IT" Prohibition

- **Centralized Procurement**: All County software, hardware, and cloud subscriptions shall be procured through the Information Operations Department to ensure security review, asset tagging, license compliance, and inventory/CMDB integration.
- **P-Card Restrictions**: The use of departmental P-Cards for technology hardware, software, or subscriptions is prohibited without written pre-authorization by the IT Director (or formally delegated technical approver). Fiscal Affairs shall flag suspected technology P-Card transactions for review and audit.
- **Grant-Funded Technology**: Grant-funded technology is subject to the same standards as County-funded assets, including security requirements, inventory/CMDB entry, supportability, and lifecycle cost planning. Departments shall engage the Information Operations Department during grant application development to validate feasibility and total cost of ownership.
- **Auto-Renewal Controls**: Technology subscriptions shall not auto-renew without Technical Approval. Where feasible, auto-renewal shall be disabled, and renewals shall be reviewed in advance to prevent unmanaged commitments.
- **Bid Splitting**: Splitting a single requirement into multiple smaller transactions to evade competitive bidding thresholds (NRS 332) is strictly prohibited.

6.3 Budgeting and Security Allocation

- **Security Resourcing**: The Information Operations Department shall plan, request, and maintain discrete funding necessary to implement required security controls and compliance obligations (NIST PM-3, SA-2).
- **Lifecycle Forecasting**: Budget submissions shall include Total Cost of Ownership (TCO) considerations, including licensing, maintenance, support, required security controls, power/cooling (as applicable), and disposal.

6.4 Asset Integration Controls

To preserve inventory integrity and ensure auditability of technology assets and services:

- **Receiving Control**: Technology shipments shall be directed to the Information Operations Department (or a designated receiving process approved by the IT Director) for inspection and inventory capture.
- **No Tag, No Pay**: Hardware invoices shall not be approved for payment until assets are received, inspected, tagged in accordance with **Policy 1.12**, and entered into the CMDB and/or asset inventory per **Policy 3.08**.
- **No Registration, No Pay**: Software and SaaS invoices shall not be approved for payment until the subscription/license is recorded in the designated license management process and the vendor/service has completed required supply chain review steps per **Policy 1.13**.

6.5 Vendor Integrity and Security Addendums

- **Conflict of Interest and Gifts**: Personnel participating in procurement decisions shall comply with **Policy 1.02**. Conflicts of interest shall be disclosed and managed. Gifts or gratuities from vendors are prohibited where County ethics rules apply.
- **Contract Security Requirements**: Contracts involving County data exchange, hosting, or access to County systems shall include required security and data protection terms as defined by Information Operations standards and applicable County contract requirements.
- **CJIS Requirement (Contractors)**: When a vendor/contractor may have logical or physical access to Criminal Justice Information (CJI):
  1. The contract shall incorporate the **CJIS Security Addendum**.
  2. The contracting agency shall ensure each contractor employee with CJI access is provided a copy of the **CJIS Security Addendum** and the **CJIS Security Policy**, and executes the **Security Addendum Certification** acknowledging receipt and agreement to comply, consistent with **CJIS Security Policy 5.1.1.5** and **Appendix H**.
  3. The contracting agency shall retain executed certifications/acknowledgments and ensure they remain available for audit purposes.

6.6 Records Retention

Procurement and procurement-related records shall be retained in accordance with the **Nevada Local Government Records Retention Schedule** and applicable County retention requirements. At a minimum, procurement records shall be retained for the period required to support audits, claims, litigation holds, and statutory retention obligations.

1.11 Data Governance and Classification Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes a mandatory governance framework for identifying, classifying, and protecting Elko County data assets. The County shall assign value and sensitivity to information so security controls are applied consistently and proportionally to the risk of unauthorized access, disclosure, modification, destruction, or loss of availability. This policy mandates data stewardship and security attribute association while preserving statutory transparency obligations under Nevada law.

2. Scope

This policy applies to all data created, received, maintained, processed, stored, or transmitted by Elko County, regardless of format (digital, physical, or audiovisual) or location (on-premises, cloud-hosted, mobile, or third-party managed).

This includes, but is not limited to:

- **Production Data**: Records, databases, and application files supporting County operations.
- **Operational and Security Data**: System logs, audit trails, configuration data, and network telemetry.
- **Physical Media**: Printed documents, tapes, portable media, and removable storage devices.

All data residing on County infrastructure or processed on behalf of the County is County property. The use of unsanctioned systems, repositories, or "Shadow IT" to store or process County data is prohibited.

3. Roles and Responsibilities

- **Board of County Commissioners**: Upon adoption of this policy, the Board delegates authority to the IT Director to administer retention and disposition procedures for Information Operations records and IT-managed data assets in accordance with Nevada retention schedules, County directives, and applicable legal holds. This delegation applies to Information Operations records and IT-managed data assets and shall not be interpreted as superseding statutory duties assigned to other County offices.
- **IT Director**: Shall serve as the primary governance authority for data classification and data security. The IT Director shall:
  - Define and enforce the County Data Classification Schema and mandatory safeguards.
  - Serve as the **Local Agency Security Officer (LASO)** and provide direct oversight for Criminal Justice Information (CJI) within County-controlled systems.
  - Serve as the **Information Operations Records Custodian** under Board delegation for Information Operations records and IT-managed data assets, including retention and disposition procedures.
  - Ensure required technical controls, handling standards, and exception decisions are implemented and enforced County-wide for County-managed systems.
- **Terminal Agency Coordinator (TAC)**: Shall serve as the operational CJIS program point of contact for the County. The TAC shall coordinate CJIS operational requirements (including user administration processes, CJIS audit support, and CJIS compliance communications) with the LASO, CSA/CSO as applicable, and County stakeholders.

- **Department Heads (Data Owners)**: Shall classify departmental data at creation or intake, ensure access is limited to authorized personnel based on business need-to-know, and ensure departmental processes comply with the handling requirements defined in this policy.
- **Information Operations Personnel (Data Custodians)**: Shall implement and operate the technical controls (e.g., access enforcement, encryption, segmentation, logging) required to protect data according to its assigned classification.
- **All County Personnel**: Shall handle, transmit, and store data in accordance with this policy and the assigned classification. Personnel shall report suspected misclassification, mishandling, or unauthorized disclosure promptly through established reporting channels to the IT Director.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all County departments and personnel.

- **Mandatory Classification**: All County data shall be classified. Data not yet classified shall be handled as Restricted until formally evaluated and assigned a classification level.
- **Public Records and Legal Precedence**: Security classification shall not be treated as an automatic exemption from disclosure. Public records requests under NRS 239 shall be handled through the County's established legal review process. When classification controls appear to conflict with a public records obligation, the District Attorney's Office shall provide binding guidance.
- **Conflict Hierarchy**: In any conflict, statutory requirements (NRS) and CJIS Security Policy requirements shall take precedence, followed by County policy, then departmental procedures.
- **Records Retention**: Retention periods shall be applied in accordance with the Nevada Local Government Records Retention Schedule and County retention requirements.
  - IT security logs, including access control and audit logs, shall be retained for a minimum of three (3) calendar years from the end of the calendar year in which the review or audit was concluded, per the applicable Nevada Local Government Records Retention Schedule for IT Security Audit Records (currently LRDA 20071728). This exceeds the CJIS minimum of one (1) year.
  - For CJIS audit records, the greater of the CJIS minimum (one year) or the applicable Nevada retention requirement shall apply.
  - The IT Director shall ensure Information Operations retention and disposition actions are suspended during litigation holds, public records preservation requirements, audits, or other legal hold events.
- **Enforcement and Sanctions**: Unauthorized disclosure or mishandling of Confidential or Restricted information may result in corrective action, disciplinary action up to and including termination, referral for investigation, and/or criminal prosecution under applicable law (including NRS 205).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved by the IT Director in accordance with **Policy 1.04** and **Policy 1.08**.
  - Any exception involving Restricted CJI shall require explicit written approval of the IT Director (as LASO) and, where applicable, written approval by the CSA/CSO or other CJIS governing authority required by governing agreements. All such approvals shall be retained for audit.

5. References

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.12: IT Asset Management Policy

- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- NRS 205 (Crimes Against Property)
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records)
- NRS 603A (Security of Personal Information)
- NAC 239.155 (Retention Schedule Adoption)
- NAC 239.165 (Destruction of Confidential Records)
- LRDA: Nevada Local Government Records Retention Schedule (Amended October 3, 2022)
- CJIS Security Policy v6.0: Section 4 (Criminal Justice Information and Personally Identifiable Information)
- CJIS Security Policy v6.0: Section AU (Audit and Accountability)
- CJIS Security Policy v6.0: Section MP (Media Protection)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- CJIS Security Policy v6.0: Section Appendix G.3 (Cloud Computing)
- NIST CSF 2.0: ID.AM-05 (Asset Prioritization)
- NIST CSF 2.0: ID.AM-07 (Data Inventories and Metadata)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST SP 800-53 Rev. 5: AC-3 (Access Enforcement)
- NIST SP 800-53 Rev. 5: AC-16 (Security and Privacy Attributes)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: MP-3 (Media Marking)
- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-53 Rev. 5: RA-2 (Security Categorization)
- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: APO13 (Manage Security)
- COBIT 2019: APO14 (Manage Data)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: DSS05 (Manage Security Services)
- NIST CMVP: FIPS 140-2 Transition Guidance

6. Policy Statement

6.1 Data Classification Schema

The County shall classify all data into one (1) of four (4) levels based on the potential impact of unauthorized disclosure, modification, destruction, or loss of availability. Classification shall drive mandatory safeguards, handling restrictions, and access enforcement.

6.2 Level 1 — Public

Public information explicitly approved for unrestricted distribution. Unauthorized disclosure would reasonably result in no harm to the County.

- **Examples**: Published press releases, public meeting agendas, job postings, public website content.
- **Minimum Safeguards**: Integrity controls sufficient to prevent unauthorized modification or defacement.

6.3 Level 2 — Internal Use

Operational information intended for internal County business use. Disclosure may cause operational confusion, reputational harm, or unnecessary disruption but is not inherently sensitive.

- **Examples**: Internal memos, internal directories, standard procedures, non-sensitive drafts.
- **Minimum Safeguards**: Standard access controls (unique user authentication), standard backup, and retention per approved schedules.

6.4 Level 3 — Confidential

Sensitive information that, if compromised, could negatively impact individual privacy, County finances, legal posture, or operational security. Access shall be limited to personnel with a validated business need-to-know.

- **Examples**: PII (as defined in NRS 603A), personnel records, vendor contracts containing non-public financial terms, draft budgets, privileged legal communications.
- **Minimum Safeguards**:
  - **Access**: Role-based access control (RBAC) and least privilege enforcement.
  - **Encryption**: County-approved encryption at rest shall be required for mobile devices, portable storage, and systems storing Confidential data outside a County-controlled physically secure location.
  - **Logging**: Systems storing Confidential information shall generate audit logs appropriate to the risk, and privileged access to such systems shall be logged in accordance with **Policy 2.11**.

6.5 Level 4 — Restricted

Highly sensitive data protected by strict federal or state requirements. Unauthorized disclosure or modification could result in severe legal penalties, loss of program access, loss of funding, or public safety impacts.

- **Examples**: Criminal Justice Information (CJI), Protected Health Information (PHI) where applicable, active investigative data, administrative credentials, cryptographic keys.
- **Minimum Safeguards**:
  - **Encryption**: Restricted data shall be protected using FIPS-validated cryptographic modules (FIPS 140-3, or FIPS 140-2 until September 21, 2026) for data at rest and in transit, consistent with CJIS requirements.

  - **Access**: Multi-factor authentication (MFA) shall be required for access to Restricted data systems, Restricted data repositories, and administrative functions.
  - **Exposure Controls**: Restricted data systems shall not be directly exposed to the public Internet without County-approved boundary protection and segmentation appropriate to the risk and consistent with CJIS requirements.
  - **Auditing**: The County shall capture and retain audit records for access, modification, and deletion events in accordance with **Policy 2.11**, CJIS requirements for CJI, and mandatory Nevada retention requirements.

6.6 Data Handling and Stewardship Principles

- **Classification Assignment and Security Attributes**: Data Owners shall assign the appropriate classification at creation or intake. The County shall associate classification as a security attribute where technically feasible to support access enforcement, handling rules, and auditability.
- **Labeling and Marking**: Where technically feasible, digital documents and physical media containing Confidential or Restricted information shall be labeled with the assigned classification (e.g., headers/footers, watermarking, media labels) to ensure personnel are aware of required handling and disclosure constraints.
- **Access Control and Need-to-Know**: Confidential and Restricted data shall be accessible only to authorized users with a validated business need-to-know. Access shall be enforced through approved identity and access management controls consistent with **Policy 2.04** and **Policy 2.05** and shall be reviewed and adjusted when personnel roles change or upon termination of employment or contract.
- **Transmission Security**: Confidential and Restricted data shall not be transmitted over unprotected channels.
  - **Restricted Data**: Shall be transmitted only using County-approved secure methods that enforce strong encryption in transit (e.g., approved VPN, TLS 1.2 or higher, or other approved secure protocols consistent with CJIS requirements).
  - **Email Restrictions**: Standard unencrypted email shall not be used to transmit Restricted data. If transmission is explicitly authorized for business necessity, the County shall use an approved encryption method or secure delivery mechanism authorized by the IT Director. Restricted CJI shall only be transmitted in accordance with the FBI CJIS Security Policy.
- **Authorized Storage Locations and Cloud Security Assurance**: County data shall be stored only in authorized repositories and systems approved by the IT Director. Personal cloud storage, personal email accounts, and unsanctioned collaboration tools are prohibited for County data.
  - **Cloud Security Assurance**: Vendors or cloud service providers hosting Confidential or Restricted County data shall be evaluated and governed through the vendor governance process defined in **Policy 1.13**. Third-party authorizations (e.g., FedRAMP, StateRAMP, SOC 2) may support due diligence but shall not be represented as automatically meeting CJIS Security Policy requirements or substituting for required CJIS agreements/addenda.
  - **CJI Cloud Requirements**: Systems storing or processing CJI in cloud environments shall meet all CJIS Security Policy requirements for encryption, access control, auditing, personnel security, and agreement/oversight obligations applicable to the service model.
  - **CJI Data Sovereignty**: As an Elko County standard for CJIS risk control and audit defensibility, CJI shall only be stored or processed within the legal jurisdiction of an APB-member country and under the legal authority of an APB-member agency unless permitted by the CSA/CSO and approved in writing by the LASO, with all required CJIS governing approvals documented.
- Storage, Media Control, and Disposal: Confidential and Restricted data shall be protected through secure storage controls and shall be destroyed or sanitized when no longer required, consistent with

retention requirements and Policy 2.12, in a manner that renders the data unrecoverable prior to disposal, transfer, or reuse of the media.

6.7 Reclassification

Data classification is not static. Data Owners shall review classifications annually, at minimum, and shall update classification when sensitivity, disclosure status, legal posture, or operational context changes.

- **CJI Reclassification Constraint**: Restricted CJI shall not be reclassified downward without written authorization from the IT Director (as LASO) and any additional CJIS authority required by governing agreements.

6.8 Data Inventory

The IT Director, in coordination with Department Heads, shall maintain a County Data Inventory that identifies:

- Data categories and assigned classification levels.
- Data Owner (Department Head) for each category.
- Logical and physical storage locations (including approved cloud services).
- Applicable retention requirements based on mandatory Nevada retention schedules and County directives.

The Data Inventory shall be reviewed and updated annually and following significant changes to systems, services, or regulatory obligations. The Data Inventory shall support the System Inventory maintained under Policy 1.12 and the Risk Register maintained under Policy 1.09.

1.12 IT Asset Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the mandatory governance framework for the lifecycle management of Information Technology (IT) assets within Elko County. It ensures that technology resources—hardware, software, and infrastructure—are acquired, tracked, supported, optimized, and disposed of in a secure, fiscally responsible, and auditable manner. This policy serves as the authoritative basis for asset accountability, the prevention of waste, the reduction of security risk from lost or unauthorized equipment, and the maintenance of audit-ready records aligned with County procurement controls and system inventory requirements.

2. Scope

This policy applies to all IT assets purchased, leased, managed, deployed, connected, or supported by Elko County, regardless of the funding source (including General Fund, Enterprise Funds, Grants, Donations, or Asset Forfeiture).

- **Covered Asset Classes**:
  - **End-User Computing**: Laptops, desktops, workstations, tablets, and thin clients.
  - **Mobile Computing**: Smartphones, cellular hotspots, and portable storage media (handling and sanitization of portable media is further governed by **Policy 2.12**).
  - **Infrastructure**: Physical and virtual servers, storage arrays, switches, routers, firewalls, wireless access points, and UPS units.
  - **Peripherals**: Network-connected printers/MFPs, scanners, and specialized interface devices.
  - **Communications**: VoIP endpoints and conferencing hardware.
  - **Physical Security**: IP cameras, Network Video Recorders (NVRs), and access control panels.
  - **Software**: Licensed software, operating systems, subscriptions, and SaaS entitlements.
- **Exclusions**:
  - **Consumables**: (e.g., toner, paper).
  - **Passive peripherals**: (e.g., keyboards, mice, standard cables) unless specifically designated for tracking by the IT Director.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the County's Asset Steward and final approving authority for lifecycle standards, exceptions, and decommissioning determinations. Shall ensure the System Inventory is maintained as a mandatory security control (NIST CM-8, PM-5) and shall ensure annual reconciliation reporting is provided to Fiscal Affairs.
- **Information Operations Personnel**: Shall execute asset management tasks, including receiving, tagging, CMDB/asset record maintenance, deployment, transfer processing, and secure decommissioning. Shall enforce the "No Tag, No Support" rule and shall deny onboarding for assets not registered in accordance with this policy.

- **Department Heads (Asset Custodians)**: Shall act as Asset Custodians for assets assigned to their department. Shall maintain physical security of assets and ensure appropriate use. Shall ensure that no asset is transferred, relocated, or disposed of without processing through the Information Operations Department.
- **All County Personnel**: Shall protect assigned assets from theft or damage and shall promptly report loss, theft, or suspected compromise.

4. Compliance and Exceptions

- **Mandatory Compliance**: Adherence to this policy is mandatory.
  - **No Tag, No Support**: Any asset that lacks a valid County IT asset tag (where applicable) or is not recorded in the designated Asset Inventory/CMDB shall be denied network connectivity and technical support.
  - **Unauthorized Acquisition**: Technology acquired without documented Technical Approval as defined in **Policy 1.10** shall be treated as "Shadow IT" and may be denied integration and support.
- **Assessment**: Asset inventory accuracy and lifecycle compliance shall be assessed via annual physical inventory audits and the annual maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Unauthorized disposal or loss of assets due to negligence may result in corrective actions defined under **Policy 5.01** (Policy Implementation and Enforcement Framework).
- **Exceptions**: Exceptions to lifecycle or replacement standards shall be documented and approved by the IT Director in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section MP (Media Protection)
- CJIS Security Policy v6.0: Section PE-3 (Physical Access Control)
- NIST CSF 2.0: ID.AM-05 (Asset Prioritization)
- NIST CSF 2.0: ID.AM-07 (Data Inventories and Metadata)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)

- NIST SP 800-53 Rev. 5: MP-6 (Media Sanitization)
- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-88 Rev. 1: (Guidelines for Media Sanitization)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: BAI10 (Manage Configuration)

6. Policy Statement

6.1 Asset Stewardship and Acquisition

Elko County shall manage IT assets under a centralized technical authority to ensure security and interoperability.

- **Centralized Technical Approval**: All technology assets and services shall be procured through the Information Operations Department or with documented Technical Approval as defined in **Policy 1.10**.
- **Receiving and Gatekeeping**: Hardware invoices shall not be approved for payment until assets are received, inspected, tagged in accordance with **Policy 1.12**, and entered into the CMDB and/or asset inventory per **Policy 3.08**. This supports "No Tag, No Pay" and "No Registration, No Pay" financial controls.
- **Software and SaaS Gatekeeping**: Software and SaaS invoices shall not be approved for payment until the license/subscription is recorded in the designated inventory/license management process and the vendor/service has completed required review steps per **Policy 1.13**.
- **County Property**: All technology assets are the property of Elko County, regardless of the specific funding source (e.g., Grants, Enterprise Funds, Donations, Asset Forfeiture), and are subject to the lifecycle controls defined in this manual.
- **County Custody and Governance**: All technology assets purchased, leased, or otherwise placed under County custody or network governance are subject to the lifecycle controls defined in this manual.

6.2 Asset Support Classification

All IT assets and systems operating within or connected to the Elko County network shall be assigned one of the following three support classifications. This classification is the authoritative basis for determining support ownership, work order routing, and service level obligations as defined in Policy 3.01 and throughout Chapter 3 of this manual. The IT Director shall ensure that each asset's support classification is recorded in the CMDB and maintained current as contracts, procurement arrangements, and operational responsibilities change.

- **IT-Managed**: Assets and systems that are wholly procured, configured, maintained, and supported by the Information Operations Department for the full duration of the asset's operational lifespan. The IT Department retains exclusive authority over all technical work performed on IT-Managed assets; no vendor, contractor, or department personnel shall perform technical work on these assets without explicit written authorization from the IT Director. All requests for service shall be submitted through the work order system. Examples include end-user computers, servers, network infrastructure, and any other technology that the IT Department has accepted full responsibility for.
- **IT-Supported**: Assets and systems that are supported under a vendor contract or lease agreement, but for which the Information Operations Department provides first-line support for minor issues, with the option to escalate to the vendor when issues exceed local resolution capability or when the nature of the contract directs vendor involvement. The IT Department shall be the first point of contact for service requests on IT-Supported assets; however, direct contact with the vendor is permissible when the contract explicitly provides for it or when the issue is clearly outside the IT Department's

scope of support. All service activity, whether performed by IT staff or escalated to the vendor, shall be documented in the work order system. Examples include court recording systems, public safety software applications, multifunction copiers under maintenance contracts, and similar systems under third-party agreements that permit local support participation.

- **Vendor-Managed:** Assets and systems for which the vendor retains exclusive support responsibility and over which the Information Operations Department exercises no technical authority. IT Department personnel shall not perform any technical work on Vendor-Managed systems beyond the minimum required to provide vendor access, such as assigning network addresses or granting physical facility access. All service requests for Vendor-Managed assets shall be referred directly to the vendor. The IT Department's responsibility is limited to facilitating vendor access and documenting any coordination activity in the work order system for tracking purposes. Examples include hosted government platform services and systems installed and maintained under exclusive vendor agreements with no local support provision.

6.3 Asset Identification and Tagging

To ensure clear visibility into asset ownership and support levels, Information Operations shall employ a visual tagging system:

- **GREEN Tags (IT-Managed)**: Assets procured (purchased or leased), configured, and supported by the Information Operations Department. These assets represent the standard authorized computing environment.
- **YELLOW Tags (Grant-Funded/Restricted)**: Assets purchased with specific grant funds. Information Operations provides standard support but shall not retire or transfer these assets without written authorization from the Grant Authority or Department Head.
- **BLUE Tags (Fiscal Inventory)**: General County inventory tags administered by Fiscal Affairs. Information Operations tracks these for reconciliation but relies on GREEN tags for technical management.

6.4 Lifecycle Standards

Information Operations shall maintain lifecycle standards to reduce outage risk and ensure supportability. The IT Director shall publish standard replacement cycles.

- **Standard Replacement Lifecycle**: The following timelines represent the standard useful life for County assets, subject to budget appropriation:
  - **Mobile Devices (Smartphones)**: 3 years
  - **End-User Computing (Laptops/Desktops/Tablets)**: 4 years
  - **Printers and Multifunction Devices (MFPs)**: 4 years
  - **UPS Batteries**: 3–5 years (or per vendor specification)
  - **Servers and Storage**: 6 years
  - **Peripherals (Monitors/Scanners)**: 8 years
  - **Infrastructure (Switches/Cabling/Cameras)**: 10 years
- **At-Risk Assets**: Assets remaining in production beyond the standard lifecycle shall be designated "**At Risk**" and prioritized for replacement.
  - The 'At Risk' designation applies to individual physical assets and is distinct from lifecycle status classifications maintained in the IT Asset Catalog under **Policy 3.01**."

6.5 Inventory and Tracking

Information Operations shall maintain a System Inventory that meets County governance and NIST CM-8 requirements.

- **System of Record**: The Configuration Management Database (CMDB), governed under **Policy 3.08**, shall serve as the authoritative system of record.
- **Required Record Elements**: At a minimum, asset records shall include:
  - **Unique Asset Identifier** (Tag ID)
  - **Lifecycle Status** (e.g., Stored, Deployed, Decommissioned)
  - **Physical Location**
  - **Assigned Custodian**
  - **Make**, **Model**, and **Serial Number**
  - **Network Identity**: Hostname, MAC Address, and IP address (as applicable)
  - **Procurement Identifiers**: Purchase Order (PO) Number and/or Lease/Contract Identifier, Invoice Number (if applicable), and Cost/Payment Terms (to support **Policy 1.10** auditability)
  - **Data Classification Relevance** (if storing Confidential/Restricted data)

6.6 Software and License Management

Information Operations shall manage software assets to ensure license compliance and security.

- **Software Inventory**: Software, subscriptions, and SaaS entitlements shall be inventoried consistent with NIST CSF ID.AM-02.
- **License Compliance**: The IT Director shall ensure license allocation is reconciled annually to prevent over-deployment (liability) or under-utilization (waste).
- **Unapproved Software**: Installation of software or cloud services not recorded in the inventory is prohibited and subject to corrective action.

6.7 Inventory Auditing and Reconciliation

Information Operations shall conduct inventory audits to validate record accuracy.

- **Annual Audit**: A physical and logical inventory validation shall be completed at least annually.
- **Reconciliation**: Discrepancies between the physical audit and the CMDB shall be investigated and reconciled within thirty (30) calendar days of discovery.
- **Fiscal Reporting**: Information Operations shall provide an annual asset reconciliation report to Fiscal Affairs to support County financial reporting.

6.8 Movement and Transfer

To preserve inventory integrity, assets shall not be transferred between users, relocated between facilities, or reassigned without an approved Service Request and corresponding CMDB update. Unauthorized relocation of assets by custodians is prohibited.

6.9 Secure Storage and Loss Reporting

Custodians shall ensure assets are stored securely.

- **Physical Security**: Storage practices for assets capable of accessing or storing Criminal Justice Information (CJI) shall align with **CJIS Security Policy Section 5.9.1**.

- **Incident Reporting**: Lost, stolen, or potentially compromised assets shall be reported to Information Operations immediately.
- **CJIS Reporting Requirement**: If a lost or stolen device contains or has access to CJI, the incident shall be reported to the IT Director (LASO) immediately, and no later than one (1) hour after discovery, and additional incident details shall be provided as soon as possible. If the incident is confirmed, the IT Director (LASO) shall ensure required CJIS notifications are made to the CSO, SIB Chief, or Interface Agency Official, as applicable.

6.10 Secure Disposal and Decommissioning

Information Operations shall control decommissioning to prevent data exposure and ensure auditable disposal.

- **Sanitization Standard**: All digital media shall be sanitized prior to disposal, release, or reuse using methods (Clear, Purge, or Destroy) consistent with **NIST SP 800-88 Rev. 1** and **Policy 2.12**.
- **Method Selection**: The IT Director shall approve the sanitization method based on the classification of data stored on the device.
- **Documentation**: Sanitization and disposal actions shall be documented, including the date, method used, and the personnel performing the validation.
- **E-Waste**: Electronic waste shall be transferred only through approved recycling vendors that provide certificates of destruction/recycling.

6.11 Offsite and Home Use

County IT assets are intended for County business use.

- **Authorized Offsite Use**: Only portable devices (laptops, tablets, smartphones) issued to a specific user are authorized for offsite use.
- **Prohibited Removal**: Infrastructure, desktop computers, printers, and monitors shall not be removed from County premises for home use without written exception approval from the IT Director.
- **Liability**: Assets used offsite are subject to the same acceptable use and security policies as onsite equipment.

1.13 Supply Chain Risk Management (SCRM) and Vendor Governance

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes a consistent and enforceable governance framework for the engagement, onboarding, oversight, and offboarding of third-party service providers, contractors, vendors, and consultants. It incorporates Supply Chain Risk Management (SCRM) principles to identify and mitigate risks associated with the acquisition of technology products and services. Its primary objective is to ensure that external entities interacting with Elko County information systems adhere to the same security, privacy, and operational standards required of County personnel.

2. Scope

This policy applies to all third-party entities, including vendors, contractors, consultants, and managed service providers (MSPs), who:

- Are granted physical or logical access to County IT assets, facilities, or systems;
- Provide hardware, software, or cloud-based solutions integrated with County operations;
- Require network connectivity (on-premise, VPN, or cloud integration); or
- Store, process, transmit, or administer Elko County data.

Exclusion: This policy does not apply to commodity off-the-shelf (COTS) consumables (e.g., toner, cables) where the vendor has no access to County systems, data, or secure facilities.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the Technical Authority. Shall validate technical scope, approve architectural fit, define security boundaries, and reject vendors that fail to meet minimum security requirements or refuse required security addendums.
- **Requesting Department Head**: Shall serve as the Relationship Manager. Shall define business requirements, fund the engagement, manage vendor deliverables/timelines, and ensure vendor adherence to County operational requirements.
- **Human Resources**: Shall maintain personnel tracking for individual contractors requiring system access and shall coordinate required background screening processes where applicable.
- **Fiscal Affairs**: Shall ensure contracts include County-required indemnification and procurement clauses and shall verify CJIS contract requirements are applied when CJI may be accessed.

4. Compliance and Exceptions

- **Mandatory Compliance**: Adherence to this policy is mandatory for all third-party interactions involving County information systems or data. Unauthorized provisioning of access or assets to a third party is a security violation subject to corrective action under **Policy 5.01**.
- **Unauthorized Commitments ("Shadow IT")**:
  - The Information Operations Department shall not integrate, onboard, or support technology acquired without documented Technical Approval.

  - Fiscal Affairs shall not process payment for technology purchases or subscriptions without documented Technical Approval, in accordance with **Policy 1.10** ("No Registration, No Pay").
  - The Requesting Department shall fund remediation, replacement, and incident-response costs resulting from unauthorized technology commitments.
- **Exceptions**: Exceptions shall be requested in writing, documented with justification, reviewed by the IT Director, and approved in accordance with **Policy 1.08**.

5. References

- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB)
- NRS 332 (Purchasing: Local Governments)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section IR (Incident Response)
- CJIS Security Policy v6.0: Section Appendix H (Security Addendum)
- NIST CSF 2.0: GV.OV-01 (Risk Management Strategy Review)
- NIST CSF 2.0: GV.SC-01 (Cybersecurity Supply Chain Risk Management)
- NIST CSF 2.0: GV.SC-04 (Supplier Prioritization)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SR-1 (Supply Chain Risk Management Policy and Procedures)
- COBIT 2019: APO10 (Manage Vendors)
- 2 CFR §200.216 (Prohibition on certain telecommunications and video surveillance equipment or services)
- FCC Covered List: 47 CFR §1.50002 (Covered List)
- NDAA FY2019: §889 (Covered telecommunications equipment/services prohibition)

6. Policy Statement

6.1 Operational Boundaries

To ensure clarity of mission and resource allocation, the following boundaries are established:

- **Business Ownership**: The Requesting Department shall serve as Project Lead and shall manage scope, timelines, acceptance, and invoicing.

- **Technical Enablement**: Information Operations shall provide security validation, network connectivity, and infrastructure provisioning necessary to support approved engagements.
- **Prohibition**: Information Operations shall not serve as Project Manager for third-party engagements initiated by other departments, and departments shall not delegate contract ownership or business-logic decisions to IT personnel.

6.2 Supply Chain Risk Management (SCRM)

Elko County shall assess and manage risk associated with the Information and Communications Technology (ICT) supply chain.

- **Vendor Risk Assessment**: All new technology vendors shall undergo a risk assessment prior to contract execution commensurate with service criticality and data classification.
- **Prohibited Technologies (NDAA §889 / Federal Funding Integrity)**:
  - Elko County shall not procure, renew, or expand deployment of equipment or services identified as "covered" under applicable federal restrictions, including items appearing on the FCC Covered List, to preserve eligibility for federal funding and reduce supply chain exposure.
  - Information Operations shall identify discovered covered equipment and shall require segregation and replacement planning based on risk and lifecycle constraints.
- **Enhanced Due Diligence**: For high-impact vendors, Information Operations may require independent attestations (e.g., SOC reports), security questionnaires, or other evidence of control effectiveness.

6.3 Contracting and Pre-Engagement Controls

- **No Contract, No Access**: No third-party logical access shall be granted, and no vendor hardware shall be installed or connected, until a contract or formal agreement is fully executed.
- **Data Protection Addendum**: Contracts involving Confidential or Restricted data (per **Policy 1.11**) shall incorporate County-required security and data protection terms.
- **CJIS Mandate**: Any vendor with potential logical access to CJI, or unescorted access to physically secure locations where CJI is processed, shall execute the CJIS Security Addendum (Appendix H) and comply with CJIS contractor oversight requirements, including acknowledgments retained for audit.
- **CJIS Contractor Certifications**: The contracting agency shall ensure each contractor employee with CJI access is provided a copy of the CJIS Security Addendum and CJIS Security Policy, executes the CJIS Security Addendum Certification, and that executed certifications are retained and available for audit.
- **CJIS External Provider Oversight**: For vendors providing external system services with access to CJI, agreements shall provide the CSA/CSO (and their designated auditors, including County representatives as authorized) authority to conduct audits (at minimum triennially) and unannounced security inspections, and to require evidence of control compliance.
- **Fingerprinting**: Prior to granting logical or unescorted physical access to CJI, all vendor personnel shall undergo a state of residency and national fingerprint-based record check, adjudicated by the CSA/SIB, in accordance with CJIS Security Policy 5.12.1.1.
- **Incident Notification and Cooperation**: Agreements shall require vendors to notify Information Operations immediately of any suspected or confirmed incident affecting County systems or County data. If CJI may be impacted, vendor notification shall occur immediately and no later than one (1) hour after discovery, to support mandatory CJIS reporting timelines.

- **Monitoring and Service Oversight**: Contracts shall support County monitoring, review, and sufficient visibility into security aspects of the provided services, consistent with CJIS monitoring expectations where applicable.

6.4 Asset Integration, Inventory, and Tagging

- County-Owned Technology: Vendor-provided or vendor-installed hardware that is owned wholly by the County, or is tagged and treated as County-governed / IO-managed technology under County custody for the duration of its deployment, and becomes part of County infrastructure shall be tagged and governed in accordance with **Policy 1.12**.
- **Leased Infrastructure Equipment (GREEN Tags)**:
  - Leased or rented devices that connect to County networks (e.g., copiers/MFPs) shall be tagged with GREEN County asset tags and treated as County-governed / IO-managed technology under County custody for the duration of service.
  - **GREEN Tag Governance**: GREEN tags indicate Information Operations technical administration, configuration control, and lifecycle governance for the duration of deployment; contractual ownership and vendor maintenance obligations remain defined by the lease/SLA. For purposes of **Policy 1.12**, “procured” includes leased acquisitions when Information Operations exercises configuration control and lifecycle governance.
  - Such devices shall be recorded in the Configuration Management Database (CMDB) as distinct configuration items, referencing lease/contract identifiers, to support lifecycle control and decommission verification.
  - Prior to return, devices shall undergo data sanitization appropriate to stored data/media in accordance with **Policy 2.12** and **NIST SP 800-88** guidance.
- **Enforcement**: Assets not tagged (where applicable) or not recorded in the Asset Inventory/CMDB shall be denied network connectivity and technical support.

6.5 Contractor Equipment and Support Model

- **Default Requirement**: Contractors shall provide their own equipment unless an exception is approved in writing by the IT Director.
- **BYOD (Zero Support Model)**: Information Operations shall not troubleshoot, configure, or install software on non-County devices.
- **Network Admission Enforcement**: Information Operations may deny connectivity to contractor devices that do not meet County security requirements.

6.6 System and Network Access Control

- **Least Privilege**: Third-party access shall be explicitly authorized, time-bounded where feasible, and limited to least privilege required.
- **Named Accounts Only**: Generic/shared vendor accounts are prohibited.
- **Remote Access**: Vendors shall use County-approved secure remote access (VPN + MFA). Persistent, unmonitored tunnels are prohibited unless explicitly authorized by the IT Director for critical support.
- **Logging and Monitoring**: Vendor activity shall be logged and monitored in accordance with **Policy 2.11**.

6.7 Data Sovereignty and Protection

- **Non-CJI Data Residency**: County data (excluding CJI) stored or processed by third-party cloud providers shall reside within the continental United States unless an exception is approved through the exception process.
- **CJI Sovereignty**: Criminal Justice Information (CJI) shall comply with Policy 1.11 CJI Data Sovereignty requirements. Where requirements conflict, CJI sovereignty requirements shall govern.
- **Data Ownership**: County data remains the property of Elko County. Vendors acquire no rights beyond contractually authorized use.

6.8 Termination and Offboarding

Upon contract termination or project completion:

- **Immediate Revocation**: The Requesting Department shall notify Information Operations within 24 hours; Information Operations shall disable logical access.
- **Asset Reclamation**: County-issued assets shall be returned within three (3) business days.
- **Data Return/Destruction**: Vendors shall certify return or secure destruction of County data consistent with County sanitization standards.

1.14 Stakeholder Engagement and Communications Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory standards for internal and external communications conducted by the Elko County Information Operations Department. It defines formal versus informal communication boundaries, promotes transparency and accountability, and ensures consistent stakeholder engagement across governance, operational, and service contexts.

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, and volunteers. It governs communications with:

- The Board of County Commissioners, County Manager, and Administrative leadership.
- Elected Officials, Department Heads, and department leadership staff.
- Third-party vendors, service providers, and contractors.
- Regulatory, compliance, and auditing bodies.
- The public and media (only where explicitly authorized).

3. Roles and Responsibilities

- **IT Director**: Shall serve as the primary strategic spokesperson for Information Operations and shall retain final approval authority for communications that establish County commitments, risk posture, or policy direction.
- **Assistant IT Director**: Shall manage operational communication standards and shall ensure service communications meet the notification requirements in this policy.
- **All Information Operations Personnel**: Shall adhere to this policy's formal vs. informal requirements and shall document material stakeholder communications in accordance with Section 6 and **Policy 1.03**.

4. Compliance and Exceptions

Adherence to this policy is mandatory.

- **Documentation Standard**: Material decisions, commitments, approvals, and scope changes shall be documented in the designated System of Engagement (Redmine) or other designated system of record. Required documentation shall be completed. Failure to document required actions constitutes noncompliance and may result in corrective action under **Policy 5.01**.
- **Data Handling**: Communications shall comply with **Policy 1.11** data classification and handling requirements. Restricted data shall not be transmitted via unencrypted email or public file shares.
- **Public Records**: Personnel shall write formal communications with the assumption they may be records subject to disclosure under **NRS 239**, unless protected by a specific statutory exemption or confidentiality requirement.

- **Exceptions**: Exceptions shall be approved in writing by the IT Director in accordance with **Policy 1.08**. Exceptions shall not authorize deviation from mandatory security controls or incident reporting requirements.
- **Emergency Priority**: Emergency communications necessary to protect life, safety, or critical infrastructure may occur outside standard protocols but shall be documented in the designated system of record within **twenty-four (24) hours**.
- **CJIS Override**: Exceptions and emergency conditions shall not delay CJIS incident reporting timelines. Suspected security incidents shall be reported immediately and shall not exceed **one (1)** hour after discovery.

5. References

- ECIO Policy 1.03: Standard Operating Ethos (Document as Standard)
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.03: End-User Communication Standards
- ECIO Policy 4.06: Communication Protocols
- ECIO Policy 4.08: Incident Response Roles and Contact Directory
- ECIO Policy 5.01: Policy Implementation and Enforcement
- NRS 239 (Public Records)
- NRS 241 (Nevada Open Meeting Law)
- NRS 603A.220 (Disclosure of breach of security of system data)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: CA-3 (Information Exchange)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: PM-15 (Contacts with Security Groups)
- COBIT 2019: APO08 (Manage Relationships)
- COBIT 2019: EDM05 (Ensure Stakeholder Engagement)
- ITIL v4: Relationship Management Practice

6. Policy Statement

6.1 Formal vs. Informal Communication

To ensure accountability, Information Operations shall distinguish strictly between binding and non-binding communications.

- **Formal Communications (Binding)**: Any written or recorded communication that creates an official record, authorizes work, directs action, commits funds, establishes scope, or signifies a decision. Examples include emails, memos, tickets/work orders, approved meeting minutes, status reports, and presentations.
- **Informal Communications (Non-Binding)**: Verbal conversations, hallway discussions, or non-recorded phone calls. Informal communications do not authorize work, financial commitments, security-impacting

changes, or policy deviations unless confirmed in writing through formal channels; however, personnel shall comply with lawful supervisory direction and shall request written confirmation within **one (1) business day** of receiving an instruction requiring confirmation. If the instruction involves directives, financial commitments, procurement direction, scope changes, or architectural decisions, written confirmation shall be provided within **four (4) business hours** in accordance with the Written Confirmation Rule. The issuing authority shall provide written confirmation within the applicable timeframe or the matter shall be escalated through the chain of command in accordance with **Policy 1.08**.

- **Written Confirmation Rule**: Verbal communications involving directives, financial commitments, procurement direction, scope changes, or architectural decisions shall be documented in writing within **four (4) business hours** of the verbal communication. Verbal directives not reduced to writing within this window are presumptively void. Until written confirmation exists, the communication shall be treated as non-binding.
- **Liability**: Personnel who act on verbal financial or procurement directives that lack written confirmation do so at personal and professional risk. Such actions may constitute a policy violation under Policy 5.01.

6.2 Strategic Reporting Cadence

The IT Director shall maintain a predictable reporting rhythm to ensure leadership visibility and alignment.

- **Monthly Executive Report**: The IT Director shall provide a formal written report to the County Manager covering project status, service performance (KPIs), budget variance, and emerging risks.
- **Monthly Briefing**: The IT Director shall conduct an in-person status briefing with the County Manager to review the Monthly Executive Report and align priorities.

6.3 Operational Communication Standards

Information Operations shall maintain a "No Surprise" standard regarding service availability.

- **Scheduled Maintenance**: Planned maintenance affecting other departments shall be communicated at least **forty-eight (48) hours** in advance whenever feasible. If forty-eight (48) hours is not feasible, notice shall be issued immediately upon scheduling and the exception shall be documented with justification.
- **Unplanned Outages**: The Service Desk shall issue an initial stakeholder notification within **fifteen (15) minutes** of confirming a widespread outage.
- **Root Cause Analysis (RCA)**: Significant outages shall have a formal RCA provided to affected Department leadership within **five (5) business days** of resolution.

6.4 Crisis and Incident Communication

During a major cybersecurity incident or infrastructure crisis, strict information discipline is mandatory.

- **One Voice Rule (Strategic/Public)**: The IT Director (or designated Incident Commander) shall serve as the sole authoritative source for strategic and public-facing messaging. Personnel shall not speculate in writing on cause, attribution, or scope until authorized.
- **Technical Coordination**: The One Voice Rule shall not prohibit technical staff from communicating operational details to vendors, service providers, or partners when necessary to resolve an incident, provided communications are limited to technical scope and follow data handling requirements.
- **Incident Communications**: Incident communications shall follow **Policy 4.06**. CJIS-related incidents shall follow CJIS reporting requirements and **Policy 4.02**/**4.06** procedures, including the one (1) hour reporting requirement.

- **Public and Stakeholder Notification**: Notifications to the public and stakeholders regarding security breaches shall be executed in strict accordance with the 'most expedient time possible' standard mandated by **NRS 603A.220** and the reporting windows defined in CJIS Security Policy 5.3
- **CJIS Reporting**: Personnel shall report suspected or confirmed security incidents immediately, but not to exceed one (1) hour after discovery. If confirmed, the IT Director (LASO) shall notify the CSO, SIB Chief, or Interface Agency Official per CJIS IR-6(b).
- **Legal Review**: When directed by County legal counsel, incident-related written communications shall be routed through the District Attorney's Office to support legal review and appropriate handling.

6.5 Information Exchange Agreements (IEAs)

- **Requirement**: Any arrangement that enables external access to, transmission of, or exchange of Criminal Justice Information (CJI) shall be supported by a written Information Exchange Agreement (IEA) or equivalent contract language, consistent with CJIS Policy Area 1 requirements.
- **Agreement Content**: Information exchange documentation shall define: (a) interface characteristics; (b) security controls implemented at each connection point; (c) authorized data elements; (d) restrictions on connections; and (e) terms/termination conditions, consistent with NIST CA-3.
- **Custody**: Executed Information Exchange Agreements shall be stored in the County's designated contract repository with version control and shall be retrievable within one (1) business day upon request.

6.6 Stakeholder Contact Management

Information Operations shall maintain and periodically validate an up-to-date contact list for key internal and external stakeholders required for operational escalation and incident coordination. This contact directory shall be maintained in accordance with **Policy 4.08**.

2. Information Security

2.01 Acceptable Use of Information Technology Resources Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory rules of behavior governing the acceptable use of Elko County Information Technology (IT) resources. It defines authorized and prohibited user activities to protect County operations, information, personnel, and the public from security, legal, operational, and reputational risk.

2. Scope

This policy applies to all users granted access to County IT resources, including employees, elected officials, contractors, vendors, interns, and volunteers . County IT resources include County-owned, County-managed, and County-provisioned systems and services, including endpoints, networks, applications, cloud services, accounts, and County data.

3. Roles and Responsibilities

- **IT Director (LASO):** Shall maintain this policy and serve as the final authority on acceptable-use determinations and exception approvals.
- **Human Resources (HR):** Shall ensure user acknowledgments are executed prior to initial access and retained for a minimum of seven (7) years following separation of employment or contract termination in accordance with the Nevada Local Government Records Retention Schedule .
- **Department Heads:** Shall ensure all personnel under their supervision execute required acknowledgments prior to access provisioning and report security incidents or lost CJI-capable devices within one (1) hour of discovery.
- **All Users:** Shall comply with this policy as a condition of access to County IT resources and shall protect County assets from unauthorized access, loss, or misuse.

4. Compliance and Exceptions

- **Compliance:** Adherence to this policy is mandatory. Violations may result in access revocation, disciplinary action up to and including termination, contract remedies, and referral for civil or criminal enforcement under **NRS 205**.
- **Universal Applicability**: The standards defined herein apply to the use of County IT resources at all times and in all locations, including but not limited to County facilities, remote work locations, and during official travel.
- **Exceptions:** Exceptions shall be documented, risk-assessed, time-bound (not to exceed 12 months), and approved in writing by the IT Director. Exceptions involving CJI shall not reduce CJIS-mandated requirements.

5. References

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy

- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- NRS 205.4765 (Unlawful acts regarding computers)
- CJIS Security Policy v6.0: Section CM-11 (User-Installed Software)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section PL-4 (Rules of Behavior)
- CJIS Security Policy v6.0: Section PS-6 (Access Agreements)
- NIST CSF 2.0: PR.AT-01 (Awareness and Training)
- NIST SP 800-53 Rev. 5: CM-11 (User-Installed Software)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PS-6 (Access Agreements)
- COBIT 2019: APO01.02 (Manage ethical and professional behavior)
- COBIT 2019: DSS05.01 (Protect against malicious software)
- COBIT 2019: DSS05.03 (Manage endpoint security)
- ITIL v4: Incident Management Practice

6. Policy Statement

6.1. Ownership and Consent to Monitoring

- **County Property**: All Information Technology resources, including hardware, software, and data created, stored, or transmitted upon them, remain the sole property of Elko County regardless of the physical location of the asset.
- **No Expectation of Privacy**: Users shall have no reasonable expectation of privacy when using County IT resources. Use constitutes consent to monitoring, logging, and disclosure for operational, security, legal, and investigative purposes.
- **System Notification**: System use notification banners implementing **NIST SP 800-53 AC-8** shall be displayed on County systems as specified in **Policy 2.04** to provide continuous notice of monitoring consent.

6.2. Identity and Credentials

- **Credential Protection**: Users shall not share passwords, tokens, or access badges. Account sharing is strictly prohibited.
- **Workstation Security**: Users shall lock devices (Win+L) whenever left unattended, even for brief periods.

6.3. Acceptable Use Standards

- **Official Use**: County IT resources are provided to support the official business of Elko County.
- **Incidental Personal Use**: Limited personal use is permissible only if it is brief, occurs during non-work time (breaks/lunch), incurs no cost to the County, and does not interfere with productivity or violate any other County policy.

6.4. Prohibited Activities Users shall not:

- Install unauthorized software, disable security controls, or use anonymization tools to bypass network filters.
- Input Confidential or Restricted County data (per Policy 1.11) into external Generative AI or public Large Language Models (LLMs).
- Use County IT resources for political campaigning, lobbying, or personal commercial ventures.
- Access, store, or distribute harassing, discriminatory, or sexually explicit content.

6.5. Reporting Requirements

- **Security Incidents**: Users shall report suspected security incidents to Information Operations immediately.
- **Lost CJI Assets**: Lost or stolen devices capable of accessing Criminal Justice Information (CJI) must be reported to the IT Director (LASO) no later than **one (1) hour** after discovery.
- **General Assets**: All other lost or stolen County devices shall be reported within **one (1) business day** of discovery.

6.6. Acknowledgment Requirement

- **Prerequisite**: All users shall execute the Acceptable Use Policy Acknowledgment (maintained in the System of Engagement (Redmine)) prior to being granted access to County IT resources.
- **Refreshes**: This acknowledgment shall be refreshed annually or upon significant updates to this policy.
- **Refusal**: Refusal to sign shall result in the immediate denial or revocation of access to all IT resources.

6.7. Additional Requirements for Privileged Users

Users with elevated privileges (Tier L3 and above) shall use privileged accounts only for tasks requiring elevated access; routine activities shall be performed using standard accounts. Privileged access is contingent on maintaining required background screening and role-based training specified in Policy 1.07 and Policy 2.03 .

2.02 Personnel Security and Background Screening Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory personnel security and background screening requirements for individuals granted logical or physical access to Elko County information systems, facilities containing IT assets, or County data. The policy minimizes insider risk and enforces compliance with federal Criminal Justice Information (CJI) personnel security requirements.

2. Scope

This policy applies to all employees, elected officials, contractors, vendors, interns, and volunteers requiring logical or physical access to County IT resources. Standards apply across these classifications:

- **General Access**: Access to systems or data not designated as CJI.
- **Privileged Access**: Elevated permissions (Role Tiers L3–L5) capable of altering system configurations or security controls.
- **CJI Access**: Any role with potential unescorted access to unencrypted Criminal Justice Information (CJI).

3. Roles and Responsibilities

- **Human Resources (HR)**:
  - Shall serve as the authoritative source for personnel status (hire, transfer, termination).
  - Shall notify Information Operations of personnel changes via the service desk or designated HRIS in accordance with the timelines defined in **Policy 1.08**.
  - Shall retain screening documentation for seven (7) years post-separation per Nevada local government retention schedules.
- **IT Director**:
  - Shall define positions requiring Privileged or CJI Access screening.
  - Shall serve as the final gatekeeper; access shall not be provisioned until HR confirms screening adjudication is "Cleared."
- **Department Heads**:
  - Shall identify roles requiring enhanced screening prior to recruitment.
  - Shall ensure third-party personnel do not begin work until screening is adjudicated and access is formally approved.
- **All Personnel**:
  - Shall truthfully disclose legal history during screening.
  - Shall report any personal arrest, criminal charge, or restraining order to HR within twenty-four (24) hours.

4. Compliance and Exceptions

- **No Clearance, No Access**: Access shall not be granted until screening and adjudication are complete for the applicable classification.
- **Universal Applicability**: These standards apply to the use of County IT resources at all times and in all locations, including remote work and official travel.
- **Sanctions**: Violations may result in access revocation, disciplinary action, and referral for civil or criminal enforcement under NRS 205.
- **Exceptions**: Prohibited for CJI roles. For non-CJI roles, temporary exceptions require documented risk assessment, compensating controls (e.g., constant physical escort), and written approval by the IT Director.

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- NRS 179A (Records of Criminal History)
- NRS 239B (Disclosure of Personal Information)
- CJIS Security Policy v6.0: Section 5.12 (Personnel Security)
- CJIS Security Policy v6.0: Section AC-2(13) (Disable Accounts for High-Risk Individuals)
- NIST CSF 2.0: PR.AA-01 (Identities and Credentials)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST SP 800-53 Rev. 5: AC-2 (Account Management)
- NIST SP 800-53 Rev. 5: PS-2 (Position Risk Designation)
- NIST SP 800-53 Rev. 5: PS-3 (Personnel Screening)
- NIST SP 800-53 Rev. 5: PS-4 (Personnel Termination)
- NIST SP 800-53 Rev. 5: PS-5 (Personnel Transfer)
- COBIT 2019: APO07.01 (Maintain Adequate and Appropriate Staffing)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

6.1. Position Risk and Access Classification

- The IT Director shall assign each role an access classification (General, Privileged, or CJI).
- **Access classification mapping**:
  - **General**: Expected user behavior; non-CJIS access.
  - **Privileged**: IT Role Tiers L3–L5.
  - **CJI Access**: Any tier with potential unescorted access to unencrypted CJI.

6.2. Screening Requirements

- **General Access**: Personnel shall complete County-required identity verification and background screening prior to access provisioning.
- **CJI Access**: Personnel shall complete CJIS-required state of residency and national fingerprint-based record checks conducted through an FBI-approved authority **prior** to access provisioning. No "pending" or temporary access is permitted for CJI environments.

6.3. CJI Adjudication Standards

- **Felony Convictions**: If a felony conviction of any kind exists, the individual **shall be denied** access to CJI.
- **Misdemeanors**: Access may be granted only if the LASO determines the nature of the offense does not warrant disqualification.
- **Fugitive Status**: Access shall be denied to any individual with an active warrant.

6.4. Continuous Vetting

- **Re-screening**: Personnel with CJI Access shall undergo a full re-investigation (including fingerprints) every **five (5) years**.
- **Self-Reporting**: Failure to self-report arrests or charges within 24 hours is grounds for immediate access revocation.

6.5. Transfers and Termination Upon HR notification, Information Operations shall revoke or adjust access:

- **High-Risk Individuals**: Accounts disabled within thirty (30) minutes.
- **Involuntary Termination**: Accounts disabled within thirty (30) minutes.
- **Standard Termination**: Accounts disabled within twenty-four (24) hours.
- **Transfers**: Access authorizations shall be modified within twenty-four (24) hours to align with the "Least Privilege" principle.

6.6. Exit Requirements

- Upon termination, HR or the Department Head shall conduct an exit interview covering non-disclosure obligations (NDA) regarding CJI and PII.
- All County-issued assets (badges, keys, tokens, devices) must be recovered prior to final departure.

6.7. High-Risk Individual Definition

A "High-Risk Individual" includes anyone with:

- Involuntary/hostile termination
- Credible threat of misuse or retaliation
- Formal notice of investigation
- Discovery of direct threat to CJI confidentiality or integrity.

2.03 Security Awareness and Training Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy defines the mandatory requirements for the Elko County Security Awareness and Training Program. It ensures that all personnel with access to County Information Technology (IT) resources possess the requisite knowledge to protect information assets, reduce operational risk, and maintain strict compliance with the FBI Criminal Justice Information Services (CJIS) Security Policy and Nevada Revised Statutes (NRS).

2. Scope

This policy applies to all Elko County personnel—including full-time and part-time employees, elected officials, contractors, vendors, interns, and volunteers—who meet any of the following criteria:

- Possess logical access to any County-managed information system or network.
- Possess unescorted physical access to areas designated as Physically Secure Locations (e.g., server rooms, dispatch centers).
- Process, store, or transmit Criminal Justice Information (CJI) or Personally Identifiable Information (PII).

3. Roles and Responsibilities

- **IT Director**
  - Shall Serve as the final Authorizing Official (AO) for the training curriculum.
  - Shall review and update training content at least annually to align with CJIS v6.0 and NIST standards.
- **Assistant IT Director**
  - Shall develop and provide the technical training content to Human Resources.
  - Shall conduct technical practical exercises (e.g., spear-phishing simulations).
  - Shall proactively "push" emerging threat alerts to the workforce.
- **Human Resources (HR)**
  - Shall serve as the Program Manager for general security literacy and must:
  - Schedule, track, and document completion of the General Security Awareness curriculum for all personnel.
  - Prohibit the onboarding or credentialing of any personnel until initial training is verified.
  - Enforce administrative actions for personnel who fail to meet annual refresher deadlines.
- **Department Heads**
  - Shall ensure 100% of their assigned personnel complete training within the mandated windows.
  - Shall enforce immediate account suspension for non-compliant subordinates.
- **All Personnel**

  - Must complete all assigned training modules and simulations by the defined deadlines.
  - Must apply training concepts to daily operations and report security anomalies immediately.

4. Compliance and Exceptions

- **Mandatory Condition of Access**
  - Training completion is a prerequisite for system access. Access shall be denied or revoked for any individual without verified training records.
- **Account Suspension**
  - The Information Operations Department must disable the network account of any user who fails to complete the annual refresher training within 365 days of their last completion.
- **Exceptions**
  - Exceptions must be documented in writing and approved by the IT Director. No exceptions are permitted regarding the requirement to be trained prior to initial CJIS access.

5. References

- ECIO Policy 1.07 (Workforce Roles, Responsibilities, and Competency Framework)
- ECIO Policy 1.11 (Data Governance and Classification Policy)
- ECIO Policy 2.01 (Acceptable Use of Information Technology Resources Policy)
- ECIO Policy 2.02 (Personnel Security and Background Screening Policy)
- ECIO Policy 2.04 (Access Control Policy)
- NRS 603A (Security of Personal Information)
- LRDA 20070048 (Training Records)
- LRDA 20071725 (IT Security Awareness Files)
- CJIS Security Policy v6.0: Section AT-1 (Policy and Procedures)
- CJIS Security Policy v6.0: Section AT-2 (Literacy Training and Awareness)
- CJIS Security Policy v6.0: Section AT-3 (Role-Based Training)
- CJIS Security Policy v6.0: Section AT-4 (Training Records)
- NIST CSF 2.0: PR.AT-01 (Awareness and Training)
- NIST CSF 2.0: PR.AT-02 (Role-Based Training)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: AT-4 (Training Records)
- COBIT 2019: APO07.03 (Maintain Skills and Competencies)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

6.1 Program Design and Authority

The IT Director shall design the curriculum, while HR shall manage the administration and tracking of the General Security Awareness Program.

6.2 Training Cadence

- **Initial Training**: Must be completed prior to receiving initial system access.
- **Annual Refresher**: Must be completed every 365 days.
- **Security Event Retraining**: Involved personnel must complete remedial training within 30 days of a major security event per CJIS AT-2.

6.3 Literacy Content

The General Security Awareness program must cover:

- **Insider Threat**: Recognizing indicators of malicious or accidental threat.
- **Social Engineering**: Identifying phishing and vishing.
- **Data Handling**: Procedures for CJI and PII protection.

6.4 Role-Based Training

Privileged users and physical security personnel shall receive targeted training relevant to their specific technical or environmental duties.

6.5 Practical Exercises

The Information Operations Department shall conduct not fewer than two (2) spear-phishing simulations annually.

6.6 Records Retention

- Training records must be retained for a minimum of three (3) years.
- Separated personnel records shall be held for 3 years from date of separation (LRDA 20070048).
- General IT awareness records shall be held for 3 years from date of access termination (LRDA 20071725).

2.04 Access Control Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory requirements for managing logical access to Elko County Information Technology (IT) resources. It implements the principles of "Least Privilege" and "Need-to-Know" to protect the confidentiality, integrity, and availability of County information.

2. Scope

This policy shall apply to all individuals—including employees, elected officials, contractors, and third-party vendors—who require logical access to Elko County information systems, networks, or data. This scope encompasses all systems used to process, store, or transmit CJI and sensitive County assets.

3. Roles and Responsibilities

IT Director

- Shall serve as the Access Control Authority; validates identity management architectures and adjudicates all policy exceptions.
- Shall ensure all access controls for CJI-processing systems meet federal mandates.

IT Administrators

- Shall provision, modify, and disable accounts strictly upon receipt of authorized triggers from Human Resources or Data Owners.

Human Resources (HR)

- Shall act as the Authoritative Source for identity verification and shall provide immediate notification of personnel status changes to the IT Department.

Department Heads / Data Owners

- Shall define the specific "need-to-know" for staff and verify that access requests are commensurate with assigned job duties.
- Shall complete periodic access recertification reviews for systems under their data ownership within the cadence defined in Section 6.9 and shall promptly notify the IT Department of any access that is no longer justified.

4. Compliance and Exceptions

- **Mandatory Compliance**: Compliance is mandatory. Prohibited actions include
  - Credential sharing
  - Unauthorized elevation of privileges
  - Bypassing access controls
- **Sanctions**: Violations shall result in immediate revocation of access and disciplinary action up to and including discharge, consistent with NRS 205.4765.

- **Exceptions**: Any deviation from this policy shall be documented as a formal Risk Acceptance with identified compensating controls and an expiration date not exceeding 12 months. Exceptions affecting CJI systems require written approval from the CSO.

5. References

- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- NRS 205.4765 (Unlawful acts regarding computers)
- CJIS Security Policy v6.0: Section AC-2 (Account Management)
- CJIS Security Policy v6.0: Section AC-2(3) (Disable Accounts)
- CJIS Security Policy v6.0: Section AC-2(13) (Disable Accounts for High-Risk Individuals)
- CJIS Security Policy v6.0: Section AC-3 (Access Enforcement)
- CJIS Security Policy v6.0: Section AC-5 (Separation of Duties)
- CJIS Security Policy v6.0: Section AC-6 (Least Privilege)
- CJIS Security Policy v6.0: Section AC-6(7) (Review of User Privileges)
- CJIS Security Policy v6.0: Section AC-7 (Unsuccessful Logon Attempts)
- CJIS Security Policy v6.0: Section AC-8 (System Use Notification)
- CJIS Security Policy v6.0: Section AC-11 (Device Lock)
- CJIS Security Policy v6.0: Section AC-17 (Remote Access)
- CJIS Security Policy v6.0: Section AC-18 (Wireless Access)
- CJIS Security Policy v6.0: Section IA-4 (Identifier Management)
- CJIS Security Policy v6.0: Section IA-5(2)(c) (Re-authentication Requirements)
- NIST CSF 2.0: PR.AA-01 (Identities and Credentials)
- NIST CSF 2.0: PR.AA-03 (Authentication)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST SP 800-53 Rev. 5: AC-1 (Access Control Policy and Procedures)
- NIST SP 800-53 Rev. 5: AC-2 (Account Management)
- NIST SP 800-53 Rev. 5: AC-3 (Access Enforcement)
- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: AC-6 (Least Privilege)
- NIST SP 800-53 Rev. 5: AC-6(7) (Review of User Privileges)
- NIST SP 800-53 Rev. 5: AC-7 (Unsuccessful Logon Attempts)
- NIST SP 800-53 Rev. 5: AC-8 (System Use Notification)
- NIST SP 800-53 Rev. 5: AC-11 (Device Lock)
- NIST SP 800-53 Rev. 5: AC-12 (Session Termination)

- NIST SP 800-53 Rev. 5: AC-17 (Remote Access)
- NIST SP 800-53 Rev. 5: AC-18 (Wireless Access)
- NIST SP 800-53 Rev. 5: IA-4 (Identifier Management)
- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Access Management Practice

6. Policy Statement

6.1. Account Management

- The IT Department shall define and manage account types for each system, including at minimum:
  - individual
  - privileged
  - shared/group (restricted)
  - service
  - system
  - guest (restricted)
  - temporary
  - emergency.
- The IT Department shall disable information system accounts within the following maximum timeframes upon notification of a trigger:
  - **Termination or Transfer**: Within 24 hours of notification from Human Resources.
  - **High-Risk Individuals**: Within 30 minutes of discovery for individuals posing a direct threat to CJI.
  - **Expired or Unauthorized Accounts**: Within seven (7) calendar days of account expiration or discovery that an account is no longer associated with an active user.
  - **Inactivity**: The information system shall automatically disable accounts after 30 calendar days of inactivity. This standard exceeds the CJIS minimum of 90 days and is adopted as a stricter Elko County internal control.
- Information Operations shall manage identifiers (usernames) such that identifiers shall not be reused for a minimum of one (1) year following the disablement or removal of the previous account.
- Shared and group accounts are prohibited unless a documented operational necessity is approved by the IT Director.
  - When shared or group account membership changes, the associated authenticators (passwords) shall be changed within 24 hours.
- Temporary and emergency accounts shall be automatically removed or disabled within 72 hours of creation unless a longer window is approved as an exception.

6.2. Separation of Duties

- The IT Department shall separate duties to reduce the risk of fraud or malevolent activity without collusion.
- Personnel administering access controls shall not be the same individuals administering the audit functions for those systems.

- Where staffing constraints prevent technical separation, compensating controls—such as independent administrative review—shall be documented and approved by the IT Director.

6.3. Least Privilege

- Access shall be restricted to the minimum privileges required for assigned job duties.
- Privileged accounts shall be used strictly for administrative functions and shall not be used for routine activities such as email or general web browsing
- The information system shall prevent non-privileged users from executing privileged functions, including the disablement or circumvention of security safeguards.

6.4. Unsuccessful Logon Attempts

- To prevent brute-force attacks, the information system shall enforce a limit of **five (5)** consecutive invalid logon attempts within a 15-minute period.
- For systems processing CJI, accounts shall remain locked until released by an authorized administrator.
- Automatic unlock is prohibited for CJI systems unless approved by the CSO for a documented operational mission need.

6.5. System Use Notification

- Before granting access, the information system shall display a notification banner stating:
  - Users are accessing a restricted Elko County / FBI CJIS information system.
  - System usage may be monitored, recorded, and subject to audit.
  - Unauthorized use is prohibited and subject to criminal/civil penalties.
  - Use of the system indicates consent to monitoring with no expectation of privacy.
- The banner shall remain on screen until the user takes an explicit action to acknowledge the notice.

6.6. Device Lock and Session Management

- The information system shall automatically initiate a device lock after 15 minutes of inactivity.
- The lock shall conceal previously visible information with a pattern-hiding display.
- Remote access sessions that authenticate via password shall automatically terminate or require re-authentication after twelve (12) hours of duration or 15 minutes of inactivity.
- Remote access sessions that authenticate via certificate (mobile data terminals) are exempt from VPN inactivity timeouts for officer safety.
- Remote access sessions utilizing certificate-based authentication on devices located within a secure Criminal Justice Conveyance (e.g., patrol vehicles) are exempt from the 15-minute VPN inactivity timeout to ensure officer safety.

6.7. Remote Access

- All remote access to Elko County information systems shall be authorized, monitored, and routed through a County-managed access control point (VPN).
- Multi-Factor Authentication (MFA), compliant with CJIS Advanced Authentication standards, is mandatory for all remote access and all privileged access.
- Remote access communications shall be protected using FIPS 140-validated cryptographic modules.

6.8. Wireless Access

- Wireless access to the internal network must be explicitly authorized and shall use WPA2/3 Enterprise authentication and encryption.
- Guest wireless networks shall be logically and/or physically separated from any environment processing CJI or sensitive County data.

6.9. Periodic Access Recertification

To ensure access privileges remain commensurate with assigned duties and current business need, the IT Department shall conduct periodic access recertification reviews. Data Owners shall validate that personnel under their authority retain a legitimate need-to-know for the access granted. IT Administrators shall disable or modify accounts where the Data Owner cannot confirm continued business need.

- **Restricted Systems (Level 4)**: Access to systems processing, storing, or transmitting Criminal Justice Information (CJI) or other Restricted data (as defined in **Policy 1.11**) shall be recertified at least quarterly. This cadence aligns with the quarterly risk assessment review cycle for CJI and Critical systems defined in Policy 1.09.
- **Confidential Systems (Level 3)**: Access to systems storing or processing Confidential data shall be recertified at least semi-annually.
- **Internal Use and Public Systems (Levels 1–2)**: Access shall be recertified at least annually, consistent with CJIS Security Policy v6.0: Section AC-6(7).
- **Privileged Accounts**: All privileged access (Tier L3 and above) shall be recertified at least semi-annually, regardless of system classification, to validate continued operational need and compliance with **Policy 1.07** competency maintenance requirements.
- **Recertification Triggers**: In addition to the scheduled cadence, an access recertification review shall be initiated within five (5) business days following a significant organizational change (e.g., departmental reorganization, system migration, or material change to a Data Owner's scope), consistent with NIST SP 800-53 Rev. 5: AC-2.
- **Documentation**: Recertification results shall be documented in the Department's designated system of record. Accounts not recertified within the required timeframe shall be suspended until the review is completed. Recertification records shall be retained in accordance with **Policy 1.11** and applicable Nevada retention schedules.

2.05 Identification and Authentication Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory requirements for uniquely identifying and authenticating all users, devices, and services prior to granting access to Elko County information systems and data. This policy ensures that all access is attributable to a verified identity, resistant to credential compromise, and compliant with FBI Criminal Justice Information Services (CJIS) Security Policy v6.0 and NIST SP 800-53 Rev. 5.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, County employees, elected officials, contractors, vendors, and any other entities accessing County IT resources. It governs all authenticators, including passwords, cryptographic tokens, smart cards, biometrics, device certificates, and service credentials used for local, network, remote, and application/API access.

3. Roles and Responsibilities

- **IT Director**
  - Shall serve as the final Authentication Authority for enterprise standards.
  - Shall approve all County authentication architectures and enterprise MFA technology selections.
- **Human Resources (HR)**
  - Shall serve as the Authoritative Source for workforce identity proofing and shall manage the lifecycle of physical County identity credentials.
- **Information Operations (Administrators)**
  - Shall configure and manage the Identity and Access Management (IAM) infrastructure, bind authenticators to verified identities, and execute credential revocation within required timeframes.
- **System and Data Owners**
  - Shall determine required authentication strength based on data classification and shall coordinate implementation with ECIO.
- **All Users**
  - Shall protect County-issued authenticators from unauthorized use
  - Shall report suspected compromise, loss, or theft within the timelines defined in Section 6.3.

4. Compliance and Exceptions

- **Mandatory Enforcement**: Personnel who refuse to utilize County-required authentication mechanisms shall be denied access to County information systems.
- **Sanctions**: Attempting to bypass authentication controls or sharing credentials constitutes a severe security violation subject to disciplinary action up to and including termination and criminal referral under NRS 205.4765.
- **CJIS Floor**: Exceptions shall not authorize non-compliance with CJIS Security Policy requirements.

- **Exception Process**:
  - Deviations must be documented in a Risk Acceptance Memo (per **Policy 1.09**) that includes compensating controls and an expiration date not exceeding twelve (12) months.
  - Exceptions involving CJI shall require written approval by the CJIS Systems Officer (CSO).

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- NRS 205.4765 (Unlawful acts regarding computers)
- CJIS Security Policy v6.0: Section IA-2 (Identification and Authentication)
- CJIS Security Policy v6.0: Section IA-2(8) (Replay Resistant)
- CJIS Security Policy v6.0: Section IA-3 (Device Identification and Authentication)
- CJIS Security Policy v6.0: Section IA-4 (Identifier Management)
- CJIS Security Policy v6.0: Section IA-5 (Authenticator Management)
- CJIS Security Policy v6.0: Section IA-6 (Authentication Feedback)
- CJIS Security Policy v6.0: Section IA-7 (Cryptographic Module Authentication)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- NIST CSF 2.0: PR.AA-01 (Identities and Credentials)
- NIST CSF 2.0: PR.AA-02 (Identity Proofing)
- NIST CSF 2.0: PR.AA-03 (Authentication)
- NIST SP 800-53 Rev. 5: IA-2 (Identification and Authentication)
- NIST SP 800-53 Rev. 5: IA-5 (Authenticator Management)
- NIST SP 800-53 Rev. 5: IA-5(2) (Public Key-Based Authentication)
- NIST SP 800-53 Rev. 5: IA-8 (Identification and Authentication-Non-Organizational Users)
- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Access Management Practice

6. Policy Statement

6.1 Unique Identification and Identifier Reuse

- **Unique Identification**: County systems shall uniquely identify each user. Assigning a single identifier to multiple individuals is prohibited.
- **Shared/Generic Accounts**: Shared, generic, or group accounts are prohibited unless a Risk Acceptance Memo is approved in accordance with Section 4.
- **Identifier Reuse Floor**: Identifiers (e.g., usernames) shall not be reused for a minimum of one (1) year following account deactivation per CJIS IA-4(d).

6.2 MFA Baselines and Authentication Strength

- **MFA Required for Restricted (Level 4)**: Multi-factor authentication (MFA) shall be required for access to Restricted data systems (CJI, PII, PHI), Restricted repositories, and administrative functions.
- **MFA Required for Remote and Privileged Access**: MFA shall be mandatory for all remote access and for privileged accounts consistent with **Policy 2.04** access control baselines.
- **Replay-Resistant Requirement (CJI/AAL2)**: For access to CJI and workflows requiring replay resistance, at least one factor shall be replay-resistant.

6.3 Authenticator Lifecycle and Revocation

- **Identity Proofing**: HR shall conduct in-person identity verification prior to issuance of County credentials.
- **Revocation Timeframes**: ECIO shall disable accounts within twenty-four (24) hours for standard termination and within thirty (30) minutes for High-Risk Individuals as defined by **Policy 2.02**.
- **Compromise/Loss Reporting**: Users shall report suspected authenticator compromise, loss, or theft immediately. If the authenticator or device provides access to CJI, reporting shall occur immediately and shall not exceed one (1) hour from discovery.
- **Temporary Authenticators**: Temporary authenticators (e.g., initial passwords) shall require an immediate change to a user-defined secret upon first use.

6.4 Rate Limiting and Unsuccessful Authentication

- **Unsuccessful Logon Attempts**: Systems shall enforce unsuccessful logon attempt limits consistent with **Policy 2.04** requirements: five (5) invalid attempts within a 15-minute period, resulting in a lockout until released by an administrator for CJI-connected systems.

6.5 Memorized Secret (Password) Standards

- **Minimum Length**: Standard accounts shall require a minimum of twelve (12) characters. Privileged accounts (Tier L3+) shall require a minimum of fourteen (14) characters.
- **Password History**: Systems shall prevent reuse of the last ten (10) passwords (County-defined standard).
- **Blocklist Screening**: Systems shall implement checks against commonly used and compromised passwords and shall update the reference data at least quarterly.
- **Compromise-Triggered Change**: Systems shall require password change upon evidence of compromise and shall not mandate periodic password changes as a primary control.

6.6 Service Accounts and API Credentials

- **Interactive Logon Prohibited**: Service accounts shall not be used by personnel for administrative work or interactive logon.
- **Legacy Exception Controls**: If an application requires interactive use of a service account, the System Owner shall obtain a Risk Acceptance Memo that mandates:
  - Interactive enablement limited to maintenance windows
  - MFA for the interactive session
  - Full event logging
- **Secrets Management**: Service credentials and API keys shall be stored in an ECIO-approved secrets management solution and rotated upon suspected compromise or owner departure.

6.7 Non-Organizational Users and Device Authentication

- **Non-Organizational Users**: Contractors and vendors shall be uniquely identified and authenticated. Access shall be time-bounded and re-verified at least annually.
- **Device Identification**: County-managed devices shall be uniquely identified prior to network connection. Device authentication shall not substitute for user authentication or user MFA requirements.

6.8 Authentication Feedback

- **Obscuration**: Systems shall mask characters during entry to protect against shoulder surfing.
- **Generic Error Messages**: Authentication error messages shall be generic and shall not disclose which element of the credentials (username or password) was incorrect.

6.9 Mobile Device Advanced Authentication

- **Requirement**: Mobile devices accessing CJI shall use advanced authentication (MFA) per **CJIS Section 5.20.7.2**.
- **Compensating Controls**: Any mobile advanced-authentication exception shall require:
  - County MDM enrollment
  - Written CSO approval
  - A documented expiration date

6.10 Public Key-Based Authentication (Smart Cards/Tokens)

- **Private Key Protection**: Systems implementing public key-based authentication (e.g., HID DigitalPersona) shall enforce protection of the private key and prevent unauthorized use.
- **Identity Mapping**: The authenticated identity shall be mapped to the unique individual account in the authoritative identity repository (e.g., Active Directory).
- **Certificate Validation and Revocation**: Systems shall validate certificates to a trusted root and maintain revocation information (e.g., CRL/OCSP) to support validation during network unavailability.

6.11 Cryptographic Protection (FIPS)

- **FIPS Validation**: Cryptographic modules used to protect Restricted data shall be FIPS validated. FIPS 140-2 is acceptable until September 21, 2026, after which FIPS 140-3 validation is mandatory.

2.06 Privacy and Data Protection Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes mandatory requirements for the protection of privacy and data, including Criminal Justice Information (CJIS), Personally Identifiable Information (PII), and Protected Health Information (PHI), to ensure the confidentiality, integrity, and availability of Elko County information assets. This policy ensures compliance with applicable federal and state laws, regulations, and standards, with adherence verified through the audit process defined in **Policy 5.02**.

2. Scope

This policy applies to all Elko County Information Operations personnel, including all employees, elected officials, contractors, vendors, interns, and volunteers, who access, use, store, process, or transmit County information assets. This policy governs all systems, applications, and projects that process, store, or transmit County data, regardless of location or media.

3. Roles and Responsibilities

- **Board of County Commissioners**: Shall approve the annual data governance plan submitted by the IT Director and review quarterly compliance reports on data protection incidents and remediation.
- **IT Director (LASO)**: Serves as the County's primary authority for data security and privacy. Shall conduct quarterly compliance audits of data handling practices and ensure incident response capabilities meet statutory timelines.
- **Data Owners**: Shall classify data in accordance with this policy and review access privileges semi-annually.
- **All Personnel**: Shall strictly adhere to data handling procedures and report all suspected incidents immediately.

4. Compliance and Exceptions

Failure to comply with this policy may result in disciplinary action, up to and including termination of employment, termination of contract, and civil or criminal prosecution. Exceptions to this policy must be documented in writing, formally approved by the IT Director and the District Attorney's Office, and reviewed annually.

5. References

- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- NRS 239.010 (Public Records)
- NRS 603A.220 (Disclosure of breach of security of system data)

- CJIS Security Policy v6.0: Section IR (Incident Response)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section SC (System and Communications Protection and Information Integrity)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST SP 800-53 Rev. 5: AR-1 (Governance and Privacy Program)
- NIST SP 800-53 Rev. 5: AR-2 (Privacy Impact and Risk Assessment)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: SA-8 (Security and Privacy Engineering Principles)
- NIST SP 800-53 Rev. 5: SC-13 (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: APO14 (Manage Data)
- COBIT 2019: DSS05 (Manage Security Services)
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1. Privacy by Design

New systems and major modifications to existing systems shall incorporate privacy protections into the system architecture during the initial design phase. Projects shall not proceed to development until a Privacy Impact Assessment (PIA) is approved by the IT Director.

6.2. Data Collection and Minimization

Only data strictly necessary for the performance of defined County business functions shall be collected. Determining the necessity of data collection shall be the responsibility of the designated Data Owner.

6.3. Access Control

- Access to non-public data shall be granted on a "Need-to-Know" and "Least Privilege" basis.
- Access rights shall be reviewed in accordance with the recertification cadence defined in **Policy 2.04**.
- Access shall be revoked upon termination of employment or contract in accordance with the timelines defined in **Policy 2.04**.

6.4. Encryption and Data Residency

- **Data at Rest**: All PII, PHI, and CJIS data stored on mobile devices, laptops, or removable media must be encrypted.
- **Data in Transit**: All sensitive data transmitted over public networks must be encrypted using TLS 1.2 or higher.

- **Cryptographic Standards**: Encryption shall use FIPS 140-3 validated modules. Legacy FIPS 140-2 validated modules are permitted only until September 21, 2026, after which they must be replaced.
- **Data Residency**: All County data must be stored within the physical borders of the United States.

6.5. Regulatory Alignment

Elko County shall comply with NRS Chapter 603A and applicable federal privacy requirements. The IT Director shall maintain a register of applicable federal and state privacy laws and shall update this policy within 90 days of any new law taking effect.

6.6. Data Retention

Data shall be retained and disposed of in accordance with **Policy 1.11** and the applicable Nevada Local Government Records Retention Schedules. Destruction of digital media must render the data irretrievable in accordance with NIST SP 800-88 Guidelines for Media Sanitization.

6.7. Data Classification Review

Data Owners shall review data classification annually and document the results in writing to the IT Director. Data Owners shall update classification within 30 days when sensitivity changes and shall notify Information Operations Personnel in writing within 5 business days to implement updated safeguards.

6.8. Data Security and Privacy Training

All personnel shall complete initial and annual security awareness and privacy training. Personnel must complete remedial training within 30 days of a major security event or policy violation.

6.9. Incident Reporting

Suspected or confirmed data breaches, privacy incidents, or security events shall be reported to the IT Director (LASO) immediately upon discovery, not to exceed 1 hour, regardless of the time of day, day of week, or holiday status. This strict timeline is mandatory to comply with FBI CJIS reporting requirements and NRS breach notification statutes.

2.07 System and Communications Protection Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory technical and procedural controls for the protection of Elko County information systems during transmission and storage. This policy mandates the implementation of boundary protection, cryptographic standards, and architectural isolation to ensure the confidentiality, integrity, and availability of County data against internal and external threats.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, employees, contractors, vendors, and volunteers, and all information systems, networks, and infrastructure owned, leased, or operated by Elko County. This specifically includes:

- **Boundary Components**: Firewalls, routers, switches, and gateways.
- **Cryptographic Components**: Encryption keys, certificates, and modules.
- **Communication Channels**: VoIP, VPNs, and wireless networks.
- **Protected Data**: CJI, Personally Identifiable Information (PII), and Restricted County records.

3. Roles and Responsibilities

- **IT Director**
  - Shall serve as the Authorizing Official (AO) for the County's security architecture.
  - Shall approve in writing all ingress/egress traffic policy changes that deviate from the "Deny-by-Default" standard.
  - Shall authorize all connections to external information systems via formal Interconnection Security Agreements.
- **Network Administrator**
  - Shall configure and maintain boundary protection devices to enforce "Deny-by-Default" traffic policies.
  - Shall implement and verify network segregation between public, internal, and CJI-dedicated network segments (DMZ implementation).
  - Shall review firewall rule sets monthly to ensure no unauthorized access points exist.
- **Systems Administrator**
  - Shall configure encryption for data in-transit and at-rest using only FIPS-validated cryptographic modules.
  - Shall manage cryptographic keys in accordance with Section 6.4.
  - Shall disable split tunneling on all remote access endpoints.
- **All Users**
- Shall use only County-authorized methods for remote access and data transmission.

- Shall physically disconnect or disable collaborative computing devices (e.g., webcams, microphones) when accessing CJI, unless the device is authorized for specific operational use.

4. Compliance and Exceptions

- **Mandatory Enforcement** - Personnel and systems must comply with the requirements defined herein. Failure to comply shall result in:
  - Immediate disconnection of the non-compliant system from the County network.
  - Revocation of administrative privileges where applicable.
  - Disciplinary action up to and including termination of employment and referral to law enforcement for statutory violations (e.g., NRS 205.4765).
- **Exceptions**
  - Any deviation from this policy must be documented in a Risk Acceptance Memo in accordance with **Policy 1.09**.
  - **CJI Exceptions**: Exceptions regarding CJI encryption, boundary protection, or split tunneling require explicit written concurrence from the Nevada CJIS Systems Officer (CSO) prior to implementation. The IT Director shall not approve CJI-related exceptions without this external authorization.

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.04: Access Control Policy
- NRS 205.4765 (Unlawful acts regarding computers)
- NRS 603A.210 (Security measures for personal information)
- CJIS Security Policy v6.0: Section SC-1 (System and Communications Protection Policy and Procedures)
- CJIS Security Policy v6.0: Section SC-5 (Denial-of-Service Protection)
- CJIS Security Policy v6.0: Section SC-7 (Boundary Protection)
- CJIS Security Policy v6.0: Section SC-8 (Transmission Confidentiality and Integrity)
- CJIS Security Policy v6.0: Section SC-10 (Network Disconnect)
- CJIS Security Policy v6.0: Section SC-12 (Cryptographic Key Establishment and Management)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- CJIS Security Policy v6.0: Section SC-15 (Collaborative Computing Devices and Applications)
- CJIS Security Policy v6.0: Section SC-28 (Protection of Information at Rest)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: PR.IR-01 (Network Protection)
- NIST SP 800-53 Rev. 5: SC-7 (Boundary Protection)
- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)

- NIST SP 800-53 Rev. 5: SC-13 (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: DSS05 (Manage Security Services)
- ITIL v4: Architecture Management Practice
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Boundary Protection and Architecture

The Network Administrator shall monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces.

- **Managed Interfaces**: Connections to external networks (Internet) or external information systems shall occur only through managed interfaces (e.g., firewalls, proxies, gateways) arranged in accordance with the security architecture.
- **Deny-by-Default**: Boundary protection devices shall be configured to deny all traffic (inbound and outbound) by default and allow only those services and ports explicitly authorized by the IT Director for business need.
- **Split Tunneling Prohibition**: For all remote access sessions connecting to the County network, the Systems Administrator shall configure the remote access mechanism to disable "split tunneling." All network traffic from the remote device must be routed through the County's managed boundary protection devices for inspection.
- **DMZ Implementation**: Publicly accessible system components (e.g., web servers) shall reside in a Demilitarized Zone (DMZ), physically or logically separated from internal organizational networks.
- **Denial of Service (DoS)**: The Network Administrator shall configure boundary devices to detect and mitigate DoS attacks by implementing rate limiting and traffic filtering to reduce attack traffic.

6.2 Transmission Confidentiality and Integrity

The Systems Administrator shall protect the confidentiality and integrity of transmitted information.

- **Encryption In-Transit**: CJI and PII transmitted outside a physically secure location (as defined in **Policy 2.13**) shall be encrypted. Wireless transmission of CJI is prohibited unless encrypted using a FIPS-validated module.
- **Cryptographic Standards**: Encryption mechanisms for data in-transit shall use cryptographic modules validated under the Cryptographic Module Validation Program (CMVP) as compliant with FIPS 140-3 (or FIPS 140-2 until sunset date of Sept 21, 2026). The symmetric cipher key strength shall be at least 128-bit.
- **Session Authenticity**: Systems shall protect the authenticity of communications sessions (e.g., TLS 1.2 or higher) to prevent Man-in-the-Middle (MitM) attacks or session hijacking.
- **Network Disconnect (Idle Timeout)**: To limit exposure of open sessions, the Network Administrator shall configure VPN and remote access gateways to automatically terminate connections after fifteen (15) minutes of inactivity.
  - **Exemption**: As defined in **Policy 2.04**, remote access sessions utilizing certificate-based authentication on devices located within a secure Criminal Justice Conveyance (e.g., patrol vehicles) are exempt from this timeout to ensure officer safety.

6.3 Protection of Information at Rest

The Systems Administrator shall protect the confidentiality and integrity of information at rest.

- **CJI Encryption**: CJI stored on digital media (servers, workstations, mobile devices, external drives) outside of a physically secure location shall be encrypted using FIPS-validated cryptographic modules (FIPS 140-2/3) with a minimum 128-bit key strength.
- **Mobile Devices**: All County-issued laptops, tablets, and smartphones shall have full-disk encryption enabled prior to deployment.

6.4 Cryptographic Key Management

The Systems Administrator shall manage cryptographic keys to secure the key lifecycle.

- **Generation**: Keys shall be generated using FIPS-validated Random Number Generators.
- **Distribution**: Keys shall be distributed via secure methods that prevent unauthorized disclosure (e.g., encrypted channels).
- **Storage**: Unencrypted keys shall not be stored on the same system or media as the encrypted data they protect.
- **Destruction**: Keys shall be destroyed/zeroized immediately when they are no longer needed or when the association with the authorized user/entity is terminated.

6.5 Collaborative Computing Devices

To prevent unauthorized remote surveillance, the Systems Administrator shall configure systems to prohibit the remote activation of collaborative computing devices (cameras, microphones).

- **Indication of Use**: Devices shall provide a physical or on-screen indication when collaborative devices are active.
- **Disablement**: Users accessing CJI via a workstation with a built-in camera/microphone must physically cover or logically disable the device if the environment is not secure or if the device is not required for the immediate task.

6.6 Secure Name/Address Resolution (DNS)

The Network Administrator shall ensure the integrity of the Domain Name System (DNS).

- **Forgery Protection**: Recursive resolvers shall be configured to request and validate DNS Security Extensions (DNSSEC) signatures to verify the authenticity of DNS responses.
- **Fault Tolerance**: The County shall maintain at least two geographically separated DNS servers (or utilize a redundant cloud DNS provider) to ensure availability.

2.08 System Integrity and Malware Protection Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory controls for maintaining the integrity of Elko County information systems. This policy mandates the implementation of malicious code protection, system monitoring, and integrity verification mechanisms to detect and prevent unauthorized changes, exploitation, and data corruption.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, employees, contractors, vendors, and volunteers, and all information systems, networks, and endpoints owned, leased, or operated by Elko County. This specifically includes all systems that process, store, or transmit Criminal Justice Information (CJI) and the infrastructure supporting these systems.

3. Roles and Responsibilities

- **IT Director**
  - Shall serve as the final Authorizing Official (AO) for malicious code protection selection and system monitoring tools.
  - Shall oversee the security posture and ultimate accountability for the County's information system integrity.
  - Shall sign Risk Acceptance Memos for systems unable to support standard integrity controls.
- **Assistant IT Director**
  - Shall oversee the operational execution of the system integrity program and coordinate incident response for detected malware.
  - Shall ensure technical personnel are trained and equipped to maintain protection mechanisms.
- **Systems Administrator**
  - Shall provision, harden, and maintain malware protection agents on all workstations and servers.
  - Shall configure automated tools (e.g., endpoint protection) to update signatures and scanning engines daily.
  - Shall execute integrity checks (e.g., File Integrity Monitoring) and remediate system flaws in accordance with **Policy 2.09**.
- **Network Administrator**
  - Shall configure and monitor boundary protection devices (Firewalls, IDS/IPS) to detect and block malicious traffic at system entry and exit points.
  - Shall monitor network flow to identify anomalies or traffic patterns indicative of malware command-and-control activity.
- **Support Specialist**
  - Shall verify the presence and compliance of antivirus and device encryption during endpoint deployment and troubleshooting.

  - Shall report and escalate confirmed malware infections to Administrators according to established incident protocols.
- **All Users**
  - Shall comply with the Acceptable Use Policy (**Policy 2.01**) and shall not disable or circumvent security controls.
  - Shall report suspected security anomalies to the Service Desk immediately.

4. Compliance and Exceptions

- **Mandatory Enforcement**
  - Personnel and systems must comply with the requirements defined herein. Failure to comply shall result in one or more of the following enforcement actions: (a) immediate isolation of the non-compliant system from the network; (b) revocation of user access privileges; (c) disciplinary action up to and including termination of employment.
- **Exceptions**
  - Any deviation from this policy must be documented in a Risk Acceptance Memo in accordance with **Policy 1.09**. Exceptions for CJI systems regarding malicious code protection or monitoring require: (a) explicit written approval from the IT Director, AND (b) documented consultation with the Nevada CJIS Systems Officer (CSO) if the exception involves removing mandatory CJIS controls.

5. References

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- NRS 205.473 (Unlawful acts regarding computers and information services)
- NRS 239.051 (Public Records)
- CJIS Security Policy v6.0: Section IR (Incident Response Family)
- CJIS Security Policy v6.0: Section SI-3 (Malicious Code Protection)
- CJIS Security Policy v6.0: Section SI-4 (System Monitoring)
- CJIS Security Policy v6.0: Section SI-5 (Security Alerts, Advisories, and Directives)
- CJIS Security Policy v6.0: Section SI-8 (Spam Protection)
- CJIS Security Policy v6.0: Section SI-10 (Information Input Validation)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: DE.AE-01 (Anomalous Activity Detection)
- NIST CSF 2.0: DE.CM-01 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: SI-2 (Flaw Remediation)
- NIST SP 800-53 Rev. 5: SI-3 (Malicious Code Protection)
- NIST SP 800-53 Rev. 5: SI-4 (System Monitoring)
- NIST SP 800-53 Rev. 5: SI-7 (Software, Firmware, and Information Integrity)

- NIST SP 800-53 Rev. 5: SI-8 (Spam Protection)
- NIST SP 800-53 Rev. 5: SI-10 (Information Input Validation)
- NIST SP 800-53 Rev. 5: SI-16 (Memory Protection)
- COBIT 2019: DSS05.01 (Protect against malware)
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Malicious Code Protection

System Administrators shall implement malicious code protection mechanisms at system entry and exit points and on all workstations, servers, and mobile devices to detect and eradicate malicious code.

- **Automatic Updates**: Malicious code protection mechanisms shall be configured to perform automatic updates of virus definitions and scanning engines at least daily. If automatic updates are not feasible, manual updates shall be performed daily.
- **Real-Time Scanning**: Mechanisms shall be configured to perform real-time scanning of files from external sources as they are downloaded, opened, or executed.
- **Periodic Scanning**: Mechanisms shall perform full system scans at weekly intervals or in accordance with the schedule defined in the System Security Plan (SSP).
- **Response Actions**: Upon detection of malicious code, the mechanism shall automatically block or quarantine the malicious code and alert the IT Service Desk.

6.2 System Monitoring

The Department shall ensure that information systems are monitored to detect attacks and indicators of potential attacks.

- Monitoring Tools: The Department shall employ automated tools (e.g., IDS/IPS, SIEM) to monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.
- Perimeter Monitoring: Monitoring shall check for indicators of attacks and unauthorized connections at external boundaries and at key internal boundaries.
- Alerting: System-generated security alerts shall be transmitted to the ISO and designated System Administrators in real-time. Personnel shall analyze and respond to alerts in accordance with **Policy 4.01**.
- Legal Review: The IT Director shall consult with the District Attorney's Office to ensure that monitoring activities comply with applicable federal and state privacy laws.

6.3 Information Integrity and Input Validation

- **Integrity Checks**: System Administrators shall employ integrity verification tools (e.g., File Integrity Monitoring - FIM) to detect unauthorized changes to software, firmware, and information. For systems processing CJI, integrity checks shall be performed at least weekly.
- **Input Validation**: Developers and System Administrators shall ensure that information systems check the validity of information inputs (e.g., character set, length, numerical range, format) to prevent injection attacks (e.g., SQL injection, Cross-Site Scripting) and data corruption.
- **Spam Protection**: The Department shall employ spam protection mechanisms at information system entry and exit points to detect and action unsolicited messages. Spam protection signatures shall be updated automatically.

6.4 Flaw Remediation

Flaw remediation (patching) shall be executed in strict accordance with **Policy 2.09**. System Administrators shall identify, report, and correct information system flaws, test software updates for effectiveness and potential side effects, and install security-relevant updates within the timelines mandated by **Policy 2.09**.

6.5 Memory Protection

System Administrators shall ensure that operating systems and applications utilize memory protection controls (e.g., Data Execution Prevention [DEP], Address Space Layout Randomization [ASLR]) to prevent the execution of unauthorized code.

2.09 Vulnerability and Patch Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory standards for the identification, classification, remediation, and mitigation of technical vulnerabilities within Elko County's information systems. This policy ensures that security flaws are addressed in a timely manner to prevent exploitation, protect the confidentiality, integrity, and availability of County data (including Criminal Justice Information), and maintain compliance with federal and state regulations.

2. Scope

This policy applies to all information systems, networks, hardware, software, and firmware owned, leased, operated, or managed by Elko County Information Operations. This includes servers, workstations, mobile devices, network infrastructure, and third-party applications.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the Authorizing Official (AO) for the vulnerability management program and shall approve all Risk Acceptance Memos for vulnerabilities that cannot be remediated within mandated timelines.
- **Assistant IT Director**: Shall oversee the operational execution of the vulnerability management lifecycle and validate that scanning tools are functioning correctly and reports are generated and reviewed.
- **System Administrators**: Shall configure and maintain automated vulnerability scanning tools, analyze scan results, test patches, and implement remediation actions for server and endpoint systems.
- **Network Administrators**: Shall manage vulnerabilities related to network infrastructure (routers, switches, firewalls) and remediate identified flaws in firmware or configuration.
- **Support Specialists**: Shall verify endpoint patch status during support engagements and deployment, ensuring antivirus and automated update agents are functional.
- **Department Heads**: Shall coordinate with Information Operations to schedule maintenance windows for business-critical applications.
- **All Personnel**: Shall comply with reboot or update notifications to ensure security patches are applied to assigned workstations.

4. Compliance and Exceptions

- **Mandatory Compliance**: Adherence to this policy is mandatory. Failure to patch or remediate known vulnerabilities within the specified timelines constitutes a security violation and may result in the quarantine of the non-compliant asset.
- **System Isolation**: Systems that cannot be patched and pose a critical risk to the network shall be logically isolated or disconnected until remediation or an approved exception is in place.
- **Exceptions**: Deviations from remediation timelines or scanning requirements must be documented in a Risk Acceptance Memo in accordance with **Policy 1.09**. The memo must include technical justification, compensating controls, and a defined expiration date (not to exceed 12 months).

- **CJI Constraints**: Exceptions for systems processing CJI must not violate mandatory FBI CJIS Security Policy requirements without written concurrence from the CJIS Systems Officer (CSO).

5. References

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.08: System Integrity and Malware Protection Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.09: Change Management Policy
- NRS 205.4765 (Unlawful acts regarding computers and information services)
- NRS 603A.210 (Security measures for personal information)
- CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning)
- CJIS Security Policy v6.0: Section SC (System and Communications Protection and Information Integrity Family)
- CJIS Security Policy v6.0: Section SI-2 (Flaw Remediation)
- CJIS Security Policy v6.0: Section SI-5 (Security Alerts, Advisories, and Directives)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST SP 800-53 Rev. 5: RA-5 (Vulnerability Monitoring and Scanning)
- NIST SP 800-53 Rev. 5: SI-2 (Flaw Remediation)
- COBIT 2019: BAI03 (Manage Solutions Identification and Build)
- ITIL v4: Change Enablement Practice
- ITIL v4: Information Security Management Practice
- ITIL v4: Release Management Practice
- ITIL v4: Software Asset Management Practice

6. Policy Statement

6.1 Vulnerability Scanning and Identification

- **Automated Scanning**: The Department shall employ automated tools to perform authenticated vulnerability scans on all active network assets.
- **Scanning Frequency**:
  - **Internal Systems**: Shall be scanned at least Monthly.
  - **External-Facing Systems**: Shall be scanned at least Weekly.
  - **CJI Systems**: Shall be scanned in accordance with the stricter of the County Monthly baseline or CJIS RA-5 requirements.
  - **Ad-Hoc**: Scans shall be initiated within 72 hours of the publication of Critical severity vendor security advisories affecting County assets.
- **Credentialed Scanning**: To ensure accuracy, scans shall be performed using privileged credentials (authenticated scans) whenever technically feasible.

- **Asset Discovery**: Scanning tools shall be configured to actively discover new or unauthorized devices connected to the network.

6.2 Vulnerability Scoring and Prioritization

- **Standard Scoring**: Vulnerabilities shall be assessed using the Common Vulnerability Scoring System (CVSS) v3.1 or higher.
- **Prioritization**: Remediation prioritization shall be determined by the base score and the asset's criticality classification (as defined in **Policy 1.11** and **Policy 1.12**).
- **Severity Categories**:
  - **Critical**: CVSS 9.0 - 10.0
  - **High**: CVSS 7.0 - 8.9
  - **Medium**: CVSS 4.0 - 6.9
  - **Low**: CVSS 0.1 - 3.9

6.3 Patch Management and Remediation Timelines

- **Remediation Mandate**: System Administrators shall test and deploy security patches or implement compensating controls within the following strict timelines, measured from the date of vendor release or vulnerability discovery:
  - **Critical Severity**: Remediate within 15 days.
  - **High Severity**: Remediate within 30 days.
  - **Medium Severity**: Remediate within 60 days.
  - **Low Severity**: Remediate within 90 days.
- **Flaw Remediation**: The Department shall identify, report, and correct information system flaws. Security-relevant software updates shall be installed automatically where feasible (e.g., workstation OS updates).
- **Testing**: All patches shall be tested on a non-production subset of systems (e.g., a "pilot group") prior to county-wide deployment to minimize operational disruption.
- **Change Control**: Critical and High severity patches may be treated as Standard Changes (pre-authorized) if defined in the **Policy 3.09**. Emergency patching requiring immediate disruption shall follow the Emergency Change procedure.

6.4 Unsupported Software (End-of-Life)

- **Prohibition**: The use of software or operating systems that are End-of-Life (EOL) or End-of-Support (EOS) by the vendor is prohibited on County networks.
- **Transition Plan**: The IT Director must approve a migration plan to replace or retire assets at least 90 days prior to their EOL date.
- **Exception**: If EOL software must remain in use for critical business functions, it shall be:
  - Covered by a formal Risk Acceptance Memo.
  - Isolated from the general network and the Internet (air-gapped or strictly firewalled).
  - Blocked from accessing CJI.

6.5 Verification and Rescanning

- **Validation**: Remediation actions shall be verified through a follow-up vulnerability scan or manual verification within seven (7) days of patch deployment.
- **False Positives**: Vulnerabilities identified as "False Positives" by System Administrators must be validated, documented with evidence, and marked as such in the scanning tool. False positive designations shall be reviewed annually.

6.6 Reporting

- **Monthly Report**: The Assistant IT Director shall generate a Monthly Vulnerability Compliance Report for the IT Director. This report shall track:
  - Total open vulnerabilities by severity.
  - Mean Time to Remediate (MTTR).
  - Percentage of assets compliant with patching timelines.
  - List of assets with overdue patches.

6.7 Cloud and Third-Party Systems

- **Shared Responsibility**: For cloud-based systems (SaaS, IaaS, PaaS), the Assistant IT Director shall ensure the contract or Service Level Agreement (SLA) specifies the vendor's responsibility for patching and vulnerability scanning.
- **Vendor Assurance**: The Department shall review third-party security attestations (e.g., SOC 2 Type II, FedRAMP authorization) annually to verify vendor vulnerability management practices comply with County standards.

2.10 Secure Configuration Baselines and Hardening Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the mandatory requirements for the secure configuration, hardening, and continuous monitoring of all Elko County Information Operations (ECIO) technology assets. This policy enforces the principle of least functionality to minimize the organizational attack surface and ensure the confidentiality, integrity, and availability of County systems, with specific emphasis on environments processing Criminal Justice Information (CJI).

2. Scope

This policy applies to all ECIO personnel, contractors, and third-party vendors. The scope encompasses all physical and virtual hardware, operating systems, network infrastructure, software applications, and cloud environments owned, leased, or managed by Elko County.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the final approval authority for all enterprise baseline configuration standards, formal risk acceptance, and policy exceptions documented in the System Security Plan (SSP). Shall serve as the Configuration Control Authority (CCA) and Local Agency Security Officer (LASO) for all configuration decisions affecting CJI systems.
- **Assistant IT Director**: Shall define the secure configuration benchmarks based on mandatory frameworks, audit baseline compliance across all operational domains, mandate remediation for non-compliant assets, and maintain the Configuration Management Database (CMDB) as the authoritative record of approved configuration baselines.
- **Systems Administrator**: Shall engineer, apply, and maintain approved configuration baselines on all assigned server and endpoint computing assets prior to production deployment and throughout the asset lifecycle.
- **Network Administrator**: Shall engineer, apply, and maintain approved configuration baselines on all assigned network infrastructure, boundary protection, and communication assets prior to production deployment and throughout the asset lifecycle.

4. Compliance and Exceptions

Violations of this policy shall result in the immediate isolation of the non-compliant asset from the production network and may subject the responsible personnel to disciplinary action.

Any deviation from an approved configuration baseline must be submitted via a formal Exception Request. The request shall include a documented technical justification, compensating controls, and a defined expiration date. Exceptions are invalid unless formally approved in writing by both the Assistant IT Director and the IT Director. For exceptions affecting systems that process, store, or transmit Criminal Justice Information (CJI), written approval from the CJIS Systems Officer (CSO) shall be obtained prior to implementation.

Unauthorized systems discovered operating without an approved baseline shall be treated as Shadow IT. In such events, Incident Response isolation protocols shall trigger automatically, and asset handling shall default to the enforcement mechanisms defined in ECIO **Policy 3.09** (Change Management Policy), ECIO **Policy 5.01** (Policy Implementation and Enforcement Framework), and ECIO **Policy 4.04** (Eradication Procedures and Scenario Guides).

5. References

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- NRS 205 (Crimes Against Property)
- NRS 603A (Security of Personal Information)
- CJIS Security Policy v6.0: Section CM-1 (Configuration Management Policy and Procedures)
- CJIS Security Policy v6.0: Section CM-2 (Baseline Configuration)
- CJIS Security Policy v6.0: Section CM-2(2) (Automation Support for Accuracy and Currency)
- CJIS Security Policy v6.0: Section CM-2(3) (Retention of Previous Configurations)
- CJIS Security Policy v6.0: Section CM-5 (Access Restrictions for Change)
- CJIS Security Policy v6.0: Section CM-6 (Configuration Settings)
- CJIS Security Policy v6.0: Section CM-7 (Least Functionality)
- CJIS Security Policy v6.0: Section CM-7(1) (Periodic Review)
- CJIS Security Policy v6.0: Section CM-8 (System Component Inventory)
- CJIS Security Policy v6.0: Section CM-9 (Configuration Management Plan)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)
- NIST SP 800-53 Rev. 5: CM-1 (Configuration Management Policy and Procedures)
- NIST SP 800-53 Rev. 5: CM-2 (Baseline Configuration)
- NIST SP 800-53 Rev. 5: CM-2(2) (Automation Support for Accuracy and Currency)
- NIST SP 800-53 Rev. 5: CM-2(3) (Retention of Previous Configurations)
- NIST SP 800-53 Rev. 5: CM-5 (Access Restrictions for Change)
- NIST SP 800-53 Rev. 5: CM-6 (Configuration Settings)
- NIST SP 800-53 Rev. 5: CM-7 (Least Functionality)
- NIST SP 800-53 Rev. 5: CM-7(1) (Periodic Review)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: CM-9 (Configuration Management Plan)
- COBIT 2019: BAI10.01 (Establish and maintain a configuration model)
- COBIT 2019: BAI10.02 (Establish and maintain a configuration repository and baseline)
- COBIT 2019: BAI10.03 (Maintain and control configuration items)
- ITIL v4: Service Configuration Management Practice

6. Policy Statement

6.1 Baseline Configuration Establishment

ECIO shall establish, document, and maintain secure configuration baselines for all information systems. Baselines must be strictly derived from Defense Information Systems Agency (DISA) Security Technical Implementation Guides (STIGs). Where an applicable DISA STIG does not exist for a specific system class, the Center for Internet Security (CIS) Benchmark at Level 2 or higher shall serve as the mandatory fallback baseline standard. The absence of an applicable STIG and the use of the CIS fallback shall be documented in the SSP. The Assistant IT Director shall review and update these baselines at least annually or upon the introduction of a new system architecture to ensure alignment with the latest releases.

To support rollback capabilities, ECIO shall retain at least one (1) prior approved version of the baseline configuration for each system.

6.2 Network Topological Drawing

ECIO shall develop, document, and maintain under configuration control a current and complete topological drawing depicting the interconnectivity of the County network to criminal justice information systems and services. The Assistant IT Director shall review and update this drawing at least annually, upon security-relevant system changes, and when network components are installed or upgraded.

6.3 Principle of Least Functionality and System Hardening

Information systems shall be configured to provide only essential capabilities. Services, daemons, ports, protocols, and applications not explicitly justified in the approved System Security Plan (SSP) and documented within the Configuration Management Database (CMDB) baseline shall be disabled or removed prior to production deployment.

Systems in production at the effective date of this policy shall be assessed against the applicable baseline within ninety (90) days of the effective date. Non-compliant systems shall be remediated or formally excepted under Section 4 within one hundred eighty (180) days.

6.4 Default Account and Credential Hardening

All default, guest, and built-in vendor accounts shall be disabled, renamed, or strictly restricted before an asset is joined to the production network. Default authentication credentials (e.g., passwords, SNMP strings, SSH keys) shall be changed to meet current enterprise cryptographic and complexity standards prior to deployment.

6.5 Configuration Change Control

Modifications to established configuration baselines shall not occur outside of the formal ITIL Change Management process, in accordance with ECIO **Policy 3.09** (Change Management Policy). System and Network Administrators must submit a Request for Change (RFC) and receive Configuration Control Authority (CCA) approval prior to altering configuration settings on production systems. Emergency changes shall follow the emergency change procedure and shall follow the emergency change procedure and complete catch-up documentation and CCA review in accordance with the timelines established in **Policy 3.09**.

6.6 Continuous Monitoring and Enforcement

ECIO shall deploy automated mechanisms to dynamically monitor systems for deviations from their approved DISA STIG or CIS baselines. When automated tools detect a deviation, the system shall generate an alert to the Assistant IT Director and the respective Systems or Network Administrator. Critical-risk deviations shall be remediated, or the affected asset logically isolated from the production network, within

four (4) hours of detection. High-risk deviations shall be remediated within twenty-four (24) hours of detection. Deviations not remediated within the required timeframe shall be escalated to the IT Director and documented as an open exception in accordance with Section 4.

2.11 Audit Logging and Monitoring Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the mandatory requirements for the generation, protection, review, and retention of security audit logs across all Elko County information systems. It ensures that system activity is continuously recorded and monitored to detect unauthorized access, support forensic investigations, maintain individual accountability, and fulfill the strict audit and accountability mandates of the FBI Criminal Justice Information Services (CJIS) Security Policy and Nevada Revised Statutes.

2. Scope

This policy applies to all Elko County information systems, network infrastructure, endpoints, and cloud services that process, store, or transmit County data. It governs the configurations, aggregation systems (e.g., SIEM), and personnel responsible for security event logging. Operational performance logging (e.g., resource utilization metrics) is explicitly out of scope for this policy and is governed under **Policy 3.12** (Monitoring and Event Management Policy).

3. Roles and Responsibilities

- **IT Director**: Shall serve as the final authority on audit logging requirements, ensure configurations for systems processing Criminal Justice Information (CJI) meet federal mandates, and serve as the delegated Information Operations Records Custodian for IT-managed data assets. The IT Director shall designate a Records Liaison responsible for maintaining the exact mapping between system log types and the Nevada retention schedule record series (LRDA 20071728).
- **Assistant IT Director**: Shall oversee the centralized log management architecture, allocate sufficient storage capacity, ensure automated audit review mechanisms are configured to alert on anomalous activities, coordinate incident response activities triggered by audit findings, and ensure the mandated weekly review of aggregated security audit logs is conducted.
- **System and Network Administrators**: Shall configure information systems to generate required audit records, forward those records to the centralized log repository, review automated security alerts in accordance with established SLAs, and protect log facilities from unauthorized access. To comply with separation of duties, personnel administering security access controls shall not possess the capability to modify or delete the audit logs that record their actions, nor shall they be the sole reviewers of their own administrative logs.
- **Department Heads (Data Owners)**: Shall identify any specific business or regulatory logging requirements applicable to their departmental data and coordinate implementation with the Information Operations Department.
- **All Personnel**: Shall not disable, bypass, or tamper with system auditing functions.

4. Compliance and Exceptions

Mandatory Enforcement: Compliance with this policy is mandatory. The intentional disablement, circumvention, or alteration of audit logging mechanisms by unauthorized personnel constitutes a severe security violation and shall result in immediate access revocation and disciplinary action, up to and including termination and criminal referral under NRS 205.

Exceptions: Exceptions shall be documented in a formal Risk Acceptance Memo, including defined compensating controls and an expiration date not to exceed twelve (12) months, and must be approved in writing by the IT Director in accordance with **Policy 1.09**. Any exception affecting systems that process CJI shall require explicit written approval from the CJIS Systems Officer (CSO) prior to implementation.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- NRS 205 (Computer Crimes)
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Access Control Reviews and Audit Trails)
- CJIS Security Policy v6.0: Section AU-2 (Event Logging)
- CJIS Security Policy v6.0: Section AU-3 (Content of Audit Records)
- CJIS Security Policy v6.0: Section AU-6 (Audit Record Review, Analysis, and Reporting)
- CJIS Security Policy v6.0: Section AU-11 (Audit Record Retention)
- CJIS Security Policy v6.0: Section AU-12 (Audit Record Generation)
- NIST CSF 2.0: DE.AE-01 (Anomalous Activity Detection)
- NIST SP 800-53 Rev. 5: AU-2 (Event Logging)
- NIST SP 800-53 Rev. 5: AU-3 (Content of Audit Records)
- NIST SP 800-53 Rev. 5: AU-4 (Audit Log Storage Capacity)
- NIST SP 800-53 Rev. 5: AU-5 (Response to Audit Processing Failures)
- NIST SP 800-53 Rev. 5: AU-6 (Audit Record Review, Analysis, and Reporting)
- NIST SP 800-53 Rev. 5: AU-7 (Audit Record Reduction and Report Generation)
- NIST SP 800-53 Rev. 5: AU-8 (Time Stamps)
- NIST SP 800-53 Rev. 5: AU-9 (Protection of Audit Information)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: AU-12 (Audit Record Generation)
- COBIT 2019: DSS05.07 (Monitor the infrastructure for security-related events)

6. Policy Statement

6.1 Auditable Events (Event Generation)

The Information Operations Department shall configure all County information systems, network infrastructure, and cloud environments to generate audit records for security-relevant events. At a minimum, the following events shall be logged:

- **Authentication and Access**: All successful and unsuccessful logon attempts, session disconnections, and access to systems processing Criminal Justice Information (CJI) or Restricted County data.

- **Privileged Operations**: All actions executed under elevated or administrative privileges (Tier L3 and above), including "break-glass" emergency access.
- **Account Management**: The creation, modification, enablement, disablement, and deletion of any system or user account.
- **Data Manipulation**: The creation, modification, and deletion of Restricted data (including CJI) and Confidential data.
- **Security Control Modifications**: Any modification to security baselines, firewall rules, group policies, or audit logging configurations.
- **System Integrity**: System restarts, shutdowns, and alerts generated by malicious code protection or file integrity monitoring (FIM) mechanisms.

6.2 Content of Audit Records

To ensure forensic viability and individual accountability, every generated audit record shall contain the following mandatory data elements:

- **Timestamp**: The exact date and time the event occurred.
- **Identity**: The unique identifier (e.g., username, service account ID) of the individual or process causing the event.
- **Event Type**: A clear categorization of the action attempted or executed.
- **Outcome**: An indicator of success or failure.
- **Originating Source**: The logical and/or physical origin of the request (e.g., source IP address, MAC address, terminal identifier).
- **Target Asset**: The name, ID, or file path of the system, application, or data record impacted by the event.

6.3 Log Centralization, Capacity, and Tamper Protection

To satisfy separation of duties and protect audit integrity, audit logs shall be protected from unauthorized modification, deletion, and spoofing.

- **Storage Capacity**: The Assistant IT Director shall allocate sufficient audit record storage capacity to prevent logs from being overwritten or dropped prior to their scheduled archival.
- **Centralized Repository**: Systems shall forward audit records continuously, or at highly frequent intervals, to a centralized, logically isolated log management repository (e.g., SIEM).
- **Append-Only Enforcemen**t: Personnel with administrative control over security baselines or system configurations shall not have the ability to modify or delete audit logs that record their actions. The centralized repository shall enforce append-only or read-only privileges for all system and network administrators.
- **Tamper Detection**: The central log repository shall employ cryptographic mechanisms (e.g., file hashing) or strict access control monitoring to detect unauthorized modifications to archived log files.

6.4 Audit Review, Analysis, and Alerting

The Information Operations Department shall proactively analyze audit records to detect anomalous activity, unauthorized access attempts, and potential security incidents.

- **Review Frequency**: The Assistant IT Director shall ensure designated Tier L3 personnel conduct a formal review of aggregated security audit logs at least weekly to identify anomalous patterns that may not trigger automated alerts.

- **Automated Alerting**: The Department shall employ automated tools configured to generate real-time alerts for critical security events, including but not limited to: multiple failed authentication attempts, unauthorized access to CJI repositories, and detection of malicious code.
- **Alert Routing**: System-generated security alerts shall be transmitted to the Assistant IT Director and designated Tier L3 System Administrators in real-time.
- **Alert Review SLA**: Alerts generated by the automated system shall be reviewed by designated Tier L3 Administrators within four (4) business hours of generation during standard operating hours, or by the start of the next business day for off-hours alerts.
- **Incident Trigger**: Personnel shall analyze and respond to alerts in accordance with the incident declaration and response protocols defined in **Policy 4.01**.

6.5 Response to Audit Processing Failures

To ensure continuous visibility, the logging architecture must immediately detect and report failures.

- **Failure Alerting**: The logging system shall be configured to alert the Assistant IT Director and designated Administrators within one (1) hour of an audit processing failure (e.g., software/hardware errors, network disruption, or storage reaching capacity thresholds).
- **Restoration SLA**: Personnel shall initiate troubleshooting and restoration of logging functionality within one (1) hour of receiving the failure alert. If restoration cannot be achieved, the affected system may be subject to logical isolation based on its risk profile, as determined by the IT Director or Assistant IT Director.

6.6 Time Synchronization

To ensure accurate correlation of audit records across distinct systems, all County information systems and network devices shall synchronize their internal clocks to an authoritative, County-approved Network Time Protocol (NTP) source. The primary internal NTP servers shall synchronize with a trusted, stratum-1 external time source (e.g., NIST internet time servers).

6.7 Records Retention and Disposition

Audit logs constitute official County records and shall be retained in strict accordance with the Nevada Local Government Records Retention Schedule and statutory public records mandates.

- **Minimum Retention Period**: IT security logs, including access control and audit logs, shall be retained for a minimum of three (3) calendar years from the end of the calendar year in which the review or audit was concluded. This standard explicitly exceeds the CJIS minimum requirement of one (1) year.
- **Legal Hold**: The IT Director, acting as the Records Custodian, shall ensure all automated and manual log disposition actions are immediately suspended during active litigation holds, public records preservation requirements, audits, or active incident investigations.

2.12 Media Protection and Sanitization Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the mandatory security controls for the protection, access, transport, and verifiable sanitization of all physical and digital media storing Elko County information. This policy prevents the unauthorized disclosure of Confidential and Restricted data, including Criminal Justice Information (CJI), by enforcing strict lifecycle constraints from media provisioning through destruction, consistent with FBI CJIS Security Policy Version 6.0 and NIST SP 800-88 Revision 1.

2. Scope

This policy applies to all Elko County Information Operations personnel, County employees, contractors, and third-party vendors who access, transport, store, or sanitize County media. Covered media includes, but is not limited to, portable storage devices (e.g., USB drives, external hard drives), optical media, magnetic tapes, solid-state drives, internal hard drives within multifunction printers/copiers (MFPs), networking equipment NVRAM, and physical/printed media containing County data.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the Technical Authority governing media sanitization standards. Shall act as the Local Agency Security Officer (LASO) and approve all sanitization methods and exceptions involving Criminal Justice Information (CJI).
- **Information Operations Personnel (Administrators and Support Specialists)**: Shall execute required media sanitization procedures prior to the disposal, transfer, or reuse of IT assets. Shall verify sanitization effectiveness and maintain the Configuration Management Database (CMDB) and logging records for all sanitized media.
- **Department Heads (Data Owners)**: Shall enforce physical media protection and ensure physical documents generated within their departments are destroyed in accordance with this policy and assigned data classification levels.
- **All Personnel**: Shall physically protect County media in their custody from unauthorized access, loss, or theft, and shall report any loss or suspected compromise of media immediately.

4. Compliance and Exceptions

Adherence to this policy is mandatory.

- **Enforcement**: The unauthorized disposal of media or the use of unsanctioned portable storage devices shall result in immediate asset confiscation, access revocation, and corrective action defined under **Policy 5.01**.
- **CJIS Reporting Requirement**: Personnel shall report the loss or theft of any media containing CJI to the IT Director (LASO) immediately, and no later than one (1) hour after discovery.
- **Records Retention**: Information Operations shall retain Certificates of Destruction and sanitization logs in accordance with the applicable Nevada Local Government Records Retention Schedules.
- **Exceptions**: Exceptions shall be documented within a formal Risk Acceptance Memo signed by the IT Director, containing specified compensating controls and a defined expiration date. Exceptions

involving CJI shall require explicit written approval from the CJIS Systems Officer (CSO) prior to implementation.

5. References

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.210 (Security measures for personal information)
- CJIS Security Policy v6.0: Section MP-1 (Media Protection Policy and Procedures)
- CJIS Security Policy v6.0: Section MP-2 (Media Access)
- CJIS Security Policy v6.0: Section MP-3 (Media Marking)
- CJIS Security Policy v6.0: Section MP-4 (Media Storage)
- CJIS Security Policy v6.0: Section MP-5 (Media Transport)
- CJIS Security Policy v6.0: Section MP-6 (Media Sanitization)
- CJIS Security Policy v6.0: Section MP-7 (Media Use)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST SP 800-53 Rev. 5: MP-1 (Media Protection Policy and Procedures)
- NIST SP 800-53 Rev. 5: MP-2 (Media Access)
- NIST SP 800-53 Rev. 5: MP-3 (Media Marking)
- NIST SP 800-53 Rev. 5: MP-4 (Media Storage)
- NIST SP 800-53 Rev. 5: MP-5 (Media Transport)
- NIST SP 800-53 Rev. 5: MP-6 (Media Sanitization)
- NIST SP 800-53 Rev. 5: MP-6(7) (Dual Authorization)
- NIST SP 800-53 Rev. 5: MP-7 (Media Use)
- NIST SP 800-88 Rev. 1: (Guidelines for Media Sanitization)
- COBIT 2019: DSS05.06 (Manage sensitive documents and output devices)

6. Policy Statement

6.1 Media Access and Storage

Personnel shall store physical and digital media containing Confidential or Restricted information (including CJI) within physically secure locations or locked containers when not in active use. Media shall only be accessible to authorized personnel with a validated business need-to-know. Removable digital media shall be encrypted using FIPS-validated cryptographic modules (FIPS 140-3, or FIPS 140-2 until September 21, 2026) prior to storing any Level 3 (Confidential) or Level 4 (Restricted) data.

6.2 Media Marking and Labeling

Where technically feasible, personnel shall mark or label physical media and removable digital media containing Confidential or Restricted data with the assigned classification level. This control ensures personnel remain aware of the required handling and disclosure constraints. Labels shall omit system-specific or operational details that could increase the risk of targeted theft.

6.3 Media Transport

Personnel shall transport media containing Confidential or Restricted data using continuous chain-of-custody controls. Digital media in transit must employ FIPS-validated cryptographic modules (FIPS 140-3, or FIPS 140-2 until September 21, 2026). If physical media containing Restricted data (e.g., printed CJI) must be transported outside of a physically secure location, it shall remain under the direct, continuous physical control of authorized personnel or be shipped via a tracked courier service utilizing signature verification upon delivery.

6.4 Digital Media Sanitization

Information Operations personnel shall sanitize all digital media prior to disposal, release, external transfer, lease return, or internal reuse. Sanitization must execute methods (Clear, Purge, or Destroy) strictly consistent with NIST SP 800-88 Rev. 1 guidelines, subject to the stricter CJIS requirements defined herein.

- **Clear**: Acceptable only for the internal reuse of media that solely stored Level 1 (Public) or Level 2 (Internal Use) data.
- **Purge**: Mandatory for the internal reuse of media that previously stored Level 3 (Confidential) or Level 4 (Restricted) non-CJI data. Cryptographic Erase (CE) constitutes an acceptable purge method for non-CJI data if the storage device natively supports it and utilizes FIPS-validated encryption.
- **CJIS Overwrite Requirement**: Media that stores or has stored Criminal Justice Information (CJI) shall be overwritten at least three (3) times or degaussed prior to disposal or release to unauthorized individuals. CE shall not be used for CJI media unless explicit, written approval is obtained from the CJIS Systems Officer (CSO).
- **Destroy**: Mandatory for End-of-Life (EOL) digital media or any media that cannot be successfully purged or overwritten. Destruction shall render the data permanently irretrievable and the media physically unusable.
- **Networking Equipment**: Networking equipment NVRAM shall be sanitized utilizing vendor-approved factory-reset commands or physical destruction.
- **Equipment Testing**: Information Operations personnel shall test sanitization equipment and procedures annually to verify that the intended sanitization is achieved.

6.5 Physical Media Sanitization and Destruction

Personnel shall destroy physical media (e.g., paper documents) containing Confidential or Restricted data when no longer required, executing a method that renders the information unrecoverable (e.g., cross-cut shredding or incineration). The destruction of physical media containing Personally Identifiable Information (PII) shall strictly comply with the destruction standards mandated by NRS 603A.210. Personnel shall not place intact physical media containing sensitive data into standard waste or recycling receptacles.

6.6 Records of Sanitization, Disposal, and Verification

Information Operations shall comprehensively document and verify all sanitization and disposal actions for IT-managed assets. Required documentation shall include the date of sanitization, the unique Asset Identifier (Tag ID), the specific sanitization method utilized, the final disposition of the media, the identity of the personnel executing the sanitization, and the identity of the personnel performing the post-sanitization verification. For media that stores or has stored Criminal Justice Information (CJI), the post-sanitization

verification shall be performed by a secondary, independent Information Operations staff member who did not execute the initial sanitization (Dual Authorization). Verification shall consist of a documented test read or visual inspection to confirm the sanitization was effective. Electronic waste (E-Waste) transferred to approved third-party recycling vendors shall mandate an official Certificate of Destruction.

6.7 Prohibited Media Types

The use of personally owned removable media (e.g., personal USB flash drives, external hard drives) on Elko County information systems is strictly prohibited. Only County-procured, encrypted portable storage devices that are actively cataloged within the CMDB shall be authorized for use.

6.8 Multifunction Printers (MFPs) and Copier Handling

Elko County utilizes MFPs with internal storage drives capable of caching Confidential and Restricted data. The terminal disposition of these assets is subject to strict chain-of-custody and sanitization controls. Specific MFP models and their corresponding configuration limitations shall be documented within the CMDB and supporting Standard Operating Procedures (SOPs).

- **Automated Data Removal Limitations**: Information Operations personnel shall configure MFPs to execute automated job data removal no less than weekly and shall implement automated alerting for job data removal failures. In the event of an automated job data removal failure, Information Operations personnel shall execute a manual clearing within twenty-four (24) hours of the alert. Personnel must acknowledge that automated job data removal operates solely as a defense-in-depth risk mitigation and does not constitute terminal sanitization for CJI media.
- **Contractual "Keep Your Drive" Requirement**: All MFP lease or purchase agreements executed after the effective date of this policy shall incorporate a "Keep Your Drive" provision. At lease expiration or hardware replacement, Elko County shall remove and retain the internal storage media for physical destruction in accordance with Section 6.5.
- **On-Site Vendor Sanitization**: For pre-existing lease agreements executed prior to the effective date of this policy that lack a "Keep Your Drive" provision, the vendor shall not remove the asset from Elko County facilities until a CJIS-compliant three-pass overwrite or degauss has been executed on-site. Information Operations personnel shall visually verify the overwrite or degauss and obtain a Certificate of Sanitization prior to the hardware's departure.
- **Inoperable Media (Break/Fix)**: Vendor technicians shall not remove inoperable MFP drives that cannot be logically overwritten. Elko County shall classify these drives as physical media for destruction and shall retain them regardless of warranty or lease return requirements. The IT Director shall proactively notify vendors of this requirement in writing prior to any service event to ensure compliance at the time of a break/fix call.

2.13 Physical Security and Environmental Controls Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory physical and environmental safeguards to protect Elko County personnel, hardware, software, networks, and data (including Criminal Justice Information [CJI]) from physical damage, unauthorized access, environmental hazards, and interruption of operations.

2. Scope

This policy shall apply to all Elko County physical facilities, data centers, network closets, and terminal areas where Elko County information systems reside or where CJI is accessed, processed, transmitted, or stored.

3. Roles and Responsibilities

- **IT Director**: Shall approve all physical access control lists and environmental control baselines.
- **Physical Security / Facilities Management**: Shall implement, test, and maintain environmental safeguards (e.g., fire suppression, climate control) and physical access mechanisms (e.g., locks, cameras).
- **Elko County Personnel**: Must escort unauthenticated visitors at all times within physically secure locations and challenge any unescorted or unbadged individual.

4. Compliance and Exceptions

Any deviation from the controls defined in this policy must be documented via a formal risk acceptance exception, justified by objective operational constraints, and explicitly approved in writing by the IT Director. Violations of this policy shall result in disciplinary action up to and including termination.

5. References

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- NRS 239C (Homeland Security)
- LRDA 20071279 (Property Management - Security Records)
- LRDA 20071749 (Property Management - Security Camera Recordings)
- CJIS Security Policy v6.0: Section 5.9 (Physically Secure Location)
- CJIS Security Policy v6.0: Section MA-5 (Maintenance Personnel)
- CJIS Security Policy v6.0: Section PE-2 (Physical Access Authorizations)

- CJIS Security Policy v6.0: Section PE-3 (Physical Access Control)
- CJIS Security Policy v6.0: Section PE-6 (Monitoring Physical Access)
- CJIS Security Policy v6.0: Section PE-6(1) (Intrusion Alarms and Surveillance Equipment)
- CJIS Security Policy v6.0: Section PE-8 (Visitor Access Records)
- CJIS Security Policy v6.0: Section PE-9 (Power Equipment and Cabling)
- CJIS Security Policy v6.0: Section PE-10 (Emergency Shutoff)
- CJIS Security Policy v6.0: Section PE-11 (Emergency Power)
- CJIS Security Policy v6.0: Section PE-12 (Emergency Lighting)
- CJIS Security Policy v6.0: Section PE-13 (Fire Protection)
- CJIS Security Policy v6.0: Section PE-13(1) (Detection Systems - Automatic Activation and Notification)
- CJIS Security Policy v6.0: Section PE-14 (Environmental Controls)
- CJIS Security Policy v6.0: Section PE-15 (Water Damage Protection)
- NIST CSF 2.0: PR.PS-01 (Platform Security)
- NIST SP 800-53 Rev. 5: PE-2 (Physical Access Authorizations)
- NIST SP 800-53 Rev. 5: PE-3 (Physical Access Control)
- NIST SP 800-53 Rev. 5: PE-6 (Monitoring Physical Access)
- NIST SP 800-53 Rev. 5: PE-6(1) (Intrusion Alarms and Surveillance Equipment)
- NIST SP 800-53 Rev. 5: PE-8 (Visitor Access Records)
- NIST SP 800-53 Rev. 5: PE-9 (Power Equipment and Cabling)
- NIST SP 800-53 Rev. 5: PE-10 (Emergency Shutoff)
- NIST SP 800-53 Rev. 5: PE-11 (Emergency Power)
- NIST SP 800-53 Rev. 5: PE-12 (Emergency Lighting)
- NIST SP 800-53 Rev. 5: PE-13 (Fire Protection)
- NIST SP 800-53 Rev. 5: PE-13(1) (Detection Systems - Automatic Activation and Notification)
- NIST SP 800-53 Rev. 5: PE-14 (Environmental Controls)
- NIST SP 800-53 Rev. 5: PE-15 (Water Damage Protection)
- COBIT 2019: DSS01 (Manage Operations)

6. Policy Statement

6.1 Physically Secure Locations & Perimeters

- The perimeter of any physically secure location containing critical IT infrastructure or processing CJI shall be prominently posted and structurally separated from non-secure locations by physical controls (e.g., locked doors, card readers).
- Information system devices shall be positioned to prevent unauthorized individuals from accessing or visually observing CJI or sensitive administrative sessions.

6.1.1 Physical Access Control Procedures

- Elko County shall maintain physical access audit logs for all physically secure IT locations. Audit logs shall record all access events and shall be retained in accordance with applicable Nevada retention schedules.
- Keys, key fobs, access cards, and combination codes shall be stored securely when not in use and shall not be shared among personnel.
- Combinations and keys shall be changed, and access cards shall be deactivated and reissued, whenever:
  - (a) a key is lost or a combination is believed to have been compromised; or
  - (b) an individual possessing a key, combination, or unescorted access credential is transferred to a role not requiring access or is separated from the County.

6.2 Physical Access Authorizations & Visitor Control

- Elko County shall develop, approve, and maintain an access list of authorized individuals permitted to access physically secure IT locations. This list shall be reviewed and updated at least annually.
- Physical access credential issuance, modification, and revocation for all secure IT facilities shall follow the personnel onboarding and offboarding procedures defined in **Policy 2.02**. Upon notification of personnel separation or role change, physical access credentials (including keycards, key fobs, and combination codes) shall be revoked on the same timelines established for logical access revocation.
- The County must maintain a visitor control log detailing the names, organizations, dates, entry/exit times, and forms of identification used to authenticate every visitor accessing a physically secure location.
- Visitors must be escorted by authorized personnel at all times within secure areas. When the escort involves vendor or contractor personnel performing maintenance on systems that process, store, or transmit Criminal Justice Information (CJI), the designated escort shall be fully cleared and technically qualified to supervise the specific maintenance activity being performed.
- Visitor access records shall be reviewed at least quarterly. Reviews shall assess whether access authorizations remain current and appropriate for organizational mission and business functions.
- Anomalies identified during visitor access record reviews — including unauthorized access patterns, missing records, or entries outside of authorized access periods — shall be reported to personnel with physical and environmental protection responsibilities and to personnel with information security responsibilities.
- **Retention Mandate**: The visitor control log must be retained for a minimum period of three (3) calendar years from the end of the calendar year to which the log pertains, in strict compliance with Nevada LRDA 20071279.

6.3 Monitoring Physical Access & Camera Surveillance

- Elko County shall monitor physical access to facilities where information systems reside to detect and respond to physical security incidents.
- Security cameras in server rooms and network closets shall be configured with motion detection. Upon detection of motion, the system shall automatically notify designated IT personnel via email during normal business hours. Motion events occurring outside of business hours shall generate a work order for IT staff follow-up on the next business day. Camera-based motion alerting satisfies the physical intrusion alarm requirement under CJIS PE-6(1).
- Physical access logs shall be reviewed at least quarterly and following any physical, environmental, or security-related incident involving CJI or systems used to process, store, or transmit CJI.

- The results of physical access log reviews and any physical security investigations shall be coordinated with the County's incident response capability in accordance with **Policy 4.01** (Incident Response Policy Overview).
- Retention Mandate: Security camera recordings strictly monitoring physical access shall be retained for a minimum of seven (7) days or for the period needed to review the recordings, whichever is longer, in strict compliance with Nevada LRDA 20071749.
- If camera footage captures an incident, breach, or legal event, the relevant segment of footage shall immediately be exported, reported in accordance with **Policy 4.02** (Identification and Reporting Procedures), reclassified as an "Incident Report" or "Investigation Record," and retained according to the applicable Nevada retention schedules governing active investigations.

6.4 Environmental Controls

- **Fire Protection**: Facilities containing critical IT infrastructure must employ automatic fire suppression and/or detection systems. These systems shall be maintained and inspected annually. Fire detection systems shall be configured to automatically activate upon detection of fire conditions and to simultaneously notify designated organizational incident response personnel and local emergency responders without requiring manual intervention.
- **Temperature and Humidity Controls**: Critical IT hardware facilities (e.g., primary server rooms) shall maintain automated temperature and humidity controls to prevent environmental degradation of systems.
- **Water Damage Protection**: Master shutoff valves shall be identified and accessible. IT equipment shall be positioned or elevated to minimize risk from water damage.

6.5 Power Equipment, Emergency Infrastructure, and Continuity

- **Power Equipment and Cabling**: Power equipment and power cabling serving critical IT infrastructure shall be protected from physical damage and destruction. Cabling paths shall be identified, documented, and physically secured within locked conduits or restricted-access routing pathways.
- **Emergency Shutoff**: Facilities housing critical IT infrastructure shall provide the capability to shut off power to all information systems in emergency situations. Emergency shutoff switches or devices shall be placed in locations readily accessible to authorized personnel. Emergency shutoff capability shall be protected from unauthorized or accidental activation.
- **Emergency Power**: Critical IT facilities shall be equipped with an uninterruptible power supply (UPS) to provide near-instantaneous protection from power interruptions and to facilitate orderly system shutdown or transition to an alternate power source upon loss of primary power. UPS units shall be maintained in accordance with **Policy 1.12** lifecycle standards.
- **Emergency Lighting**: Critical IT facilities shall employ and maintain automatic emergency lighting that activates upon power outage or disruption. Emergency lighting shall cover emergency exits and evacuation routes within the facility.

2.14 Mobile Device and Remote Access Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory security controls for mobile devices and remote access technologies connecting to Elko County Information Systems. This policy ensures the confidentiality, integrity, and availability of County data, including Criminal Justice Information (CJI), by defining strict configuration, authorization, and usage requirements for wireless networking, remote connectivity, and mobile computing assets.

2. Scope

This policy applies to all Elko County Information Operations personnel, employees, contractors, vendors, and agents who utilize mobile devices or remote access technologies to access County information assets. This scope includes:

- **Agency-Controlled Devices**: Devices owned, leased, and managed by Elko County.
- **Remote Access Connections**: Any logical connection originating from outside the County's internal trusted network.
- **Wireless Infrastructure**: All wireless access points (APs) and clients managed by the County.
- **Personally Owned Devices**: Personally owned devices are strictly prohibited from accessing CJI or internal County network infrastructure. Limited access to non-CJI cloud services (e.g., Office 365 web access) via personally owned devices is permitted only if it does not require full Mobile Device Management (MDM) enrollment, consistent with the Zero Support Model defined in **Policy 1.13**.

3. Roles and Responsibilities

- **IT Director**: Shall authorize all remote access methods and mobile device platforms prior to deployment. Shall approve the selection of MDM solutions, designate compelling operational needs for privileged remote access, and approve all Risk Acceptance Memos for deviations. Serves as the Local Agency Security Officer (LASO) for CJI exception processing.
- **Assistant IT Director**: Shall ensure validation testing for rogue wireless access points is performed quarterly. Shall review wireless access point logs, VPN connection logs, and remote desktop session logs at least monthly.
- **System and Network Administrators**: Shall configure and maintain the MDM and VPN infrastructure, apply critical security patches, route all remote access traffic through managed gateways, and change administrative passwords on wireless access points in accordance with established baselines.
- **All Users**: Shall physically protect mobile devices, immediately report lost or stolen devices to the Assistant IT Director, and initiate session locks before leaving devices unattended.

4. Compliance and Exceptions

Compliance with this policy is mandatory. Failure to comply shall result in the immediate revocation of remote access privileges, seizure of non-compliant County devices, and disciplinary action up to and including termination of employment or contract.

Exceptions to this policy must be documented using a formal Risk Acceptance Memo, including compensating controls, and approved in writing by the IT Director in accordance with **Policy 1.09**. Exceptions involving CJI shall not be granted if they violate FBI CJIS Security Policy requirements without written concurrence from the CJIS Systems Officer (CSO).

5. References

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.07: System and Communications Protection Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- CJIS Security Policy v6.0: Section AC-11 (Device Lock)
- CJIS Security Policy v6.0: Section AC-18 (Wireless Access)
- CJIS Security Policy v6.0: Section AC-18(1) (Authentication and Encryption)
- CJIS Security Policy v6.0: Section AC-19 (Access Control for Mobile Devices)
- CJIS Security Policy v6.0: Section AC-19(5) (Full Device or Container-Based Encryption)
- CJIS Security Policy v6.0: Section IA-2(1) (Multi-Factor Authentication to Privileged Accounts)
- CJIS Security Policy v6.0: Section IA-2(2) (Multi-Factor Authentication to Non-Privileged Accounts)
- CJIS Security Policy v6.0: Section IR-4(1) (Automated Incident Handling Processes)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section SC-8(1) (Cryptographic Protection)
- CJIS Security Policy v6.0: Section Appendix G.4 (Mobile Device Guidance - Cellular Service Abroad)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)
- NIST SP 800-53 Rev. 5: AC-11 (Device Lock)
- NIST SP 800-53 Rev. 5: AC-17 (Remote Access)
- NIST SP 800-53 Rev. 5: AC-17(4) (Privileged Commands Over Remote Access)
- NIST SP 800-53 Rev. 5: AC-18 (Wireless Access)
- NIST SP 800-53 Rev. 5: AC-19 (Access Control for Mobile Devices)
- NIST SP 800-53 Rev. 5: AC-20 (Use of External Systems)
- NIST SP 800-53 Rev. 5: IA-3 (Device Identification and Authentication)
- NIST SP 800-53 Rev. 5: SC-7 (Boundary Protection)
- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)
- COBIT 2019: DSS05.01 (Protect against malware)
- COBIT 2019: DSS05.03 (Manage endpoint security)

- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Remote Access Management

The Information Operations Department shall establish and document usage restrictions and configuration requirements for each type of remote access allowed.

- **Authorization**: The IT Director must explicitly authorize each remote access connection type prior to use.
- **Managed Access Points**: Network Administrators shall route all remote access traffic through authorized and managed network access control points (e.g., VPN Gateways).
- **Encryption**: System Administrators shall configure all remote access sessions to employ FIPS-validated cryptographic mechanisms (e.g., TLS 1.2+, IPsec) to protect confidentiality and integrity in transit, consistent with the cryptographic standards established in **Policy 2.07**.
- **Privileged Access**: Users shall not execute privileged commands via remote access unless the IT Director has documented a compelling operational need in accordance with AC-17(4). Such access shall require automated generation of assessable evidence (logging).
- **Session Termination**: Remote access sessions shall be configured to automatically terminate after twelve (12) hours of duration or fifteen (15) minutes of inactivity. Remote access sessions utilizing certificate-based authentication on devices located within a secure Criminal Justice Conveyance (e.g., patrol vehicles) are exempt from the fifteen (15)-minute inactivity timeout to ensure officer safety.

6.2 Wireless Networking Security

The Information Operations Department shall manage all wireless access to Elko County networks in strict accordance with CJIS and NIST standards.

- **Validation and Inventory**: Network Administrators shall perform validation testing quarterly to verify rogue APs do not exist and maintain a complete inventory of all APs. Network Administrators shall test AP range boundaries to determine the precise extent of wireless coverage and shall design AP coverage areas to be strictly limited to approved operational boundaries.
- **Physical and Logical Security**: APs shall be placed in secured areas to prevent unauthorized physical access and user manipulation. Network Administrators shall virtually insulate the wireless network from the wired operational infrastructure using boundary protection devices (e.g., VLANs and ACLs), limiting access between wireless and wired networks to operational needs only.
- **Required Protocol**: Wireless access to County internal networks shall use WPA2 or WPA3 Enterprise authentication and encryption. All encryption key sizes shall be at least 128-bits, and default shared keys shall be replaced by unique keys.
- **Prohibited Protocols**: Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA) original shall not be used.
- **Configuration Baselines**: Network Administrators shall change default SSIDs, disable ad hoc mode, disable all nonessential management protocols, and utilize FIPS-compliant protocols (e.g., SFTP, HTTPS, SNMP over TLS) for all management access. Non-FIPS compliant management access shall be disabled.
- **AP Reset Procedures**: The AP reset function shall be used only when necessary and shall be invoked only by authorized personnel. Following any reset, APs shall be restored to the latest approved security configuration baselines; factory default configurations shall not be utilized.

- **AP Logging**: AP logging shall be enabled on all access points. Access points incapable of logging shall not be deployed without a formal Risk Acceptance Memo approved by the IT Director. Logs shall be reviewed on a recurring basis at minimum monthly, consistent with **Policy 2.11**.
- **Mobile Hotspots**: If a County mobile device authorized to access CJI is used as a Wi-Fi hotspot, it must employ encryption, utilize a strong pre-shared key, enable port filtering, and allow connections only from agency-controlled devices. Because mobile hotspots are limited in providing infrastructure-grade device authentication, CJI shall not be transmitted or exposed on the hotspot network without appropriate application-layer encryption.

6.3 Mobile Device Management (MDM)

All County-owned mobile devices accessing CJI or County data must be managed via a centralized MDM solution.

- **Mandatory Controls**: System Administrators shall configure the MDM to enforce remote locking, remote wiping, detection of jailbroken or rooted devices with automatic access blocking, folder- and disk-level encryption, and automatic device wiping after a maximum of ten (10) failed access attempts.
- **Device Patching**: System Administrators shall apply critical security patches to mobile operating systems within fifteen (15) days of vendor release, consistent with **Policy 2.09.** Deferrals require a formal Risk Acceptance Memo approved by the IT Director.
- **Encryption**: Full-device encryption shall be employed on all mobile devices authorized to process, store, or transmit CJI.
- **Bluetooth**: Bluetooth capabilities on CJI-authorized mobile devices shall be disabled or restricted via MDM policy unless explicitly required for an approved operational purpose. Any authorized Bluetooth configuration shall restrict associations to known and agency-approved accessories only. Users shall not have the ability to create unapproved Bluetooth associations on CJI-capable devices.
- **Prohibited Transmission Methods**: SMS, MMS, and consumer VoIP or chat applications (e.g., FaceTime, standard SMS) shall not be used for the transmission of CJI. Any application-based communication used for CJI transmission must employ authentication and encryption mechanisms compliant with CJIS requirements, independent of the device PIN or password. VoIP applications are not granted the voice communication exemptions applicable to traditional cellular voice under CJIS.
- **Cryptographic Key Protections**: Any certificates or cryptographic keys stored on mobile devices shall include protections against extraction from the device. Certificates or keys that grant special access or unique device identification shall be configured for remote wipe on demand or self-deletion upon a defined number of unsuccessful access attempts.

6.4 Identification and Authentication

All mobile and remote access usage shall comply with the strict identification and authentication requirements defined in **Policy 2.05**.

- **Local Device Authentication:** When mobile devices are authorized for CJI access, local device authentication shall be used to unlock the device. The authenticator used shall meet the minimum requirements defined in **Policy 2.05**.
- **Advanced Authentication (AA)**: Multi-factor authentication shall be used for all remote access to CJI and all privileged remote access. If a specific mobile scenario cannot support AA, the IT Director (LASO) must approve compensating controls prior to implementation in accordance with CJIS Security Policy IA-2(1) and IA-2(2).
- **Session Lock**: Devices shall be configured to automatically initiate a pattern-hiding display lock after a maximum of fifteen (15) minutes of inactivity.

6.5 Mobile Device Incident Response

In addition to the incident response requirements in **Policy 4.01**, specific reporting procedures shall apply to mobile device operating scenarios. Users shall immediately report the loss, theft, or suspected compromise of any County mobile device to the Assistant IT Director. If a lost, stolen, or compromised device is authorized to access CJI, the incident shall be reported to the IT Director (LASO) immediately and no later than one (1) hour after discovery. Enhanced incident handling procedures shall address, at minimum, the following tiered scenarios:

- Device known to be locked, loss of physical control for less than fifteen (15) minutes.
- Device known to be locked, loss of physical control for fifteen (15) minutes or greater.
- Device lock state unknown, loss of physical control for less than fifteen (15) minutes.
- Device lock state unknown, loss of physical control for fifteen (15) minutes or greater.
- Device known to be unlocked, any loss of physical control exceeding five (5) minutes.
- Total loss of device.
- Device compromise or suspected compromise.
- Device loss or compromise outside the United States.

Upon notification of device loss, theft, or compromise, the System Administrator shall initiate remote lock and remote wipe procedures via the MDM platform without delay.

6.6 International Travel

Devices authorized to access CJI shall not be transported outside the United States unless explicitly authorized in writing by the IT Director. If authorized, the Assistant IT Director shall perform a pre-departure inspection to verify all controls are functioning properly, and a post-return inspection immediately upon the device's return to County custody. Any device returned from international travel that was connected to foreign cellular networks or foreign wireless infrastructure shall be subject to a security assessment prior to being returned to operational use, consistent with **Policy** 4.01.

2.15 System Development and Secure Software Lifecycle Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the mandatory System Development Life Cycle (SDLC) and secure software engineering requirements for Elko County. This policy ensures that information security and privacy controls are systematically integrated into the acquisition, development, implementation, and maintenance of all county information systems, thereby protecting Elko County data and Criminal Justice Information (CJI) from unauthorized access, modification, or destruction.

2. Scope

This policy applies to all Elko County employees, contractors, external service providers, and vendors involved in the specification, design, development, acquisition, testing, implementation, and modification of information systems, software, and system components that process, store, or transmit Elko County data.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the executive approval authority for major system acquisitions, development tasks requiring official county clearance, and formal risk acceptance of policy exceptions including intellectual property deviations and unsupported component exceptions.
- **Assistant IT Director**: Shall manage day-to-day SDLC compliance tasks. This includes defining security and privacy roles within SDLC phases, integrating risk management into daily operational activities, reviewing developer processes and tools, and validating that system developers execute secure development processes prior to deployment.
- **IT Department Personnel** / **System Developers**: Shall execute software development and system integration tasks utilizing agency-documented security and privacy engineering principles in strict alignment with this policy. External Service Providers shall perform required testing, remediate identified flaws within the timeframes defined in Section 6.4, and provide all documentation defined in Section 6.2 prior to system acceptance.

4. Compliance and Exceptions

- **Mandatory Adherence**: All personnel defined in Section 2 must strictly adhere to the controls specified within this policy.
- **Exception Handling**: All exceptions and deviations to this policy, including the retention of unsupported system components or deviations in software ownership, shall require a formal Risk Acceptance Memo signed by the IT Director and recorded in the central Risk Register in accordance with **Policy 1.09**.

5. References

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.09: Vulnerability and Patch Management Policy

- NRS 205 (Computer Crimes)
- NRS 239 (Public Records)
- NRS 332 (Purchasing: Local Governments)
- NRS 603A (Security of Personal Information)
- CJIS Security Policy v6.0: Section SA-3 (System Development Life Cycle)
- CJIS Security Policy v6.0: Section SA-4 (Acquisition Process)
- CJIS Security Policy v6.0: Section SA-4(1) (Functional Properties of Controls)
- CJIS Security Policy v6.0: Section SA-4(2) (Design and Implementation Information for Controls)
- CJIS Security Policy v6.0: Section SA-4(9) (Functions, Ports, Protocols, and Services In Use)
- CJIS Security Policy v6.0: Section SA-8 (Security and Privacy Engineering Principles)
- CJIS Security Policy v6.0: Section SA-8(33) (Minimization)
- CJIS Security Policy v6.0: Section SA-9 (External System Services)
- CJIS Security Policy v6.0: Section SA-9(2) (Identification of Functions, Ports, Protocols, and Services)
- CJIS Security Policy v6.0: Section SA-10 (Developer Configuration Management)
- CJIS Security Policy v6.0: Section SA-11 (Developer Testing and Evaluation)
- CJIS Security Policy v6.0: Section SA-15 (Development Process, Standards, and Tools)
- CJIS Security Policy v6.0: Section SA-15(1) (Criticality Analysis)
- CJIS Security Policy v6.0: Section SA-22 (Unsupported System Components)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)
- NIST SP 800-53 Rev. 5: SA-3 (System Development Life Cycle)
- NIST SP 800-53 Rev. 5: SA-3(1) (Manage Preproduction Environment)
- NIST SP 800-53 Rev. 5: SA-4 (Acquisition Process)
- NIST SP 800-53 Rev. 5: SA-8 (Security and Privacy Engineering Principles)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SA-10 (Developer Configuration Management)
- NIST SP 800-53 Rev. 5: SA-11 (Developer Testing and Evaluation)
- NIST SP 800-53 Rev. 5: SA-15 (Development Process, Standards, and Tools)
- NIST SP 800-53 Rev. 5: SA-22 (Unsupported System Components)
- COBIT 2019: BAI02 (Manage Requirements Definition)
- COBIT 2019: BAI03 (Manage Solutions Identification and Build)
- ITIL v4: Software Development and Management Practice

6. Policy Statement

6.1 System Development Life Cycle (SDLC) Baseline

Elko County shall manage information systems using a formally defined System Development Life Cycle (SDLC) that incorporates information security and privacy considerations at every phase, from initiation through disposal.

- The Assistant IT Director shall ensure that security and privacy roles and responsibilities are explicitly defined and assigned prior to the initiation of any SDLC project.
- The Assistant IT Director shall integrate the organizational information security and privacy risk management process into all SDLC activities prior to system authorization.
- Individuals executing SDLC tasks must possess the necessary skills and technical competencies corresponding to their assigned roles.
- All system preproduction environments, including development, test, and integration environments, shall be protected commensurate with risk throughout the system development life cycle, consistent with NIST SP 800-53 Rev. 5: SA-3(1).

6.2 Acquisition Process and Contracting (Hard Gate)

Prior to executing contracts or initiating development involving third-party systems or external service providers, the procurement workflow must successfully pass the Supply Chain Risk Management and IT Financial Management stage gates.

- All SDLC acquisitions shall satisfy the vendor risk assessments and technical approvals mandated by ECIO **Policy 1.13** and **Policy 1.10**
- The Assistant IT Director must ensure that all third-party contracts legally obligate External Service Providers to execute secure development processes in strict alignment with NIST SP 800-53 Rev. 5: SA-8.
- Contracts with external service providers shall explicitly identify the functions, ports, protocols, and services employed, consistent with CJIS Security Policy v6.0: Section SA-9(2).
- For all system, system component, or system service acquisitions, the following requirements shall be included explicitly or by reference in the acquisition contract:
  - (a) Security and privacy functional requirements;
  - (b) Strength of mechanism requirements;
  - (c) Security and privacy assurance requirements;
  - (d) Controls needed to satisfy the security and privacy requirements;
  - (e) Security and privacy documentation requirements;
  - (f) Requirements for protecting security and privacy documentation;
  - (g) Description of the system development environment and the environment in which the system is intended to operate;
  - (h) Allocation of responsibility or identification of parties responsible for information security, privacy, and supply chain risk management; and
  - (i) Acceptance criteria.

6.3 Security and Privacy Engineering Principles

IT Department personnel and system developers shall apply agency-documented systems security and privacy engineering principles in the specification, design, development, implementation, and modification of all systems and system components.

- System developers and IT Department personnel shall implement the privacy principle of minimization, using only the Personally Identifiable Information (PII) strictly necessary to perform system engineering and development tasks, consistent with CJIS Security Policy v6.0: Section SA-8(33).

6.4 Developer Configuration Management, Testing, and Standards

All software developed or acquired for Elko County systems shall be subject to controlled development practices that ensure the integrity, security, and quality of the resulting product.

- **Version Control and Configuration Integrity**: The IT Department shall require that all development artifacts, including source code, scripts, and configuration files, are maintained under version control. Changes to development tools and processes shall be documented and managed to facilitate supply chain risk assessment, consistent with CJIS Security Policy v6.0: Section SA-10.
- **Developer Testing and Evaluation**: The IT Department shall require the developer to develop and implement a plan for ongoing security and privacy control assessments. Prior to deployment into any production environment, all software shall undergo security-focused testing including at minimum: functional testing, integration testing, regression testing, and information security testing. Test results shall be documented and provided to IT Department personnel as verifiable evidence of execution prior to system acceptance, consistent with CJIS Security Policy v6.0: Section SA-11.
- **Development Process Standards**: IT Department personnel shall utilize approved development tools, standards, and methodologies. The Assistant IT Director shall review development processes, tools, tool options, and configurations at least annually (every 365 calendar days) to confirm they satisfy security and privacy requirements throughout the development life cycle, consistent with CJIS Security Policy v6.0: Section SA-15.

6.5 Flaw Remediation

The IT Department shall require all system developers and External Service Providers to implement a verifiable flaw remediation process. All flaws identified during development, testing, or post-deployment operation shall be corrected according to the following severity-based schedule, consistent with CJIS Security Policy v6.0: Section SA-11 and ECIO **Policy 2.09**.

- **Pre-production discovery**: Critical and High severity flaws identified during testing shall be fully remediated prior to production deployment. No system containing an unmitigated Critical or High severity flaw shall be accepted into production.
- **Post-deployment discovery**: All severity timelines shall conform to the schedule established in **ECIO Policy 2.09**:
  - **Critical severity** (CVSS score 9.0–10.0): remediated within 15 days;
  - **High severity** (CVSS score 7.0–8.9): remediated within 30 days;
  - **Medium severity** (CVSS score 4.0–6.9): remediated within 60 days;
  - **Low severity** (CVSS score 0.1–3.9): remediated within 90 days.

6.6 End of Life and Unsupported System Components

Elko County information systems and system components shall be proactively replaced or upgraded when the developer, vendor, or manufacturer ceases to provide analytical support, software updates, or security patches.

- IT Department personnel shall replace system components when support is no longer available, or shall establish in-house support or obtain contractual vendor support as an alternative.
- Retained unsupported components must be fully isolated from public and uncontrolled networks by placement in segmented, access-controlled network zones with documented compensating controls.
- Retained unsupported components must operate under a documented Risk Acceptance Memo satisfying all criteria defined in Section 6.8.

6.7 Intellectual Property and Source Code Ownership

To ensure the continuous security, maintainability, and auditability of Elko County systems:

- All software, source code, scripts, configurations, and related intellectual property engineered or developed by Elko County employees shall remain the exclusive and sole property of Elko County.
- All software and related intellectual property developed by External Service Providers, contractors, or vendors utilizing Elko County systems, funding, or data shall become the exclusive property of Elko County upon creation.
- **Pre-Commencement Exception Gate**: Any deviation from this ownership model — including commercial-off-the-shelf software licensing, shared-rights agreements, or vendor retention of underlying IP — must be explicitly documented in a legally binding contract and authorized via a Risk Acceptance Memo signed by the IT Director prior to the initiation of the project or procurement. Development or deployment shall not commence without this formalized clearance.

6.8 Unsupported Component Exception Criteria

To obtain a Risk Acceptance Memo for an unsupported system component, the Assistant IT Director must verify and document that all of the following conditions are satisfied:

- **Business Criticality**: The component supports a mission or business function for which no operationally equivalent replacement exists, as documented in a written business impact analysis approved by the IT Director.
- **Market Survey**: IT Department personnel must conduct and document a formal market survey within the preceding 90 calendar days confirming that no vendor-supported replacement product is commercially available that meets the functional requirements.
- **Network Isolation**: The component must be logically and physically isolated from all public and uncontrolled networks, residing in a dedicated, access-controlled network segment with no direct inbound or outbound internet connectivity.
- **Compensating Controls**: IT personnel must document and implement compensating controls — including at minimum application whitelisting, enhanced monitoring, and restricted physical and logical access — sufficient to reduce residual risk to a level accepted by the IT Director.
- **Review Frequency**: The IT Director must review and reauthorize the exception no less than every 365 calendar days. Exceptions failing to satisfy all criteria shall be immediately revoked, requiring component decommissioning within 90 calendar days.

3. Service Management and Operations

3.01 Service Catalog and SLA Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the governance framework for the Elko County Information Operations Department's IT Asset Catalog and service level commitments. This policy defines the lifecycle status classifications governing IT support posture, the standards by which work orders are triaged and prioritized, and the response and resolution commitments the Department makes to County personnel and departments. It ensures that service delivery expectations are clearly defined, consistently applied, and auditably enforced across all asset types and support tiers.

2. Scope

This policy applies to all hardware models, software titles, and services within the operational purview of the Information Operations Department, regardless of asset support tier as defined in **Policy 1.12**. It governs all work orders submitted to the Department by County personnel, departments, or internal IT staff, and all vendor contracts or service agreements for IT-Supported and Vendor-Managed assets. This policy applies to all Information Operations personnel involved in triage, service delivery, escalation, and vendor coordination.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the sole approving authority for the IT Asset Catalog and all lifecycle status classifications and reclassifications. Shall maintain the authoritative list of mission-critical systems eligible for after-hours on-call activation. Shall authorize extensions to Deprecated asset replacement deadlines in writing. Shall authorize continued remediation beyond the standard labor ceiling by written notation in the work order. Shall approve vendor SLA terms at contract execution.
- **Assistant IT Director**: Shall ensure the IT Asset Catalog is maintained current in Redmine. Shall conduct lifecycle status classification reviews and prepare reclassification proposals for IT Director approval. Shall ensure triage is performed within required timeframes and that service level commitments are met across all active work orders. Shall monitor vendor SLA performance in accordance with **Policy 3.02**. Shall maintain after-hours contact procedures and on-call rotation schedules in Redmine. Shall identify and document vendor SLA gaps in existing contracts and present them to the IT Director no later than ninety (90) days prior to each applicable renewal opportunity.
- **IT Department Personnel (All Tiers)**: Shall perform triage on assigned work orders within the required window, confirming or reclassifying severity based on verified operational impact. Shall document all reclassifications, remediation attempts, escalation rationale, and closure decisions in the work order. Shall adhere to response and resolution commitments as defined in this policy. Shall refer work orders for Unsupported assets to the IT Director for disposition without performing remediation.
- **County Personnel and Department Heads**: Shall submit service requests through the designated work order system. Shall provide sufficient information at the time of submission to enable triage. Shall respond to pending information requests from IT staff within five (5) consecutive business days to prevent work order closure.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel involved in service delivery, triage, escalation, or vendor coordination.

- **Assessment**: Compliance with service level commitments, triage timeliness, and catalog maintenance obligations shall be assessed through the service level reporting process defined in **Policy 3.02** and the annual policy review and maturity scoring process defined in**Policy5.07**.
- **Enforcement**: Failure to meet triage, response, or resolution commitments without documented escalation or rationale shall be treated as non-compliance and may result in corrective actions under **Policy 5.01**. Vendor non-compliance with contracted SLA terms shall be addressed through the vendor compliance framework established in **Policy 5.06**.
- **Exceptions**: Exceptions to the service level commitments defined in this policy shall be documented with justification and approved by the IT Director in accordance with **Policy 1.08**. Exceptions shall not be granted on an open-ended basis and shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy5.07: Annual Policy Review and Maturity Scoring
- NRS 332 (Purchasing: Local Governments)
- NIST CSF 2.0: GV.SC-06 (Cybersecurity Supply Chain Risk Management)
- NIST CSF 2.0: ID.AM-01 (Inventories of hardware managed by the organization)
- NIST CSF 2.0: ID.AM-02 (Inventories of software, services, and systems managed by the organization)
- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- COBIT 2019: APO09 (Manage Service Agreements)
- COBIT 2019: APO10 (Manage Vendors)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Service Catalogue Management Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 IT Asset Catalog

Information Operations shall maintain a current IT Asset Catalog in the designated system of record (Redmine). The catalog shall enumerate all hardware models, software titles, and services that fall within the operational purview of the Information Operations Department, regardless of asset support tier as defined

in **Policy 1.12.** The IT Asset Catalog is an internal operational reference document maintained for IT Department use and shall not be published to general County staff. The IT Director holds sole authority to establish and approve the catalog and its contents. The Assistant IT Director shall ensure the catalog is maintained current in Redmine and shall present the catalog for IT Director review and approval no less than annually and following any significant change to the County's technology environment, contract portfolio, or vendor relationships.

6.2 Asset Lifecycle Status Classifications

Every hardware model, software title, and service enumerated in the IT Asset Catalog shall carry one of the following three lifecycle status classifications. These classifications govern the IT Department's support commitment for each item and inform service level obligations as defined in Section 6.4 of this policy.

- **Supported** status designates hardware, software, or services that are fully endorsed and actively supported by the Information Operations Department. Assets carrying Supported status represent the standard authorized technology environment for Elko County. The IT Department shall fulfill its full service level commitments for Supported assets as defined in this policy.
- **Deprecated** status designates hardware, software, or services that remain operational but have been formally identified for replacement. At the time of Deprecated classification, the IT Director shall establish and document a mandatory replacement deadline in the IT Asset Catalog. Deprecated assets are no longer authorized for new deployments or expanded use. The IT Department shall provide best-effort support for Deprecated assets within the labor ceiling defined in **Policy 3.05** for the duration of the replacement window. Upon reaching the replacement deadline, the asset shall automatically transition to Unsupported status unless the IT Director has formally authorized an extension in writing, documented in the IT Asset Catalog with a new deadline and supporting rationale. No open-ended extensions shall be granted. The IT Director may, by written notation in the work order, authorize continued remediation beyond the standard labor ceiling. Such authorization constitutes a deliberate project-level commitment and supersedes the Deprecated asset replacement preference for the duration of the authorized effort.
- **Unsupported** status designates hardware, software, or services that the Information Operations Department does not support and will not remediate. Unsupported assets represent an active operational and security risk and shall be prioritized for immediate replacement or decommissioning under **Policy 1.12**. Work orders submitted for Unsupported assets shall be closed with a documented replacement referral. The IT Department's obligation for Unsupported assets is limited to documenting the referral and initiating the replacement process.

The IT Director shall approve all lifecycle status classifications and reclassifications. The Assistant IT Director shall ensure that classification reviews are conducted no less than annually and whenever a vendor announces end-of-life, a contract expires, a security risk materially changes, or a replacement technology is formally adopted. Reclassification proposals shall be prepared by the Assistant IT Director, documented with the proposed effective date and supporting rationale, and submitted to the IT Director for approval prior to implementation in the IT Asset Catalog.

6.3 Triage and Severity Classification Authority

All work orders submitted to the Information Operations Department shall undergo IT-side triage prior to the commencement of active work. User-submitted severity levels represent the requester's assessment and shall be treated as an input to triage, not as a binding operational classification. The assigned technician or queue reviewer shall confirm or reclassify the severity level based on verified operational impact assessment prior to committing to a service level response. Any reclassification shall be documented in the work order with a brief rationale. The operative severity, as confirmed or reclassified by IT staff, governs all service level commitments defined in this policy.

The Assistant IT Director shall ensure that triage is attempted within one (1) business hour of work order submission. Triage is complete when IT staff have assessed the ticket, confirmed or reclassified the severity,

and initiated or queued the appropriate response. Where a submitted work order lacks sufficient information to complete triage, IT staff shall document the attempt, specify the information required, and notify the requester that more information is required. Service level clocks shall be paused for the duration of pending information status and shall resume upon receipt of the required information from the requester. Work orders that remain in pending information status without requester response for five (5) consecutive business days shall be closed by the assigned technician or queue reviewer, with closure rationale documented in the work order.

6.4 Service Level Commitments

Service level commitments consist of two sequential obligations: a response commitment and a resolution or escalation commitment. All timeframes are measured in business hours or business days from the completion of triage unless otherwise specified. Business hours are defined as Monday through Friday, 8:00 AM to 5:00 PM, excluding Elko County observed holidays. The Assistant IT Director shall ensure that service level commitments are met and shall monitor adherence in accordance with **Policy 3.02**.

Response and resolution commitments by severity level are as follows:

- **Critical severity**:
  - Response within one (1) business hour of triage completion
  - Resolution or formal escalation within one (1) business day of triage completion.
- **Urgent severity**:
  - Response within two (2) business hours of triage completion
  - Resolution or formal escalation within three (3) business days of triage completion.
- **High severity**:
  - Response within four (4) business hours of triage completion
  - Resolution or formal escalation within five (5) business days of triage completion.
- **Normal severity**:
  - Response within one (1) business day of triage completion
  - Resolution or formal escalation within ten (10) business days of triage completion.
- **Low severity**:
  - Response within two (2) business days of triage completion
  - Resolution or formal escalation within twenty (20) business days of triage completion.
  - Where a Low severity ticket carries a specified due date at the time of submission, that due date governs resolution in lieu of the default twenty (20) business day window.

Resolution commitments apply in full to IT-Managed assets as defined in **Policy 1.12**. For IT-Supported assets, the resolution commitment represents IT's obligation to initiate vendor escalation within the defined window, not to guarantee vendor resolution within that timeframe. Vendor resolution timelines for IT-Supported assets are governed by the applicable contract or service agreement. For Vendor-Managed assets, IT's commitment is limited to referral — the Information Operations Department shall route the request to the appropriate vendor contact within the response window defined above, and resolution execution shall be handled entirely by the vendor.

6.5 After-Hours and Emergency Response

The Information Operations Department maintains an on-call capability for after-hours emergencies. Severity level alone does not constitute sufficient basis for after-hours on-call activation. A situation qualifies for

after-hours on-call response only when a mission-critical system supporting public safety operations, law enforcement functions, or a time-bound legal or financial obligation is completely non-functional and no reasonable operational workaround exists. Low and Normal severity tickets are explicitly excluded from after-hours on-call activation by definition.

The IT Director shall maintain and annually review the authoritative list of systems qualifying as mission-critical for purposes of after-hours on-call activation in the designated system of record. The Assistant IT Director shall maintain after-hours contact procedures and on-call rotation schedules in Redmine. These operational details are not enumerated in this policy.

6.6 Vendor SLA Requirements

Any contract or service agreement governing an IT-Supported or Vendor-Managed asset entered into or renewed following the effective date of this policy shall include defined vendor response and resolution commitments as a condition of the engagement. The Assistant IT Director shall ensure that vendor SLA terms are documented at the time of contract execution and recorded in the IT Asset Catalog entry for the applicable system, subject to IT Director approval. Vendor SLA performance shall be monitored by the Assistant IT Director in accordance with **Policy 3.02** and evaluated under the vendor compliance framework established in **Policy 5.06**. Where an existing contract does not include defined service level terms, the Assistant IT Director shall identify the gap, document it in the IT Asset Catalog, and present it to the IT Director no later than ninety (90) days prior to the next available renewal opportunity so that incorporation of vendor SLA terms may be pursued at renewal.

3.02 Service Level Management and Metrics Reporting

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the operational framework for monitoring, measuring, and reporting on the Information Operations Department's adherence to the service level commitments defined in **Policy 3.01** (Service Catalog and SLA Policy). This policy governs the in-flight collection of service performance data, the thresholds and protocols that trigger corrective action when commitments are at risk, and the reporting cadence through which performance data is surfaced to the IT Director and, ultimately, to the organizational performance management function defined in **Policy 5.04** (Performance Metrics and Operational KPIs).

This policy is concerned with operational execution: whether commitments are being met, when and how deviations are detected, and what happens next. It does not redefine SLA targets (**Policy 3.01**), establish the broader KPI taxonomy (**Policy 5.04**), or govern the audit and self-assessment functions that verify long-term compliance (**Policy 5.02**).

2. Scope

This policy applies to all Information Operations personnel involved in service delivery, triage, escalation, vendor coordination, or performance reporting. It governs:

- All active work orders subject to the service level commitments established in **Policy 3.01**.
- All IT-Managed and IT-Supported assets as defined in **Policy 1.12**, for which the Information Operations Department holds response and resolution obligations.
- Vendor-Managed assets for which IT holds a referral obligation, to the extent that vendor response performance is monitored under Section 6.5.
- All performance data collected for the purpose of service level management, internal reporting, and upward contribution to the KPI framework in **Policy 5.04**.

This policy does not govern the collection or retention of system audit logs (**Policy 2.11**), security event monitoring (**Policy 2.11**), or infrastructure availability monitoring beyond its intersection with service level commitments.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the approving authority for service level performance reports and any corrective action plans arising from sustained SLA non-compliance. Shall review monthly performance summary reports prepared by the Assistant IT Director. Shall authorize any formal deviation from reporting cadences or data collection standards established in this policy. Shall ensure that performance data generated under this policy is integrated with the quarterly KPI review process defined in **Policy 5.04**.
- **Assistant IT Director**: Shall serve as the primary operational owner of the service level management and reporting function. Shall ensure that performance data is collected continuously and accurately from the work order system and any supporting monitoring tools. Shall monitor SLA adherence across all open and closed work orders no less than weekly. Shall prepare and distribute the reports defined in Section 6.4. Shall identify deviations meeting the thresholds defined in Section 6.3, document them in the work order system, and initiate the prescribed escalation or corrective action response. Shall ensure that vendor SLA performance is tracked and reported in accordance with Section 6.5. Shall

prepare the quarterly performance data summary submitted to the IT Director for integration with **Policy 5.04** reporting.

- **IT Department Personnel (All Tiers)**: Shall document all triage decisions, reclassifications, remediation milestones, escalation actions, and closure decisions in the work order system in sufficient detail to support accurate SLA adherence measurement. Shall notify the Assistant IT Director promptly when a work order is at risk of missing a response or resolution commitment. Shall cooperate with data collection and reporting activities as directed.
- **County Department Heads**: Shall review service level performance summaries for services used by their departments when distributed by the Assistant IT Director. Shall communicate service delivery concerns to the Assistant IT Director through the work order system or direct written correspondence.

4. Compliance and Exceptions

Adherence to the data collection, monitoring, escalation, and reporting obligations defined in this policy is mandatory for all Information Operations personnel within scope.

- **Assessment**: Compliance with this policy shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in**Policy5.07**.
- **Enforcement**: Failure to collect required performance data, report deviations within the required windows, or produce reports on the cadences established in Section 6.4 shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action Policy
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA: Nevada Local Government Records Retention Schedule (Amended October 3, 2022)
- NIST CSF 2.0: ID.IM-04 (Incident response performance data are used to improve incident response)
- NIST CSF 2.0: PR.AT-03 (Information security performance is measured and evaluated)
- NIST SP 800-53 Rev. 5: PM-6 (Information Security Measures of Performance)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)

- ITIL v4: Measurement and Reporting Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Performance Data Collection

The Information Operations Department shall maintain continuous, accurate collection of service performance data as the operational foundation of this policy. Performance data collection shall be systematic, automated where technically supported by the designated work order system, and sufficient to support the SLA adherence measurements, deviation analyses, and reports defined in this policy.

- **Work Order System as System of Record**: The designated work order system (Redmine) is the authoritative source for all service level performance data. IT Department personnel shall ensure that all triage completions, response actions, escalation events, and closure decisions are recorded in the work order system with timestamps accurate to the minute. No performance measurement activity shall rely on data sources that are not traceable to the work order system or a formally designated supplementary monitoring tool approved by the IT Director.
- **Data Collection Intervals**: For work orders subject to Critical or Urgent severity commitments, the Assistant IT Director shall verify adherence status no less than every four (4) business hours from triage completion. For High severity work orders, adherence status shall be verified no less than daily. Normal and Low severity work orders shall be reviewed in aggregate no less than weekly. These intervals represent minimum monitoring frequency; continuous automated alerting, where available, shall supplement but not replace these review obligations.
- **Required Data Elements**: For each closed work order, the following elements shall be captured and retained to support SLA adherence measurement: (a) work order identifier and submission timestamp, (b) assigned severity level at triage completion and triage completion timestamp, (c) response action timestamp and responding technician, (d) resolution or escalation timestamp and disposition, (e) any reclassifications with documented rationale, (f) asset support classification (IT-Managed, IT-Supported, or Vendor-Managed) as defined in **Policy 1.12**, and (g) escalation chain and vendor contact timestamps where applicable.
- **Automated Monitoring Tools**: Where automated monitoring tools are deployed to support service delivery, the Assistant IT Director shall ensure that tool outputs are integrated with the work order system or formally reconciled against it at minimum weekly. Tool configurations and data collection parameters shall be reviewed no less than annually by the Assistant IT Director and approved by the IT Director.

6.2 SLA Adherence Monitoring

The Assistant IT Director shall maintain ongoing visibility into SLA adherence across all active work orders, using the performance data defined in Section 6.1 and the service level commitments established in **Policy 3.01**.

- **Adherence Tracking**: The Assistant IT Director shall maintain a current adherence view of all open work orders that are within or approaching their response or resolution windows. This view shall be updated continuously from the work order system and shall be accessible to IT Department personnel for self-monitoring.
- **At-Risk Identification**: A work order shall be classified as At-Risk when 75% or more of its applicable response or resolution window has elapsed without the required action being completed. At the time of At-Risk classification, the assigned technician shall be notified by the Assistant IT Director and the work order status shall be flagged in the system. The assigned technician shall acknowledge the At-Risk flag and provide a written status update within one (1) business hour of notification.

- **Breach Detection**: A work order shall be recorded as an SLA Breach when the applicable response or resolution commitment has not been met by the deadline established in **Policy 3.01**. All SLA Breaches shall be recorded in the work order system with a Breach designation, the breach timestamp, and the technician of record at time of breach. SLA Breaches are distinct from formal escalations; a work order may breach a commitment and remain under active remediation.
- **Trend Monitoring**: The Assistant IT Director shall review SLA adherence trends no less than monthly, examining breach rates by severity level, by technician, by asset support classification, and by service category. Trend data shall be incorporated into the monthly summary report defined in Section 6.4.

6.3 Deviation Thresholds and Corrective Action Protocol

Not all SLA deviations require the same response. This section establishes the thresholds at which a deviation escalates from a work order management issue to a documented operational deficiency requiring formal action, and defines the required response at each threshold.

- **Threshold 1 — Individual Breach (Operational Response)**: A single SLA Breach shall trigger an At-Risk review at next-business-hour by the Assistant IT Director. The Assistant IT Director shall document the cause in the work order record and determine whether the breach resulted from (a) resource or workload conditions, (b) a process or triage failure, (c) a vendor response gap, or (d) an approved exception. No formal corrective action plan is required for an isolated breach, but the cause documentation shall be retained and counted toward threshold calculations below.
- **Threshold 2 — Severity-Weighted Breach Rate (Formal Review)**: When the SLA breach rate for any individual severity level exceeds ten percent (10%) of all work orders at that severity level within any rolling thirty (30) calendar day period, the Assistant IT Director shall initiate a formal review. The formal review shall be documented in writing, completed within five (5) business days of threshold detection, and submitted to the IT Director. The review shall identify systemic causes, affected services or personnel, and recommended remediation. The IT Director shall approve or direct modifications to the recommended remediation within five (5) business days of receipt.
- **Threshold 3 — Sustained Non-Compliance (Corrective Action Plan)**: When a formal review under Threshold 2 identifies the same root cause for the second consecutive thirty-day period, or when the breach rate for any severity level exceeds twenty percent (20%) in any single thirty-day period, a formal Corrective Action Plan (CAP) shall be initiated under **Policy 5.03**. The CAP shall be assigned to the Assistant IT Director, approved by the IT Director, and tracked to closure. Open CAPs shall be reported in the monthly performance summary defined in Section 6.4.
- **Vendor-Specific Deviation**: When a vendor governing an IT-Supported asset fails to meet contracted SLA terms and the failure results in an IT breach of the referral or escalation commitment defined in **Policy 3.01**, the Assistant IT Director shall document the vendor failure separately from the IT breach record. Vendor performance data shall be maintained as defined in Section 6.5. Sustained vendor SLA failures shall be escalated to the vendor compliance framework under **Policy 5.06**.

6.4 Service Level Reporting

The Information Operations Department shall produce and distribute service level performance reports on the following cadences, with the defined content and distribution.

- **Weekly At-Risk and Open Ticket Summary**: The Assistant IT Director shall produce a brief internal summary each week identifying all open work orders classified as At-Risk, all open SLA Breaches in active remediation, and any Threshold 2 formal reviews in progress. Distribution is internal to IT Department personnel. This report is an operational tool and shall be retained as a transitory record until no longer administratively useful, in accordance with applicable retention schedules.
- **Monthly Performance Summary Report**: The Assistant IT Director shall produce a formal Monthly Performance Summary Report and submit it to the IT Director no later than the fifth (5th) business day of the following month. This report shall include, at minimum: (a) total work orders opened and

closed by severity level; (b) SLA compliance rate by severity level, expressed as a percentage of work orders meeting both response and resolution commitments; (c) breach count and breach rate by severity level; (d) open Corrective Action Plans and their current status; (e) vendor SLA performance summary as defined in Section 6.5; (f) Recurring Ticket analysis as defined in Section 6.6; and (g) any notable trends or anomalies requiring IT Director attention. The IT Director shall review and acknowledge each Monthly Performance Summary Report within five (5) business days of receipt.

- **Quarterly Contribution to KPI Framework**: No later than ten (10) business days following the close of each calendar quarter, the Assistant IT Director shall prepare and submit to the IT Director a Quarterly Service Level Performance Summary for integration with the departmental KPI review process defined in **Policy 5.04**. This summary shall aggregate the three preceding monthly reports and provide trend analysis across the quarter for all service level KPIs identified in **Policy 5.04** that are sourced from service level management data. The IT Director shall include this summary in the quarterly KPI review.
- **On-Request Reporting**: The IT Director may request performance reports outside the standard cadences for any purpose, including audit preparation, vendor negotiations, budget planning, or executive presentation. The Assistant IT Director shall produce requested reports within the timeframe specified by the IT Director, not to exceed five (5) business days for standard compilation requests.
- **Report Format and Retention**: All formal reports produced under this section shall be stored in the designated system of record (Redmine) and retained in accordance with the Nevada Local Government Records Retention Schedule (for a minimum of three (3) years) from the date of production. Report formats shall be reviewed annually by the Assistant IT Director for accuracy and utility, with proposed format changes submitted to the IT Director for approval.

6.5 Vendor SLA Performance Monitoring

For all IT-Supported and Vendor-Managed assets governed by a vendor contract that includes defined service level terms, as required by **Policy 3.01** Section 6.6, the Information Operations Department shall maintain active monitoring of vendor adherence to those terms.

- **Vendor Performance Tracking**: The Assistant IT Director shall maintain a vendor SLA performance record for each IT-Supported and Vendor-Managed asset with contractual service level terms. This record shall be maintained in the IT Asset Catalog entry for the applicable asset in Redmine and shall capture: (a) contracted response and resolution commitments; (b) each vendor escalation event, including the timestamp IT initiated contact, the timestamp vendor acknowledged, and the timestamp vendor resolved or reported status; and (c) a running compliance calculation for each vendor across the current contract period.
- **Vendor Breach Recording**: A vendor SLA breach shall be recorded when a vendor fails to meet a contracted response or resolution commitment. Vendor breaches are separate from IT SLA breaches but shall be included in the monthly performance summary required by Section 6.4. Vendor breach records shall be preserved for the duration of the applicable contract plus three (3) years and shall be made available to the IT Director and, where applicable, to the vendor compliance review process under **Policy 5.06**.
- **Contract Renewal Input**: No later than ninety (90) calendar days prior to any contract renewal, the Assistant IT Director shall prepare a vendor SLA performance summary for IT Director review. This summary shall inform vendor compliance evaluation under **Policy 5.06** and shall be retained as part of the contract renewal documentation.
- **Contracts Without Defined SLA Terms**: For existing contracts that do not include defined service level terms, as identified under **Policy 3.01** Section 6.6, the Assistant IT Director shall document vendor response and resolution performance by extracting and analyzing all available vendor communication timestamps, ticket histories, and resolution logs currently held within the work order system. This documentation shall be used to support SLA negotiation at renewal.

6.6 Recurring Ticket Analysis and Upward Reporting Integration

- **Recurring Ticket Identification**: Consistent with **Policy 5.04**, a work order shall be flagged as a Recurring Ticket when the same user experiences the same issue within any rolling ninety (90) calendar day window and a prior work order for that issue was closed as resolved. The Assistant IT Director shall review the work order system monthly to identify recurring ticket patterns and shall ensure that all Recurring Tickets are flagged in the system.
- **Root Cause Assignment**: Each Recurring Ticket flag shall trigger assignment of a root cause determination by the Assistant IT Director or delegated technician. Root cause determinations shall be documented in the work order record within five (5) business days of the Recurring Ticket flag and shall classify the cause as one of the following: (a) user training or documentation gap, (b) unresolved underlying technical issue, (c) process failure, or (d) environmental or infrastructure condition. Root cause classifications shall be reported in the Monthly Performance Summary.
- **Upward Reporting to Policy 5.04**: The monthly and quarterly reports produced under Section 6.4 constitute the primary data feed from this policy into the organizational performance management function governed by **Policy 5.04**. The following service level KPIs defined in **Policy 5.04** are sourced from this policy's data collection and reporting activities: SLA compliance rate; Recurring Ticket Ratio; Mean Time to Repair/Recovery (MTTR); and first contact resolution rate. The Assistant IT Director shall ensure these values are accurately derived from the work order system and accurately reported in the quarterly contribution required by Section 6.4. No separate data collection process for these KPIs shall be established outside this policy; **Policy 5.04** reporting shall draw from the authoritative values produced here.

3.03 End-User Communication Standards

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish mandatory standards for all communications conducted by Elko County Information Operations personnel with end users, internal stakeholders, vendors, and external partners. Clear, professional, and documented communication is foundational to service accountability, operational continuity, and public trust in County IT operations. This policy ensures that all interactions — regardless of channel or audience — are traceable, appropriately scoped, and consistent with the Department's governance obligations.

2. Scope

This policy applies to all Information Operations Department personnel, including the IT Director, Assistant IT Director, and all IT staff at every tier. It governs verbal, written, and electronic communications conducted in the performance of IT duties, including but not limited to: service request interactions with County end users and department heads; coordination with vendors and managed service providers; and communications with external partners acting on behalf of or in support of County IT operations. This policy does not govern security incident communications during active incident response; those communications are governed by **Policy 4.06**, with this policy providing foundational channel and documentation standards that apply during the pre-escalation and post-resolution phases.

3. Roles and Responsibilities

- **IT Director**: Shall serve as the final authority on communication standards and shall conduct or authorize spot audits of communication quality and traceability as part of quarterly reviews, postmortems, or compliance assessments. Shall approve all exceptions to this policy in accordance with **Policy 1.08**. Shall ensure vendor and external partner communication expectations are codified in applicable contracts and service agreements in coordination with **Policy 1.13**.
- **Assistant IT Director**: Shall ensure that all IT Department personnel are trained on and consistently applying the communication standards defined in this policy. Shall review communication quality during service level reporting activities under **Policy 3.02** and shall flag systemic communication deficiencies to the IT Director. Shall maintain documentation templates and work order notation standards in the designated system of record (Redmine).
- **All IT Personnel**: Shall follow the communication protocols defined in this policy for all service interactions, including documentation, clarification, escalation, and closure. Shall ensure that verbal and informal communications are summarized in the relevant work order within one (1) business day. Shall apply the writing standards defined in Section 6.2 in all written communications conducted on behalf of the Department.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Communication quality, channel compliance, and documentation traceability shall be assessed as part of quarterly service reviews, postmortem processes, and the annual policy review and maturity scoring process defined in **Policy 5.07**.

- **Enforcement**: Repeated failure to document communications, use required channels, or adhere to the writing and conduct standards defined in this policy shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions — such as operationally necessary verbal briefings that cannot be fully documented — must still be summarized within internal work order documentation using Private Notes strictly in accordance with the Private Note constraints defined in Section 6.1, and within one (1) business day. Where the sensitive nature of an exception precludes narrative documentation, a placeholder record shall be generated in the work order system referencing the authorized exception without disclosing the sensitive content. All exceptions must be approved in writing by the IT Director in accordance with **Policy 1.08** and shall not be granted on an open-ended basis.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- LRDA 20071280 (Correspondence: Transitory)
- LRDA 20071715 (Work Orders)
- LRDA 20141919 (Correspondence: Routine Business)
- CJIS Security Policy v6.0: Section SI-12 (Information Management and Retention)
- NIST SP 800-53 Rev. 5: AU-3 (Content of Audit Records)
- NIST SP 800-53 Rev. 5: AU-6 (Audit Record Review, Analysis, and Reporting)
- NIST SP 800-53 Rev. 5: IR-7 (Incident Response Assistance)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- COBIT 2019: APO09 (Manage Service Agreements)
- COBIT 2019: APO10 (Manage Vendors)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)

- ITIL v4: Service Desk Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Required Communication Channels

The designated work order system (Redmine) is the authoritative channel for all service requests, technical communications, and service lifecycle documentation. Work order records are subject to retention obligations under the Nevada Local Government Records Retention Schedule.

- **Channel Mandate**: Unless the work order system is inaccessible due to a documented system outage, all service requests and IT responses shall be initiated, tracked, and closed within the work order system. Channel exceptions require justification documented in the relevant work order.
- **Out-of-Band Summarization**: Verbal or informal communications — including hallway conversations, phone calls, and instant messages — shall be summarized and entered into the relevant work order by the IT staff member conducting or receiving the communication. This entry shall be completed within one (1) business day of the interaction, or prior to ticket closure, whichever occurs first.
- **Constraint on Private Notes**: Standard, user-visible notes shall be the default for all ticket documentation. Private Notes shall only be utilized for the following authorized purposes: documenting internal security vulnerabilities or unpatched exploit data; redacting or handling accidental spillage of PII, PHI, or CJI; documenting personnel-sensitive actions such as HR-directed account lockouts; and internal technical diagnostics that would not be meaningful for the end user. Private Notes remain subject to applicable retention obligations and public records law.
- **Vendor and External Partner Communications**: Communications with vendors or external partners shall likewise be summarized in the relevant work order or project record. Where such communications occur outside the work order system (e.g., via vendor portal, email, or phone), IT staff shall document the substance of those communications in Redmine within one (1) business day.

6.2 Written Communication as Default

Written communication is the departmental standard. It reduces ambiguity, supports auditability, and ensures continuity of service knowledge across staff. Requests from County personnel shall be directed to the work order system rather than resolved through informal verbal channels.

6.3 English Prime (E-Prime) Guidance

IT personnel may apply English Prime (E-Prime) principles in written communications — specifically, avoiding forms of the verb "to be" when greater precision or flexibility would benefit the communication. This practice reduces false certainty in service communications and naturally invites end-user confirmation.

For example: "This appears to be resolved" or "This should be working now — please verify" invites the user to confirm, whereas "This is fixed" places the user in a position of either agreement or conflict. The goal is not to introduce ambiguity, but to invite collaborative confirmation and reduce premature closure of unresolved issues. E-Prime is guidance, not a rigid rule; personnel may apply it where it improves communication clarity.

6.4 Disambiguation and Clarity

IT personnel shall communicate in plain language accessible to non-technical County staff.

- Unexplained acronyms and technical jargon shall not be used in end-user communications without definition.

- When multiple questions are required, they shall be numbered individually. Example: "1. When did the issue begin? 2. What error message appears? 3. Can you reproduce the issue consistently?" This format reduces missed answers and vague responses.
- Compound or binary questions that allow for ambiguous single-word answers shall be avoided. Example: "Can I come before or after lunch?" invites the response "Yes." The clearer form is "Can I come before lunch? If not, what time after lunch works for you?" The goal is not to talk down to users, but to provide prompts precise enough that their responses are actionable.

6.5 Vendor and External Partner Communications

When communicating with vendors or external partners on behalf of the Department, IT personnel shall maintain the same documentation and clarity standards as for end-user communications. Commitments made to vendors — including agreed timelines, approved scopes, or escalation acknowledgments — shall be confirmed in writing and documented in the relevant work order or contract record. IT personnel shall not communicate acceptance of deliverables, changes to contracted scope, or authorization of additional costs without IT Director approval in accordance with **Policies 1.08** and **1.13.**

6.6 Accountability in Language

IT personnel shall use precise language of personal and departmental accountability in service communications.

- Use "I" when taking personal responsibility for a specific action or commitment. Example: "I will follow up with you by 3:00 PM today."
- Use "We" when speaking on behalf of the Department as a whole. Example: "We received your request and are currently reviewing it."
- Do not imply action, approval, or authority beyond the scope of your assigned role. Commitments that exceed role authority shall be escalated to the designated authority as defined in **Policy 1.08** and the Service Catalog before being communicated to the user or vendor.

6.7 Information Spillage Prevention

ECIO personnel shall not instruct or permit end users to transmit passwords, Criminal Justice Information (CJI), or unprotected Personally Identifiable Information (PII) through standard work order notes or unencrypted email. If a user transmits such data into a work order, the receiving IT staff member shall immediately move the data to a Private Note, sanitize the user-facing record, and initiate the data spillage protocols required by **Policy 4.02** (Identification and Reporting Procedures), consistent with CJIS Security Policy v6.0: SI-12 (Information Management and Retention).

6.8 Communication During Service Incidents

During active service incidents or outages, the communication standards defined in this policy remain in effect for documentation and channel requirements. Specific protocols governing the frequency, content, and escalation of communications during active incident response — including user notification timelines and external reporting obligations — are defined in **Policy 4.06**. IT personnel shall not communicate incident scope, affected systems, or estimated recovery timelines to external parties, media, or non-IT County staff without IT Director authorization.

3.04 Service Delivery Feedback and Grievance Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to define how the Elko County Information Operations Department receives, routes, and responds to service-related feedback and grievances. It establishes the authoritative definition of service quality under the Department's compliance-enforcement mandate, specifies the legitimate channels through which feedback is accepted, defines formal grievance pathways for end users and County departments, and protects IT personnel from lateral political pressure by decoupling staff performance evaluation from end-user satisfaction with compliance outcomes. This policy does not govern employment or personnel matters, which are subject to County HR policies and applicable collective bargaining agreements.

2. Scope

This policy applies to all Information Operations Department personnel. It governs service-related feedback, grievances, and complaints concerning service delivery, technical decisions, and compliance-enforcement activities conducted by IT Department personnel in the performance of their duties.

This policy does not govern personnel or employment complaints — including allegations of misconduct, harassment, discrimination, or ethics violations — which are subject to County HR processes regardless of whether the subject of the complaint is an IT staff member. The boundary between service grievances and personnel complaints is addressed in Section 6.5.

This policy does not alter or supersede the professional conduct standards established in **Policy 1.02** (Code of Ethics and Professional Conduct) or **Policy 1.03** (Standard Operating Ethos), which define the mandatory conduct floor for all IT personnel and remain in full effect during all service interactions.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the primary authority for receiving, evaluating, and dispositioning service-related grievances brought by department heads or end users.
  - Shall solicit feedback from the County Manager at each regularly scheduled monthly meeting as a minimum cadence, and may bring matters to the County Manager outside that cadence when circumstances warrant.
  - Shall receive and evaluate upward feedback from IT staff through the chain of command.
  - Shall evaluate grievances against IT personnel by reference to the compliance record, the communication standards in **Policy 3.03**, and the conduct standards in **Policies 1.02** and **1.03**.
  - Shall document grievance dispositions in the Department's system of record.
  - Shall not be subject to lateral pressure from department heads on technical or compliance decisions; service grievances against the IT Director shall be directed to the County Manager in accordance with Section 6.3.
- **Assistant IT Director**:
  - Shall receive and route service-related feedback and complaints directed to the Department.

  - Shall ensure that IT personnel are aware of and consistently apply the grievance pathways defined in this policy.
  - Shall surface staff-sourced operational feedback to the IT Director through the established chain of command.
- **All IT Personnel**:
  - Shall document service-related feedback received through informal channels in the relevant work order within one (1) business day in accordance with **Policy 3.03**.
  - Shall escalate complaints or expressions of dissatisfaction that exceed their authority to the Assistant IT Director or IT Director without delay.
  - Shall not commit to operational or compliance-related changes in response to end-user or departmental pressure without authorization from the appropriate authority as defined in **Policy 1.08**.
- **County Manager**:
  - Serves as the escalation authority for department heads unsatisfied with the IT Director's disposition of a service grievance.
  - Serves as the direct authority for complaints about the IT Director.
  - The County Manager's role in this policy is defined by the governance structure established in **Policy 1.06** and the delegation framework in **Policy 1.08**.
- **Department Heads**:
  - Shall direct service-related grievances to the IT Director in writing.
  - Shall not use informal channels, lateral communication, or HR processes as substitutes for the grievance pathways defined in this policy.
  - Requests to relax or waive compliance standards are not service grievances and shall be directed through the risk management process defined in **Policy 1.09**, not through this policy.

4. Compliance and Exceptions

Adherence to the routing and documentation requirements of this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with grievance routing and documentation requirements shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to route, document, or disposition service-related feedback in accordance with this policy may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved by the IT Director in accordance with **Policy 1.08,** except where the exception concerns a complaint about the IT Director, in which case County Manager approval is required.

5. References

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.03: End-User Communication Standards
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 244 (Counties: Government)
- NRS 281A (Ethics in Government)
- NIST CSF 2.0: GV.OC-02 (Stakeholder Expectations)
- NIST CSF 2.0: GV.RR-01 (Leadership Accountability)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership)
- COBIT 2019: APO09 (Manage Service Agreements)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- ITIL v4: Relationship Management Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Definition of Service Quality

The Information Operations Department operates as a compliance-enforcement and technology governance function within Elko County. The Department's mandate is to establish, maintain, and enforce compliance with information and technology standards, and to bring non-compliant systems and practices into alignment with those standards. It does not operate as a hospitality or satisfaction-driven service organization, and end-user satisfaction with the outcome of a compliance decision does not constitute a measure of service quality under this mandate.

Service quality is defined by accuracy, auditability, and adherence to policy. A technician who brings a non-compliant system into compliance clearly, professionally, and in accordance with the communication standards defined in **Policy 3.03** has delivered service of the highest quality, regardless of whether the end user found the outcome convenient or welcome.

The IT Director is accountable to the County Manager for the performance and conduct of the Department. Department heads and end users are not the Department's managerial authority, and their dissatisfaction with a technically correct and professionally executed compliance action does not constitute grounds for corrective action against IT personnel.

6.2 Authorized Feedback Channels

The Department does not operate passive feedback collection mechanisms such as satisfaction surveys, open feedback forms, or suggestion systems. End-user satisfaction with compliance outcomes is not an operational input to technical standards or service delivery decisions, and passive feedback mechanisms

of this type do not produce actionable intelligence sufficient to justify the administrative overhead or the implied premise that survey sentiment governs operational direction.

The Department accepts feedback through the following authorized channels:

- **County Manager**: The IT Director shall solicit feedback from the County Manager at each regularly scheduled monthly meeting as a minimum cadence. This does not limit communication — the County Manager may raise concerns, complaints, commendations, or observations at any time through any channel, and the IT Director may likewise bring matters to the County Manager outside the scheduled meeting when circumstances warrant. The monthly meeting establishes the routine checkpoint; it does not constrain the relationship to that interval. The IT Director shall document the substance of any actionable feedback received through this channel in the Department's system of record (Redmine) and shall initiate a response or corrective action as warranted.
- **Work Order System and Written Correspondence**: End users and department heads may provide service-related feedback through the designated work order system (Redmine) or in direct written correspondence addressed to the IT Director. IT personnel shall document feedback received informally — including verbal complaints and hallway conversations — in the relevant work order in accordance with **Policy 3.03**. Feedback submitted through the work order system or written correspondence shall be acknowledged by the IT Director or Assistant IT Director within five (5) business days of receipt.
- **IT Staff (Upward Feedback)**: IT personnel shall surface operational feedback, service delivery concerns, and process improvement observations to their direct supervisor or the IT Director through the established chain of command. Staff observations have direct operational value as the Department's primary ground-level intelligence on service delivery effectiveness and shall be actively solicited and considered by Department leadership. This upward feedback channel is the Department's principal mechanism for identifying process improvements and service delivery gaps.

6.3 Grievance Pathways

Service-related grievances — defined as formal expressions of dissatisfaction with IT service delivery, technical decisions, or compliance-enforcement actions — shall be routed exclusively through the pathways defined in this section. These pathways are the only legitimate channels for service grievances. Informal or lateral communications that attempt to circumvent these pathways — including direct appeals to County leadership outside the defined chain, back-channel pressure on IT staff, or misrouting of service disputes into HR processes — shall be redirected to the appropriate channel by the receiving party.

- **Grievance against an IT technician or staff member**: The complainant shall submit the grievance in writing to the IT Director. The IT Director shall evaluate the grievance against the compliance record, the communication standards in **Policy 3.03**, and the conduct standards in **Policies 1.02** and **1.03**. Where the grievance concerns a technically correct and professionally executed compliance action, the IT Director shall document the finding, close the matter, and provide written notification of the disposition to the complainant. Where the grievance identifies a legitimate conduct or process deficiency, the IT Director shall initiate appropriate corrective action through the Department's internal performance management process. Grievance dispositions shall be documented in the Department's system of record.
- **Grievance against the IT Director**: The complainant shall direct the grievance to the County Manager. The County Manager serves as the IT Director's administrative authority and is the appropriate party to evaluate complaints about the IT Director's decisions or conduct. This pathway shall not be used as a mechanism to compel changes to compliance policy or technical standards; such requests remain subject to the risk management process in **Policy 1.09** regardless of the channel through which they are raised.
- **Department head escalation**: Where a department head is unsatisfied with the IT Director's written disposition of a service grievance, the department head may escalate the matter to the County Manager. This pathway represents the final internal escalation available for service-related disputes.

- **Compliance relaxation requests**: A request by any party to relax, waive, or deviate from a technical standard or compliance control is not a service grievance and shall not be processed through the pathways defined in this section. Such requests shall be directed to the IT Director and processed through the formal risk acceptance process defined in **Policy 1.09** This determination applies regardless of how the request is framed.

6.4 Staff Protection and Performance Evaluation

IT personnel shall not be subject to negative performance evaluations, formal corrective action, or adverse informal treatment on the basis of end-user or departmental dissatisfaction with a compliance outcome, provided the personnel member acted in accordance with the technical standards of this manual, the communication standards of **Policy 3.03**, and the conduct standards of **Policies 1.02** and **1.03**.

This protection is precise in its scope. It shields IT personnel from lateral political pressure to violate or circumvent compliance standards. It does not shield personnel from accountability for:

- Genuine conduct deficiencies, including rudeness, unprofessional behavior, or violations of **Policy 1.02** or **Policy 1.03**.
- Errors in technical execution or professional judgment.
- Failure to document actions in accordance with the requirements of **Policy 1.03** and **Policy 3.03**.
- Failure to escalate appropriately within the chain of command as defined in **Policy 1.03** and **Policy 1.08**.

Performance evaluations for IT personnel shall be conducted by the IT Director or Assistant IT Director in accordance with **Policy 1.07**. External pressure from department heads or end users shall not substitute for, or override, the Department's internal performance evaluation process.

6.5 Boundary with HR and Personnel Processes

This policy governs service-related feedback and grievances only. Complaints alleging employee misconduct, harassment, discrimination, ethics violations, or other employment-related matters are not service grievances and are not governed by this policy. Such complaints shall be directed to the County's Human Resources function and handled in accordance with County HR policies and applicable collective bargaining agreements, regardless of whether the subject of the complaint is an IT staff member.

The distinction between a service grievance and a personnel complaint shall be determined by the substance of the allegation, not its framing or channel of submission. A complaint that characterizes a technically correct and professionally executed compliance action as hostile, inappropriate, or otherwise objectionable — when submitted to HR rather than through the grievance pathways in Section 6.3 — remains a service grievance and shall be evaluated as such. When a complaint is redirected from the HR channel to the service grievance process, the IT Director shall notify HR of the routing decision and its rationale in writing.

Conversely, a genuine allegation of misconduct — including an alleged violation of the Code of Ethics under **Policy 1.02** — that arises in the context of a service interaction shall not be processed under this policy. The IT Director shall route such allegations to HR immediately upon identification. Where the allegation is directed against the IT Director, the County Manager shall be notified directly and HR shall be engaged by the County Manager.

3.05 Service Request Fulfillment Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to define the complete lifecycle of work order management within the Elko County Information Operations Department, from initial intake through authorized closure. This policy establishes the work order as the non-negotiable unit of accountability for all IT work, regardless of origin, and defines the mandatory requirements for intake routing, triage, authorization, execution, documentation, and closure across all categories of IT activity. It further codifies the labor ceiling framework for Deprecated assets referenced in **Policy 3.01**.

2. Scope

This policy applies to all Information Operations Department personnel and governs all work performed by the Department, whether reactive (user-submitted requests) or proactive (IT-initiated tasks). No work performed by IT Department personnel that constitutes an actionable task is exempt from work order requirements, regardless of the channel through which the work was identified or initiated.

This policy does not redefine the service level commitments, asset lifecycle classifications, or triage severity framework established in **Policy 3.01**, nor the performance monitoring and reporting obligations established in **Policy 3.02**, nor the communication standards established in **Policy 3.03**, nor the feedback and grievance framework established in **Policy 3.04**. All of those policies remain in full effect and are incorporated by reference where applicable. The work order operational standards defined in **Appendix ??** govern the technical anatomy of work orders — field definitions, status workflows, category taxonomy, and the terminal closure state — and are incorporated by reference throughout this policy. Where this policy establishes procedural mandates, **Appendix ??** provides the operational detail for executing them.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for IT-initiated work orders requiring Director-level authorization as defined in Section 6.3.
  - Shall conduct disposition reviews for Deprecated assets flagged under the labor ceiling framework defined in Section 6.5 and shall issue written disposition decisions within the timeframes specified therein.
  - Shall authorize continued remediation beyond the standard labor ceiling by written notation in the work order, in accordance with **Policy 3.01**, Section 6.2.
  - Shall review emergency exception work orders in aggregate no less than quarterly in accordance with Section 6.8.
- **Assistant IT Director**:
  - Shall ensure that work order intake, triage, and documentation standards are consistently applied by all IT personnel in accordance with this policy and **Appendix ??**.
  - Shall monitor the work order queue for compliance with triage timeliness obligations defined in **Policy 3.01**.
  - Shall ensure that Deprecated asset trigger calculations are maintained and that flagged assets are escalated to the IT Director within the timeframes defined in Section 6.5.

  - Shall ensure that emergency exception work orders are created and acknowledged within the timeframes defined in Section 6.8.
  - Shall conduct monthly audits of work order closure quality and report findings to the IT Director.
- **IT Department Personnel (All Tiers)**:
  - Shall create a work order for every actionable task, without exception, regardless of task origin or channel of identification.
  - Shall adhere to the intake, triage, documentation, and closure standards defined in this policy and **Appendix ??**.
  - Shall flag Deprecated assets meeting objective trigger thresholds, or submit written technical assessments through the Technician Judgment Pathway, as defined in Section 6.5.
  - Shall document emergency actions and create catch-up work orders within the timeframes defined in Section 6.8.
- **County Personnel and Department Heads**:
  - Shall utilize the designated work order system as the primary and initial method for submitting all service requests.
  - Shall route walk-in and telephone requests to the work order system in accordance with Section 6.2 when directed to do so by IT staff.
  - Shall respond to IT requests for additional information within five (5) consecutive business days to prevent work order closure under the provisions of Section 6.4.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with work order creation, documentation, triage, and closure obligations shall be assessed through the service level reporting process defined in **Policy 3.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to create required work orders, document actions within work orders, or meet closure standards without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.03: End-User Communication Standards
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework

- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix **??**: Work Order Structure and Standards
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- LRDA 20071715 (Work Orders)
- CJIS Security Policy v6.0: Section SI-12 (Information Management and Retention)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: ID.AM-01 (Hardware Inventories)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: MA-2 (Controlled Maintenance)
- NIST SP 800-53 Rev. 5: SA-22 (Unsupported System Components)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Service Request Management Practice

6. Policy Statement

6.1 Work Order as Universal Requirement

The work order is the non-negotiable unit of accountability for all work performed by the Information Operations Department. A work order shall be created for every actionable task, without exception. This obligation applies regardless of whether the work is reactive or proactive, regardless of the channel through which the work was identified or requested, and regardless of the estimated duration or complexity of the task.

No IT work shall be performed, and no commitment to perform IT work shall be made, without an associated work order. The work order is the authoritative record of why a task was undertaken, who authorized it, what was done, and how it was resolved. The absence of a work order for completed work constitutes a documentation failure regardless of the operational outcome.

The creation of a work order indicates that a request has been submitted to the IT Department for evaluation. It does not guarantee acceptance or execution. Work orders that fall outside the scope of IT responsibilities, that are submitted for Unsupported assets, or that cannot be resourced within current operational capacity shall be dispositioned in accordance with **Appendix ??** and this policy.

6.2 Intake and Channel Routing

The designated work order system (Redmine) is the authoritative intake channel for all service requests. Requests received through any other channel shall be routed to the work order system immediately, and in all cases no later than one (1) business hour following the receipt of the request or the initiation of the task, whichever occurs first.

- **Walk-in requests**: When a County employee presents a request in person, the receiving IT staff member shall direct the requester to submit the request through the work order system. Where the requester is unable to do so, the IT staff member shall create the work order on the requester's behalf, ensuring that the Requested By field accurately identifies the actual requester in accordance with **Appendix ??**.

- **Telephone requests**: Requests received by telephone shall be handled in the same manner as walk-in requests. The IT staff member shall create a work order concurrent with or immediately following the call and shall document the substance of the conversation in the work order notes in accordance with the out-of-band summarization requirements of **Policy 3.03**, Section 6.1.
- Email and informal digital communications: Requests received by email or other informal digital channels shall be routed to the work order system. The communication shall be summarized in the work order notes in accordance with **Policy 3.03**.

In all cases, the work order is the record of the request. Channel acknowledgment to the requester — including verbal or informal confirmation — does not substitute for work order creation. IT staff shall not begin work on a request prior to work order creation except as provided under the emergency exception in Section 6.8.

6.3 IT-Initiated Work Orders

The Information Operations Department regularly initiates work that is not triggered by a user request. This includes infrastructure maintenance, proactive upgrades, compliance remediations, internal projects, and any other IT-driven activity that constitutes actionable work. All IT-initiated work requires a work order, and all IT-initiated work orders shall be designated using the Internal Project checkbox as defined in **Appendix ??**. The Internal Project designation is mandatory for all IT-initiated work without exception.

Authorization requirements for IT-initiated work orders are as follows:

- **Routine IT-initiated tasks** — including scheduled maintenance, standard configuration updates, and minor proactive remediations — may be authorized by the assigned technician in accordance with their defined role authority under **Policy 1.08**. The basis for authorization shall be documented in the work order at the time of creation.
- **Non-routine or significant IT-initiated tasks** — including infrastructure changes, new deployments, system decommissions, or any task that materially alters the County's operational technology environment — shall be authorized by the Assistant IT Director or IT Director prior to work commencement. The authorizing official's name and the basis for authorization shall be documented in the work order before work begins.
- **Project-level IT-initiated work** — as determined by scope, resource requirements, or duration — shall additionally be subject to the project management requirements of **Policy 3.14**.

6.4 Triage and Authorization

All work orders shall undergo IT-side triage prior to the commencement of active work, in accordance with **Policy 3.01**, Section 6.3. Triage confirms or reclassifies the severity level, validates scope, identifies the applicable asset support classification, and initiates or queues the appropriate response. Work shall not begin on a work order until triage is complete.

Where a submitted work order lacks sufficient information to complete triage, the assigned technician or queue reviewer shall document the triage attempt, specify the information required, and notify the requester that more information is needed. The work order shall remain in Queued status for the duration of this pending information period. Service level clocks shall be paused and shall resume upon receipt of the required information from the requester. Work orders that remain without requester response for five (5) consecutive business days shall be closed by the assigned technician or queue reviewer, with closure rationale documented in the work order.

The Waiting for User status, as defined in **Appendix ??**, applies during the active execution phase of a work order when an IT-side action cannot proceed due to a user-side dependency — not during triage. IT staff shall apply Waiting for User status in accordance with **Appendix ??** when that condition is encountered after triage and work commencement.

Triage for Unsupported assets shall result in immediate closure with a documented replacement referral, in accordance with **Policy 3.01**, Section 6.2. No remediation shall be performed. Triage for Deprecated assets shall include confirmation of the asset's lifecycle status and shall initiate the labor ceiling monitoring obligations defined in Section 6.5.

6.5 Deprecated Asset Labor Ceiling

The Information Operations Department operates on the principle that unreliable tools are replaced rather than indefinitely maintained. For Deprecated assets — those already formally identified for replacement — this principle governs remediation decisions. The Department's obligation is to keep the user functional for the duration of the replacement window, not to restore a failing asset to full health. Where an asset demonstrates a pattern of failure that undermines that reliability, the appropriate response is to accelerate replacement, not to continue investing remediation labor.

This framework operates through one objective trigger and a technician judgment pathway. Either activates the IT Director disposition review process.

- **Objective Trigger — Incident Frequency**: A Deprecated asset shall be flagged for IT Director disposition review when it generates five (5) or more reactive work orders within the same category within any rolling ninety (90) calendar day window.
  - The same-category requirement is essential. Five or more reactive tickets across different categories may indicate a heavily utilized asset. Five or more within the same category indicates a specific, repeating failure pattern in that functional dimension.
  - Tickets in different categories do not aggregate toward this trigger, even if the total exceeds five.
  - For purposes of this trigger, reactive work orders are those submitted in response to asset failures or degradation, as distinct from IT-initiated maintenance or proactive work orders.
- **Technician Judgment Pathway**: The assigned technician may initiate a disposition review for any Deprecated asset at any time, independent of whether the objective trigger has been crossed.
  - The technician shall enter a written technical assessment in the work order record identifying the specific observations, failure patterns, or reliability concerns supporting the recommendation. Qualitative characterizations without supporting observations do not satisfy this requirement.
  - This pathway is the primary mechanism of this framework. Reliability failure does not always express itself in countable tickets — it expresses itself in whether the asset can be depended upon. That judgment, when documented, is sufficient basis for a disposition review.
  - The IT Director shall issue a written disposition decision within five (5) business days of the assessment being entered in the work order record.
- **IT Director Disposition Review**: When a Deprecated asset is flagged under either mechanism, the Assistant IT Director shall notify the IT Director within one (1) business day, with a summary of the trigger conditions or technician assessment and the relevant work order history.
  - The IT Director shall issue a written disposition decision within five (5) business days of notification, except where the Technician Judgment Pathway specifies its own review window above.
  - The disposition decision shall be one of the following: (a) authorize replacement acceleration; (b) authorize continued remediation beyond the standard labor ceiling in accordance with **Policy 3.01**, Section 6.2, with documented rationale; or (c) determine that the existing replacement timeline remains appropriate and direct that remediation continue within existing parameters.
  - All disposition decisions shall be documented in the relevant work order and in the IT Asset Catalog entry for the asset.
- **Proximity-to-Deadline Standard**: Deprecated assets with an established replacement deadline within thirty (30) calendar days of the date of triage shall be subject to a restricted remediation standard.

  - Remediation shall be limited to maintaining basic operational capability sufficient for the user to perform their assigned job function.
  - Full trigger framework analysis is not required for assets already imminently scheduled for replacement.
  - The assigned technician shall inform the user of the replacement timeline and advise of any available interim workarounds.
- **Exclusions from Disposition Decisions**: The following factors are explicitly excluded from consideration in any disposition decision made under this framework.
  - **Sunk cost**: Prior investment in consumables, supplies, parts, or remediation labor is not a factor. Disposition shall be evaluated on the basis of forward-looking operational analysis only.
  - **End-user workflow disruption and preference**: If the user can perform their assigned job function, the operational standard is met. User preferences regarding specific equipment shall not influence IT disposition decisions.

6.6 Execution and Documentation

Once a work order has been triaged, authorized, and assigned, the assigned technician shall execute the work in accordance with the scope defined in the work order and the service level commitments defined in **Policy 3.01**. All actions taken during the lifecycle of a work order shall be documented in the Notes section in accordance with **Appendix ??**, and shall be entered into the work order system within twenty-four (24) hours of each action taken, in accordance with **Policy 1.03**, Section 6.4.

Documentation shall be specific and sufficient to reconstruct the work performed by a subsequent reviewer who was not present. This standard is not aspirational — it is the minimum required to support resolution audits, continuity across technicians, SLA adherence measurement under **Policy 3.02** and the broader reporting obligations of the Department. Required documentation elements include, at minimum:

- Troubleshooting steps taken and their outcomes.
- Configuration changes made, with before and after states where applicable.
- User communications summarized in accordance with **Policy 3.03**.
- Any escalations, their rationale, and their outcomes.
- The basis for any reclassification of severity or scope.
- Where a user has transmitted Criminal Justice Information (CJI), Personally Identifiable Information (PII), or credentials into a work order, the assigned technician shall immediately execute the information spillage protocols defined in **Policy 3.03**, Section 6.7.

The use of Private Notes shall comply with the constraints defined in **Appendix ??** and **Policy 3.03**, Section 6.1. Private Notes are not a substitute for standard documentation and shall not be used to conceal routine work activity from the record. Subtasks, related issues, asset linkages, and checklist items shall be maintained in accordance with **Appendix ??** throughout the work order lifecycle.

6.7 Closure Standards

A work order shall not be closed until the work is complete, the resolution is documented, and the appropriate closure status has been applied in accordance with **Appendix ??**. The terminal closure state for confirmed, properly completed work is Resolution Confirmed, as defined in **Appendix ??**. Resolution Confirmed seals the work order record. Any future work on the same asset or issue requires a new work order.

- Prior to applying any closed status, the assigned technician shall ensure that:
- All actions taken are documented in the Notes section.

- The resolution or disposition is stated clearly and completely.
- Applicable assets are linked via the Related Issues field.
- The user has been notified of the closure or disposition in accordance with **Policy 3.03**.
- Where user confirmation is required, the Reached for Confirmation checkbox has been applied and the user's response documented.

Closure status selection is not discretionary — it is a data element used in performance reporting under **Policy 3.02** and shall accurately characterize the terminal outcome of the work. The available closure statuses and their definitions are established in **Appendix ??**. Work orders closed due to requester non-response shall have the five-day notification requirement documented prior to closure, consistent with **Policy 3.01**, Section 6.3 and Section 6.4 of this policy.

6.8 Emergency Exception

When an operational emergency requires immediate IT action before a work order can be created, the assigned technician or responding IT staff member may proceed with emergency action prior to work order creation. This exception is narrow. It applies only when the time required to create a work order before acting would materially extend the duration or severity of the impact. It does not represent a general relaxation of the work order requirement.

The emergency exception suspends the sequence; it does not eliminate the requirement. A work order shall be created as soon as operationally practicable and in all cases no later than one (1) business hour following the initiation of emergency action or the conclusion of the immediate emergency phase, whichever is earlier.

Work orders created under this exception shall document:

- The nature of the emergency and the specific conditions that justified bypassing standard work order creation.
- All actions taken prior to work order creation, with the most precise timestamps recoverable.
- A notation in the work order that the emergency exception was invoked.
- The acknowledgment of the Assistant IT Director, which shall occur within one (1) business day of work order creation.

The On-Call checkbox defined in **Appendix ??** shall be applied to all work orders created in connection with after-hours emergency response for statistical tracking purposes. The IT Director shall review emergency exception work orders in aggregate no less than quarterly. Patterns of emergency exception usage inconsistent with the narrow criteria defined above shall be addressed as a compliance matter under **Policy 5.01**.

3.06 Operational Incident Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to govern the detection, intake, triage, resolution, and closure of operational incidents within the Elko County Information Operations Department. An operational incident is any unplanned interruption to, or degradation of, an IT service caused by a non-malicious technical failure. The objective of this policy is speed of restoration — returning County staff to full operational capability as rapidly as possible.

This policy establishes the mandatory workflow for responding to operational incidents, defines the single command authority for incident management, codifies the conditions under which operational incidents transfer jurisdiction to Chapter 4 cybersecurity incident protocols, and defines the objective triggers by which closed incidents spawn formal Problem investigations under **Policy 3.07**.

2. Scope

This policy applies to all Information Operations Department personnel and governs all operational incidents involving County IT assets and services, regardless of the channel through which the incident was identified or reported.

Operational incidents within the scope of this policy include, but are not limited to: hardware failures and component degradations, application crashes and service outages, network connectivity failures, ISP disruptions, failed or rollback-required software patches, account or access failures not involving unauthorized access, and any other unplanned event that interrupts or degrades normal IT service delivery.

This policy does not govern malicious events, suspected or confirmed unauthorized access, ransomware or malicious code activity, data spillage involving Criminal Justice Information (CJI) or Personally Identifiable Information (PII), insider threats, or any other event involving an Indicator of Compromise (IoC) as defined in Chapter 4. Those events are governed exclusively by Chapter 4 (Incident Response). Section 6.2 of this policy defines the mandatory procedure for transferring jurisdiction to Chapter 4 when an IoC is discovered during an otherwise routine operational incident.

This policy does not redefine the service level commitments or severity classification framework established in **Policy 3.01**, the performance monitoring and reporting obligations established in **Policy 3.02**, the work order lifecycle requirements established in **Policy 3.05**, or the root cause analysis and Problem management obligations established in **Policy 3.07**. All of those policies remain in full effect and are incorporated by reference where applicable. This policy does not perform root cause analysis; it restores service and routes root cause responsibility to **Policy 3.07** at incident closure.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the Incident Commander by default for all operational incidents governed by this policy.
  - May designate any IT Department staff member as Incident Commander for a specific incident, in accordance with the delegation authority established in **Policy 1.08**. Designation shall be documented in the relevant work order at the time it is made.
  - Shall exercise final decision authority on incident prioritization, escalation, and resource allocation for any incident under active management.

  - Shall review Problem records spawned under the triggers defined in Section 6.7 and shall fulfill the authorization obligations defined in **Policy 3.07**.

- **Assistant IT Director**:
  - Shall ensure that work order intake, triage, documentation, and closure standards are consistently applied by all IT personnel in accordance with this policy, **Policy 3.05**, and **Appendix ??**.
  - Shall monitor the work order queue for compliance with SLA obligations defined in **Policy 3.01** and for recurring incident patterns that trigger Problem record requirements under Section 6.7.
  - Shall notify the IT Director when an incident is classified as Critical severity and shall support Incident Commander functions as directed.
  - Shall notify the relevant technician when a recurring incident threshold under Section 6.7 has been crossed without a corresponding Problem record having been opened.

- **IT Department Personnel (All Tiers)**:
  - Shall create a work order for every operational incident, without exception, in accordance with **Policy 3.05**.
  - Shall search the Knowledge Base maintained under **Policy 3.13** for documented workarounds before escalating any incident, as required by Section 6.4.
  - Shall document all troubleshooting steps, configuration changes, communications, and outcomes in the work order notes in accordance with **Policy 1.03**, Section 6.4.
  - Shall recognize and respond to Indicators of Compromise in accordance with the Hard Fork procedure defined in Section 6.2. Failure to initiate the Hard Fork upon discovery of an IoC constitutes a compliance failure under this policy.
  - Shall apply the Parent-Child linkage mechanic defined in Section 6.6 when receiving incidents that match an active Parent Problem investigation.
  - Shall evaluate and act upon Problem record spawn triggers at incident closure, as defined in Section 6.7.

- **Incident Commander (when designated)**:
  - Shall exercise full command authority over the operational response for the duration of the designated incident.
  - Shall coordinate technician assignments, escalation decisions, and external vendor engagement for the incident.
  - Shall direct the Hard Fork transfer to Chapter 4 jurisdiction upon confirmation of an IoC, and shall coordinate with Chapter 4 protocols as the incident record transitions.
  - Shall document all command-level decisions in the incident work order.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with incident intake, triage, workaround search, documentation, Hard Fork recognition, Parent-Child linkage, Problem spawn trigger, and closure obligations shall be assessed through the service level reporting process defined in **Policy 3.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to create required work orders, failure to initiate the Hard Fork procedure upon IoC discovery, failure to document actions within required timeframes, or failure to open mandated Problem records at incident closure, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.

- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix **??**: Work Order Structure and Standards
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- NIST CSF 2.0: RS.MA-01 (Incident Triage)
- NIST CSF 2.0: RS.MA-02 (Incident Escalation)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Incident Management Practice
- ITIL v4: Monitoring and Event Management Practice
- ITIL v4: Service Desk Practice

6. Policy Statement

6.1 Operational Boundary and Scope

The Information Operations Department responds to two fundamentally different categories of adverse IT events, governed by two different policy regimes with two different objectives.

Policy 3.06 governs operational incidents — unplanned technical failures whose cause is non-malicious and whose resolution requires restoring service. The governing objective is speed: identify the failure, locate a workaround or fix, and return County operations to normal. **Policy 3.06** does not care why something broke. Its job is to restore service as quickly as possible. Root cause analysis is the exclusive domain of **Policy 3.07** and does not begin until the **Policy 3.06** incident is closed.

Chapter 4 governs cybersecurity incidents — events involving malicious activity, unauthorized access, data compromise, or any Indicator of Compromise as defined in that chapter. The governing objective for Chapter 4 is containment and forensic integrity. A Chapter 4 response may deliberately extend an outage in order to stop the bleed, preserve evidence, or prevent further compromise. Speed of restoration is subordinate to that objective.

These two regimes are not interchangeable, and a technician shall not substitute one for the other. If an event involves or is suspected to involve an Indicator of Compromise, Chapter 4 shall control, and **Policy 3.06** shall automatically subordinate. The procedure for that transfer is defined in Section 6.2.

6.2 Hard Fork — Indicator of Compromise Discovery and Jurisdictional Transfer

If a technician working a **Policy 3.06** operational incident discovers, at any point during the response, any event or condition that constitutes an Indicator of Compromise (IoC) as defined in **Policy 4.02**, **Policy 3.06** immediately and automatically subordinates to Chapter 4. This transition is not discretionary. It shall not require supervisor approval. The technician's obligation upon IoC discovery is to act immediately.

Upon discovering an IoC, the technician shall:

1. Cease all troubleshooting immediately. No further diagnostic, remediation, or configuration activity shall be performed on the affected system or systems without express direction from the Incident Commander.
2. Preserve the system's current state. The technician shall not power off, reboot, disconnect, or otherwise alter the affected system's physical or logical state, except to prevent immediate harm to persons or to prevent active data loss that cannot be addressed by other means — and only then with immediate notification to the Incident Commander of the action taken.
3. Document the IoC observation in the work order notes immediately. The notation shall describe specifically what was observed, when, and on which system. This entry constitutes the initial forensic record.
4. Notify the Incident Commander immediately via the most direct communication channel available.
5. Await direction from the Incident Commander before taking any further action on the affected system or the incident work order.

The work order shall not be abandoned upon Hard Fork. It shall transfer jurisdiction. The **Policy 3.01** SLA obligations associated with the work order are formally suspended as of the date and time the IoC observation is documented in the work order notes, pending Chapter 4 disposition. The suspension and its effective date shall be noted in the work order. When Chapter 4 activity concludes and the operational recovery phase begins, **Policy 3.06** obligations shall resume if applicable, as directed by the Incident Commander.

The canonical list of Indicators of Compromise that trigger the Hard Fork is maintained in **Policy 4.02** and is incorporated into this policy by reference. Technicians shall be familiar with that list. Where a technician is uncertain whether an observed condition constitutes an IoC, the technician shall treat it as one and initiate the Hard Fork procedure. A false positive that triggers an unnecessary Chapter 4 review is a recoverable error. A missed IoC that allows a malicious event to proceed unchecked is not.

6.3 Incident Commander

The IT Director shall serve as the Incident Commander for all operational incidents governed by this policy by default. The IT Director may designate any IT Department staff member as Incident Commander for a specific incident. Designations shall be documented in the relevant work order at the time they are made and shall specify the scope and duration of the designation. Designation authority and decision rights for this role align with **Policy 1.08**.

The title Incident Commander is singular. No parallel title — Major Incident Manager or equivalent — exists within the ECIO framework. This role applies uniformly to both **Policy 3.06** operational incidents and Chapter 4 cybersecurity incidents. There is no disambiguation of title between the two contexts.

The Incident Commander shall exercise final authority over the incident response for the duration of their designation. This includes technician assignments, escalation decisions, communication with external vendors, the determination to invoke the Hard Fork under Section 6.2, and the decision to return jurisdiction from Chapter 4 to **Policy 3.06** operational recovery where applicable.

6.4 Incident Lifecycle

1. **Detection and Intake**
   - Every operational incident shall be documented in a work order in the designated system of record (Redmine).
   - All channel routing requirements of **Policy 3.05,** Section 6.2 apply: incidents identified through any channel — user report, helpdesk contact, direct technician observation, or automated monitoring alert from **Policy 3.12** — shall be recorded in a work order no later than one (1) business hour following detection or the initiation of any response activity, whichever occurs first.
   - No response activity shall proceed without an associated work order.
2. **Triage**
   - All incident work orders shall undergo IT-side triage prior to the commencement of active response work, in accordance with **Policy 3.01**, Section 6.3.
   - Triage shall confirm or reclassify the severity level, validate the asset support classification, and assign the incident to the appropriate technician or escalation path.
   - Triage shall be completed within the timeliness obligations defined in **Policy 3.01** for the assigned severity level.
3. **Workaround Search (Mandatory Before Escalation)**
   - Before escalating any incident to a higher support tier or requesting external vendor support, the assigned technician shall search the Knowledge Base maintained under **Policy 3.13** for documented workarounds applicable to the reported condition.
   - This obligation applies regardless of the technician's familiarity with the system.
   - The Knowledge Base represents the Department's accumulated resolution intelligence and shall be the first resource consulted, not a fallback after independent troubleshooting has been exhausted.
   - If an applicable documented workaround exists, the technician shall attempt it and document the attempt and outcome in the work order notes.
   - The technician may proceed to escalation when: (a) no applicable workaround exists in the Knowledge Base; (b) an applicable workaround was attempted and did not resolve the condition; or (c) an applicable workaround partially restored service but did not meet the required service level.
   - In all cases, the reason for escalation shall be documented in the work order before escalation occurs.
4. **Active Resolution**
   - The assigned technician or Incident Commander shall pursue the fastest path to service restoration.
   - Technicians shall document all troubleshooting steps, configuration changes, and outcomes in the work order notes in accordance with **Policy 1.03**, Section 6.4.
   - All actions shall be entered into the work order system within twenty-four (24) hours of each action taken.
   - Technicians shall remain alert throughout the resolution process for any condition that may constitute an Indicator of Compromise.
   - If any such condition is discovered, the technician shall immediately invoke the Hard Fork procedure defined in Section 6.2.

5. **Closure**
   - Upon service restoration, the assigned technician shall confirm resolution with the affected user or users.
   - If the user is unavailable to confirm resolution, the technician shall document the unresponsiveness in the work order notes before proceeding to closure.
   - The technician shall update the work order status to the appropriate terminal status in accordance with **Appendix ??** and shall document the resolution state in the work order notes.
   - The technician shall then evaluate whether the incident meets either Problem record spawn trigger defined in Section 6.7 and shall act accordingly before the work order is sealed.

6.5 SLA Obligations During Incidents

Full **Policy 3.01** service level commitments shall remain in effect during operational incidents. No special SLA suspension mechanism exists within this policy for routine operational incidents.

Incidents classified as Critical severity under **Policy 3.01** require:

- **Response**: Within one (1) business hour of triage completion.
- **Resolution or formal escalation**: Within one (1) business day of triage completion.

For extended outages that cannot be resolved within the Critical resolution window, the formal escalation pathway within the Critical SLA is the appropriate mechanism. The SLA clock shall be satisfied when formal escalation is documented in the work order — not when service is restored. No additional carve-out or SLA pause is required for extended outages that are actively managed and escalated.

The only condition under which **Policy 3.01** SLA obligations are suspended for a work order originated under this policy is when the Hard Fork fires under Section 6.2, transferring jurisdiction to Chapter 4. In that event, the SLA suspension and its effective date shall be documented in the work order at the time the suspension takes effect.

6.6 Parent-Child Linkage and Incident Suppression During Active Problem Investigations

When a formal Problem record has been opened under **Policy 3.07** for an active failure condition, that Problem record becomes the Parent record for that condition. Duplicate troubleshooting of the same underlying failure by independent technicians wastes remediation resources and risks contaminating the Problem investigation. The following mechanic governs incidents received while a relevant Parent Problem investigation is active.

If a technician receives a new incident work order whose symptoms match those of an active Parent Problem record, the technician shall:

1. Set the work order status to In Progress in accordance with **Appendix ??**.
2. Link the work order to the Parent Problem record via the Related Issues field in **Appendix ??**.
3. Document in the work order notes that the incident has been identified as related to an active Problem investigation, identifying the Parent record by its Redmine issue number and providing a brief notation of the matching symptoms.
4. Not attempt independent troubleshooting on the underlying failure condition while the Parent Problem investigation is active.

The Related Issues link to the Parent Problem record is the required audit trail for why the child work order remains In Progress without independent resolution activity. This link shall be established before or concurrent with the In Progress status assignment. An In Progress work order with no Related Issues link to a Parent Problem record is not compliant with this section.

At the time the Parent Problem record is resolved, the assigned technician shall revisit each linked child work order and close it with the appropriate terminal status in accordance with **Appendix ??**:

- **Duplicate** if the Parent Problem resolution fully addressed the child work order's reported condition and no additional end-system work was required on the child work order's asset or user environment.
- **Resolved** if end-system work was required on the child work order's asset or user environment following or concurrent with the Problem resolution — for example, reinstalling software, restoring a user configuration, re-imaging a device, or performing any other technician action specific to the child work order's asset or user.

The closure rationale shall be documented in each child work order's notes at the time of closure.

6.7 Problem Record Spawn Triggers

Two objective conditions automatically mandate that a formal Problem record be opened under **Policy 3.07**. The technician closing the qualifying incident work order shall evaluate whether either trigger has been met and shall open the Problem record if so. This obligation is not discretionary and is not satisfied by referencing the trigger threshold in the work order notes without opening the record.

- **Major Incident Trigger**

  Every incident classified as Critical severity under **Policy 3.01**, without exception, shall generate a formal Problem record upon closure. The Problem record shall be opened no later than the close of business on the calendar day the incident work order is resolved. This requirement is non-negotiable. Critical severity incidents represent the most significant service failures within the Department's operational environment. The causes of those failures shall be formally investigated regardless of whether a technician believes the cause to be self-evident.

- **Recurring Incident Trigger**

  Five (5) or more incidents against the same asset or service, within the same work order category, within any rolling thirty (30) calendar day window, shall automatically generate a formal Problem record. The technician closing the fifth qualifying incident shall open the Problem record at the time of that closure.

  For purposes of this trigger:

  - The same-category requirement is essential. Five or more incidents across different categories on the same asset may indicate a heavily utilized or aging asset; five or more within the same category indicates a specific, repeating failure pattern in that functional dimension. Tickets in different categories do not aggregate toward this trigger, even if the total exceeds five.
  - The thirty (30) calendar day window is a rolling calculation, not a fixed calendar period. Any thirty-day span ending on the date of the most recent incident is the applicable window.
  - The Assistant IT Director shall monitor queue data to identify recurring incident patterns and shall notify the relevant technician if the threshold has been crossed without a corresponding Problem record.

- **Relationship to Policy 3.05 Deprecated Asset Trigger**

  The Recurring Incident Trigger above shall not be conflated with the Deprecated Asset labor ceiling trigger defined in **Policy 3.05**, Section 6.5. These are related but distinct mechanisms. The **Policy 3.05** trigger uses a ninety (90) calendar day window to ask whether a Deprecated asset is failing with sufficient frequency to warrant accelerated replacement. The **Policy 3.07** trigger uses a thirty (30) calendar day window to ask whether something is actively wrong with an asset or service right now — a tighter window that reflects the need to investigate while evidence is fresh.

  Both triggers may fire simultaneously on the same asset. When they do, the Problem investigation asks why the asset is failing while the disposition review asks whether it is worth fixing. These are

complementary obligations, not conflicting ones, and both shall be executed.

6.8 Handoff to Policy 3.07 at Closure

Policy 3.06 jurisdiction ends at service restoration. A **Policy 3.06** technician's job is complete when the County is back to work. This policy does not perform root cause analysis, and technicians shall not delay incident closure pending root cause identification. Holding an incident work order open to investigate the cause is the wrong tool — that work belongs to **Policy 3.07**.

Where a Problem record spawn trigger has been met under Section 6.7, the responsible technician shall open the Problem record under **Policy 3.07** before or concurrently with closing the incident work order. The Problem record shall reference the originating incident work order via the Related Issues field in **Appendix ??**. From that point forward, root cause analysis, permanent remediation authorization, and Known Error management are the exclusive domain of **Policy 3.07**. The closed **Policy 3.06** work order is the evidentiary foundation for the investigation — it shall not be modified or extended once sealed.

3.07 Problem Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to govern the formal investigation of the root causes of IT service failures within the Elko County Information Operations Department. A Problem is the underlying cause of one or more incidents. Where **Policy 3.06** governs the restoration of service, this policy governs the identification and permanent elimination of the conditions that caused the service to fail. The objective of this policy is durable resolution — finding why something broke and ensuring it does not break the same way again.

This policy establishes the mandatory framework for opening, investigating, authorizing, and closing Problem records, defines the roles and decision rights governing investigation and remediation authorization, codifies the Known Error management process that feeds documented workarounds back to **Policy 3.06** technicians, and defines the formal closure declaration that triggers mass-resolution of linked child work orders under **Policy 3.06**, Section 6.6.

2. Scope

This policy applies to all Information Operations Department personnel and governs all formal Problem investigations involving County IT assets and services.

A Problem record is opened under this policy through one of two objective triggers defined in **Policy 3.06**, Section 6.7, or by IT Director discretion. Problem records are not opened by individual technician preference outside of those mechanisms. The investigation of a Problem is the Department's deliberate, structured response to evidence that a failure condition is systemic or significant — not a general-purpose research activity.

This policy does not govern the restoration of service during active incidents. That function belongs exclusively to **Policy 3.06**. Problem investigations shall not delay incident closure under **Policy 3.06**, and **Policy 3.06** incidents shall not be held open pending root cause identification. The Problem record is the continuation of accountability after service has been restored, not a parallel track to restoration.

This policy does not govern cybersecurity incident postmortems. Post-incident reviews following Chapter 4 events are governed by **Policy 4.07** (Postmortem Review and Lessons Learned). Where a Chapter 4 event also generates operational findings that warrant a Problem investigation under this policy, the IT Director shall determine whether a **Policy 3.07** Problem record is appropriate and shall authorize its opening.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the final authorizing authority for all permanent remediations and system changes proposed through the Problem management process, in accordance with the authorization framework defined in Section 6.4 (Separation of Investigative and Remediation Authority).
  - Shall authorize the opening of discretionary Problem records outside the objective spawn triggers defined in **Policy 3.06**, Section 6.7.
  - Shall review and sign off on Problem record closure in accordance with Section 6.6.
  - Shall determine investigation priority when an active Problem investigation conflicts with other operational demands, in accordance with Section 6.3.

  - Shall review Known Error declarations and confirm publication authorization to the Knowledge Base under **Policy 3.13** where required by Section 6.5.

- **Assistant IT Director**:
  - Shall ensure that Problem records are opened in accordance with the spawn triggers defined in **Policy 3.06**, Section 6.7 and shall notify the IT Director when a Problem record is opened.
  - Shall review proposed remediations prior to IT Director authorization and shall provide a documented recommendation to the IT Director as part of the authorization workflow defined in Section 6.4.
  - Shall serve as co-authorizing authority alongside the IT Director for permanent remediations, in accordance with Section 6.4.
  - Shall ensure that Known Error workarounds are published to the Knowledge Base under **Policy 3.13** within the timeframes defined in Section 6.5.
  - Shall verify Problem record closure quality and confirm that all required documentation elements are present before the IT Director's closure sign-off is sought.
  - Shall monitor open Problem records for compliance with the investigation activity obligations defined in Section 6.3 and shall escalate stalled investigations to the IT Director.

- **IT Department Personnel (All Tiers) — Investigator Role**:
  - Any IT Department staff member at any tier may be assigned as the Investigator on a Problem record. Assignment as Investigator shall not require a specific seniority level.
  - The assigned Investigator shall conduct all analysis activities defined in Section 6.3, including log analysis, configuration review, routing traces, and any other investigative action required to pursue root cause.
  - The Investigator shall document all investigative steps, findings, and intermediate conclusions in the Problem record in accordance with **Policy 1.03**, Section 6.4, within twenty-four (24) hours of each investigative action taken.
  - The Investigator shall not implement any permanent system change or deploy any Known Error workaround independently. All proposed remediations shall be submitted for authorization in accordance with Section 6.4 before implementation.
  - The Investigator shall notify the Assistant IT Director when root cause has been identified and a remediation proposal is ready for authorization review.
  - The Investigator shall notify the Assistant IT Director when a Known Error condition exists and a workaround is available for publication, in accordance with Section 6.5.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with Problem record opening obligations, investigation documentation standards, Known Error publication timelines, remediation authorization requirements, and closure sign-off obligations shall be assessed through the service level reporting process defined in **Policy 3.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to open a required Problem record following a spawn trigger, failure to document investigation activity within required timeframes, implementation of a permanent remediation without required authorization, or closure of a Problem record without required sign-off, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.

- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix **??**: Work Order Structure and Standards
- NIST CSF 2.0: ID.IM-03 (Improvements are identified from the execution of operational processes, procedures, and activities)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: DSS03 (Manage Problems)
- ITIL v4: Knowledge Management Practice
- ITIL v4: Problem Management Practice

6. Policy Statement

6.1 Problem Record Intake

A Problem record shall be opened through one of the following three mechanisms. No other mechanism authorizes the creation of a Problem record.

- **Objective Trigger — Major Incident**: Every incident classified as Critical severity under **Policy 3.01** shall generate a formal Problem record upon closure of the originating incident work order, in accordance with **Policy 3.06**, Section 6.7. The technician closing the qualifying incident work order shall open the Problem record no later than the close of business on the calendar day the incident work order is resolved. The Problem record shall be linked to the originating incident work order via the Related Issues field in **Appendix ??** at the time of creation.
- **Objective Trigger — Recurring Incident**: Five (5) or more incidents against the same asset or service, within the same work order category, within any rolling thirty (30) calendar day window, shall generate a formal Problem record. The technician closing the fifth qualifying incident shall open the Problem record at the time of that closure, in accordance with **Policy 3.06**, Section 6.7. The Problem record shall be linked to all qualifying incident work orders via the Related Issues field in **Appendix ??** at the time of creation.

- **IT Director Discretion**: The IT Director may authorize the opening of a Problem record for any failure condition that, in the IT Director's judgment, warrants formal root cause investigation outside the objective triggers above. The IT Director's authorization shall be documented in the Problem record at the time of creation.

Upon opening, all Problem records shall include, at minimum: the originating trigger or authorization, a description of the symptoms and affected asset or service, links to all associated incident work orders, and the name of the assigned Investigator. The Assistant IT Director shall be notified of all Problem record openings no later than the close of business on the day the record is created.

6.2 Relationship to Policy 3.05 Deprecated Asset Trigger

The Recurring Incident spawn trigger above shall not be conflated with the Deprecated Asset labor ceiling trigger defined in **Policy 3.05**, Section 6.5. These are related but distinct mechanisms operating on different windows and asking different questions.

The **Policy 3.05** trigger uses a ninety (90) calendar day window to ask whether a Deprecated asset is failing with sufficient frequency to warrant accelerated replacement. The **Policy 3.07** trigger uses a thirty (30) calendar day window to ask whether something is actively wrong with an asset or service right now.

Both triggers may fire simultaneously on the same asset. When they do, the Problem investigation and the disposition review shall proceed in parallel as complementary obligations. The Problem Investigator shall ask why the asset is failing. The IT Director disposition review shall ask whether the asset is worth fixing. The findings of the Problem investigation shall be made available to the IT Director as an input to the disposition decision, but the two processes shall not be merged or held pending the other's conclusion.

6.3 Investigation Conduct and Priority

- **Investigator Authority**: The assigned Investigator shall be authorized to pursue root cause through any analytical method appropriate to the failure condition. This includes, without limitation: log analysis, network trace and routing review, configuration comparison, vendor documentation review, testing in non-production environments, and consultation with subject matter experts within or outside the Department. The Investigator's analytical authority shall be unrestricted. The Investigator's remediation authority shall be strictly limited in accordance with Section 6.4.

  The Department's operating philosophy on Problem investigation is that curiosity and investigative drive shall not be gatekept by job title. Any staff member at any tier may be assigned as Investigator and shall be given the full investigative access necessary to pursue root cause. The quality of the investigation is measured by the rigor of the documentation and the validity of the findings, not by the seniority of the Investigator.

- **Investigation Documentation**: The Investigator shall document all investigative steps, analytical findings, and intermediate conclusions in the Problem record within twenty-four (24) hours of each action taken, in accordance with **Policy 1.03**, Section 6.4. Documentation shall be specific and sufficient to reconstruct the investigation by a subsequent reviewer who was not present. At minimum, the Problem record shall contain:
  - A description of each investigative action taken and the system or data source examined.
  - The findings or output of each investigative action.
  - Any hypotheses considered and the basis on which they were confirmed or eliminated.
  - The identified root cause, stated with sufficient specificity to inform a permanent remediation proposal.
  - The proposed remediation, including scope, affected systems, and estimated implementation effort.

- **Investigation Priority**: Active **Policy 3.06** incidents classified as Critical or Urgent severity against the same asset or service as an open Problem investigation shall automatically take priority over the Problem investigation for the duration of the active incident. The Investigator shall pause investigation activity on the affected asset and shall support incident resolution under **Policy 3.06** as directed by the Incident Commander. Investigation activity shall resume upon closure of the preempting incident.

Below the Critical and Urgent threshold, the IT Director shall determine priority between active Problem investigations and other operational demands on a case-by-case basis. The IT Director's priority determination shall be documented in the Problem record.

- **RCA Methodology**: This policy shall not prescribe a specific root cause analysis methodology. The Investigator shall select and apply the analytical approach best suited to the failure condition under investigation. The obligation is that root cause analysis is conducted rigorously, documented completely, and produces a finding that is specific enough to support a permanent remediation proposal. The methodology used shall be noted in the Problem record.

6.4 Separation of Investigative and Remediation Authority

The Problem management process is divided into two distinct phases with different authority structures: Execution and Authorization. This separation ensures that investigative capability is distributed across all staff tiers while permanent system changes remain subject to appropriate oversight.

- **Execution — The Investigation**: The assigned Investigator, at any staff tier, shall be fully authorized to conduct all investigative activities described in Section 6.3 without restriction or additional approval. The Investigator shall not require supervisory sign-off to analyze logs, review configurations, trace network paths, or pursue any other analytical activity in furtherance of root cause identification. Investigation is the Investigator's domain.
- **Authorization — The Fix**: The Investigator shall not implement any permanent system change, configuration modification, patch deployment, architectural adjustment, or other remediation action independently. Once the Investigator has identified root cause and developed a remediation proposal, the following authorization process applies before any remediation action is taken:
  1. The Investigator shall document the proposed remediation in full in the Problem record, including: the root cause finding, the proposed corrective action, the systems affected, the implementation plan, and any risks or dependencies associated with the remediation.
  2. The Investigator shall notify the Assistant IT Director that a remediation proposal is ready for review.
  3. The Assistant IT Director shall review the proposal and shall provide a documented recommendation to the IT Director within three (3) business days of notification.
  4. The IT Director shall review the proposal and the Assistant IT Director's recommendation and shall issue a written authorization or denial within five (5) business days of the Assistant IT Director's recommendation.
  5. Remediation shall not commence until the IT Director's written authorization is documented in the Problem record.

If the IT Director denies the proposed remediation, the denial shall be documented with rationale in the Problem record. The Investigator may develop an alternative remediation proposal, which shall follow the same authorization process.

The Problem record shall not be closed without IT Director sign-off, regardless of whether a remediation has been implemented. A Problem record that reaches closure without a viable permanent remediation shall be closed as a Known Error in accordance with Section 6.5.

6.5 Known Error Management and Knowledge Base Publication

A Known Error is a Problem for which root cause has been identified but for which a permanent remediation has not yet been implemented, whether because the remediation is pending authorization, pending resources, pending a vendor fix, or has been determined not to be cost-effective relative to an available workaround.

- **Known Error Declaration**: When the Investigator identifies root cause and determines that a permanent remediation will not be immediately implemented — for any reason — the Investigator shall notify the Assistant IT Director and shall declare a Known Error condition in the Problem record. The Known Error declaration shall include:
  - The identified root cause.
  - The reason a permanent remediation is not immediately forthcoming.
  - A documented workaround sufficient to restore or maintain service for affected users in the interim.
- **Knowledge Base Publication**: Upon Known Error declaration, the Assistant IT Director shall ensure that the documented workaround is published to the Knowledge Base maintained under Policy 3.13 within two (2) business days of the declaration. The published entry shall include the symptoms that identify the Known Error condition, the workaround procedure, and the Problem record number for traceability. Publication to the Knowledge Base shall not be deferred pending Problem closure.

  This publication obligation is the direct upstream feed for the mandatory workaround search required of **Policy 3.06** technicians under **Policy 3.06**, Section 6.4. A Known Error workaround that is not published to the Knowledge Base is not accessible to the technicians who need it, and the Knowledge Base's value as a resolution resource degrades accordingly. Timely publication is not optional.
- **Known Error Lifecycle**: A Known Error entry in the Knowledge Base shall remain active until the underlying Problem record is formally closed with a permanent remediation implemented and verified. Upon permanent remediation, the Assistant IT Director shall ensure that the corresponding Knowledge Base entry is updated to reflect the resolution and marked inactive within two (2) business days of Problem closure.

6.6 Problem Closure and the Formal Closure Declaration

- **Problem Record Resolution Conditions**: A Problem record shall not be considered resolved by informal agreement or by the cessation of investigation activity. Closure requires a formal declaration that satisfies all of the following conditions:
  1. **Root cause has been identified** and is documented in the Problem record with sufficient specificity to distinguish the underlying cause from its symptoms.
  2. **A permanent remediation has been implemented and verified**, or the Problem has been formally reclassified as a Known Error in accordance with Section 6.5 with a workaround published to the Knowledge Base.
  3. **All required authorization documentation** under Section 6.4 is present in the Problem record, including the IT Director's written authorization for any remediation implemented.
  4. **The Assistant IT Director has reviewed the record** and confirmed that all required documentation elements are complete.
  5. **The IT Director has reviewed and signed off** on the closure.
- **Formal Closure Declaration**: Upon satisfaction of all conditions above, the IT Director shall issue the Formal Closure Declaration by updating the Problem record status to the appropriate closed status in **Appendix ??** and documenting the closure rationale. The IT Director's status update constitutes the authoritative declaration that the Problem is resolved.

- **Trigger for Policy 3.06 Child Work Order Mass-Closure**: The Formal Closure Declaration is the event that triggers the mass-closure of child work orders linked to the Problem record under **Policy 3.06**, Section 6.6. Upon the IT Director's closure of the Problem record, the Assistant IT Director shall notify all technicians with linked child work orders that the Parent Problem record has been closed and that child work orders are to be dispositioned in accordance with **Policy 3.06**, Section 6.6 — as either Duplicate or Resolved depending on whether end-system work was required. This notification shall occur no later than the close of business on the day the Formal Closure Declaration is issued. Child work order dispositions shall be completed within two (2) business days of notification.

6.7 Relationship to Policy 3.06 — Jurisdictional Boundary

Policy 3.07 is the downstream continuation of **Policy 3.06**. These two policies are sequential, not concurrent. **Policy 3.06** shall govern service restoration. **Policy 3.07** shall govern root cause identification. The jurisdictional boundary between them shall be the closure of the originating incident work order.

Policy 3.07 shall not be used as a mechanism to defer incident closure. A technician shall not hold a **Policy 3.06** incident work order open on the grounds that root cause has not yet been identified. Service restoration and root cause identification are different jobs, owned by different policy instruments. When service is restored, the **Policy 3.06** work order closes and the **Policy 3.07** Problem record begins — not before.

The Problem record inherits the evidentiary record of the originating incident work order. The closed **Policy 3.06** work order is not modified after sealing. All subsequent findings, analysis, and remediation documentation belong to the Problem record.

3.08 Service Configuration Management (CMDB) Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the Configuration Management Database (CMDB) as the authoritative record of configuration identity for all deployed IT assets within the Elko County Information Operations Department. This policy defines what constitutes a Configuration Item (CI), governs the creation, maintenance, and verification of CI records in the designated system of record (Redmine), and establishes the enforcement mechanism by which CI record accuracy is embedded into day-to-day operational work.

A CI record is distinct from an asset record. A **Policy 1.12** asset record answers whether a physical asset exists, who owns it, where it is, and what its lifecycle status is. A **Policy 3.08** CI record answers what that asset's current configuration identity is, what its operational relationships are, and whether its record is complete and current. Both records co-exist in Redmine and cross-reference each other via the Related Issues field, but they serve different governance purposes and neither substitutes for the other. An asset enters inventory under **Policy 1.12**. It becomes a CI under this policy at the time of deployment into the operational environment.

The Department treats CI record accuracy as an operational obligation, not an administrative one. A deployed asset with an incomplete or inaccurate CI record is not fully serviceable. This policy establishes the mechanisms by which that standard is maintained continuously.

2. Scope

This policy applies to all Information Operations Department personnel and governs the creation, maintenance, verification, and retirement of CI records for all assets with Deployed status in Redmine.

CI types within scope include hardware assets, software and application instances, network infrastructure components, and virtual infrastructure components — any deployed asset whose configuration identity and operational relationships require tracking to support service delivery, incident response, problem investigation, and change management.

The following are outside the scope of this policy: consumables and passive peripherals excluded from asset tracking under **Policy 1.12**; assets not yet deployed (those are **Policy 1.12** asset records awaiting CI creation at deployment); active endpoint configuration state including OS version, patch level, and software inventory (those are owned by Comodo/XCitium as defined in Section 6.2); and security baseline definitions and hardening requirements (those are owned by **Policy 2.10**). Financial controls governing asset acquisition and payment are established in **Policy 1.10** and **Policy 1.12** and are not restated here.

This policy shall not govern change authorization. Change authorization is owned by **Policy 3.09**. This policy enforces the CI record update obligation that is the downstream consequence of every authorized change.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for any modification to the CI minimum field set defined in Section 6.3.
  - Shall ensure that the annual physical asset audit conducted under **Policy 1.12** incorporates the CI verification obligation defined in Section 6.5 of this policy.

  - Shall review and approve exceptions to CI record requirements in accordance with **Policy 1.08**.
- **Assistant IT Director**:
  - Shall ensure that CI record creation, maintenance, and verification obligations are consistently applied by all IT Department personnel in accordance with this policy.
  - Shall monitor Redmine for deployed assets whose CI records contain record deficits and shall ensure remediation obligations are tracked to completion.
  - Shall ensure that deployed assets whose Verified date exceeds the twelve (12) month threshold defined in Section 6.5 are flagged and scheduled for verification.
  - Shall coordinate with the IT Director to ensure that supply chain review status under **Policy 1.13** is confirmed before CI record creation is initiated for any new asset.
- **IT Department Personnel (All Tiers)**:
  - Shall create a CI record in Redmine for every asset at the time of deployment, following confirmation that supply chain review under **Policy 1.13** is complete.
  - Shall verify that all required CI fields defined in Section 6.3 are populated accurately as a condition of work order closure for any work order in which the asset is the primary subject of active work, in accordance with Section 6.4.
  - Shall remediate any CI record deficit discovered during a work order before closing that work order, in accordance with Section 6.4.
  - Shall update the CI record in Redmine to reflect the post-change configuration state before or concurrent with closing any change record under **Policy 3.09**, in accordance with Section 6.6.
  - Shall update CI records associated with emergency changes within twenty-four (24) hours of the emergency change, in accordance with Section 6.6.
- **All County Personnel**:
  - Shall not modify, relocate, or alter any deployed IT asset in a manner that would affect its CI record without initiating a work order through the Information Operations Department.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel within scope.

- **Assessment**: CI record accuracy, work order closure quality, annual verification currency, and change record coupling shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to create required CI records at deployment, failure to remediate CI record deficits before work order closure, failure to update CI records following authorized changes, or failure to meet the annual verification obligations defined in this policy shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.10: IT Financial Management and Procurement Policy

- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix **??**: Work Order Structure and Standards
- CJIS Security Policy v6.0: Section CM-1 (Configuration Management Policy and Procedures)
- CJIS Security Policy v6.0: Section CM-2 (Baseline Configuration)
- CJIS Security Policy v6.0: Section CM-8 (System Component Inventory)
- NIST CSF 2.0: ID.AM-01 (Inventories of hardware managed by the organization)
- NIST CSF 2.0: ID.AM-02 (Inventories of software, services, and systems managed by the organization)
- NIST SP 800-53 Rev. 5: CM-1 (Configuration Management Policy and Procedures)
- NIST SP 800-53 Rev. 5: CM-2 (Baseline Configuration)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: CM-8(1) (Updates During Installation and Removal)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: BAI10 (Manage Configuration)
- ITIL v4: Service Configuration Management Practice

6. Policy Statement

6.1 Configuration Item Definition and Lifecycle

A Configuration Item (CI) is any deployed IT asset whose configuration identity, operational relationships, and work order history require tracking to support service delivery, incident response, problem investigation, and change management. A CI record is created in Redmine at the time an asset is deployed into the operational environment. CI record creation shall not precede completion of supply chain review under **Policy 1.13**. The CI record shall co-exist with the **Policy 1.12** asset record for the same physical asset and shall cross-reference it via the Related Issues field in Redmine. The CI record shall be retired when the asset is decommissioned under **Policy 1.12**.

6.2 System of Record Architecture

The Information Operations Department operates a two-layer configuration management architecture. Both layers are authoritative within their respective domains.

- **Redmine** is the designated system of record for CI identity and inventory. Redmine holds configuration identity, physical location, lifecycle status, funding source, assigned user, network identifiers, work order linkage, and annual verification date. Redmine is the authoritative record of what a deployed asset is and where it belongs within the County's operational environment.
- **Comodo/XCitium** is the designated system of record for active endpoint configuration management. Comodo/XCitium holds OS version, patch level, software inventory, and endpoint compliance state. Comodo/XCitium is the authoritative source for what a deployed asset is running. Reporting and compliance obligations for endpoint configuration state shall be satisfied by reference to Comodo/XCitium output. Redmine CI records shall not attempt to replicate Comodo/XCitium data, and population of Redmine fields shall not be used as a substitute for Comodo/XCitium compliance reporting.

Active configuration compliance — including OS patch level and endpoint hardening state — is enforced through Comodo/XCitium. **Policy 2.10** defines the security baseline requirements that Comodo/XCitium enforces. This policy does not restate those requirements and does not own baseline enforcement.

6.3 CI Minimum Field Set

The following fields constitute a complete CI record in Redmine and shall all be populated for any deployed asset. The obligation this policy establishes is population discipline — ensuring that these fields are populated accurately and kept current — not the creation of new fields beyond those defined here.

- Subject (Device Name / Asset Tag)
- Status
- Location and Room Number
- Date Received
- Equipment Type
- Manufacturer and Model
- Serial Number
- Assigned User (where applicable)
- Device Name
- IP Address (Ethernet and/or Wireless, where applicable)
- MAC Address (Ethernet and/or Wireless, where applicable)
- Funding Source
- Cost
- Expected Expiration Date
- Verified (annual audit date)
- Related Issues (work order linkage)

Network identity fields (IP Address and MAC Address) shall be populated for all deployed networked assets. A deployed asset with Deployed status and empty network identity fields constitutes a record deficit requiring remediation. Modifications to the CI minimum field set shall be approved by the IT Director.

6.4 CI Record Accuracy — Governing Principle and Work Order Closure Condition

The Department treats CI record deficits as operationally equivalent to functional deficits. A deployed asset with an incomplete or inaccurate CI record is not fully serviceable. A work order in which that asset is the primary subject of active work shall not be closed until the record deficit is remediated.

The CI verification and remediation obligation applies when the asset is the primary subject of active work in the work order — the asset being repaired, configured, deployed, or serviced. This obligation shall be restricted to the primary CI; it shall not extend to assets mentioned incidentally in a work order where active work is being performed on a different asset. The annual physical audit defined in Section 6.5 is the systematic mechanism for identifying and remediating record deficits on assets not recently touched by a work order.

The following mechanics govern CI record accuracy enforcement:

- Any work order in which an asset is the primary subject shall include verification that all required CI fields defined in Section 6.3 are populated as a condition of closure.
- If a technician discovers a record deficit during a work order, the technician shall remediate the CI record before closing the work order.
- If remediation requires information the technician cannot obtain independently, the work order shall remain open until the information is obtained and the CI record is updated. Work orders shall not be closed with a known CI deficit documented and deferred.
- Discovery of a CI record deficit during any work order shall be treated as a defect requiring correction, not an observation to be deferred.

This principle does not create a standalone SLA or a separate monitoring obligation. It embeds CI record hygiene into the work order closure standard established by **Policy 3.05** and **Appendix ??**.

6.5 Annual CI Verification

CI records shall be actively verified against the deployed asset on an annual basis, tied to the physical asset audit conducted under **Policy 1.12**. The Verified field in Redmine shall be updated to reflect the date of verification at the time of each annual audit. A deployed asset whose Verified date is more than twelve (12) months prior to the current date shall be treated as pending verification for audit purposes.

The annual physical audit is the systematic sweep for CI record accuracy across the full deployed asset population. Work order closure enforcement under Section 6.4 is the continuous mechanism between audits. Both mechanisms are complementary and shall operate in parallel.

6.6 CI Record Updates and Change Management Coupling

The coupling between this policy and **Policy 3.09** (Change Management Policy) is bidirectional and mandatory.

Policy 3.08 → Policy 3.09 direction: No CI record in Redmine shall be modified to reflect a configuration change without a corresponding authorized change record under **Policy 3.09**. A CI update reflecting a configuration change without a corresponding change record constitutes a compliance failure under this policy.

Policy 3.09 → Policy 3.08 direction: No change record under **Policy 3.09** shall be closed without a corresponding CI record update confirming that the Redmine record reflects the post-change configuration state. A closed change record with an un-updated CI record constitutes a compliance failure under **Policy 3.09**.

Emergency changes: Emergency changes executed under **Policy 3.09** emergency protocols may precede the formal change record. In those cases, the CI record update obligation is deferred, not waived. The CI record shall be updated within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later, concurrent with the catch-up documentation obligation under **Policy 3.09**. Both timelines are governed by **Policy 3.09**.

6.7 Relationship to Downstream Policies

CI record accuracy directly supports the operational effectiveness of the following policies. The obligations defined in each relationship are stated here for clarity and shall not be construed as restatements of those policies' requirements.

- **Policy 3.06 (Operational Incident Management)**: Incident work orders reference CI records to identify affected assets and their configuration identity. An incomplete CI record at the time of an incident is an operational liability that degrades incident response speed and accuracy.
- **Policy 3.07 (Problem Management)**: Problem investigations use CI records and work order history to trace failure patterns and support root cause analysis. CI record accuracy and work order linkage directly support investigation quality. An incomplete or inaccurate CI record may impair the Investigator's ability to establish a reliable configuration baseline for comparison.
- **Policy 1.13 (Supply Chain Risk Management)**: CI record creation shall not be initiated for any new asset until supply chain review under **Policy 1.13** is complete. CI creation is a post-clearance event.

3.09 Change Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the governance framework for all changes to production systems, infrastructure, configurations, and software within the Elko County Information Operations Department. This policy defines three change categories — Standard, Significant, and Emergency — and prescribes the authorization, documentation, review, and closure requirements for each. It establishes the Configuration Control Authority (CCA) function, the Request for Change (RFC) record structure, rollback obligations, Post-Implementation Review (PIR) requirements, and the conditions under which County Manager consultation is mandatory before a change may proceed.

2. Scope

This policy applies to all Information Operations Department personnel and governs all changes to production systems, infrastructure, configurations, and software within the County technology environment administered by the Information Operations Department.

The following are outside the scope of this policy: security baseline definitions and hardening requirements, which are governed by **Policy 2.10**; CI record governance, which is governed by **Policy 3.08**; and incident response actions taken under Chapter 4. The CI record update obligation and catch-up RFC documentation obligation apply following any emergency change, regardless of whether the change originated from an incident response context, per **Policy 3.08** and Section 6.7 of this policy.

Release and deployment mechanics are governed by **Policy 3.10** and are not restated here.

Standard change authorization is captured within the work order per **Policy 3.05** mechanics. Significant and Emergency change records are standalone RFC records that exist alongside, but separately from, any associated work order.

3. Roles and Responsibilities

- **IT Director**:
  - Shall hold CCA authority for all Significant changes.
  - Shall delegate CCA authority for specific Significant changes to the Assistant IT Director only by explicit written authorization documented at the time of delegation.
  - Shall serve as the catch-up CCA reviewer for Emergency changes, completing review of the emergency change within twenty-four (24) hours, or by noon on the next business day, whichever is later.
  - May countermand any Emergency change designation; the countermand shall be documented in the change record at the time it is issued.
  - Shall authorize any alternative resolution path adopted in lieu of rollback for a failed Significant change; that authorization shall be documented in the change record at the time it is issued, with rationale.
  - Shall consult with the County Manager prior to implementation of any Significant change meeting the triggers defined in Section 6.6.
  - Shall review and approve exceptions to this policy in accordance with **Policy 1.08**.

- **Assistant IT Director**:
  - Shall hold CCA authority for all Standard changes, by reference to standing authority under **Policy 1.08**.
  - Shall hold CCA authority for Significant changes only where explicitly delegated in writing by the IT Director.
  - Shall ensure that all IT Department personnel comply with the change categorization, RFC documentation, rollback, PIR, and CI update obligations established in this policy.
  - Shall ensure that catch-up RFC documentation and CCA review for Emergency changes are completed within twenty-four (24) hours, or by noon on the next business day, whichever is later.
  - Shall ensure that no change record is closed without a corresponding CI record update per Section 6.7.
  - May designate a change as Emergency in accordance with Section 6.3.
- **IT Department Personnel**:
  - Shall classify all changes using the categories defined in Section 6.1 prior to initiating any change activity.
  - Shall document Standard change authorization within the associated work order, including the basis for Standard classification and a reference to the qualifying Knowledge Base procedure under **Policy 3.13**.
  - Shall submit a standalone RFC record in Redmine prior to implementation of any Significant change.
  - Shall structure Significant changes as discrete, incremental steps, each with a defined rollback point, as required by Section 6.4.
  - Shall complete PIR documentation within the change record for all Significant and Emergency changes within five (5) business days of implementation, per Section 6.5.
  - Shall update the CI record in Redmine to reflect the post-change configuration state before or concurrent with closing any change record, per Section 6.7 and **Policy 3.08**.
  - Shall create catch-up RFC documentation for Emergency changes. The catch-up RFC shall be completed within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- **Incident Commander**:
  - May designate a change as Emergency when operating under an active incident response action, in accordance with Section 6.3.
- **County Manager**:
  - Shall be consulted by the IT Director prior to implementation of Significant changes meeting the triggers defined in Section 6.6.
  - Shall be notified as soon as operationally practicable, but no later than four (4) hours following the initiation of implementation, when Emergency changes meet the consultation triggers defined in Section 6.6.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel. Deviations from mandatory requirements shall be managed through the formal exception process defined in **Policy 5.01**. Exceptions require IT Director approval in accordance with **Policy 1.08** and shall be documented prior to implementation.

The following each constitute compliance failures under this policy and shall be documented as exceptions subject to corrective action under **Policy 5.01**:

- Implementation of a Significant change without prior CCA authorization.
- Failure to complete catch-up RFC documentation or CCA review of an Emergency change within twenty-four (24) hours, or by noon on the next business day, whichever is later.
- Closure of a change record without a corresponding CI record update per Section 6.7.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Appendix **??**: Work Order Structure and Standards
- CJIS Security Policy v6.0: Section CM-3 (Configuration Change Control)
- CJIS Security Policy v6.0: Section CM-5 (Access Restrictions for Change)
- NIST CSF 2.0: ID.AM-04 (Inventories of services and systems are maintained)
- NIST CSF 2.0: PR.PS-01 (Configuration management practices are established and applied)
- NIST SP 800-53 Rev. 5: CM-3 (Configuration Change Control)
- NIST SP 800-53 Rev. 5: CM-4 (Impact Analyses)
- NIST SP 800-53 Rev. 5: CM-5 (Access Restrictions for Change)
- COBIT 2019: BAI06 (Manage IT Changes)
- COBIT 2019: BAI10 (Manage Configuration)
- ITIL v4: Change Enablement Practice

6. Policy Statement

6.1 Change Categories

All changes to production systems, infrastructure, configurations, and software within the Information Operations Department's technology environment shall be classified into one of three categories prior to initiation: Standard, Significant, or Emergency. The responsible IT staff member shall determine the classification before any change activity begins.

- **Standard Change**: A Standard change is a low-risk, pre-approved change type for which a documented procedure exists in the Knowledge Base under **Policy 3.13**. Standard changes shall not require a per-instance standalone RFC record; authorization shall be captured within the associated work order per Section 6.2. A change type qualifies as Standard only if a pre-approved procedure for that change type is documented in the Knowledge Base under **Policy 3.13**. If no qualifying Knowledge Base procedure exists for a given change type, the change shall be classified as Significant until such

a procedure is established and documented. Standard change examples include routine patching, password resets, and network printer additions.

- **Significant Change**: A Significant change is any change that materially alters the County's operational technology environment and does not qualify as Standard or Emergency. Significant changes align with the "non-routine or significant IT-initiated tasks" category established in **Policy 3.05**, Section 6.3. A standalone RFC record in Redmine shall be submitted and CCA authorization shall be obtained prior to implementation.
- **Emergency Change**: An Emergency change is an unplanned change that shall be implemented immediately to restore service or address a critical security threat, where the time required to complete standard RFC and CCA review before acting would materially extend the duration or severity of the impact. Emergency changes shall be designated in accordance with Section 6.2. Implementation may precede the formal RFC record; catch-up documentation obligations are defined in Section 6.3.

6.2 Change Authorization and CCA

CCA is a function, not a title or organizational body. It is fulfilled as follows.

For **Standard** changes, the Assistant IT Director holds CCA authority by reference to standing authority under **Policy 1.08**.

For **Significant** changes, the IT Director holds CCA authority. The Assistant IT Director holds CCA authority for Significant changes only where the IT Director has explicitly delegated that authority in writing; the delegation shall be documented at the time it is issued and shall be specific to the change or class of change to which it applies.

For **Emergency** changes, the IT Director, the Assistant IT Director, or the active Incident Commander may designate a change as Emergency. Emergency designation serves as a trigger for expedited change review and implementation; it does not itself constitute CCA authorization. The IT Director or Assistant IT Director shall hold provisional CCA authority to authorize immediate implementation of the designated Emergency change. Where the IT Director is the designating authority, that designation constitutes provisional CCA authorization. The IT Director may countermand any Emergency change designation; the countermand shall be documented in the change record at the time it is issued. Catch-up CCA review shall be completed by the IT Director within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later.

The County Manager consultation obligations defined in Section 6.6 shall be satisfied prior to CCA authorization for Significant changes. For Emergency changes meeting Section 6.6 triggers, County Manager notification shall occur as soon as operationally practicable, but no later than four (4) hours following the initiation of implementation.

6.3 RFC Structure and Requirements

- **Standard Changes**: No standalone RFC record shall be required. Authorization shall be documented within the associated work order and shall include: the basis for Standard classification, and a reference to the Knowledge Base procedure under **Policy 3.13** that qualifies this change type as Standard.
- **Significant Changes**: A standalone RFC record shall be created in Redmine prior to implementation. The RFC shall include at minimum: a description and scope of the change; a risk assessment; discrete, incremental implementation steps each with a defined rollback point; a rollback plan; anticipated impact and affected systems; the CCA authorization record; and County Manager consultation status where applicable under Section 6.6.
- **Emergency Changes**: Implementation may precede the RFC record. A standalone RFC record shall be created in Redmine within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later. This is the same clock as the CI record update obligation under **Policy 3.08** and the catch-up CCA review obligation under Section 6.2; all three obligations run concurrently on the same clock. The catch-up RFC shall document: all actions taken prior to

record creation with the most precise timestamps recoverable; the conditions that justified Emergency designation; the CCA review outcome; and CI update confirmation per **Policy 3.08** and Section 6.7.

6.4 Rollback and Failed Change Protocol

Significant changes shall be structured as discrete, incremental steps, each with a defined rollback point. A single monolithic implementation is not permitted. The incremental step structure required in the RFC is the mechanism that makes rollback to a stable state operationally feasible; it is a design requirement of the change, not a documentation preference.

A Significant change that fails mid-implementation shall be rolled back to the last stable incremental state immediately. Rollback shall not require additional authorization; it is the default response to implementation failure.

The IT Director may authorize an alternative resolution path in lieu of rollback. That authorization shall be documented in the change record at the time it is issued, with rationale.

The change record owner shall evaluate a failed Significant change that required rollback against the Problem record spawn triggers defined in **Policy 3.07**. If the failure condition meets those triggers, a Problem record shall be created independently of the change management process. The change management process and the problem management process are complementary and shall not be merged or held pending the other's conclusion.

6.5 Post-Implementation Review (PIR)

A PIR shall be required for all Significant and Emergency changes. The PIR shall be documented within the change record itself; no standalone record is required.

The PIR shall address at minimum: whether the change achieved its intended outcome; whether any unintended impacts occurred; whether the rollback plan was invoked and, if so, why; and any follow-on actions required.

The PIR shall be completed and documented within five (5) business days of implementation.

6.6 County Manager Consultation

The following conditions require mandatory County Manager consultation prior to implementation of a Significant change:

- Changes to systems whose failure, compromise, or misconfiguration could directly affect the conduct, security, or publicly reported outcome of an election — such as voter registration systems, election night reporting systems, or network infrastructure dedicated to election administration. Routine support work for the Clerk's office, including workstation support, peripherals, and streaming setup, shall not qualify.
- Changes that will cause planned downtime or degraded service visible to the public or to other County departments for more than one (1) business day.
- Changes involving decommission or replacement of a system designated as operationally critical infrastructure by the IT Director.
- Any change not meeting the above criteria that the IT Director determines carries political or notable operational implications.

County Manager consultation shall be documented in the RFC record prior to CCA authorization. Emergency changes meeting any of the above criteria shall notify the County Manager as soon as operationally practicable, but no later than four (4) hours following the initiation of implementation.

6.7 Change Record Closure and CI Record Coupling

The coupling between this policy and **Policy 3.08** is bidirectional and mandatory.

- **Policy 3.09 → Policy 3.08 direction**: No change record under this policy shall be closed without a corresponding CI record update confirming that the Redmine record reflects the post-change configuration state. A closed change record with an un-updated CI record constitutes a compliance failure under this policy.
- **Policy 3.08 → Policy 3.09 direction**: No CI record in Redmine shall be modified to reflect a configuration change without a corresponding authorized change record under this policy. This obligation is established in **Policy 3.08**, Section 6.6; this policy carries the reciprocal.
- **Emergency exception**: The CI record update obligation for Emergency changes is deferred, not waived. The CI record shall be updated within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later, concurrent with the catch-up RFC documentation obligation under Section 6.3. Both obligations run on the same clock.

3.10 Release and Deployment Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the deployment mechanics by which authorized changes are packaged, tested, and moved to production within the Elko County Information Operations Department. This policy governs how applications, drivers, firmware, and associated documentation are sourced, validated, and deployed across all change categories defined in **Policy 3.09**. It designates the IOPS Software Repository as the authoritative and exclusive source for all deployment packages, establishes the eligibility criteria that govern repository contents, and defines the category-specific deployment requirements that apply to Standard, Significant, and Emergency changes.

This policy is the downstream operational partner of **Policy 3.09** (Change Management Policy). Where **Policy 3.09** governs the authorization decision — whether a change may proceed and on what terms — this policy governs what happens after that authorization is granted.

2. Scope

This policy applies to all Information Operations Department personnel involved in the deployment of applications, drivers, firmware, and associated documentation to production environments within the County technology environment administered by the Information Operations Department.

All three change categories defined in **Policy 3.09** — Standard, Significant, and Emergency — have distinct deployment mechanics under this policy, and all are within scope. Firmware deployments to network devices, switches, and infrastructure are within scope and shall follow the same category-based mechanics as all other deployments. Device-specific deployment procedures are not prescribed by this policy; those procedures are maintained in the Knowledge Base under **Policy 3.13**.

The following are outside the scope of this policy:

- Change authorization is governed by **Policy 3.09**. CCA authorization from **Policy 3.09** is a mandatory prerequisite for all Significant and Emergency deployments under this policy but is not restated here.
- CI record governance following deployment is governed by **Policy 3.08**. The CI update obligation is unchanged by this policy.
- Vendor deployments in cloud environments that ECIO does not directly control are governed by **Policy 5.06**. Where a vendor deployment affects County-managed systems, notification and CI update obligations apply as described in Section 6.9.

3. Roles and Responsibilities

- **IT Director**: The IT Director shall ensure this policy is implemented and enforced across all deployment activity within the Information Operations Department. The IT Director shall ensure the IOPS Software Repository is maintained as the exclusive authorized deployment source and that the Department's test environment is established and operational.
- **Assistant IT Director**: The Assistant IT Director shall ensure deployment activities comply with this policy across all change categories. The Assistant IT Director shall ensure the pre-deployment checklist for Emergency deployments is completed and documented before any Emergency deployment proceeds. The Assistant IT Director shall oversee post-deployment verification for Significant and Emergency deployments and shall confirm that CI update obligations under **Policy 3.08** are fulfilled within the applicable timelines.

- **IT Department Personnel**: IT Department personnel authorized with write access to the IOPS Software Repository shall ensure that only items with a corresponding Supported classification under **Policy 3.01** are present in the repository. All other IT Department personnel shall deploy exclusively from the IOPS Software Repository under all change categories. No personnel shall deploy from any source other than the IOPS Software Repository regardless of urgency or authorization status.

4. Compliance and Exceptions

All deployment activity within the scope of this policy shall conform to the requirements established herein. Deviation from mandatory requirements designated by "shall" or "must" constitutes a policy violation and is subject to enforcement under Policy 5.01.

Exceptions to recommended practices designated by "should" require written approval from the IT Director prior to the deviation. The IT Director shall document the rationale and any compensating controls in the relevant change or work order record.

No exception process exists for the IOPS Software Repository requirement. Deployment from any source other than the IOPS Software Repository is prohibited under all change categories, including Emergency, and shall not be authorized by any exception mechanism under this policy or **Policy 3.09**.

5. References

- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Appendix **??**: Work Order Structure and Standards
- CJIS Security Policy v6.0: Section CM-3 (Configuration Change Control)
- CJIS Security Policy v6.0: Section SA-10 (Developer Configuration Management)
- NIST CSF 2.0: PR.PS-01 (Configuration management practices are established and applied)
- NIST CSF 2.0: PR.PS-02 (Software is maintained, replaced, and removed commensurate with risk)
- NIST SP 800-53 Rev. 5: CM-3 (Configuration Change Control)
- NIST SP 800-53 Rev. 5: CM-7 (Least Functionality)
- NIST SP 800-53 Rev. 5: SA-10 (Developer Configuration Management)
- COBIT 2019: BAI06 (Manage IT Changes)
- COBIT 2019: BAI07 (Manage IT Change Acceptance and Transitioning)
- ITIL v4: Deployment Management Practice
- ITIL v4: Release Management Practice

6. Policy Statement

6.1 The IOPS Software Repository

The IOPS Software Repository is the IT-controlled repository designated as the authoritative and exclusive source for all deployment packages within the scope of this policy.

The IOPS Software Repository shall be read-only for all personnel except IT Department personnel with authorized write access. No personnel shall modify, add to, or remove items from the repository except through the write-access process established by the IT Director.

The IOPS Software Repository shall not be referred to by server path or share name in this policy or in any policy instrument. References shall use the designation "IOPS Software Repository" to preserve policy validity if the repository is relocated.

6.2 Repository Eligibility

Only applications, drivers, firmware, and associated documentation corresponding to items with a current Supported classification on the Supported software list maintained under **Policy 3.01** shall be present in the IOPS Software Repository and eligible for deployment.

Presence in the repository without a corresponding Supported classification under **Policy 3.01** constitutes a policy violation. The Assistant IT Director shall remediate any such condition upon discovery.

The Assistant IT Director approval for adding an item to the Supported software list under **Policy 3.01** is the intake authorization gate for repository eligibility. No separate intake approval process is required under this policy.

6.3 Repository Requirement — No Exceptions

Deployment from any source other than the IOPS Software Repository is prohibited under all change categories, including Emergency. This requirement applies regardless of urgency, authorization status, or the identity of the personnel directing the deployment.

The Emergency category in **Policy 3.09** authorizes expedited change authorization. It does not alter, waive, or supersede the deployment source requirement or the Supported software list eligibility requirement established in this policy. An Incident Commander's Emergency designation under **Policy 3.09** does not constitute authorization to deploy from an uncontrolled source.

6.4 Standard Deployments

A Standard deployment shall be deployed from the IOPS Software Repository per the pre-approved Knowledge Base procedure maintained under **Policy 3.13**. The Knowledge Base procedure is the deployment control for Standard changes; no staging or pilot group is required.

The deploying technician shall document the deployment within the associated work order in accordance with **Policy 3.05**. The CI update obligation under **Policy 3.08** applies upon completion of the deployment.

Post-deployment verification for Standard deployments is implicit in work order closure under **Policy 3.05**.

6.5 Significant Deployments

A Significant deployment shall be deployed from the IOPS Software Repository. Before implementation, a deployment package shall be prepared and documented within the RFC record under **Policy 3.09**.

Staging or pilot group testing is required prior to full production deployment, in accordance with the testing requirements defined in Section 6.7. For Significant deployments affecting end-user systems, a phased rollout — pilot group before full production — shall be the default approach where operationally feasible. Where a phased rollout is not operationally feasible, the deploying technician shall document the basis for that determination in the RFC record.

The rollback procedure shall be verified as operational before the deployment proceeds to production. All deployment steps shall be documented in the RFC record.

Post-deployment verification is required before the **Policy 3.09** PIR may be initiated. The Assistant IT Director shall confirm that post-deployment verification is complete and documented in the RFC record before the PIR is opened. The CI update obligation under **Policy 3.08** applies upon completion of the deployment.

6.6 Emergency Deployments

An Emergency deployment shall be deployed from the IOPS Software Repository. No exception to this requirement applies under Emergency conditions.

Before any Emergency deployment proceeds, a pre-deployment checklist shall be completed and documented by the deploying technician. The checklist shall confirm each of the following: the deployment source is the IOPS Software Repository; the package has a corresponding Supported classification under **Policy 3.01**; and the deploying technician has confirmed the target systems. The Assistant IT Director shall verify that the completed checklist is documented in the catch-up RFC record under **Policy 3.09**.

Staging is waived for Emergency deployments. Post-deployment verification is required before the catch-up RFC record under **Policy 3.09** may be closed. The **Policy 3.09** PIR serves as the post-deployment review for Emergency deployments; no separate deployment review record is required.

The CI update obligation under **Policy 3.08** applies under the same twenty-four (24) hour and noon-next-business-day timeline established in **Policy 3.09**.

6.7 Staging and Testing

The Information Operations Department shall maintain a dedicated test environment for pre-production validation of Significant deployments. The test environment shall consist of one or more virtual machines representative of production system configurations. Maintenance of the test environment is a standing operational obligation within the IT Director's operational authority to establish and maintain.

Where the dedicated test environment is not applicable to a specific deployment type — for example, infrastructure changes that cannot be meaningfully replicated in a virtual machine environment — a defined pilot group shall serve as the validation mechanism.

The criteria for test environment applicability and pilot group selection shall be documented in the Knowledge Base under **Policy 3.13**. The Assistant IT Director shall ensure that the relevant Knowledge Base entries are current.

6.8 Post-Deployment Verification and PIR Sequencing

Post-deployment verification is a prerequisite to initiating the **Policy 3.09** PIR for Significant and Emergency deployments. The PIR shall not be initiated until post-deployment verification confirms that the deployment completed successfully and that no immediate unintended impacts are present. The **Policy 3.09** PIR is sufficient for both change review and deployment review purposes; no separate deployment post-implementation record is required.

For Standard deployments, post-deployment verification is implicit in work order closure under **Policy 3.05**.

6.9 Vendor Cloud Deployments

Where a vendor deployment in a cloud environment that ECIO does not directly control affects County-managed systems, the IT Director or Assistant IT Director shall be notified. A CI update obligation under **Policy 3.08** is triggered upon such notification. Vendor deployment obligations are governed by **Policy 5.06** and are not restated here.

3.11 Capacity and Availability Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the proactive governance framework for capacity and availability management within the Elko County Information Operations Department. This policy governs how the Department baselines current capacity and availability, forecasts future needs, and ensures that infrastructure can meet the service level commitments defined in **Policy 3.01** before those commitments are at risk.

This policy is concerned with planning: establishing baselines, identifying trends, defining thresholds, and driving remediation before gaps become failures. Real-time monitoring and alerting against those thresholds is governed by **Policy 3.12**. The threshold values that **Policy 3.12** implements are defined under this policy.

2. Scope

This policy applies to all Information Operations Department personnel and governs the baselining, forecasting, and planning of capacity and availability for all IT services, infrastructure, endpoints, and applications administered by the Department. In-scope resource categories include storage capacity, compute resources, network bandwidth, and application performance as they relate to the Department's ability to meet service level commitments. All services with active SLA targets under **Policy 3.01** are within scope for availability measurement.

The following are outside the scope of this policy:

- **SLA target-setting** is governed by **Policy 3.01**. This policy plans to meet those targets; it does not define them.
- **Real-time monitoring, alerting, and event response** are governed by **Policy 3.12**. Threshold values defined under this policy are provided to **Policy 3.12** for implementation in monitoring configurations; the monitoring itself is not governed here.
- **Service continuity and recovery planning** for major disruptions are governed by **Policy 3.15**. This policy governs steady-state proactive capacity and availability management, not failure-scenario recovery planning.
- **Performance reporting to stakeholders** is governed by **Policy 3.02**. This policy generates the underlying capacity and availability data; reporting obligations are governed by **Policy 3.02**.
- **Change authorization** for capacity-driven infrastructure changes is governed by **Policy 3.09**. This policy identifies the need; **Policy 3.09** authorizes the change.

3. Roles and Responsibilities

- **IT Director**:
  - Shall receive and review a quarterly capacity and availability briefing prepared by the Assistant IT Director.
  - Shall serve as the approving authority for any remediation plan that carries budget implications or requires infrastructure change before submission to the **Policy 3.09** change process.
  - Shall authorize any formal deviation from the planning cadences or threshold documentation requirements established in this policy.

- **Assistant IT Director**:
  - Shall maintain a current capacity baseline across all in-scope resource categories.
  - Shall measure availability actuals against **Policy 3.01** SLA targets no less than monthly and shall update availability records to reflect current actuals in advance of each quarterly briefing.
  - Shall define capacity and availability thresholds and provide those threshold values to the **Policy 3.12** monitoring function for implementation in automated monitoring configurations.
  - Shall review threshold values no less than annually, or whenever a Significant or Emergency change (as defined in **Policy 3.09**) is executed against the service catalog or infrastructure.
  - Shall conduct forward-looking capacity and availability planning no less than annually, timed to inform the County budget cycle.
  - Where forecasting identifies a gap between projected capacity and committed service levels, the Assistant IT Director shall develop a remediation plan and present any plan requiring budget or infrastructure change to the IT Director for approval before submission to **Policy 3.09**.
  - Shall prepare and present the quarterly capacity and availability briefing to the IT Director.
  - Shall ensure that capacity and availability data is made available to **Policy 3.02** reporting processes.
  - Shall ensure that relevant Knowledge Base entries under **Policy 3.13** remain current where applicable.
- **IT Department Personnel**:
  - Shall support capacity and availability data collection as directed by the Assistant IT Director.
  - Shall document relevant performance observations in the work order system in accordance with **Policy 3.05**.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel within scope.

- **Assessment**: Compliance with baseline maintenance, threshold documentation, planning cadence, and briefing obligations shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to maintain required baselines, document threshold values, conduct planning on the required cadence, or deliver required briefings without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy

- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- COBIT 2019: BAI04 (Manage Availability and Capacity)
- ITIL v4: Availability Management Practice
- ITIL v4: Capacity and Performance Management Practice

6. Policy Statement

6.1 Capacity Baseline

The Department shall maintain a current capacity baseline across all in-scope resource categories: storage, compute, network bandwidth, and application performance. The baseline shall be established from measured actuals and updated no less than quarterly. The baseline is the authoritative reference point against which forecasting, trend analysis, and threshold calibration are conducted. The Assistant IT Director shall ensure the accuracy of the capacity baseline through quarterly validation.

6.2 Availability Measurement

Availability shall be measured for all services with active SLA targets under **Policy 3.01**. Availability measurement shall distinguish planned downtime from unplanned downtime. The Assistant IT Director shall measure availability actuals against **Policy 3.01** SLA targets no less than monthly and shall update availability records to reflect current actuals in advance of each quarterly briefing. Availability data shall be made available to **Policy 3.02** reporting processes.

6.3 Threshold Definition

The Assistant IT Director shall define capacity and availability thresholds that, when breached, indicate risk to service level commitments. Threshold values shall be documented and provided to the **Policy 3.12** monitoring function for implementation in automated monitoring configurations. Threshold values shall be reviewed no less than annually or whenever a Significant or Emergency change (as defined in **Policy 3.09**) is executed against the service catalog or infrastructure.

6.4 Forecasting and Planning

The Department shall conduct forward-looking capacity and availability planning no less than annually. Planning shall be timed to inform the County budget cycle and shall account for known service changes, projected growth, and aging infrastructure. Where forecasting identifies a gap between projected capacity and committed service levels, the Assistant IT Director shall develop a remediation plan. Remediation plans requiring budget or infrastructure change shall be presented to the IT Director for approval before submission to the **Policy 3.09** change process. Emergency capacity issues requiring immediate infrastructure change shall be routed through the **Policy 3.09** Emergency change category.

6.5 Issue Response

When monitoring under **Policy 3.12** identifies a threshold breach, the Assistant IT Director shall investigate and determine whether the breach represents a transient condition or a structural capacity or availability gap. The Assistant IT Director shall document transient conditions, including duration and impact, within the designated System of Engagement (Redmine) prior to closing the event. Structural gaps shall be addressed through the forecasting and planning process defined in Section 6.4.

6.6 Quarterly Briefing

The Assistant IT Director shall prepare and present a quarterly capacity and availability briefing to the IT Director. The briefing shall include, at minimum:

- Current baseline status across all in-scope resource categories.
- Availability actuals against **Policy 3.01** SLA targets.
- Identified trends or emerging gaps.
- Status of any active remediation plans.

The quarterly briefing cycle shall be timed to align with the County budget calendar.

3.12 Monitoring and Event Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the operational framework for real-time monitoring and event management within the Elko County Information Operations Department. This policy governs how the Department monitors IT services, infrastructure, endpoints, and applications; classifies events according to a defined taxonomy; and routes events to the appropriate response path.

This policy shall govern real-time detection and operational response: collecting monitoring data, classifying events, generating work orders for actionable conditions, and ensuring that threshold breaches feed the capacity and availability investigation process defined in **Policy 3.11**. Proactive planning, baselining, and threshold definition are governed by **Policy 3.11**. The threshold values that this policy implements are defined there.

2. Scope

This policy applies to all Information Operations Department personnel and governs the real-time monitoring of all IT services, infrastructure, endpoints, and applications administered by the Department. In-scope data collection types include availability and ping checks, performance metrics (CPU utilization, memory utilization, disk utilization, and application response times), flow data (NetFlow and sFlow), syslog and event logs from network equipment and servers, and SNMP polling. All events generated by the monitoring function shall be classified under the event taxonomy defined in Section 6.2 of this policy.

This policy governs operational performance and resource utilization monitoring, establishing a strict boundary from security event logging governed by **Policy 2.11** (Audit Logging and Monitoring Policy). **Policy 2.11** owns security event logging and the SIEM; this policy owns operational and performance monitoring. These are distinct data streams, and the boundary between them is intentional and maintained.

The following are outside the scope of this policy:

- **Configuration drift detection** is governed by **Policy 2.10** (Secure Configuration Baselines and Hardening Policy). This policy may serve as transport infrastructure for drift detection signals, but the governance, remediation timeframes, and escalation path for those signals are owned by **Policy 2.10**.
- **Physical security and environmental monitoring** is governed by **Policy 2.13** (Physical Security and Environmental Controls Policy). Camera motion events, door access log anomalies, temperature and humidity readings, power monitoring, and UPS monitoring are governed by **Policy 2.13** with response paths defined there.
- **Security audit logging** is governed by **Policy 2.11**. This policy governs operational performance monitoring only.
- **Threshold definition and capacity planning** are governed by **Policy 3.11**. This policy implements thresholds; it does not define them.
- **Incident response once a work order is opened** is governed by **Policy 3.06** (Operational Incident Management Policy). This policy's obligation ends when the work order is created; **Policy 3.06** governs all subsequent response activity.
- **Service continuity and recovery** are governed by **Policy 3.15** (Service Continuity and Contingency Planning Policy).

- **Specific monitoring tool names, tool configurations, and tool-specific procedures** are maintained in the Knowledge Base under **Policy 3.13** (Knowledge Management Policy).

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the Incident Commander by default for all events that generate work orders under this policy, consistent with the designation established in **Policy 3.06**.
  - Shall serve as the external communications spokesperson for monitoring-triggered incidents.
  - Shall escalate to the County Manager, the Board, or Department Heads as warranted by the nature and scope of the event.
  - Shall authorize any formal deviation from the monitoring cadences, configuration review requirements, or threshold implementation obligations established in this policy.
- **Assistant IT Director**:
  - Shall serve as the primary operational owner of the monitoring and event management function.
  - Shall ensure that all in-scope monitoring functions are operational and producing current data.
  - Shall review events and ensure that work orders are generated for Alert and Major events in accordance with this policy.
  - Shall ensure that monitoring tool configurations are maintained current and reviewed on the cadence established in this policy.
  - Shall ensure that threshold values received from **Policy 3.11** are implemented in monitoring configurations.
  - Shall ensure that relevant Knowledge Base entries under **Policy 3.13** remain current where applicable.
- **Network Administrator**:
  - Shall configure all network equipment within scope to forward syslog and event data to the designated collection infrastructure.
  - Shall maintain network equipment SNMP configurations to support polling.
  - Shall ensure that NetFlow and sFlow export configurations on applicable network devices are current and functioning.
  - Shall document relevant network monitoring configurations in the Knowledge Base under **Policy 3.13**.
- **Systems Administrator**:
  - Shall maintain the monitoring collection infrastructure, including servers and collection platforms.
  - Shall configure server-side monitoring agents and ensure that performance and availability data is collected from all in-scope systems.
  - Shall ensure that server syslog forwarding to the collection infrastructure is current and functioning.
  - Shall document relevant server monitoring configurations in the Knowledge Base under **Policy 3.13**.
- **IT Department Personnel**:
  - Shall respond to work orders generated by automated monitoring events in accordance with **Policy 3.06** and **Policy 3.05**.

  - Shall document all actions taken in the work order system.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel within scope.

- **Assessment**: Compliance with monitoring configuration currency, event classification, work order generation, threshold implementation, and retention obligations shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to maintain required monitoring configurations, classify and route events in accordance with the taxonomy established in this policy, generate required work orders, or retain monitoring records for the required period without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- LRDA 20071728 (IT Access Control Reviews and Audit Trails)
- COBIT 2019: BAI04 (Manage Availability and Capacity)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: Monitoring and Event Management Practice

6. Policy Statement

6.1 Monitoring Scope and Configuration Ownership

The Department shall maintain real-time monitoring coverage across all IT services, infrastructure, endpoints, and applications within the scope defined in Section 2. In-scope data collection includes availability and ping checks, performance metrics, flow data, syslog and event logs, and SNMP polling.

The Network Administrator owns monitoring configurations for all network equipment within scope. The Systems Administrator owns the monitoring collection infrastructure and all server-side monitoring configurations. The Assistant IT Director is accountable for ensuring that both configuration sets are current, functional, and producing data sufficient to support event classification under this policy.

Tool configurations, procedures, and monitoring runbooks shall be maintained in the Knowledge Base under **Policy 3.13**.

6.2 Event Taxonomy

All events generated by the monitoring function shall be classified under the following four-tier taxonomy, regardless of monitoring stream. A single taxonomy governs all in-scope monitoring data types.

- **Informational** — System behavior is within normal parameters. No action is required. Events at this tier shall be logged for baseline and trending purposes. No work order is generated.
- **Warning** — System behavior is approaching a defined threshold. No action is required. Events at this tier shall be logged. The Assistant IT Director shall maintain awareness of Warning-tier events as part of the threshold review obligations established in **Policy 3.11**, Section 6.3. No work order is generated.
- **Alert** — A defined threshold has been breached and action is required. A work order shall be generated in Redmine at Urgent or High severity, determined by the scope of impact at the time of the event. Alert-tier events initiate the **Policy 3.06** incident intake process and are subject to all intake, triage, and response obligations defined there.
- **Major** — Service impact is confirmed or imminent. A work order shall be generated in Redmine at Critical severity. The IT Director shall be notified immediately. Major-tier events initiate the **Policy 3.06** incident intake process and are subject to all intake, triage, and response obligations defined there.

6.3 Security Handoff

Any event at any tier that meets the Indicator of Compromise (IoC) definition in **Policy 4.02** shall route immediately to Chapter 4, regardless of its tier classification at the time. The event tier governs operational response; **4.02** governs jurisdictional transfer. This handoff is consistent with the Hard Fork procedure established in **Policy 3.06**, Section 6.2. Tier classification does not delay or qualify the security handoff obligation.

6.4 Automated Event Intake and Work Order Generation

The monitoring system is a valid intake channel under **Policy 3.06**, Section 6.4. Work orders generated by Alert and Major events shall be created in Redmine no later than one (1) business hour following event detection, consistent with the intake obligation established in **Policy 3.06** for all intake channels. Work orders shall be created following the same submission standards as any other intake channel. Once created, the work order is triaged and worked under standard **Policy 3.06** mechanics.

No response activity shall proceed on an Alert or Major event without an associated work order.

The **Policy 3.07** problem spawn path is satisfied organically through this mechanism. Persistent threshold breach patterns produce recurring work orders that accumulate in the work order queue and trigger the existing **Policy 3.07** spawn conditions without requiring a separate mechanism under this policy.

6.5 Threshold Implementation and Review

Threshold values shall be received from the **Policy 3.11** process defined in Section 6.3 of that policy and implemented by the Assistant IT Director in monitoring configurations. Threshold values in monitoring configurations shall be reviewed no less than annually or whenever a Significant or Emergency change, as defined in **Policy 3.09**, is executed against the service catalog or infrastructure. This review cadence mirrors the obligation established in **Policy 3.11**, Section 6.3.

When monitoring under this policy identifies a threshold breach, the Assistant IT Director shall conduct the investigation defined in **Policy 3.11**, Section 6.5 to determine whether the breach represents a transient condition or a structural capacity or availability gap.

6.6 Retention

Monitoring records shall be retained for a minimum of three (3) calendar years from the end of the calendar year in which the review or audit was concluded, in accordance with **Policy 1.11** (Data Governance and Classification Policy) and the Nevada Local Government Records Retention Schedule: LRDA 20071728 (IT Access Control Reviews and Audit Trails).

3.13 Knowledge Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the governance and operational framework for the Department's Knowledge Base as the single authoritative repository of operational procedures, workarounds, Known Error entries, Standard change pre-authorization procedures, deployment procedures, tool configurations, runbooks, and reference documentation. This policy governs the creation, maintenance, review, and retirement of all knowledge artifacts and serves as the authorization backbone for Standard change classification under **Policy 3.09**.

2. Scope

This policy applies to all Information Operations Department personnel and governs all knowledge artifacts created, maintained, or retired by the Department. In-scope artifact types include operational procedures, workaround and resolution documentation, Known Error entries, Standard change pre-authorization procedures, Standard deployment procedures, system and tool configurations, monitoring runbooks, escalation paths, service delivery workflows, and reference documentation.

The following are outside the scope of this policy:

- **Policy documents** — governed by **Policy 1.04** and **Policy 1.05**.
- **Work order records** — governed by **Policy 3.05**.
- **Configuration Management Database (CMDB) records** — governed by **Policy 3.08**.
- **Security audit logs and SIEM data** — governed by **Policy 2.11**.
- **Incident and Problem records** — governed by **Policy 3.06** and **Policy 3.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for the formal retirement of any KB article.
  - Shall approve KB procedures that carry Standard change authorization weight, consistent with the change authorization framework in **Policy 3.09**.
  - Shall authorize any external distribution of KB content.
  - Shall authorize any formal deviation from the documentation, review, or retention obligations established in this policy.
- **Assistant IT Director**:
  - Shall serve as the primary operational owner of the Knowledge Base.
  - Shall ensure the KB is accessible, current, and organized to support the mandatory pre-escalation search obligation established in **Policy 3.06**.
  - Shall ensure Known Error entries are published and marked inactive within the timeframes established in **Policy 3.07**.
  - Shall ensure that tool configuration and runbook entries required by **Policy 3.12** are maintained current.

  - Shall conduct or coordinate the annual KB review cycle.
  - Shall ensure all KB entries associated with any modified system, service, or configuration are current following Significant or Emergency changes, consistent with the obligations established in **Policy 3.09** and **Policy 3.12**.
  - Shall establish and maintain the operational standard governing KB procedure formatting conventions and templates.
- **Network Administrator**:
  - Shall author and maintain all KB entries governing network equipment monitoring configurations, SNMP configurations, and NetFlow/sFlow export configurations, as required by **Policy 3.12**.
  - Shall author and maintain all Reference Documentation entries within the network domain, including network schemas, addressing plans, VLAN tables, and topology diagrams.
  - Shall review assigned KB entries for accuracy no less than annually.
- **Systems Administrator**:
  - Shall author and maintain all KB entries governing server-side monitoring configurations, collection infrastructure, and server syslog forwarding, as required by **Policy 3.12**.
  - Shall author and maintain all Reference Documentation entries within the server and systems domain, including system architecture overviews and similar informational artifacts.
  - Shall review assigned KB entries for accuracy no less than annually.
- **Administrators (general)**:
  - Shall own and maintain all technical KB entries within their domain.
  - Shall review assigned entries for accuracy no less than annually or following any change that affects the documented procedure or reference artifact.
  - Shall approve new technical entries authored by Support Specialists before publication.
  - Shall author Standard change pre-authorization procedures and submit for IT Director approval.
- **Support Specialists**:
  - Shall author and revise KB entries under Administrator guidance.
  - Shall document new procedures prior to closing any work order for a task that lacked prior documentation.
  - Shall reference applicable KB entries in all work orders.
- **All IT Department Personnel**:
  - Shall search the KB before escalating any incident, as required by **Policy 3.06**.
  - Shall flag outdated, inaccurate, or missing KB content to the responsible Administrator or the Assistant IT Director.
  - Shall reference applicable KB entries in work order documentation.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with KB currency, Known Error publication timelines, Standard change procedure approval, annual review cadence, and documentation-before-closure obligations shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.

- **Enforcement**: Failure to maintain required KB entries, publish Known Error entries within established timeframes, obtain required approvals for Standard change procedures, or document new procedures prior to work order closure shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20070057 (Departmental Regulations, Policies and Procedures)
- COBIT 2019: BAI08 (Manage Knowledge)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: Knowledge Management Practice

6. Policy Statement

6.1 Knowledge Base as System of Record

Redmine is the authoritative System of Record for all KB content. All KB articles shall be stored in Redmine as the primary repository. The Assistant IT Director shall maintain at least one secondary accessible medium synchronized no less than monthly.

6.2 KB Content Categories

All knowledge artifacts shall be classified under the following categories:

- **Workaround Procedures**: Resolution procedures for known conditions; mandatory pre-escalation reference per **Policy 3.06**.

- **Known Error Entries**: Documented Known Errors with symptom description, workaround procedure, and Problem record reference.
- **Standard Change Procedures**: Pre-approved procedures that authorize Standard change classification under **Policy 3.09**.
- **Standard Deployment Procedures**: Pre-approved deployment steps for Standard changes, maintained as the deployment control per **Policy 3.10**.
- **Tool Configurations and Runbooks**: Monitoring tool configurations, collection parameters, and operational runbooks maintained by role per **Policy 3.12**.
- **Operational Procedures**: Recurring procedures, system workflows, and escalation paths not covered by the categories above.
- **Reference Documentation**: Static informational artifacts that document the state of the environment and support operational decision-making, including network schemas, addressing plans, VLAN tables, topology diagrams, and system architecture overviews. Reference Documentation entries do not prescribe action steps and are not subject to the structured procedure format requirement in Section 6.3.

Ownership and review obligations for each category shall follow the roles defined in Section 3.

6.3 Structured Procedure Format

All KB procedures shall document tasks as discrete, sequentially numbered steps. Procedures shall address known error conditions and their corresponding recovery actions as conditional branches within the step sequence. Procedures shall specify the expected end state upon successful completion. The formatting conventions and templates implementing this requirement are operational decisions established and maintained by the Assistant IT Director.

6.4 Standard Change Authorization Function

A KB procedure qualifies a change type as Standard only when it carries explicit IT Director approval. If no qualifying KB procedure exists, the change shall be classified as Significant. Retirement or material modification of any Standard change procedure shall require the same IT Director approval path as creation.

6.5 Known Error Entry Lifecycle

Known Error entries are a distinct KB record type. Upon Known Error declaration, the Assistant IT Director shall ensure publication within two (2) business days, including symptoms, workaround procedure, and Problem record reference. Upon permanent remediation and Problem closure, the entry shall be marked inactive within two (2) business days. The Known Error declaration and closure triggers are governed by **Policy 3.07**; this policy governs the KB mechanics of the entry lifecycle.

6.6 Documentation-Before-Closure Obligation

Any task executed without a corresponding KB entry shall result in creation or revision of a KB article prior to work order closure.

6.7 Review and Retirement

All KB entries shall be reviewed no less than annually or following any Significant or Emergency change affecting a documented procedure or reference artifact. Only the IT Director shall authorize formal retirement of any KB article. Retired articles shall be marked inactive and retained for a minimum of six (6) calendar years after supersession or official abandonment, in accordance with Nevada Local Government Records Retention Schedule LRDA 20070057. All KB content is operationally confidential; external distribution requires written IT Director authorization.

3.14 IT Project Management Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish a consistent, auditable framework for the designation, governance, execution, and closure of IT projects within the Elko County Information Operations Department. This policy defines what constitutes a formal IT project, governs the full project lifecycle from charter through post-mortem, and ensures that project work is authorized, documented, and delivered in alignment with the Department's governance obligations and service commitments.

2. Scope

- **In Scope**: This policy governs all initiatives formally designated as IT projects by the Information Operations Department, including new system implementations, major infrastructure changes, county-wide technology rollouts, departmental pilots, and multi-stakeholder technology initiatives managed by the Department. Both internal projects — those originated by the Information Operations Department to fulfill its own operational, infrastructure, or governance objectives — and external projects — those initiated by a County department, agency, or external entity where the Department participates as a technical authority and service partner — are governed by this policy.
- **Out of Scope**: The following are explicitly excluded from this policy:
  - Routine and standard operational work, governed by **Policy 3.05**.
  - Standard and Significant changes that fall below the project designation threshold in Section 6.1, governed by **Policy 3.09**.
  - Unauthorized technology procurement or implementation, governed by **Policy 1.10**.
  - Vendor governance and supply chain risk review, governed by **Policy 1.13**.
  - SDLC and secure development requirements for system acquisitions, governed by **Policy 2.15**.
  - Cybersecurity incident post-mortems, governed by **Policy 4.07**.
  - Budget appropriation and funding timelines — the sponsoring department's obligation, outside the scope of this policy.
- **External Project Authority**: In external projects, the sponsoring department or entity provides direction on business objectives and outcomes. The Information Operations Department retains full authority over technical design, security compliance, architecture decisions, and all IT governance obligations established in this manual. External project sponsors hold no supervisory or directive authority over IT personnel or IT technical determinations.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for all project charters.
  - Shall serve as the approving authority for any change to the active project priority order.
  - Shall serve as the approving authority for all annual project re-authorizations.
  - Shall receive project status as part of the monthly executive report obligation established in **Policy 1.14**.

  - Shall authorize emergency project designations and emergency waivers of project process components with documented rationale; normal procedures shall resume as soon as operationally practicable.
  - Shall serve as joint authority with the Assistant IT Director for formal IT withdrawal from external projects.
  - Shall provide final sign-off for project closure on all complex projects and on any project involving a Significant or Emergency change.
- **Assistant IT Director**:
  - Shall serve as the primary owner of the project portfolio per **Policy 1.07**.
  - Shall maintain the active project priority order in Redmine.
  - Shall ensure project documentation compliance across all active projects.
  - Shall coordinate with the IT Director on charter approval, re-authorization, and closure.
  - Shall confirm go-live stability as the trigger for complex project post-mortems.
  - Shall ensure that all KB, CMDB, CI update, and service catalog obligations are satisfied at project closure.
  - Shall serve as joint authority with the IT Director for formal IT withdrawal from external projects.
  - Shall provide sign-off for routine project closure, with IT Director countersign.
- **Project Owner**:
  - Project Owner is a functional designation assigned per-project to an existing role holder — IT Director, Assistant IT Director, or Administrator.
  - Shall be designated at charter by the IT Director for internal projects.
  - Shall be designated as the assigned ECIO Administrator for vendor-led external projects.
  - Shall coordinate stakeholders, own the project timeline and task assignments, and ensure that all required documentation is attached to the project record throughout the lifecycle.
  - Shall escalate risks and scope changes to the Assistant IT Director promptly upon identification.
  - Shall conduct or coordinate the post-mortem.
  - Shall serve as the primary notification recipient if IT withdrawal is invoked on an external project.
- **IT Staff**:
  - Shall execute assigned project tasks documented in child work orders.
  - Shall document execution details, configuration changes, and risk observations in the work order system per **Policy 3.05**.
  - Shall raise risks to the Project Owner promptly upon identification.
- **Departmental Stakeholders**:
  - Shall participate in requirements definition, testing, and evaluation as designated in the project charter.
  - Shall participate in post-mortem review as designated.
- **County Manager**:
  - Receives project status via the IT Director's monthly executive report per **Policy 1.14**.
  - Shall receive written notification prior to any IT withdrawal from an external project.

  - May, at her option, serve as a neutral arbitrator between the sponsoring agency and the Information Operations Department prior to withdrawal being finalized, consistent with **Policy 1.08**.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all personnel of the Information Operations Department and all stakeholders participating in formally designated IT projects.

- **Assessment**: Project management compliance shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** and through internal audit procedures defined in **Policy 5.02**.
- **Exceptions**: Exceptions to this policy shall be authorized in writing by the IT Director. Emergency waivers of specific process components are permitted per Section 6.1 of this policy. All exceptions shall be documented in the project record and retained with the master work order.
- **Enforcement**: Non-compliance may result in corrective actions as defined in **Policy 5.01**.

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- COBIT 2019: BAI01 (Manage Programs)
- COBIT 2019: BAI02 (Manage Requirements Definition)
- ITIL v4: Project Management Practice

6. Policy Statement

6.1 Project Designation

An initiative qualifies for formal project designation when it (a) requires three or more discrete work orders to complete, and (b) requires advance resource planning, stakeholder coordination, or sequenced task dependencies that cannot be captured within a single work order record. Both conditions shall be satisfied for threshold-based designation.

The Assistant IT Director or IT Director may designate any initiative as a formal project regardless of whether it meets the threshold criteria. No initiative may self-designate as a project below the threshold without authorization from the Assistant IT Director or IT Director.

- **Emergency Designation**: An initiative may be formally designated as a project after work has already begun when urgency precludes advance charter preparation — for example, a county-mandated security remediation requiring an immediate multi-work-order response. Emergency designation requires IT Director authorization. Catch-up documentation, including the project charter, risk log, stakeholder map, and all other required project record elements defined in Section 6.10, shall be completed and attached to the master work order within five business days of emergency designation.

6.2 Project Record Structure

Each formally designated project shall be represented in Redmine as a master work order, which serves as the project record and coordination hub. The master work order shall have the Internal Project checkbox set per **Policy 3.05** and **Appendix ??**. Individual task units shall be created as child work orders and linked to the master via the Related Issues field.

A **Policy 3.09** Post-Implementation Review (PIR) fires on any Significant or Emergency change within a child work order per the timelines and mechanics established in **Policy 3.09**. This is a change-level obligation that runs independently of this policy. A separate project post-mortem under Section 6.7 fires when the master work order closes, covering the initiative as a whole. These two obligations are parallel and distinct.

6.3 Phase 1 — Initiation and Charter

The Project Owner shall define the project scope, objectives, impacted stakeholders, resource requirements, success criteria, and target completion date. The charter shall explicitly document:

- Whether the project is net-new-service-bearing, for purposes of the service catalog closure gate in Section 6.6.
- Whether the project involves vendor engagement, which triggers the **Policy 1.13** SCRM gate before contracts are executed.
- Whether the project involves systems that process, store, or transmit County data, which flags the data classification obligation in Section 6.4.

The IT Director shall approve the charter before any project work begins. The master work order shall be created in Redmine upon charter approval.

For emergency project designations, IT Director authorization substitutes for advance charter approval. Catch-up documentation shall be completed within five business days of emergency designation per Section 6.1.

6.4 Phase 2 — Planning

The Project Owner shall complete the following activities during the planning phase, before execution begins:

- Stakeholder and tester identification.

- Solution evaluation and selection, including vendor demonstrations where applicable. Solution evaluation shall follow the requirements definition standards in COBIT 2019 BAI02. Planning-phase activities shall not absorb SDLC or secure development obligations governed by **Policy 2.15**.
- For projects involving systems that process, store, or transmit County data: data classification under **Policy 1.11** shall be completed during this phase before execution begins.
- Timeline and milestone definition, with task ownership assigned per work order.
- Risk log creation. Risk scoring shall apply the criteria established in **Policy 1.09** .
- Communication plan development.
- Child work orders shall be created for each discrete task unit and linked to the master work order via the Related Issues field.

6.5 Phase 3 — Execution and Ongoing Oversight

All task execution shall be documented in child work orders per **Policy 3.05**. All production changes shall be classified and authorized per **Policy 3.09**; Significant and Emergency changes trigger **Policy 3.09** PIR obligations on the relevant child work orders independently of this policy. All deployments shall be executed from the IOPS Software Repository per **Policy 3.10**. The Project Owner shall monitor KPIs against defined success criteria and escalate identified risks to the Assistant IT Director promptly.

Ninety-Day Status Reviews: For projects exceeding ninety days in duration, a status review shall be conducted at ninety-day intervals from project initiation for the life of the project. Each review shall confirm that scope, budget, and timeline remain on track and shall be documented in the project record. Any ninety-day review that identifies material scope, budget, or resource changes shall escalate to IT Director re-authorization regardless of where it falls on the annual re-authorization clock.

Annual Re-Authorization: For projects exceeding twelve months in duration, the IT Director shall provide annual re-authorization confirming that the project continues under its current charter. Re-authorization shall be documented in the project record.

6.6 Phase 4 — Closure Gates

The following gates shall be satisfied before the master work order may be closed:

- All child work orders resolved or formally dispositioned.
- CI records updated per **Policy 3.08**.
- KB documentation completed per **Policy 3.13**.
- All **Policy 3.09** PIRs completed for any Significant or Emergency changes, within the timelines established in **Policy 3.09**.
- **For net-new-service-bearing projects**: the service shall be registered in the service catalog under **Policy 3.01**, and SLA targets shall be established under **Policy 3.02**, before closure.
- **Formal acceptance**: the Assistant IT Director and IT Director shall jointly confirm that acceptance criteria have been met and shall authorize transition to steady-state operations. For external projects, the Project Owner shall countersign acceptance.

6.7 Phase 5 — Post-Mortem

A project post-mortem shall be conducted for every formally designated project upon master work order closure. Post-mortem timing is tiered by project complexity:

- **Routine projects** — those completing within ninety days with no Significant or Emergency changes — shall conduct the post-mortem within two weeks of master work order closure.

- **Complex projects** — those exceeding ninety days in duration, involving Significant or Emergency changes, or involving vendor delivery — shall initiate the post-mortem upon Assistant IT Director confirmation of go-live stability, with a hard outer bound of thirty calendar days from master work order closure regardless of stability status.

The post-mortem shall address:

- Whether the project achieved its defined success criteria.
- Scope, budget, and timeline variance.
- Risks that materialized and the means by which they were resolved
- Stakeholder and communication plan effectiveness
- Actionable takeaways for future projects.

The post-mortem summary shall be documented in the project record and retained with the master work order.

Training requirements identified during a project shall be documented in the project charter and communicated to the relevant department for that department's own planning purposes. End-user training delivery falls outside the Department's service delivery mission and carries no project closure gate obligation under this policy.

6.8 Project Portfolio Management

The Assistant IT Director shall maintain the active project priority order in Redmine. Any change to the active project priority order requires IT Director approval, documented in the project record at the time the change is made.

When a vendor leads project delivery, an ECIO Administrator shall serve as the internal Project Owner and shall carry all oversight obligations defined in this policy. **Policy 1.13** governs the vendor governance obligations; this policy governs the internal accountability structure.

Project KPI performance data shall feed into the broader performance management framework defined in **Policy 5.04**.

6.9 Project Cancellation, Suspension, and IT Withdrawal

Internal Projects: Formal cancellation or suspension of an internal project requires IT Director authorization. All in-flight child work orders shall be closed or suspended with their current state documented. CMDB and KB entries shall be updated to reflect completed work. No obligation exists to revert partially-configured systems to their pre-project baseline.

External Projects — Agreed Closure: IT's role in an external project may be formally closed when the IT Director and all project sponsors concur that IT's role is complete. IT's role may be formally closed while the project continues under the sponsor's direction. Upon formal closure of IT's involvement, the Information Operations Department carries no further obligation for the project's outcomes.

External Projects — IT Withdrawal Over Objection: The IT Director and Assistant IT Director may jointly declare a formal IT withdrawal from an external project when continued involvement is technically, financially, or operationally untenable — for example, when scope changes imposed by external parties conflict with the Department's security, architecture, or resource obligations, or when the project direction creates unacceptable risk to County systems or ongoing service commitments. Neither the IT Director nor the Assistant IT Director may invoke withdrawal unilaterally.

Prior to withdrawal, the County Manager shall be notified in writing of the basis for the Department's position. The County Manager may, at her option, serve as a neutral arbitrator between the sponsoring agency and the Information Operations Department to ensure good-faith resolution before withdrawal is finalized,

consistent with **Policy 1.08**. If the County Manager's arbitration does not resolve the impasse, the IT Director and Assistant IT Director may proceed with withdrawal.

Upon withdrawal, the Project Owner and County Manager shall receive written notice documenting the basis for withdrawal and the current state of all IT work. All in-flight IT work orders shall be closed or suspended with their current state documented. CMDB and KB entries shall be updated to reflect completed work. No obligation exists to revert partially-configured systems to their pre-project baseline. The project may continue under the sponsor's direction; the Information Operations Department carries no further obligation for its outcomes.

6.10 Documentation Requirements

All project records shall include the following elements, maintained in Redmine as the system of record, attached to or linked from the master work order:

- Project Charter (IT Director approved; or catch-up charter for emergency designations, completed within five business days of emergency designation)
- Stakeholder Map
- Risk Log
- Timeline and Task Assignments
- Communication Plan
- KPI Results
- Post-Mortem Summary
- Ninety-day status review records (for projects exceeding ninety days in duration)
- Annual re-authorization record (for projects exceeding twelve months in duration)

Project records shall be retained under the work order retention framework established in **Policy 3.05**.

3.15 Service Continuity and Contingency Planning Policy

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the framework by which the Elko County Information Operations Department (ECIO) plans for, prepares against, and recovers from disruptions to IT services. It defines the governing requirements for business impact analysis, asset criticality classification, recovery objective-setting, continuity plan maintenance, backup governance, continuity plan activation, and operational recovery sequencing. It provides the planning artifacts against which operational incident response execution under **Policy 3.06** operates, and it establishes the receiving mechanics for operational recovery authority following a cybersecurity incident response phase governed by Chapter 4 policies.

2. Scope

This policy applies to all IT systems, services, and infrastructure operated or managed by the Information Operations Department. Governed activities include: Business Impact Analysis (BIA) development and maintenance, asset criticality classification, Recovery Time Objective (RTO) and Recovery Point Objective (RPO) definition, Continuity Plan development and maintenance, backup governance framework requirements, continuity plan activation, and operational recovery sequencing following plan activation or Operational Handback from Chapter 4.The following are outside the scope of this policy:

- Steady-state capacity and availability management — governed by **Policy 3.11**.
- Real-time monitoring, alerting, and event detection — governed by **Policy 3.12**.
- Operational incident response execution — governed by **Policy 3.06**.
- Cybersecurity incident response and security-phase recovery sequencing, including recovery operations during the active security response phase — governed by Chapter 4 policies. **Policy 4.05** governs recovery operations and Operational Handback initiation mechanics during that phase.
- Physical security and environmental controls, including UPS governance and emergency power — governed by **Policy 2.13**.
- Risk scoring and Risk Register maintenance — governed by **Policy 1.09**.
- Backup operational procedures, including execution, verification, and storage — maintained as Knowledge Base procedures under **Policy 3.13**.
- SLA target-setting for normal operations — governed by **Policy 3.01**.
- Change authorization for infrastructure changes identified during continuity planning — governed by **Policy 3.09**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the Incident Commander by default for all continuity plan activations, consistent with the designation established in **Policy 3.06**.
  - Shall serve as the approving authority for the Business Impact Analysis, including all criticality classification assignments, RTOs, RPOs, and backup minimums.
  - Shall serve as the approving authority for the Continuity Plan and all material amendments to it.

  - Shall authorize continuity plan activation under the Incident Commander judgment pathway defined in Section 6.3.
  - Shall authorize any formal exception to the testing cadence established in Section 6.5.
  - Shall receive the annual tabletop exercise findings report.
- **Assistant IT Director**:
  - Shall own the Business Impact Analysis as a planning artifact and shall maintain it on the cadence defined in Section 6.2.
  - Shall develop and maintain the Continuity Plan in Redmine.
  - Shall coordinate the annual tabletop exercise, document findings, and present the findings report to the IT Director.
  - Shall ensure that Knowledge Base documentation under **Policy 3.13** for backup procedures and test procedures remains current and consistent with the backup minimums approved in the BIA.
  - Shall ensure that CI records and CMDB entries under **Policy 3.08** reflect recovery configuration requirements for in-scope systems.
  - Shall coordinate with the Systems Administrator to ensure quarterly backup restoration verification records are produced and retained.
- **Systems Administrator**:
  - Shall execute backup operations in accordance with the procedures maintained in the Knowledge Base under **Policy 3.13**.
  - Shall implement and maintain cryptographic mechanisms to protect the confidentiality and integrity of all backups at rest and in transit.
  - Shall conduct quarterly backup restoration verification and document results in a restoration verification record.
  - Shall escalate backup failures or integrity verification failures to the Assistant IT Director within one business day of identification.
  - Shall participate in annual tabletop exercises.
- **Network Administrator**:
  - Shall maintain awareness of network infrastructure dependencies documented in the BIA.
  - Shall participate in annual tabletop exercises.
  - Shall support recovery operations as directed by the Incident Commander upon plan activation.
- **IT Staff**:
  - Shall execute assigned recovery tasks as directed by the Incident Commander upon plan activation.
  - Shall participate in annual tabletop exercises as designated by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel within scope.

- **Assessment**: Compliance with BIA maintenance, continuity plan currency, backup governance obligations, and testing cadence shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.

- **Enforcement**: Failure to maintain the BIA, produce or maintain the Continuity Plan, execute required backups, conduct required testing, or document required activation and handback decisions without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NIST CSF 2.0: ID.RA-04 (Risk Impacts)
- NIST CSF 2.0: RC.CO-03 (Recovery Communications)
- NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution)
- NIST CSF 2.0: RC.RP-02 (Recovery Actions Selection and Execution)
- NIST CSF 2.0: RC.RP-03 (Backup and Restoration Asset Integrity)
- NIST CSF 2.0: RC.RP-04 (Post-Incident Operational Norms)
- NIST CSF 2.0: RC.RP-05 (Restoration Verification)
- NIST CSF 2.0: RC.RP-06 (Recovery Closure and Documentation)
- NIST SP 800-53 Rev. 5: CP-1 (Contingency Planning Policy and Procedures)
- NIST SP 800-53 Rev. 5: CP-2 (Contingency Plan)
- NIST SP 800-53 Rev. 5: CP-4 (Contingency Plan Testing)

- NIST SP 800-53 Rev. 5: CP-9 (System Backup)
- NIST SP 800-53 Rev. 5: CP-9(8) (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: CP-10 (System Recovery and Reconstitution)
- COBIT 2019: DSS04 (Manage Continuity)
- ITIL v4: IT Service Continuity Management Practice

6. Policy Statement

6.1 Purpose and Governing Principle

The Department shall maintain a documented, tested, and IT Director-approved Continuity Plan that enables the restoration of IT services following any disruption affecting systems within the scope of this policy. Recovery planning under this policy governs failure scenarios; Service Level Agreement targets for normal operations are governed by **Policy 3.01**. The two frameworks are complementary and distinct — neither supersedes the other.

6.2 Business Impact Analysis

The Business Impact Analysis (BIA) is a formal planning artifact owned by the Assistant IT Director and approved by the IT Director. The BIA is distinct from the Risk Register governed by **Policy 1.09**. The Risk Register produces risk scores; the BIA produces recovery planning outputs. **Policy 1.09**'s Criticality Analysis informs BIA inputs; the BIA produces the criticality classifications, RTOs, RPOs, backup minimums, and recovery sequence priority order that continuity execution depends upon.

The BIA shall document, at minimum: a criticality classification assignment for each in-scope system and service using the four-class taxonomy defined in Section 6.4; the approved RTO for each criticality classification; the approved RPO for each criticality classification; the minimum backup frequency, retention period, and offsite storage requirement for each criticality classification; and the recovery sequence priority order across all in-scope systems.

The BIA shall be reviewed and updated no less than annually and following any Significant or Emergency change as defined in **Policy 3.09** that materially alters the service catalog or infrastructure. The IT Director shall approve each updated version before it takes effect.

6.3 Continuity Plan

The Continuity Plan is a governed document maintained in Redmine by the Assistant IT Director. The Continuity Plan shall be protected from unauthorized disclosure and modification. The Continuity Plan shall contain, at minimum:

- **Criticality Classification Register** — all in-scope systems and services assigned to one of the four classifications defined in Section 6.4, with BIA-derived RTO, RPO, and backup minimums for each classification documented alongside.
- **Recovery Sequence Priority Order** — the order in which systems are restored by classification. Where multiple systems exist within the same wave, the priority order within that wave shall be explicitly documented. Security Infrastructure sequencing shall follow the three-state rule defined in Section 6.4.
- **Backup Procedures Reference** — a pointer to the Knowledge Base procedures under **Policy 3.13** governing the operational execution of backups to achieve the BIA-approved schedules, retention cadences, and offsite storage requirements.
- **Activation Criteria and Authority** — a summary of the two-pathway activation model defined below and the documented authority for each pathway.

- **Operational Handback Protocol** — the receiving mechanics upon Operational Handback from Chapter 4, including documentation requirements and a cross-reference to **Policy 4.05** for handback initiation mechanics.
- **Recovery Procedures Reference** — pointers to system-specific recovery procedures maintained in the Knowledge Base under **Policy 3.13**.
- **Testing Records** — the most recent annual tabletop exercise record and the four most recent quarterly backup restoration verification records.

Continuity plan activation may occur through either of two pathways. Both pathways require the activation decision to be documented in the incident work order at the time it is made.

Objective Trigger: When the projected or elapsed restoration time for a disrupted system exceeds the RTO established for that system's criticality classification in the BIA, the Incident Commander shall declare continuity plan activation and initiate recovery procedures under this policy.

Incident Commander Judgment Pathway: The Incident Commander may declare continuity plan activation at any time, independent of whether the objective RTO threshold has been crossed, based on a documented professional assessment of operational conditions — for example, where the nature of the failure, resource availability, or cascading impact makes continued repair inadvisable before the RTO is breached. Qualitative assessments without supporting observations do not satisfy this requirement. The basis for the judgment shall be documented in the incident work order at the time of activation.

6.4 Asset Criticality Classification

The Department operates four asset classification classes for continuity and backup governance purposes. Specific RTO, RPO, and backup minimums for each classification are established in the BIA and approved by the IT Director.

- **Tier 1 — Mission Critical**: Systems whose failure immediately impairs the Department's ability to deliver mandated services or maintain operations across the County.
- **Tier 2 — Operationally Important**: Systems that support individual department functions. Their failure degrades service for specific departments but does not immediately impair County-wide operations.
- **Tier 3 — Administrative** / **Deferrable**: Systems that provide operational convenience or supplementary capability. County operations continue normally without these systems.
- **Security Infrastructure**: Systems that support the Department's security monitoring, logging, and vulnerability management functions. Recovery priority is driven by security posture rather than operational impact; sequencing follows the three-state rule below.

Recovery sequencing for Security Infrastructure is determined by the Incident Commander's declared event classification, documented in the incident work order:

- **Known non-security disruption:** Hardware failure, utility outage, natural disaster, or other event with no security nexus, as declared by the Incident Commander. Security Infrastructure recovers at Tier 2 priority, in the second wave alongside Tier 2 operational systems.
- **Known or suspected security event**: Operational Handback received from Chapter 4, or security nexus not yet ruled out. Security Infrastructure recovers concurrently with Tier 1. Log visibility shall be confirmed before broader restoration proceeds, to ensure no residual threat is present before systems are returned to the environment.
- **Unknown or unclassified disruption**: Treated as a suspected security event until the Incident Commander explicitly declares otherwise. Security Infrastructure recovers concurrently with Tier 1 by default. This principle is consistent with **Policy 3.06**, under which uncertainty is resolved in favor of caution.

6.5 Testing

The Assistant IT Director shall coordinate an annual tabletop exercise covering the full Continuity Plan. The exercise shall produce a written record documenting participants, scenarios tested, and findings, which the IT Director shall receive. IT staff designated for contingency roles shall receive contingency training within thirty days of assuming those responsibilities and following any significant change to the Continuity Plan or in-scope systems. Annual participation in the tabletop exercise satisfies the recurring training obligation; no additional training artifact is required.

The Systems Administrator shall conduct quarterly backup restoration verification by restoring from backup to a non-production environment and confirming data integrity. Results shall be documented in a restoration verification record. Backup failures or integrity verification failures shall be escalated to the Assistant IT Director within one business day of identification. Specific test procedures are maintained in the Knowledge Base under **Policy 3.13**.

The most recent annual tabletop exercise record and the four most recent quarterly backup restoration verification records shall be retained with the Continuity Plan. Exceptions to the testing cadence require written IT Director approval and shall be documented in the Continuity Plan.

6.6 Backup Governance

All in-scope systems shall have backups maintained in accordance with the parameters established in this section. The BIA shall define minimum backup frequency, retention period, and offsite storage requirements by asset classification, subject to IT Director approval. Operational procedures to execute, verify, and store backups in compliance with the BIA-approved parameters shall be maintained in the Knowledge Base under **Policy 3.13**. All backups shall be encrypted at rest and in transit regardless of the classification of the system being backed up.

6.7 Operational Handback

Operational Handback is the mechanism by which operational recovery authority passes from Chapter 4 back to this policy following a cybersecurity incident. **Policy 4.05** governs Operational Handback initiation — the conditions under which the Incident Commander declares the Chapter 4 security response phase complete, the declaration procedure, and the documentation requirements on the Chapter 4 side. This policy governs the receiving obligations that attach upon Operational Handback.

Chapter 4 authority holds until the Incident Commander explicitly declares Operational Handback. Ambiguity or assumption of handback is not permitted. Upon Operational Handback, the BIA-driven recovery priority order established in this policy governs operational restoration sequencing, subject to the Security Infrastructure sequencing rules in Section 6.4.

For hybrid events where a cybersecurity incident has also caused infrastructure failure, Chapter 4 holds full authority through the security response phase. This policy receives authority for operational restoration only after explicit Operational Handback is declared. The Incident Commander's declaration shall be documented in the incident work order at the time it is made. Upon receiving Operational Handback, the Assistant IT Director shall confirm that the Continuity Plan's Operational Handback Protocol section has been consulted and that recovery sequencing is proceeding in accordance with the BIA priority order.

6.8 Relationship to Change Management

Infrastructure changes identified as necessary during continuity planning or recovery operations require change authorization under **Policy 3.09**. This policy does not modify or supersede change authorization requirements.

6.9 Relationship to Capacity and Availability Management

Policy 3.11 governs steady-state capacity and availability management and explicitly designates failure-scenario recovery planning as the domain of this policy. The two policies are complementary; findings from

capacity or availability trend analysis conducted under **Policy 3.11** may inform BIA inputs.

6.10 Relationship to Monitoring and Event Management

Policy 3.12 governs real-time monitoring, alerting, and event detection and explicitly states that service continuity and recovery are governed by this policy. Events escalated under **Policy 3.12** that result in continuity plan activation are subject to the activation mechanics defined in Section 6.3.

3.16 Service Improvement and Continual Improvement Plan

Effective: July 01, 2026 Version: 1.0

1. Purpose

The purpose of this policy is to establish the governance framework by which the Elko County Information Operations Department identifies, logs, triages, and routes IT service improvement opportunities. This policy defines the Service Improvement Register as the authoritative record of improvement intake and triage activity, and the Service Improvement Plan as the initiation document for improvement initiatives that qualify for formal project designation under **Policy 3.14**. It establishes the Assistant IT Director as the owner of the improvement intake function and defines the conditions under which improvement work routes to the standard work order system or to formal project management.

This policy governs the intake funnel and the triage decision. Once a triage decision is made and the improvement is routed, execution is governed entirely by the receiving policy. Work order lifecycle, escalation, and closure are governed by **Policy 3.05** and **Policy 3.06**. Project execution is governed by **Policy 3.14**. Change authorization is governed by **Policy 3.09**.

2. Scope

In Scope: This policy governs the identification, logging, triage, and routing of all IT service improvement initiatives for the Information Operations Department. In-scope activities include:

- Service Improvement Register maintenance.
- Service Improvement Plan preparation.
- Intake from mandatory trigger sources.
- Triage decisions.
- Annual improvement summary production.

Out of Scope:

- Work order lifecycle management — governed by **Policy 3.05**.
- Operational incident response — governed by **Policy 3.06**.
- Root cause analysis and Problem investigation — governed by **Policy 3.07**.
- Technical execution of changes required to implement improvements — governed by **Policy 3.09**.
- Project execution lifecycle — governed by **Policy 3.14**
- Service continuity planning — governed by **Policy 3.15**.
- Annual governance and framework maturity scoring — governed by **Policy 5.07**.
- SLA target definition — governed by **Policy 3.01**.
- KPI taxonomy and baseline definition — governed by **Policy 5.04**.
- Performance data collection and SLA adherence measurement — governed by **Policy 3.02**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for all Service Improvement Plans and the corresponding project charters initiated under **Policy 3.14**. IT Director approval of a Service Improvement Plan constitutes charter approval under **Policy 3.14**.
  - Shall authorize cancellation of any Service Improvement Register entry that cannot be resolved through normal progression, with cancellation rationale documented in the register entry.
  - Shall receive the annual improvement summary as part of the **Policy 5.07** review cycle.
  - Shall authorize any formal exception to the obligations established in this policy in accordance with **Policy 1.08**.
- **Assistant IT Director**:
  - Shall own and maintain the Service Improvement Register in Redmine.
  - Shall log a Service Improvement Register entry upon identification of any mandatory intake trigger defined in Section 6.2.
  - Shall complete the triage decision for each Service Improvement Register entry and route it to the appropriate execution path in accordance with Section 6.3.
  - Shall prepare Service Improvement Plans for IT Director approval for all entries meeting the project route threshold defined in Section 6.3.
  - Shall record the linked work order or project record number in each Service Improvement Register entry at the time of routing.
  - Shall confirm closure of each Service Improvement Register entry when its linked work order or project record closes, within two business days of that closure.
  - Shall produce the annual improvement summary for submission to the IT Director in accordance with the **Policy 5.07** review cycle.
- **IT Staff**:
  - Shall surface operational observations, service delivery concerns, and process improvement candidates to the Assistant IT Director or IT Director through the channels established in **Policy 3.04**.
  - Shall execute improvement tasks as assigned through the standard work order system.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel.

- **Assessment**: Compliance with Service Improvement Register maintenance, triage obligations, and annual summary production shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to log required Service Improvement Register entries, complete required triage decisions, or produce the annual improvement summary without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NIST CSF 2.0: ID.IM-01 (Improvements are identified from evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements are identified from execution of operational processes, procedures, and activities)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-6 (Information Security Measures of Performance)
- COBIT 2019: APO11 (Manage Quality)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Service Improvement Register

The Service Improvement Register (SIR) is the authoritative record of the Department's improvement intake and triage activity. The Assistant IT Director shall maintain the SIR in Redmine. Each SIR entry shall record, at minimum: the improvement identified, the intake source, the date logged, the triage decision, the linked work order or project record number, and closure confirmation.

The SIR is a log. Once a SIR entry is routed and a work order or project record is linked, execution is governed entirely by the receiving policy. SIR entries shall remain linked to an active work order or project record from the time of routing through closure. Where a linked work order or project is cancelled, the SIR

entry shall be formally closed with a cancellation notation and IT Director authorization documented in the entry.

SIR records shall be retained for a minimum of two calendar years from the end of the calendar year in which the entry was created, in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule: LRDA 20071558 (Activity Reports).

6.2 Mandatory Intake Triggers

The Assistant IT Director shall log a SIR entry upon identification of any of the following:

- An SLA deviation meeting the escalation threshold defined in **Policy 3.02**.
- A KPI underperformance pattern identified under **Policy 5.04**.
- Closure of a Problem record under **Policy 3.07** where the permanent remediation identifies a systemic improvement opportunity beyond the immediate fix.
- A capacity or availability remediation plan produced under **Policy 3.11** that does not immediately require a change record under **Policy 3.09**.
- A threshold breach pattern identified under **Policy 3.12** that does not resolve through a single work order.
- Findings from the annual tabletop exercise conducted under **Policy 3.15**.
- Upward staff feedback surfaced through **Policy 3.04** that the Assistant IT Director or IT Director determines warrants a tracked improvement.
- IT Director or Assistant IT Director discretionary entry — any operational observation that warrants tracked improvement, regardless of source.

6.3 Triage and Execution Routing

Every SIR entry shall be triaged by the Assistant IT Director. The triage decision determines execution routing.

Work order route: Improvements that fall below the project designation threshold defined in **Policy 3.14**, Section 6.1 shall be routed to the standard work order system. The Assistant IT Director shall create a work order under **Policy 3.05**. The work order number shall be recorded in the SIR entry. All work order lifecycle, escalation, and closure obligations are governed by **Policy 3.05** and **Policy 3.06**.

Project route: Improvements that meet the project designation threshold defined in **Policy 3.14**, Section 6.1 — requiring three or more discrete work orders to complete, and requiring advance resource planning, stakeholder coordination, or sequenced task dependencies that cannot be captured within a single work order record — shall be routed to formal project management. The Assistant IT Director shall prepare a Service Improvement Plan and present it to the IT Director for approval. IT Director approval of the Service Improvement Plan constitutes charter approval under **Policy 3.14**, and the master work order shall be created in Redmine upon that approval. The project record number shall be recorded in the SIR entry. All project execution obligations are governed by **Policy 3.14**.

The Assistant IT Director or IT Director may designate any improvement as a formal project regardless of whether it meets the threshold criteria, consistent with the discretionary designation authority established in **Policy 3.14**, Section 6.1.

Any improvement initiative requiring alteration of a configuration item, software deployment, or infrastructure change shall generate a Request for Change governed by **Policy 3.09**, regardless of whether the improvement routes through the work order or project path. This policy authorizes the business objective; **Policy 3.09** governs the technical risk of implementation.

6.4 Service Improvement Plan

A Service Improvement Plan (SIP) is required for any SIR entry routed through the project path. The SIP serves as the project initiation document submitted to the IT Director for charter approval under **Policy 3.14**. The SIP obligation arises only when the project route threshold is met or a discretionary project designation is made under Section 6.3.

6.5 SIR Entry Closure

A SIR entry closes when its linked work order or project record closes. The Assistant IT Director shall confirm closure of the SIR entry within two business days of the linked artifact's closure.

6.6 Annual Improvement Summary

The Assistant IT Director shall produce an annual improvement summary documenting: volume of SIR entries logged, entries routed to work orders, entries routed to projects, entries closed, and entries cancelled. The summary shall be submitted to the IT Director as part of the **Policy 5.07** annual maturity review cycle. The summary is the evidentiary record that the improvement intake function is operating.

Annual improvement summaries shall be retained permanently in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule: LRDA 20071558 (Activity Reports).

3.17 System Maintenance and Vendor Repairs

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the requirements for authorized, documented, supervised, and verified maintenance and repair work performed on County IT systems. It ensures that all maintenance events are formally authorized before work begins, that maintenance records contain the content required for audit reconstruction, that data-bearing components are sanitized before leaving County facilities, and that systems are verified as correctly and securely operational upon completion of maintenance activity.

2. Scope

In Scope: This policy applies to all maintenance and repair work performed on County IT systems. Covered activity includes:

- Maintenance or repair performed by IT Department personnel, contractors, or vendors.
- Maintenance performed on-site or remotely.
- Systems serviced in place and systems from which a component is removed.
- Scheduled preventive maintenance.
- Reactive repairs.
- Component replacements.
- Warranty service calls.
- Remote diagnostic and repair sessions.

All three asset support classifications — IT-Managed, IT-Supported, and Vendor-Managed — are within scope, with differentiated obligations for each classification as defined in **Policy 1.12**, Section 6.2.

Out of Scope:

- Vendor relationship management, contracting, and access provisioning — governed by **Policy 1.13**.
- Ongoing vendor compliance and third-party assurance — governed by **Policy 5.06**.
- Change authorization for maintenance-driven configuration changes — governed by **Policy 3.09**.
- Work order lifecycle management — governed by **Policy 3.05**.
- CI record updates following maintenance activity — governed by **Policy 3.08**.
- Media sanitization execution standards — governed by **Policy 2.12**.
- Physical access control and escort requirements — governed by **Policy 2.13**.
- Remote session logging and audit trail obligations — governed by **Policy 2.11**.
- Service continuity and recovery planning — governed by **Policy 3.15**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for vendor or contractor technical work performed on IT-Managed assets.
  - Shall authorize the off-site removal of any County IT system component for maintenance, repair, or replacement.
  - Shall approve the authorized maintenance personnel list and the authorized maintenance tool list maintained in the Knowledge Base under **Policy 3.13**.
  - Shall authorize any formal exception to the obligations established in this policy in accordance with **Policy 1.08.**
- **Assistant IT Director**:
  - Shall serve as the primary operational owner of the maintenance and repair function.
  - Shall authorize vendor involvement in IT-Supported asset maintenance within contracted support scope.
  - Shall ensure that all maintenance activity is documented in the work order system with the required content defined in Section 6.5.
  - Shall ensure that post-maintenance verification is completed and documented before maintenance work orders are closed.
  - Shall ensure that the authorized maintenance personnel list and the authorized maintenance tool list in the Knowledge Base under **Policy 3.13** are current.
  - Shall directly observe, or designate IT Department personnel to directly observe, all remote maintenance sessions for the duration of the session.
- **IT Department Personnel**:
  - Shall ensure that no maintenance work begins on IT-Managed assets without the required authorization documented in a work order.
  - Shall escort vendor and contractor personnel during on-site maintenance activity on IT-Managed assets in accordance with **Policy 2.13**. When escorting personnel performing maintenance on systems that process, store, or transmit Criminal Justice Information (CJI), the designated escort shall be fully cleared and technically qualified to supervise the specific maintenance activity being performed.
  - Shall inspect maintenance tools against the approved list in the Knowledge Base under **Policy 3.13** before allowing use on County systems.
  - Shall conduct post-maintenance verification in accordance with Knowledge Base procedures under **Policy 3.13** and document results in the work order.
  - Shall directly observe remote maintenance sessions as designated by the Assistant IT Director.
- **Network Administrator** / **Systems Administrator**:
  - Shall ensure that remote maintenance sessions are conducted exclusively through County-approved secure remote access mechanisms in accordance with **Policy 1.13**.
  - Shall verify that the session and all associated network connections are fully terminated upon completion of remote maintenance activity.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel and for all contractors and vendors performing maintenance or repair work on County IT systems.

- **Assessment**: Compliance with this policy shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in**Policy5.07**. This policy is subject to the universal applicability and enforcement framework established in **Policy 5.01**.
- **Enforcement**: Failure to obtain required authorizations before maintenance commences, failure to document maintenance activity in a work order with the required content, or failure to complete post-maintenance verification before closing a work order shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted that would place County systems or CJI out of compliance with applicable CJIS Security Policy obligations. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- CJIS Security Policy v6.0: Section MA-2 (Controlled Maintenance)
- CJIS Security Policy v6.0: Section MA-3 (Maintenance Tools)
- CJIS Security Policy v6.0: Section MA-4 (Nonlocal Maintenance)
- CJIS Security Policy v6.0: Section MA-5 (Maintenance Personnel)
- CJIS Security Policy v6.0: Section MA-6 (Timely Maintenance)
- NIST CSF 2.0: PR.MA-02 (Remote Maintenance)

- NIST SP 800-53 Rev. 5: MA-2 (Controlled Maintenance)
- NIST SP 800-53 Rev. 5: MA-3 (Maintenance Tools)
- NIST SP 800-53 Rev. 5: MA-4 (Nonlocal Maintenance)
- NIST SP 800-53 Rev. 5: MA-5 (Maintenance Personnel)
- NIST SP 800-53 Rev. 5: MA-6 (Timely Maintenance)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: IT Asset Management Practice

6. Policy Statement

6.1 Authorization Requirements

Authorization requirements for maintenance and repair activity are differentiated by asset support classification as defined in **Policy 1.12**, Section 6.2.

IT-Managed Assets: No vendor, contractor, or non-IT Department personnel shall perform technical work on an IT-Managed asset without explicit written IT Director authorization. IT Department personnel initiating scheduled maintenance on IT-Managed assets shall obtain authorization in accordance with the IT-initiated work order requirements of **Policy 3.05**, Section 6.3: routine maintenance tasks may be authorized by the assigned technician in accordance with their defined role authority under **Policy 1.08**; non-routine or significant maintenance tasks shall be authorized by the Assistant IT Director or IT Director prior to work commencement. When maintenance activity is performed on systems that process, store, or transmit CJI, the IT Department escort shall be fully cleared and technically qualified to supervise the specific maintenance activity being performed.

IT-Supported Assets: Vendor involvement in maintenance on an IT-Supported asset that falls within the contracted support scope shall be authorized by the Assistant IT Director. Vendor involvement outside the contracted support scope shall require IT Director authorization.

Vendor-Managed Assets: Vendor personnel performing maintenance within their exclusive support domain do not require ECIO authorization. The IT Department's obligations for Vendor-Managed maintenance events are limited to access facilitation in accordance with **Policy 1.13**, physical escort in accordance with **Policy 2.13**, and work order documentation of coordination activity in accordance with **Policy 1.12**.

All maintenance activity shall be documented in a work order prior to commencement, except as provided under the emergency exception defined in **Policy 3.05**. The authorizing official and the basis for authorization shall be recorded in the work order before work begins.

6.2 Remote Maintenance Session Controls

All remote maintenance sessions on County IT systems shall be directly observed by the IT Department personnel assigned to the work order for the duration of the session. Unmonitored remote access — including desktop sharing, screen sharing, or any remote control session initiated by any party — is strictly prohibited regardless of asset classification.

Remote maintenance sessions shall be conducted exclusively through County-approved secure remote access mechanisms in accordance with **Policy 1.13**. Remote session logging and audit trail obligations are governed by **Policy 2.11**.

Upon completion of remote maintenance, the IT Department personnel observing the session shall verify that the session and all associated network connections have been fully terminated before the maintenance work order is closed. Termination verification shall be documented in the work order.

6.3 Maintenance Tool Controls

Any maintenance tool — hardware, software, or firmware — brought onto County premises or connected remotely for maintenance purposes shall appear on the approved maintenance tool list maintained in the Knowledge Base under **Policy 3.13**. No maintenance tool may be used on County systems unless it appears on that list.

Media containing diagnostic or test programs shall be inspected for malicious code before use on any County system. Maintenance tools brought by vendors or contractors shall be subject to the same inspection requirement as tools used by IT Department personnel. Tool inspection procedures are maintained in the Knowledge Base under **Policy 3.13**.

Prior to the removal of any vendor-supplied or contractor-supplied maintenance tool or diagnostic equipment from County facilities, the IT Department personnel assigned to the work order shall verify that the equipment contains no County data, or shall ensure the equipment is sanitized before departure.

The IT Director shall approve the authorized maintenance tool list. The Assistant IT Director shall ensure the list is current.

6.4 Post-Maintenance Verification

Upon completion of any maintenance or repair activity on an IT-Managed or IT-Supported asset, the IT Department personnel assigned to the work order shall verify that the system and all potentially affected controls are functioning correctly before the maintenance work order is closed. Post-maintenance verification procedures are maintained in the Knowledge Base under **Policy 3.13**.

Verification results shall be documented in the work order. A work order shall not be closed in the absence of a documented post-maintenance verification result.

6.5 Maintenance Record Content Standard

Maintenance records are work orders governed by **Policy 3.05**. Each work order documenting a maintenance event shall contain, at minimum, the following content:

- The name and serial number of the component serviced
- The date and time of maintenance
- A description of the maintenance performed
- The name of the personnel performing the maintenance
- The name of the IT Department escort, where escort was required
- The post-maintenance verification result

This content standard supplements the work order documentation requirements established in **Policy 3.05** and **Appendix ??**. Where this standard imposes additional requirements beyond those established in **Policy 3.05**, this standard governs.

6.6 Off-Site Component Removal

No County IT system component shall be removed from County facilities for off-site maintenance, repair, or replacement without explicit written IT Director authorization. The authorization shall be documented in the work order prior to removal.

Prior to removal, the component shall be sanitized in accordance with **Policy 2.12** to remove County data from all associated media. If sanitization is not technically feasible prior to removal, the IT Director shall authorize an alternative control, which shall be documented in the work order in lieu of the sanitization confirmation.

The work order shall record the authorization, the sanitization confirmation or the authorized alternative control, and the chain of custody for the removed component from departure through return or disposal.

6.7 Timely Maintenance for CJI-Processing Systems

Maintenance support and spare parts for system components that process, store, or transmit Criminal Justice Information (CJI) shall be obtained within the recovery time objective (RTO) and recovery point objective (RPO) defined for those systems in **Policy 3.15**. This requirement ties maintenance support availability to the existing continuity planning framework established in **Policy 3.15** and does not create independent planning obligations.

6.8 Retention

Work orders documenting maintenance and repair activity under this policy shall be retained for a minimum of three (3) calendar years after the repair is completed, in accordance with NRS 239.125.

4. Incident Response

4.01 Incident Response Policy Overview

Effective: July 01, 2026 Version: 1.0

1. Purpose

The Elko County Information Operations Department (ECIO) establishes this policy to define the authority, structure, and program framework governing the Department's cybersecurity incident response capability. This policy is the governing capstone of Chapter 4 (Incident Response) of the ECIO Policy Manual and constitutes the Department's formal cybersecurity incident response program statement for submission to the Nevada state cyber defense office.

This policy serves two distinct audiences: internal personnel and auditors evaluating it within the full context of the ECIO Policy Manual, and external reviewers—including the Nevada state cyber defense office—who may review it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside elsewhere in the manual, it states the operative substance in plain language. Those statements are incorporative and do not constitute independent definitions; the ECIO Policy Manual's governance framework remains the authoritative source.

Chapter 4 Subordination Principle. Chapter 4 is an explicitly subordinate program framework within the ECIO Policy Manual. No policy in Chapter 4 creates an independent authority structure, modifies role definitions or authorities established elsewhere in the manual, or supersedes any obligation established in Chapters 1 through 3 or Chapter 5. Where Chapter 4 references a role, timeline, classification, or procedure established in another policy, that reference is incorporative — Chapter 4 operates under those established definitions without restating or redefining them. This principle is established here once and governs the entire chapter.

2. Scope

This policy governs the establishment, authority, structure, and program framework of the ECIO cybersecurity incident response capability. It applies to all IT systems, services, and infrastructure operated or managed by the Information Operations Department, and to all IT Department personnel.

Governed activities include: formal declaration of cybersecurity incidents, exercise of Incident Commander authority during cybersecurity incidents, the IR lifecycle framework used to organize response activity, mandatory external reporting obligations, and the operational policy roadmap established in Section 6.2.

The following are outside the scope of this policy:

- Physical security and environmental controls — governed by **Policy 2.13**.
- Service level commitments and five-tier operational severity classification — governed by **Policy 3.01**.
- Operational incident response for non-security service disruptions — governed by **Policy 3.06**.
- Business continuity, RTO/RPO definitions, and contingency planning — governed by **Policy 3.15**.
- Indicator of Compromise (IoC) definition and incident identification procedures — governed by **Policy 4.02**.
- Containment strategy selection and playbook execution — governed by **Policy 4.03**.
- Eradication procedures and scenario-specific guidance — governed by **Policy 4.04**.
- Recovery operations and Operational Handback initiation mechanics — governed by **Policy 4.05**.
- Incident communication execution and stakeholder notification — governed by **Policy 4.06**.

- Data and system classification for recovery prioritization — governed by **Policy 4.05.**
- Postmortem review and lessons learned procedures — governed by **Policy 4.07**.
- IR roles and contact directory — governed by**Policy4.08**.
- External partner integration procedures — governed by**Policy4.06**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 3.06**, Section 6.3 and incorporated into this chapter.
  - Shall hold primary authority to declare a cybersecurity incident, subject to the delegation provisions established in Section 6.1 of this policy.
  - Shall exercise final authority over all incident response activity as Incident Commander for the duration of the incident, including technician assignments, escalation decisions, external vendor engagement, and communication authorization.
  - Shall authorize emergency procurement necessary to maintain or restore mandated security controls, using County emergency procedures with after-the-fact ratification, consistent with **Policy 1.08**.
  - Shall serve as the sole authoritative source for strategic and public-facing incident communications under the One Voice Rule established in **Policy 4.06**.
  - Shall execute all incident reporting obligations mandated by the CJIS Security Policy in the capacity of the Local Agency Security Officer (LASO).
  - Shall identify in writing the Tier L3+ technical lead(s) authorized to declare cybersecurity incidents and serve as Incident Commander, subject to annual review, in accordance with **Policy 1.08**.
  - Shall authorize any formal exception to the obligations established in this policy in accordance with **Policy 1.08**.
- **Assistant IT Director**:
  - Shall serve as Incident Commander in the IT Director's absence or by IT Director designation.
  - Shall hold authority to declare a cybersecurity incident when the IT Director is genuinely unavailable and the operational situation requires immediate action.
  - Shall serve as the primary operational coordinator for incident response activities under Incident Commander direction.
  - Shall ensure the IR Roles and Contact Directory maintained under**Policy4.08** is current.
  - Shall ensure all IT Department personnel maintain familiarity with the IR lifecycle framework established in this policy and their respective obligations under Chapter 4.
- **IT Department Personnel**:
  - Shall execute incident response activities as directed by the Incident Commander.
  - Shall initiate the Hard Fork procedure established in **Policy 3.06**, Section 6.2 upon discovery of any Indicator of Compromise, without exception.
  - Shall not communicate incident scope, affected systems, attribution, or recovery timelines to external parties, media, or non-IT County personnel without express Incident Commander authorization.

  - Shall maintain familiarity with the IoC list maintained in **Policy 4.02** and the chapter roadmap established in Section 6.2 of this policy.
- **Network Administrator / Systems Administrator**:
  - Shall provide technical IR support as directed by the Incident Commander.
  - Shall execute containment, eradication, and recovery technical actions under Incident Commander authority in accordance with **Policy 4.03**, **Policy 4.04**, and **Policy 4.05**.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel in accordance with **Policy 5.01**.

- **Assessment**: Compliance with the IR program obligations established in this policy shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** and the internal audit and self-assessment procedures defined in **Policy 5.02**.
- **Enforcement**: Failure to observe declaration authority requirements, failure to initiate the Hard Fork procedure upon IoC discovery, failure to document Incident Commander designations at the time they are made, or unauthorized external communication of incident information, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols
- ECIO Policy 4.05: Data and System Classification for Recovery
- ECIO Policy 4.07: Postmortem Review and Lessons Learned

- ECIO Policy4.08: Incident Response Roles and Contact Directory
- ECIO Policy4.06: Integration with Local, State, and Federal Partners
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of breach of security of system data)
- CJIS Security Policy v6.0: Section IR-1 (Incident Response Policy and Procedures)
- CJIS Security Policy v6.0: Section IR-2 (Incident Response Training)
- CJIS Security Policy v6.0: Section IR-3 (Incident Response Testing)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section IR-8 (Incident Response Plan)
- NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution)
- NIST CSF 2.0: RS.CO-02 (Stakeholder Notification)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-02 (Incident Report Triage and Validation)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST CSF 2.0: RS.MA-04 (Incident Escalation and Elevation)
- NIST SP 800-53 Rev. 5: IR-1 (Incident Response Policy and Procedures)
- NIST SP 800-53 Rev. 5: IR-2 (Incident Response Training)
- NIST SP 800-53 Rev. 5: IR-3 (Incident Response Testing)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: (Incident Response Recommendations and Considerations for Cyber Risk Management)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: DSS04 (Manage Continuity)
- ITIL v4: Incident Management Practice
- ITIL v4: Service Continuity Management Practice

6. Policy Statement

6.1 ECIO Cybersecurity Incident Response Program

Program Establishment. The ECIO shall maintain a formal cybersecurity incident response program to detect, contain, eradicate, and recover from cybersecurity incidents affecting IT systems, services, and infrastructure under the Department's management. The program is established and governed by this policy. It is a subordinate program framework within the ECIO Policy Manual and operates within the governance structure established across Chapters 1 through 3 and Chapter 5.

The ECIO does not maintain a formally designated, standing Incident Response Team. Cybersecurity incident response is executed by IT Department personnel under Incident Commander authority. The absence of a standing team does not diminish the rigor or authority of the program; it reflects the Department's operating model, in which response authority is vested in defined roles rather than a standing team construct.

Incident Commander. The IT Director shall serve as Incident Commander for all cybersecurity incidents by default. The IT Director may designate any IT Department staff member as Incident Commander for a specific incident; designations shall be made at the time they become effective and documented in the incident record. The Incident Commander shall exercise final authority over all incident response activity for the duration of the incident. This title is singular within the ECIO framework — no parallel title exists. The Incident Commander role is established in **Policy 3.06**, Section 6.3 and incorporated into Chapter 4 by reference without modification.

Declaration Authority. Authority to declare a cybersecurity incident shall reside with the IT Director and the Assistant IT Director. A designated Tier L3+ technical lead may declare a cybersecurity incident only when the IT Director and the Assistant IT Director are both genuinely unavailable and the operational situation requires immediate action. The technical lead(s) authorized to exercise this authority shall be identified in writing by the IT Director in accordance with **Policy 1.08** and reviewed at least annually. Upon declaration, all operational authority shall transfer immediately and exclusively to the Incident Commander. Administrative stand-ins shall not intervene in, delay, or countermand Incident Commander directives. Fiscal Affairs and Purchasing shall process Incident Commander emergency procurement requests without delay.

Incident Severity Classification. Chapter 4 shall use a three-tier severity classification to categorize cybersecurity incidents. This classification is independent of, and does not interact with, the five-tier operational severity framework (Critical, Urgent, High, Normal, Low) established in **Policy 3.01** for service level management. **Policy 3.01** SLA obligations are suspended for the duration of any active Chapter 4 incident per the Hard Fork mechanics established in **Policy 3.06**, Section 6.2.

The three tiers are as follows:

- **High** — Incidents with confirmed or severe impact on operations, Criminal Justice Information (CJI), or public safety systems. Examples include compromise of sensitive or CJI data, widespread malware or ransomware, unauthorized access to critical systems, and denial-of-service attacks affecting enterprise operations.
- **Medium** — Incidents with significant current impact or confirmed potential for severe impact. Examples include small-scale denial-of-service attacks, website compromise, unauthorized access attempts with confirmed breach, and phishing campaigns with confirmed credential capture.
- **Low** — Incidents with minimal current impact but potential for escalation if unaddressed. Examples include network probes or reconnaissance scans, isolated virus infections, acceptable use violations, and unconfirmed anomalies under active investigation.

Severity may be reclassified upward or downward at any point during the response at the Incident Commander's direction. The initial severity classification shall be documented in the incident record at the time of declaration.

IR Lifecycle Framework. The ECIO IR program shall be organized around a six-phase lifecycle: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned. This is ECIO's selected framework, consistent with the incident response lifecycle model recognized in NIST SP 800-61 Rev. 3,

which affirms that organizations should use the lifecycle framework that best suits their operating model. Each phase is governed by one or more of the operational policies in Chapter 4, as mapped in Section 6.2 of this policy.

Relationship to Operational Incident Management — Hard Fork. The ECIO distinguishes between two categories of adverse IT events. **Policy 3.06** governs operational incidents — unplanned technical failures whose resolution requires restoring service as quickly as possible. Chapter 4 governs cybersecurity incidents — events involving malicious activity, unauthorized access, data compromise, or any Indicator of Compromise as defined in **Policy 4.02**. These two regimes are not interchangeable and one shall not be substituted for the other. A Chapter 4 response may deliberately extend an outage to stop active compromise, preserve forensic evidence, or prevent further damage; speed of restoration is subordinate to containment and forensic integrity.

When a technician working a **Policy 3.06** operational incident discovers any condition that constitutes an Indicator of Compromise, **Policy 3.06** immediately and automatically subordinates to Chapter 4. This jurisdictional transfer is called the Hard Fork. It is not discretionary and does not require supervisor approval. The canonical IoC list that triggers the Hard Fork is maintained in **Policy 4.02**. The mechanics governing the Hard Fork procedure are established in **Policy 3.06**, Section 6.2 and incorporated into this chapter by reference.

CJIS Incident Reporting. The CJIS Security Policy establishes a two-part incident reporting obligation. First, all IT Department personnel shall report any suspected or confirmed security incident to the Incident Commander immediately, not to exceed one (1) hour after discovery. Second, upon the Incident Commander's confirmation of a reportable incident, the IT Director, acting in the capacity of the Local Agency Security Officer (LASO), shall notify the CJIS Systems Officer (CSO), the State Identification Bureau (SIB) Chief, or the Interface Agency Official as required by CJIS Security Policy Section IR-6. The CJIS Security Policy does not attach a specific timer to this external notification obligation; it is triggered by confirmation, not by the one-hour internal reporting clock. This obligation is acknowledged here at the program level. Its operational execution — including notification mechanics, documentation requirements, and escalation procedures — is governed by **Policy 4.02** and **Policy 4.06**.

Breach Notification. Public and stakeholder notification regarding security breaches affecting personal information shall be executed in strict accordance with NRS 603A.220, which requires notification in the most expedient time possible following discovery of a breach. This obligation is acknowledged here at the program level. Its operational execution is governed by **Policy 4.06**.

External Partner Relationships. The ECIO maintains active membership in the Multi-State Information Sharing and Analysis Center (MS-ISAC) and the Nevada Information Sharing and Analysis Center (NV-ISAC). These memberships provide access to threat intelligence, incident coordination resources, and analytical support from the broader state and national cybersecurity community. The ECIO also maintains working relationships with the Federal Bureau of Investigation (FBI) and the Nevada Department of Public Safety (DPS) for purposes of incident coordination and law enforcement referral. The operational procedures governing engagement with these and other external partners are established in**Policy4.06**.

Operational Handback. When the security response phase of a cybersecurity incident concludes — that is, when the threat has been contained, eradicated, and the affected environment has been stabilized to a state suitable for operational recovery — the Incident Commander shall issue an explicit Operational Handback declaration. This declaration marks the transfer of recovery authority from Chapter 4 back to the operational continuity framework governed by **Policy 3.15**. Operational Handback shall never be assumed; ambiguity is not permitted. An incident remains under Chapter 4 authority until the Incident Commander explicitly declares otherwise. The full mechanics governing Operational Handback initiation are established in **Policy 4.05**. **Policy 3.15** governs the receiving obligations on the continuity side of the transfer.

Record Retention. Incident records produced under Chapter 4 — including incident work orders, declaration documentation, Incident Commander designation records, evidence preservation logs, communication records, and postmortem reports — shall be retained in accordance with the Nevada Local Government Records Retention Schedule and NRS 239.125. Specific retention obligations for each record type are

established in the governing policy for that record type: **Policy 4.02** governs incident reports, **Policy 4.06** governs communication records, and **Policy 4.07** governs postmortem reports.

6.2 Chapter 4 Policy Roadmap

This section provides a navigational overview of the operational policies governing each phase of the ECIO cybersecurity incident response lifecycle. Each policy is summarized below with its lifecycle phase alignment, primary governing subject, and key interfaces with other Chapter 4 policies. This roadmap is provided for the benefit of both IT Department personnel and external reviewers who may not have access to the full ECIO Policy Manual.

Policy 4.02 — Identification and Reporting Procedures

Lifecycle Phase: Identification

Policy 4.02 is the first operational policy activated upon cybersecurity incident declaration. It maintains the canonical list of Indicators of Compromise (IoCs) that govern both the Hard Fork procedure under **Policy 3.06** and the initial identification of cybersecurity incidents under Chapter 4. **Policy 4.02** establishes the intake and triage procedures for newly declared incidents, the documentation requirements for the incident record from the moment of declaration forward, and the CJIS one-hour internal reporting mechanics and notification sequence required under CJIS Security Policy Section IR-6. It also governs incident record retention. **Policy 4.02** feeds directly into **Policy 4.03** (Containment) upon completion of initial identification and triage.

Policy 4.03 — Containment Strategy and Playbooks

Lifecycle Phase: Containment

Policy 4.03 governs the selection and execution of containment strategies following incident identification. It establishes the decision framework the Incident Commander uses to select a containment approach — including considerations of operational impact, forensic preservation, and threat scope — and maintains the playbooks for specific incident scenarios that guide technical response staff through containment execution. **Policy 4.03** operates in direct sequence following **Policy 4.02** and interfaces with **Policy 4.04** (Eradication), as containment decisions affect the scope and sequencing of eradication activity. Technical configuration actions taken under **Policy 4.03** trigger change authorization obligations governed by **Policy 3.09**.

Policy 4.04 — Eradication Procedures and Scenario Guides

Lifecycle Phase: Eradication

Policy 4.04 governs the removal of threat actors, malicious artifacts, and compromised configurations from the affected environment following containment. It establishes the eradication decision criteria used to confirm that the threat has been fully neutralized before the recovery phase begins, and maintains scenario-specific eradication guides for the incident types most likely to affect ECIO systems. **Policy 4.04** operates in sequence following **Policy 4.03**. It interfaces with **Policy 4.05** (Recovery), as the eradication completion determination is the primary criterion for initiating the recovery phase. CI record update obligations triggered by eradication-driven changes are governed by **Policy 3.08**.

Policy 4.05 — Recovery Operations and Restoration Prioritization

Lifecycle Phase: Recovery

Policy 4.05 governs the restoration of IT systems, services, and infrastructure to normal operational status following the completion of eradication. It establishes the recovery sequencing framework — determining the order in which systems are restored based on criticality classifications maintained under **Policy 4.05** — and governs the verification criteria required before any system is returned to production status. **Policy 4.05** also owns the Operational Handback initiation mechanics: the Incident Commander's formal declaration that the security response phase is complete and that recovery authority transfers to **Policy 3.15**. **Policy 4.05** interfaces with **Policy 3.15** (continuity receiving mechanics), **Policy 4.05** (criticality and classification), and **Policy 4.06** (recovery communication obligations).

Policy 4.06 — Communication Protocols

Lifecycle Phase: Spans all phases

Policy 4.06 governs all internal and external communications produced during a cybersecurity incident. It establishes the One Voice Rule — the requirement that all strategic and public-facing communications be authorized by the Incident Commander and issued through a single authoritative channel — and defines the communication cadences, authorized audiences, and approval requirements for each communication type. **Policy 4.06** governs the operational execution of both the CJIS external notification obligation (acknowledged in this policy and initiated in **Policy 4.02**) and the NRS 603A.220 breach notification obligation. It applies from the moment of incident declaration through the conclusion of post-incident communications following Operational Handback. **Policy 4.06** interfaces with every other Chapter 4 policy at the point where that policy triggers a communication obligation.

Policy 4.05 — Data and System Classification for Recovery

Lifecycle Phase: Support infrastructure — Preparation and Recovery

Policy 4.05 maintains the data and system criticality classifications that drive recovery prioritization during a cybersecurity incident. Unlike the operational Chapter 4 policies that govern sequential phases of the IR lifecycle, **Policy 4.05** is support infrastructure: it is prepared during the Preparation phase and consumed during the Recovery phase by **Policy 4.05**. It establishes the classification criteria and tier assignments for ECIO systems and data assets, and requires that those classifications be reviewed and validated on a defined cadence so that they remain accurate at the time of an actual incident. **Policy 4.05** interfaces with **Policy 3.15**, which uses the same classification framework for continuity planning purposes.

Policy 4.07 — Postmortem Review and Lessons Learned

Lifecycle Phase: Lessons Learned

Policy 4.07 governs the postmortem review process conducted following the closure of a cybersecurity incident. It establishes the mandatory postmortem trigger conditions, the postmortem review structure, the timeline for completion, and the documentation requirements for findings and corrective actions. Postmortem findings that identify systemic failures in controls, configurations, or procedures shall be routed to the Risk Register maintained under **Policy 1.09**. **Policy 4.07** is distinct from the Problem Management postmortem process governed by **Policy 3.07**, which applies to operational incidents. Cybersecurity incident postmortems are exclusively governed by **Policy 4.07**. Postmortem reports are subject to the retention obligations established in this policy.

Policy4.08 — Incident Response Roles and Contact Directory

Lifecycle Phase: Support infrastructure — all phases

Policy4.08 maintains the IR Roles and Contact Directory — the living reference document that identifies current personnel assigned to incident response roles, their contact information, and the escalation sequence to be followed during an active incident. This directory is support infrastructure consumed across all phases of the IR lifecycle. It does not establish role authority or delegation rights; those originate in **Policy 1.07** and **Policy 1.08** and are incorporated by reference.**Policy4.08** requires that the directory be reviewed and validated at a defined cadence and updated immediately upon any personnel change affecting an IR role assignment. The Incident Commander designation records required under this policy and **Policy 3.06** are maintained separately from the directory in the incident record at the time of designation.

Policy4.06 — Communication Protocols and Partner Integration

Lifecycle Phase: Support infrastructure — spans Identification through Recovery

Policy4.06 governs incident communication protocols and incorporates external partner integration as a dedicated subsection. The partner integration subsection of**Policy4.06** establishes the conditions and criteria under which ECIO initiates contact with the MS-ISAC, NV-ISAC, FBI, Nevada DPS, and other external entities; the authorization requirements for sharing incident information with external parties; and the documentation obligations for all external partner interactions. All external partner engagement during an active

incident requires Incident Commander authorization and shall be executed within the One Voice Rule and communication authorization framework established by**Policy4.06**. Partner integration is not governed by a standalone policy; it is addressed as an integrated subsection of**Policy4.06**.

4.02 Identification and Reporting Procedures

Effective: July 01, 2026 Version: 1.0

1. Purpose

Policy 4.02 establishes the identification, intake, triage, classification, notification, and documentation obligations for all cybersecurity incidents within the Elko County Information Operations Department (ECIO). This policy normalizes seven distinct upstream intake paths into a single, consistent handling framework; maintains the canonical Indicator of Compromise (IoC) list that governs incident declaration throughout the manual; and establishes the CJIS-compliant reporting mechanics and incident record structure required for operational execution and audit accountability. **Policy 4.02** is activated immediately upon potential cybersecurity incident discovery and governs all activity through declaration and handoff to the appropriate operational response policies.

2. Scope

In Scope

This policy applies to all ECIO personnel, contractors, and vendors operating within or interfacing with ECIO systems. It governs:

- Maintenance and governance of the canonical IoC list, including its two-layer architecture and amendment procedures.
- Intake channel normalization for all upstream referrals originating from **Policy 1.09**, **Policy 1.13**, **Policy 2.08**, **Policy 2.13**, **Policy 3.03**, **Policy 3.05**, **Policy 3.06**, and **Policy 3.12**.
- IoC evaluation, incident declaration, and decline documentation.
- Incident type and severity classification.
- CJIS IR-6 internal one-hour reporting mechanics and external notification obligation triggers.
- Incident record structure, mandatory documentation requirements, and the Chapter 4 checklist template.
- Triage authority, declaration authority, and delegation parameters.
- Evidence artifact preservation and retention.
- False positive disposition and indicator review procedures.

Out of Scope

The following matters are governed by the indicated policies and shall not be addressed under this policy:

- Operational incident response for non-security events — **Policy 3.06**.
- Hard Fork procedure mechanics — **Policy 3.06**, Section 6.2.
- CI record updates following incident-driven changes — **Policy 3.08**.
- Catch-up RFC documentation for emergency configuration changes — **Policy 3.09**.
- Monitoring event classification and work order generation — **Policy 3.12**.
- Containment strategy selection and execution — **Policy 4.03**.
- Eradication procedures — **Policy 4.04**.

- Recovery operations and Operational Handback — **Policy 4.05**.
- Communication execution and external notification mechanics — **Policy 4.06**.
- Data and system classification for recovery — **Policy 4.05**.
- Postmortem review and lessons learned — **Policy 4.07**.
- Incident Response Roles and Contact Directory —**Policy4.08**.
- External partner engagement procedures —**Policy4.06**.

3. Roles and Responsibilities

- IT Director:
  - Shall serve as Incident Commander for all cybersecurity incidents by default, per **Policy 3.06**, Section 6.3.
  - Shall hold primary declaration authority per **Policy 4.01**, Section 6.1 and **Policy 1.08**.
  - Shall review Safety and Security work orders in the Redmine queue and release them to Reviewed status upon declaration, or document the basis for decline in the work order notes.
  - Shall execute CJIS IR-6 Part (b) external notification obligations in the role of LASO, within the notification windows established in Section 6.6 of this policy.
  - Shall approve any structural change to Layer 1 IoC categories or definitions.
  - Shall identify in writing the Tier L3+ technical leads authorized to declare incidents and serve as Incident Commander, per **Policy 1.08**.
  - Shall authorize formal exceptions to the requirements of this policy per **Policy 1.08**.
- Assistant IT Director:
  - Shall hold declaration authority in the IT Director's absence, per **Policy 4.01**, Section 6.1.
  - Shall review Safety and Security work orders and release them to Reviewed status in the IT Director's absence or upon IT Director direction.
  - Shall own and maintain the Layer 2 IoC indicator artifact in Redmine under standing maintenance authority, with IT Director notification upon each update.
  - Shall conduct the thirty-day false positive indicator review for each flagged indicator.
  - Shall conduct the quarterly IoC list review.
  - Shall ensure the Chapter 4 checklist template in the Knowledge Base remains current, per **Policy 3.13**.
- IT Department Personnel:
  - Shall create a Safety and Security category work order in Redmine immediately upon discovery of any condition that may constitute an IoC, without exception.
  - Shall create Safety and Security work orders on behalf of external reporters — including vendors, end-users, and members of the public — documenting the reporting party as the source.
  - Shall not perform any response activity on a suspected cybersecurity incident without an associated work order.
  - Shall maintain familiarity with Layer 1 IoC categories and the Layer 2 indicator artifact.
  - Shall treat uncertain conditions as IoCs and initiate intake, consistent with the false-positive-safe principle established in **Policy 3.06**.

- Network Administrator / Systems Administrator:
  - Shall provide domain-specific technical analysis as delegated by the Incident Commander.
  - Network Administrator shall lead analysis for network-related incidents.
  - Systems Administrator shall lead analysis for server and endpoint-related incidents.
  - Shall not exercise declaration authority by virtue of delegated analysis responsibility alone; declaration authority remains with the IT Director, the Assistant IT Director, or a Tier L3+ technical lead designated in writing by the IT Director per **Policy 1.08**.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel, contractors, and vendors subject to ECIO governance, in accordance with **Policy 5.01**.

- **Assessment**: Compliance with IoC list governance, intake and triage obligations, classification and documentation requirements, CJIS notification mechanics, and retention obligations shall be assessed through the internal audit and self-assessment procedures defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to create required work orders, failure to perform IoC evaluation before other response activity, failure to document declaration or decline with its basis, failure to execute CJIS notification within the windows established in Section 6.6, or failure to maintain required retention obligations, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in advance in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. No exception may suspend or modify the CJIS notification obligations established in Section 6.6.

5. References

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.08: System Integrity and Malware Protection Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.03: End-User Communication Standards
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.06: Communication Protocols

- ECIO Policy 4.05: Data and System Classification for Recovery
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy4.08: Incident Response Roles and Contact Directory
- ECIO Policy4.06: Integration with Local, State, and Federal Partners
- ECIO Policy 5.01: Policy Implementation and Enforcement Framework
- ECIO Policy 5.02: Internal Audits and Self-Assessment Procedures
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of breach of security of system data)
- CJIS Security Policy v6.0: Section AU-11 (Audit Record Retention)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section IR-8 (Incident Response Plan)
- NIST CSF 2.0: DE.AE-02 (Potentially Adverse Events Analysis)
- NIST CSF 2.0: DE.AE-03 (Event Data Aggregation)
- NIST CSF 2.0: DE.AE-06 (Adverse Event Information Sharing)
- NIST CSF 2.0: RS.AN-03 (Incident Analysis and Root Cause)
- NIST CSF 2.0: RS.AN-08 (Incident Magnitude Estimation)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-02 (Incident Report Triage and Validation)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: (Incident Response Recommendations and Considerations for Cyber Risk Management)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

6.1 Indicator of Compromise List Architecture

Policy 4.02 maintains the canonical IoC list that governs cybersecurity incident declaration across the ECIO Policy Manual. The list uses a two-layer architecture separating permanent categorical triggers from current technical indicators.

- **Layer 1 — Categorical Triggers**. Layer 1 consists of six permanent, technology-agnostic categories that constitute an IoC regardless of how they manifest technically. Layer 1 categories reside in this policy text. They shall not change unless the fundamental nature of cybersecurity threats changes. Any change to a Layer 1 category or its definition requires IT Director approval and shall be documented as a policy amendment.
  - **Category A — Unauthorized Access or Access Anomaly**. Any confirmed or strongly suspected access to systems, data, or accounts by an unauthorized party, or any access by an authorized party outside their defined scope. Includes credential compromise, privilege escalation, lateral movement, and account takeover.
  - **Category B — Malicious Code Activity**. Presence or execution of malware, ransomware, spyware, rootkits, trojans, worms, or any software not authorized under the ECIO software management framework that exhibits destructive, exfiltration, or command-and-control behavior.
  - **Category C — Denial of Service**. Any attack that impairs the availability of County IT systems or services through resource exhaustion, flooding, or disruption, whether targeted at ECIO infrastructure or originating from ECIO infrastructure against external targets.
  - **Category D — Data Compromise or Exfiltration**. Any confirmed or suspected unauthorized access to, disclosure of, modification of, or exfiltration of County data, with particular emphasis on CJI, PII, and systems classified as Tier 1 or Tier 2 under **Policy 4.05**.
  - **Category E — Targeted Reconnaissance**. Systematic probing, scanning, or enumeration of ECIO infrastructure that demonstrates specific targeting of internal systems, knowledge of internal topology or naming conventions not publicly available, or that is combined with any follow-on access attempt, credential probe, or lateral movement indicator. Undifferentiated broad-sweep scanning of external-facing IP space does not constitute an IoC under this category absent one of the preceding qualifying conditions.
  - **Category F — Improper Use with Security Nexus**. Acceptable use violations, insider activity, or policy violations that involve attempted or confirmed unauthorized access to data, systems, or accounts beyond the violator's authorized scope. Routine acceptable use violations without a security nexus remain within the governance of **Policy 3.06**.
- **Layer 2 — Specific Indicators**. Layer 2 consists of current, actionable technical signatures — including file hashes, IP ranges, behavioral patterns, known malware identifiers, and credential stuffing signatures — maintained as a governed artifact in Redmine. Layer 2 reflects the evolving threat landscape and shall be updated as that landscape changes. The Assistant IT Director owns routine Layer 2 maintenance under standing authority. Routine maintenance includes adding new indicators and removing stale ones. The IT Director shall be notified of each update. Intelligence sources for Layer 2 shall be recognized threat intelligence sources and internal postmortem findings. No source list is hard-locked.
- **IoC List Review**. The IoC list as a whole shall be reviewed no less than quarterly. The quarterly cadence is a floor, not a ceiling.
- **False Positive Disposition**. When a declared incident is determined to be a false positive, the triggering indicator shall be flagged in the work order notes at the time of that determination. The indicator shall not be modified at the time of disposition. A standalone thirty-day review window shall be initiated at the time of false positive determination. Indicator modification requires a deliberate review cycle conducted within that thirty-day window, not an in-the-moment decision at disposition.

6.2 Intake Channel Architecture

- **Mandatory Work Order Requirement**. All Chapter 4 intake shall enter through a Safety and Security category work order in Redmine without exception. No cybersecurity incident response activity shall proceed without an associated work order. This requirement is consistent with the work order discipline established in **Policy 3.05** and **Policy 3.06**. **Policy 4.02** designates the Safety and Security work

order category as the mandatory Chapter 4 intake channel, conferring explicit governance authority on that category for all cybersecurity incident intake.

- **Intake States**. All upstream intake paths normalize into one of two functional states at the point of **Policy 4.02** evaluation.
  - **State 1 — Work order with existing IoC documentation**. This state applies to Hard Fork referrals from **Policy 3.06** and monitoring handoffs from **Policy 3.12**. The work order already exists with the IoC observation documented in the notes, SLA suspension noted, and a forensic timestamp established. **Policy 4.02** receives the work order and proceeds directly to IoC evaluation.
  - **State 2 — Safety and Security intake work order**. This state applies to staff reports, vendor notifications relayed by staff, device loss or theft reports, camera footage referrals from **Policy 2.13**, and data spillage events. An IT Department staff member shall create the Safety and Security work order at the point of intake, documenting the reported condition. IoC evaluation proceeds before any other response activity.
- **Vendor Notification Handling**. ECIO staff receiving a vendor notification of a suspected or confirmed security incident shall create the Safety and Security work order on the vendor's behalf, documenting the vendor's report as the source. Vendors shall not create Redmine tickets directly.
- **IoC Evaluation**. IoC evaluation is mandatory for every Safety and Security work order before any other response activity proceeds. Evaluation shall be performed against Layer 1 categories and Layer 2 specific indicators. The result of each evaluation — declaration or decline — shall be documented in the work order at the time of determination. A declined work order shall include the basis for decline.

6.3 Triage and Declaration Authority

IoC evaluation and declaration authority rests with the IT Director and the Assistant IT Director, consistent with the authority established in **Policy 4.01**, Section 6.1 and **Policy 1.08**. The standard Redmine triage workflow applies: Safety and Security work orders enter the queue, are reviewed by the IT Director or the Assistant IT Director, and are released to Reviewed status upon declaration.

The IT Director and the Assistant IT Director may delegate incident analysis to domain-appropriate technical leads — the Network Administrator for network-related incidents and the Systems Administrator for server and endpoint-related incidents — to ensure technically qualified personnel execute the analysis. Delegation of analysis responsibility does not transfer declaration authority. Declaration authority remains with the IT Director, the Assistant IT Director, or a Tier L3+ technical lead designated in writing by the IT Director per **Policy 1.08**.

6.4 Incident Record Structure

The incident record for all declared Chapter 4 incidents shall use the existing Redmine work order infrastructure supplemented by the mandatory Chapter 4 checklist template. No new Redmine fields are required.

Work Order Infrastructure. The following existing Redmine work order fields constitute the structural foundation of the incident record: Subject, Description, Category (Safety and Security), Assignee, Notes, Files, Related Issues, Watchers, and operational Severity. These fields shall not be modified for Chapter 4 intake purposes. The Redmine History provides the system-generated, timestamped audit trail for all status changes, field modifications, and note additions. This trail is tamper-evident and constitutes the authoritative chronological record of the incident.

Chapter 4 Checklist Template. A Chapter 4 checklist template shall be maintained as a governed Knowledge Base artifact per **Policy 3.13**. **Policy 4.02** mandates the existence of the checklist and the fields it shall contain. **Policy 3.13** governs its maintenance and version control. The checklist shall be completed for every declared incident and attached to the work order. The checklist shall capture, at minimum:

- Chapter 4 jurisdiction flag
- Declaration authority and the identity of the declaring party.

- Incident Commander designation, including scope and effective time if the Incident Commander is not the IT Director.
- Layer 1 incident type classification (Category A through F; multi-category classification is permissible).
- Chapter 4 severity classification (High, Medium, or Low).
- CJI involvement determination (confirmed, possible, or ruled out with documented basis).
- CJIS notification log, including: the internal one-hour clock start; the IT Director notification timestamp; and external notification details to the CSO, SIB Chief, or Interface Agency Official where applicable.
- Evidence preservation log identifying what was preserved, how it was preserved, and by whom.
- False positive disposition notation and thirty-day indicator review flag, where applicable.
- Operational Handback declaration, completed at incident conclusion per **Policy 4.05**.

Notes Field — Operational Narrative. The work order Notes field shall serve as the running operational narrative for the incident. All IoC observation detail, investigation activity, response decisions and their rationale, and actions taken shall be entered in real time, or as close to real time as operational conditions permit, but in no case later than four hours after the action is taken or the conclusion of the assigned technician's current work shift, whichever occurs first.

Files Field — Evidence Artifacts. The work order Files field shall serve as the repository for all preserved evidence artifacts, including screenshots, exported logs, camera footage segments, and forensic captures attached to the record. If an evidence artifact exceeds the technical file-size upload limit of the Redmine system, the artifact may be stored in a dedicated, access-controlled directory on an ECIO-managed secure file server. When this alternative storage method is utilized, the exact network file path, file name, and the identity of the personnel depositing the file shall be documented in the work order Notes field to preserve the chain of custody. Any such external storage location shall be subject to the identical access restrictions and retention schedules as the primary incident record.

6.5 Incident Classification

All declared Chapter 4 incidents shall be classified on two independent dimensions. Both shall be documented in the Chapter 4 checklist.

Incident Type. Incident type is determined by the applicable Layer 1 category or categories (A through F) and answers what kind of incident is being handled. An incident may carry multiple type classifications if it spans multiple categories. Incident type shall be documented at declaration and may be updated as investigation unfolds. Any update to incident type shall be documented in the work order Notes with the basis for the change.

Incident Severity. Incident severity is determined using the three-tier framework established in **Policy 4.01**, Section 6.1 — High, Medium, or Low — and answers how serious the incident is. Chapter 4 severity classification is independent of and non-interacting with the five-tier operational severity framework established in **Policy 3.01**. Severity may be reclassified at any point at Incident Commander direction. Any reclassification shall be documented in the work order Notes with the basis for the change.

6.6 CJIS Notification

CJIS Security Policy v6.0, Section IR-6 establishes a two-part notification obligation. Both parts apply to all declared incidents and shall be executed and documented in the Chapter 4 checklist CJIS notification log.

Part (a) — Internal Reporting. All IT Department Personnel shall report any suspected or confirmed security incident to the Incident Commander immediately upon discovery, not to exceed one hour after discovery. Work order creation constitutes the formal internal report satisfying Part (a). The work order creation timestamp in Redmine is the documented record of internal report completion.

Part (b) — External Notification. Upon declaration, the IT Director acting in the role of LASO shall notify the CSO, the SIB Chief, or the Interface Agency Official where CJI involvement is confirmed or cannot be ruled out at triage. **Policy 4.06** governs the execution of external notification. **Policy 4.02** owns the obligation trigger and the CJIS notification log entry documenting that handoff.

One-Hour Clock. The one-hour Part (a) clock starts at the first documented action in Redmine: the work order creation timestamp for State 2 intake events, and the IoC observation notation timestamp for State 1 events. If prior awareness is established through a channel outside of Redmine before the work order is created, that earlier time shall be noted in the work order and becomes the operative clock start for Part (a).

CJI Involvement Determination. CJIS Part (b) external notification attaches only to declared incidents where CJI involvement is confirmed or cannot be ruled out at triage. A documented CJI involvement determination — confirmed, possible, or ruled out with its basis — shall be recorded in the Chapter 4 checklist for every declared incident, regardless of whether Part (b) is ultimately triggered.

Notification Windows. All notification windows are measured in continuous calendar hours. No business-hours qualification applies, and no after-hours exception applies. For declared incidents with a CJI nexus, the handoff to **Policy 4.06** for external notification shall occur within the following windows measured from the time of declaration:

- **High severity with CJI nexus**: not to exceed one hour from declaration
- **Medium severity with CJI nexus**: not to exceed four hours from declaration
- **Low severity with CJI nexus**: not to exceed twenty-four hours from declaration

6.7 Evidence Artifact Retention

Incident Record Retention. The incident record — comprising the Redmine work order, Chapter 4 checklist, Notes, and Redmine History — shall be retained for three calendar years from the end of the calendar year of incident closure, in accordance with LRDA 20071728 (IT Access Control Reviews and Audit Trails). This retention period exceeds the CJIS AU-11 one-year minimum for audit records.

Evidence Artifact Retention. Evidence artifacts — including camera footage segments, exported logs, forensic captures, and file attachments in the work order — constitute security activity records and incident reports under LRDA 20071279 (Property Management: Security Records) and shall be retained for three calendar years from the end of the calendar year to which they pertain, subject to the path-specific conditions below.

- **Path 1 — Confirmed incident, law enforcement involved**. Evidence artifacts shall be turned over to law enforcement. ECIO shall retain documentation of the transfer — identifying what was transferred, to whom, when, and under what authority — for three calendar years from the end of the calendar year of custody transfer. Evidence artifacts are released from ECIO retention upon documented custody transfer.
- **Path 2 — Confirmed incident, no law enforcement involvement**. Evidence artifacts shall be retained for three calendar years from the end of the calendar year to which the incident pertains, in accordance with LRDA 20071279, or for the duration of any related audit or legal hold, whichever is longer.
- **Path 3 — False positive disposition**. Evidence artifacts shall be retained for three calendar years from the end of the calendar year of the false positive determination, in accordance with LRDA 20071279, or for the duration of any related audit or legal hold, whichever is longer. The thirty-day indicator review window established in Section 6.1 governs modification of the triggering IoC indicator and is independent of this retention obligation.
- **Path 4 — CJI-involved incidents**. Standard tiered retention as described in Paths 1 through 3 applies. A due-diligence review for any applicable CJIS-specific retention requirement shall be conducted before disposition.

All retention obligations under this section are subject to legal hold requirements, litigation preservation obligations, and NRS 239.125. In the event of a conflict between this section and a legal hold or litigation preservation obligation, the legal hold or litigation preservation obligation governs.

4.03 Containment Strategy and Playbooks

Effective: July 01, 2026 Version: 1.0

1. Purpose

Policy 4.03 governs the Containment phase of the ECIO six-phase incident response lifecycle: Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned. It establishes the decision framework the Incident Commander uses to select a containment approach, defines the mandatory criteria for that selection, and governs the playbooks that guide technical response staff through containment execution for each incident type recognized by the ECIO classification system.

This policy activates upon handoff from **Policy 4.02**, following incident declaration, incident classification, and initial incident record creation. It governs all activity from that handoff point through containment-complete determination and handoff to **Policy 4.04**. Technical configuration actions taken under this policy's authority trigger change authorization obligations governed by **Policy 3.09**.

Policy 4.03 is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

2. Scope

Policy 4.03 applies to all Information Operations Department personnel participating in incident response operations during the containment phase, including the IT Director, Assistant IT Director, Network Administrator, Systems Administrator, and all technicians operating under Incident Commander authority.

- **In Scope**:
  - Containment strategy selection and execution following handoff from **Policy 4.02**.
  - Incident Commander decision framework and evaluation criteria.
  - Short-term and long-term containment posture.
  - Emergency Change obligations arising from containment configuration actions.
  - Forensic preservation obligations during containment.
  - Containment documentation requirements.
  - Playbook framework and governance.
  - Containment-complete determination and eradication handoff.
  - False positive containment reversal.
- **Out of Scope**:
  - IoC evaluation and incident declaration — governed by **Policy 4.02**.
  - Hard Fork mechanics — governed by **Policy 3.06** Section 6.2.
  - Eradication procedures — governed by **Policy 4.04**.
  - Recovery operations and Operational Handback — governed by **Policy 4.05**.

- Stakeholder communication and external notification execution — governed by **Policy 4.06**.
- Data and system classification for recovery — governed by **Policy 4.05**.
- Postmortem review and lessons learned — governed by **Policy 4.07**.
- CI record governance — governed by **Policy 3.08**.
- Change categorization and RFC governance — governed by **Policy 3.09** .
- Security baseline definitions — governed by **Policy 2.10**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as Incident Commander by default, as established in **Policy 4.01** (Incident Response Policy Overview), and shall exercise Designated Appointment and Emergency Declaration Authority per **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall complete catch-up Change Control Authority (CCA) review for all Emergency Changes within twenty-four (24) hours of implementation per **Policy 3.09** (Change Management Policy).
  - Shall authorize formal exceptions to the requirements of this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director**:
  - Shall serve as Incident Commander in the IT Director's absence or by designation, per **Policy 4.01** and **Policy 1.08**.
  - Shall own playbook maintenance under standing authority per **Policy 3.13** (Knowledge Management Policy).
  - Shall ensure catch-up RFC documentation and CCA review timelines are met.
  - Shall ensure that affected CI records are flagged at the time of containment action for subsequent update per **Policy 3.08** (Service Configuration Management (CMDB) Policy).
- **Network Administrator**:
  - Shall lead network-related containment actions as directed by the Incident Commander.
  - Shall flag affected CI records at the time of containment action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Systems Administrator**:
  - Shall lead server- and endpoint-related containment actions as directed by the Incident Commander.
  - Shall flag affected CI records at the time of containment action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Incident Commander (when not the IT Director)**:
  - Shall exercise all IC authority incorporatively from **Policy 4.01** and **Policy 1.08**.

  - Shall select the containment mode and document the rationale against the three mandatory evaluation criteria.
  - Shall designate containment configuration actions as Emergency Changes.
  - Shall make the containment-complete determination.
  - Shall designate the primary category for multi-category incidents.
  - Shall initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**.
- **IT Department Personnel**:
  - Shall execute containment directives under Incident Commander authority.
  - Shall not take any containment action without an associated Redmine work order and IC authorization.
  - Shall document all actions in work order Notes in real time, or as close to real time as operational conditions permit, consistent with the documentation standards established in **Policy 4.02** (Identification and Reporting Procedures) Section 6.4.
  - Shall not destroy, overwrite, or cause the disposition of audit logs under any circumstances during the containment phase.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel participating in incident response operations during the containment phase.

- **Assessment**: Compliance with this policy shall be assessed through the ECIO internal audit program governed by **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process governed by **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: The following conditions constitute specific non-compliance with this policy: failure to document the IC's containment strategy decision — including mode selected and rationale against the three mandatory evaluation criteria — in the work order Notes before execution begins; execution of containment configuration actions without IC authorization or without an associated Redmine work order; failure to create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**; any containment action that destroys, overwrites, or causes the disposition of audit logs; and failure to document a containment-complete determination in the work order Notes before initiating eradication activity. Non-compliance may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are permitted. All approved exceptions shall be documented and time-bounded. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy

- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST CSF 2.0: RS.MI-01 (Incident Containment)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cyber Risk Management

Framework Alignment:

- ECIO Policy 1.09: Risk Management Policy
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Security Audit Records)
- NIST CSF 2.0: RS.CO-02 (Stakeholder Notification)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST CSF 2.0: RS.MA-04 (Incident Escalation and Elevation)
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

6.1 Containment Strategy Selection Framework

When **Policy 4.03** activates, the following have been completed by **Policy 4.02** and are not repeated or redefined here:

- IoC evaluation.
- Incident declaration.

- Incident type classification by Layer 1 category.
- Incident severity classification.
- CJI involvement determination.
- Initial forensic record creation.
- CJIS IR-6 Part (a) internal reporting clock initiation.

The Incident Commander is in command. The Redmine work order and Chapter 4 checklist are active.

For the benefit of external readers: the Incident Commander is the single accountable authority for all containment decisions. The IT Director holds this role by default; the Assistant IT Director assumes it upon designation or in the IT Director's absence. Full IC appointment mechanics are governed by **Policy 4.01** and **Policy 3.06**.

The Layer 1 IoC categories are six permanent categorical triggers governing incident classification:

- **Category A**: Unauthorized Access or Access Anomaly.
- **Category B**: Malicious Code Activity.
- **Category C**: Denial of Service.
- **Category D**: Data Compromise or Exfiltration.
- **Category E**: Targeted Reconnaissance.
- **Category F**: Improper Use with Security Nexus.

Full definitions are governed by **Policy 4.02** Section 6.1.

Incident severity is classified in three tiers — High, Medium, and Low — reflecting the scope, sensitivity, and operational impact of the incident. Severity classification is governed by **Policy 4.01** Section 6.1.

The Incident Commander shall select one of two strategic containment modes:

- **Isolation:** A hard cutoff account disabling, or system quarantine
- **Active Monitoring:** Deliberate continued observation of threat activity while covert defensive measures are positioned, preserving forensic evidence and allowing threat scope to be confirmed before the isolation boundary is drawn.

Neither mode is a universal default. Both are legitimate IC choices depending on incident-specific evaluation. The IC shall document the mode selected and the rationale in the work order Notes before execution begins.

The Incident Commander shall evaluate all three of the following criteria for every incident before selecting a containment mode:

- **Operational Impact:** What operational capabilities are disrupted, degraded, or lost if the system or segment is isolated? What is the effect on other County departments, public-facing services, or critical infrastructure?
- **Forensic Preservation:** What evidence is gained by observing threat activity before isolation, and what evidence is lost or degraded by immediate isolation? Does the incident present a novel threat pattern that warrants observation to improve future detection?
- **Threat Scope:** How far has the threat spread, or how far could it spread if containment is deferred? Is active lateral movement occurring? Is the affected perimeter bounded or uncertain?

Containment proceeds in two phases. Short-term containment achieves immediate stabilization and bounds the active threat. Short-term actions may be temporary — a firewall block, an account suspension, a network segment quarantine — sufficient to stop the immediate spread while a sustainable long-term posture is designed. Long-term containment establishes a sustained configuration or monitoring state that can be

maintained while eradication is prepared under **Policy 4.04**. **Policy 4.04** shall not be initiated until long-term containment is stable.

Two conditions mandate isolation regardless of IC mode discretion, pursuant to **Policy 2.10**. Unauthorized systems discovered without an approved configuration baseline (**Policy 2.10** Section 4) trigger incident response isolation protocols automatically. Critical-risk baseline deviations (**Policy 2.10** Section 6.6) shall result in logical isolation within four (4) hours of detection if not remediated. When a mandatory isolation trigger applies, the IC shall document the triggering condition and the isolation action taken in the work order Notes.

For incidents where CJI involvement is confirmed or cannot be ruled out at triage, the IC's mode selection shall account for the forensic preservation constraints in Section 6.2. When CJIS forensic preservation requirements and operational isolation requirements conflict, the IC shall document both considerations and the rationale for the chosen path in the work order Notes before execution begins.

6.2 Hard Fork Transition and Forensic Preservation

For the benefit of external readers: the Hard Fork is the jurisdictional transfer from operational incident management to Chapter 4 incident response, triggered upon IoC discovery by a technician. Full Hard Fork mechanics are governed by **Policy 3.06** Section 6.2.

The system preservation obligation in **Policy 3.06** Section 6.2 — which requires a technician who discovers an IoC to cease troubleshooting, preserve current system state, and await direction — governs the technician's actions during the interval before the Incident Commander issues a containment directive. It is a constraint on unilateral technician action, not a constraint on IC authority. Upon receiving the IC's first containment directive, the technician shall execute that directive. The IC's containment direction supersedes the interim preservation hold.

The audit log preservation obligation established in **Policy 2.11** Section 6.7 is a standing constraint that applies to all personnel, including the Incident Commander, throughout the containment phase. No containment action shall destroy, overwrite, or cause the disposition of audit logs. This obligation is separate from and survives the sequencing resolution above.

Before any destructive containment action system reimaging, or irreversible configuration change stores, or transmits CJI, forensic evidence shall be preserved. This constraint applies regardless of operational urgency and is not overridden by IC discretion. The method of preservation shall be documented in the work order Notes before the destructive action is executed.

When an incident involves audit processing failure as defined in **Policy 2.11** Section 6.5, restoring logging capability is a containment prerequisite. Containment perimeter integrity cannot be confirmed without functioning audit logs. The IC shall direct restoration of audit logging before declaring long-term containment stable.

6.3 Emergency Change Obligations During Containment

Every network isolation, firewall rule modification, account disabling, or system reconfiguration executed under containment authority is an Emergency Change under **Policy 3.09**. Emergency Change obligations attach at the moment of implementation, not after containment is complete.

The Incident Commander is authorized to designate containment configuration actions as Emergency Changes under **Policy 3.09** Section 6.2. This authority requires no prior approval and shall be exercised at the time of action.

Three documentation obligations run concurrently from the moment of each containment configuration action:

- The assigned technician shall create a standalone RFC record in Redmine within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- The IT Director shall complete catch-up CCA review within the same window.

- The assigned technician shall flag affected CI records at the time of action; the CI record update obligation is deferred but not waived, and runs on the same concurrent 24-hour clock per **Policy 3.09**.

Documentation obligations do not pause containment execution. They run concurrently with, or immediately following, containment actions. These obligations are not prerequisites to taking network or system action.

The catch-up RFC shall document:

- All actions taken with the most precise timestamps recoverable from system and audit logs.
- The conditions justifying Emergency Change designation.
- The CCA review outcome.
- CI record update confirmation.

The IT Director or designee shall complete Post-Implementation Review (PIR) documentation within five (5) business days of implementation for all Emergency Changes executed under this policy.

If a containment action meets any of the following triggers, the County Manager shall be notified no later than four (4) hours after implementation begins, per **Policy 3.09** Section 6.6:

- Systems whose compromise could affect elections.
- Planned downtime or degraded service visible to the public or other County departments for more than one (1) business day.
- Decommission or replacement of operationally critical infrastructure.
- Any action the IT Director determines carries political or notable operational implications.

The IC shall identify applicable triggers at the time of action and ensure notification is initiated within the four (4) hour window.

If containment requires procurement — emergency hardware, vendor engagement, or tooling — the Incident Commander is authorized to initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**. Administrative funding authority shall not be exercised to delay, suspend, or condition containment actions. Fiscal Affairs and Purchasing shall not delay containment for procurement review.

6.4 Containment Completion and Eradication Handoff

Containment is complete when the threat has been demonstrably bounded — further spread is not occurring, and the affected perimeter is defined with sufficient confidence to begin eradication. No phase transition is assumed. The IC shall make an explicit containment-complete determination, documented in the work order Notes, before any eradication activity under **Policy 4.04** begins.

Before initiating eradication activity, the following shall be documented in the work order Notes and Chapter 4 checklist:

- The confirmed containment perimeter with all affected systems identified.
- Systems isolated, accounts disabled, or segments under active monitoring posture.
- Evidence artifacts preserved during containment, including forensic copies, log extracts, and network captures.
- Outstanding catch-up RFC items with assigned owners and due dates.

The CJIS IR-6 Part (a) notification clock established in **Policy 4.02** Section 6.6 continues running during containment. Containment activities do not pause or satisfy external notification obligations. The notification windows — High: 1 hour; Medium: 4 hours; Low: 24 hours from declaration — are not affected by the duration of the containment phase. External notification execution is governed by **Policy 4.06**.

If a declared incident resolves as a false positive during containment, the false positive disposition process in **Policy 4.02** Section 6.1 governs indicator review. The IC shall direct reversal of all containment actions taken, including rollback of isolated systems to operational status, restoration of disabled accounts, and catch-up RFC documentation for any reversed Emergency changes. The IC shall document the false positive determination and all reversal actions in the work order Notes. Operational jurisdiction may return to **Policy 3.06** per the IC's direction.

6.5 Playbook Framework

Policy 4.03 mandates the existence of a governed containment playbook for each of the six Layer 1 IoC categories (A–F). Playbooks are maintained as Knowledge Base artifacts in Redmine per **Policy 3.13** and formatted per **Policy 1.04** Section 6.9. All six category playbooks shall be in force at v1.0 of this policy.

When an incident receives multi-category classification under **Policy 4.02**, the IC shall designate a primary category at the time of containment strategy selection. The primary category playbook governs containment execution. Supplementary category playbooks inform the response. The IC shall document the primary category designation and rationale in the work order Notes.

Severity tier (High, Medium, or Low per **Policy 4.01** Section 6.1) modulates urgency and escalation thresholds within each category playbook. It does not alter the fundamental playbook structure. Each playbook's structure is consistent across severity tiers; the severity tier determines execution tempo and escalation trigger points.

Each category playbook shall contain, at minimum, the following seven elements:

- **Scenario Description:** A brief characterization of the incident type and its typical manifestations within the ECIO environment.
- **Containment Mode Guidance:** Scenario-specific considerations for isolation vs. active monitoring, informed by the three mandatory evaluation criteria in Section 6.1.
- **Short-Term Containment Actions:** Immediate technical steps to stabilize and bound the threat.
- **Long-Term Containment Posture:** Sustained configuration or monitoring state to maintain while eradication is prepared under **Policy 4.04**.
- **CJIS Considerations:** Specific forensic preservation and notification obligations applicable when CJI involvement is confirmed or cannot be ruled out.
- **Documentation Checkpoints:** What shall be documented in the work order Notes and Chapter 4 checklist at each stage of playbook execution.
- **Eradication Handoff Criteria:** The specific conditions that constitute containment-complete for this incident type, triggering handoff to **Policy 4.04**.

Each playbook shall be reviewed no less than annually, upon closure of any incident that invoked it, and upon any change to the ECIO environment classified as a Significant or Emergency Change under **Policy 3.09** that is relevant to that scenario. The Assistant IT Director owns playbook review and maintenance under standing authority.

4.04 Eradication Procedures and Scenario Guides

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy governs the eradication of cybersecurity threats from the Elko County Information Operations environment following containment and establishes the eradication-complete determination that gates transition to recovery operations under **Policy 4.05**.

2. Scope

This policy applies to all Information Operations Department personnel participating in incident response operations during the eradication phase, including the IT Director, Assistant IT Director, Network Administrator, Systems Administrator, and all technicians operating under Incident Commander authority.

- **In Scope**:
  - Eradication strategy selection and execution following containment-complete determination.
  - Threat neutralization, including removal of threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities.
  - Pre-execution forensic confirmation for destructive or irreversible eradication actions.
  - Emergency Change obligations arising from eradication configuration actions.
  - Eradication-complete determination and recovery handoff.
  - Eradication procedure framework and governance.
  - Eradication documentation requirements.
- **Out of Scope**:
  - IoC evaluation and incident declaration — governed by **Policy 4.02**.
  - Containment strategy selection and execution — governed by **Policy 4.03**.
  - Recovery operations and Operational Handback — governed by **Policy 4.05**.
  - Data and system classification for recovery — governed by **Policy 4.05**.
  - Stakeholder communication and external notification execution — governed by **Policy 4.06**.
  - Postmortem review and lessons learned — governed by **Policy 4.07**.
  - IR roles and contact directory — governed by **Policy 4.08**.
  - CI record governance — governed by **Policy 3.08**.
  - Change categorization and RFC governance — governed by **Policy 3.09**.
  - Security baseline definitions — governed by **Policy 2.10**.

3. Roles and Responsibilities

- **IT Director**:

  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 4.01** (Incident Response Policy Overview) and governed by the delegation provisions in **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall approve the eradication strategy, including selection of applicable eradication procedures and authorization of destructive eradication actions.
  - Shall make the eradication-complete determination, documenting the basis in the work order Notes and Chapter 4 checklist before any recovery activity under **Policy 4.05** (Recovery Operations and Restoration Prioritization) begins.
  - Shall confirm that forensic preservation requirements have been satisfied before authorizing any destructive or irreversible eradication action.
  - Shall complete Configuration Control Authority (CCA) review for all eradication-phase Emergency Changes within the twenty-four (24) hour concurrent documentation window established by **Policy 3.09** (Change Management Policy).
  - Shall authorize formal exceptions to the requirements of this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director**:
  - Shall serve as Incident Commander in the IT Director's absence or by IT Director designation, per **Policy 4.01** and **Policy 1.08**.
  - Shall serve as the primary operational coordinator for eradication activities under Incident Commander direction.
  - Shall own maintenance and review of eradication procedures maintained in the Knowledge Base per **Policy 3.13** (Knowledge Management Policy) under standing authority.
- **Network Administrator**:
  - Shall execute network-layer eradication actions as directed by the Incident Commander, including removal of unauthorized firewall rules, rogue DNS entries, compromised routing configurations, and other malicious network artifacts.
  - Shall flag affected CI records at the time of eradication action for subsequent update per **Policy 3.08** (Service Configuration Management (CMDB) Policy).
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Systems Administrator**:
  - Shall execute server- and endpoint-layer eradication actions as directed by the Incident Commander, including malware removal, compromised account remediation, persistence mechanism elimination, and system rebuild when required.
  - Shall flag affected CI records at the time of eradication action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Incident Commander (when not the IT Director)**:
  - Shall exercise all IC authority incorporatively from **Policy 4.01** and **Policy 1.08**.
  - Shall approve the eradication strategy and select the applicable eradication procedures.

  - Shall authorize destructive eradication actions after confirming the Forensic Preservation Gate defined in Section 6.3 has been satisfied.
  - Shall make the eradication-complete determination in accordance with Section 6.4 of this policy.
  - Shall initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**, when eradication requires emergency tooling, replacement hardware, or vendor engagement.
- **IT Department Personnel**:
  - Shall execute eradication activities as directed by the Incident Commander.
  - Shall not initiate eradication actions independently or deviate from the selected eradication procedures without express IC authorization.
  - Shall document all eradication actions taken in the work order Notes as actions are completed.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel participating in incident response operations during the eradication phase.

- **Assessment**: Compliance with this policy shall be assessed through the ECIO internal audit program governed by **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process governed by **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: The following conditions constitute specific non-compliance with this policy: initiation of eradication activity before the Incident Commander has documented a containment-complete determination under **Policy 4.03**; execution of destructive or irreversible eradication actions without prior IC authorization or without documented confirmation that forensic preservation requirements have been satisfied; execution of eradication actions that deviate from the IC-selected eradication procedures without documented IC authorization; execution of eradication actions without an associated Redmine work order; failure to create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**; any eradication action that destroys, overwrites, or causes the disposition of audit logs maintained under **Policy 2.11** (Audit Logging and Monitoring Policy) or forensic evidence without documented IC authorization and justification; and failure to document an eradication-complete determination in the work order Notes before initiating recovery activity under **Policy 4.05**. Non-compliance may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are permitted. All approved exceptions shall be documented and time-bounded. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy

- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST CSF 2.0: RS.MI-02 (Incident Eradication)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cyber Risk Management

Framework Alignment:

- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Security Audit Records)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

Eradication is the phase of the cybersecurity incident response lifecycle in which the threat is neutralized. Threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities are identified and removed from the affected environment. Eradication follows containment and precedes recovery. It is governed by NIST CSF 2.0: RS.MI-02 (Incident Eradication) and aligned with the guidance in NIST SP 800-61 Rev. 3.

6.1 Activation and Handoff State

When **Policy 4.04** activates, the following have been completed by **Policy 4.03** (Containment Strategy and Playbooks) and are not repeated or redefined here:

- Containment strategy selection and execution.
- Short-term and long-term containment posture establishment.
- Containment-complete determination by the Incident Commander (IC).

- All containment-phase documentation and change management obligations.

The IC is in command. The Redmine work order and Chapter 4 checklist are active. The following documentation package has been completed under **Policy 4.03** Section 6.4 and is available in the work order Notes and Chapter 4 checklist:

- The confirmed containment perimeter with all affected systems identified.
- Systems isolated, accounts disabled, or segments under active monitoring posture.
- Evidence artifacts preserved during containment, including forensic copies, log extracts, and network captures.
- Outstanding catch-up RFC items with assigned owners and due dates.

The CJIS IR-6 notification clock established in **Policy 4.02** (Identification and Reporting Procedures) Section 6.6 continues running during eradication. Eradication activities do not pause or satisfy external notification obligations. External notification execution is governed by **Policy 4.06** (Communication Protocols and Partner Integration).

Eradication shall not be initiated until the IC has documented a containment-complete determination under **Policy 4.03** Section 6.4 and long-term containment is stable.

6.2 Eradication Framework

The IC holds authority over all eradication activity. No eradication action shall be initiated without IC authorization. The IC shall select the applicable eradication procedures, assign technical leads, and direct the sequence and timing of eradication actions.

Before eradication execution begins, the IC shall confirm the scope of eradication based on the containment perimeter and the incident classification established in **Policy 4.02**. The IC shall document the eradication scope in the work order Notes before execution begins. The eradication scope shall identify:

- All systems within the containment perimeter requiring remediation.
- The specific threat artifacts and persistence mechanisms to be removed from each system.
- The applicable eradication procedures to be invoked.
- Any systems where the eradication approach requires a destructive action.

Eradication actions fall into three (3) categories, distinguished by reversibility and forensic impact.

- **Non-Destructive Eradication:** Actions that remove threat artifacts without altering the underlying system's ability to be forensically examined after the fact. Examples include deleting malware files, removing unauthorized scheduled tasks or services, closing unauthorized network connections, and revoking compromised authentication tokens.
- **Credential and Access Remediation:** Actions that revoke, rotate, or replace compromised authentication credentials and access authorizations. Examples include password resets, certificate revocation, API key rotation, and disabling compromised accounts. These actions are operationally reversible
- **Destructive Eradication:** Actions that alter or destroy system state in a manner that cannot be reversed and that may eliminate forensic evidence if not preceded by preservation. Examples include reimaging a compromised endpoint, rebuilding a server from clean media, wiping and redeploying a virtual machine, and overwriting compromised storage volumes. Destructive Eradication actions require the Forensic Preservation Gate defined in Section 6.3 to be satisfied before execution.

Eradication owns everything required to neutralize the threat and confirm clean state. Recovery owns everything required to restore operational capability. A system rebuild is eradication when it is performed because the system cannot be confirmed clean. A system rebuild is recovery when the system is confirmed

clean and is being rebuilt to restore service. The eradication-complete determination in Section 6.4 marks this boundary.

For incidents where Criminal Justice Information (CJI) involvement is confirmed or has not been ruled out at triage, the IC shall ensure the following:

- No eradication action shall alter, overwrite, or destroy CJI or CJI audit records without documented IC authorization and written justification.
- The assigned technician shall complete forensic copies of CJI-bearing systems and the IC shall verify those copies before any Destructive Eradication action proceeds.
- The assigned technician shall document all eradication actions on CJI-bearing systems with sufficient detail to support post-incident CJIS compliance review.

6.3 Change Management Integration

All eradication configuration actions constitute Emergency Changes under **Policy 3.09**. The concurrent documentation clock established in **Policy 4.03** Section 6.3 applies to eradication actions without modification.

Three documentation obligations run concurrently from the moment of each eradication configuration action:

- The assigned technician (Network Administrator or Systems Administrator, depending on the affected system) shall create a standalone RFC record in Redmine within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- The IT Director shall complete CCA review within the same window.
- The assigned technician shall flag affected CI records at the time of action per **Policy 3.08**; the CI record update obligation is deferred but not waived and runs on the same concurrent twenty-four (24) hour clock per **Policy 3.09**.

Documentation obligations do not pause eradication execution. They run concurrently with, or immediately following, eradication actions. These obligations are not prerequisites to taking technical action.

The IT Director or designee shall complete Post-Implementation Review (PIR) documentation within five (5) business days of implementation for all Emergency Changes executed under this policy.

Before any Destructive Eradication action is executed, the IC shall confirm and document in the work order Notes that:

- All forensic preservation requirements for the affected system have been satisfied, including any requirements identified during containment under **Policy 4.03** Section 6.2.
- CJI forensic preservation obligations, where applicable, have been completed.
- The evidence record is sufficient to support postmortem review under **Policy 4.07** (Postmortem Review and Lessons Learned) and any external investigation or compliance review.

The Forensic Preservation Gate is a pre-execution confirmation, not a new process. It confirms that preservation actions already completed during containment remain intact and that no additional preservation is required before the system's state is irreversibly altered.

When an eradication action requires simultaneous or coordinated changes across multiple systems — such as domain-wide credential rotation or synchronized malware removal — the IC may authorize a single umbrella RFC documenting the coordinated action. The assigned technician shall document individual systems affected by the coordinated action as line items within the umbrella RFC rather than as separate RFC records. The assigned technician shall apply a CI record flag for each affected system at the time of action per **Policy 3.08**.

When eradication requires action by an external vendor, cloud service provider, or partner organization requesting an ISP-level block, or directing a cloud provider to terminate a compromised session:

- The action requested.
- The party to whom the request was directed.
- The time of request.
- The response received.
- The time of confirmation.

The catch-up RFC obligation does not apply to systems outside ECIO operational control. The documentation obligation survives.

The IC is authorized to initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**. This authority covers emergency tooling, replacement hardware, external incident response vendor engagement, and any other procurement required to sustain or complete eradication. Administrative funding authority shall not be exercised to delay, suspend, or condition eradication actions. Fiscal Affairs and Purchasing shall not delay eradication for procurement review.

If an eradication action meets any of the following triggers, the IC shall notify the County Manager no later than four (4) hours after the action begins, per **Policy 3.09** Section 6.6:

- Systems whose compromise could affect elections.
- Planned downtime or degraded service visible to the public or other County departments for more than one (1) business day.
- Decommission or replacement of operationally critical infrastructure.
- Any action the IC determines carries political or notable operational implications.

The IC shall identify applicable triggers at the time of action and ensure notification is initiated within the four (4) hour window.

6.4 Eradication-Complete Determination

Eradication is complete when the threat has been fully neutralized — all identified threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities have been removed or remediated across all systems within the containment perimeter. No phase transition is assumed. The IC shall make an explicit eradication-complete determination, documented in the work order Notes and Chapter 4 checklist, before any recovery activity under **Policy 4.05** begins.

The following verification conditions are required for every eradication-complete determination. These conditions are necessary but explicitly not sufficient. The IC shall confirm that all scenario-specific verification criteria identified in the applicable eradication procedures have also been satisfied and shall document the basis for that confirmation in the work order Notes.

- The assigned technician shall verify all systems within the containment perimeter as clean using an authorized detection or validation method defined in the applicable eradication procedure. Where automated scanning is supported, a clean scan result from the Department's authorized scanning tools is required. Where automated scanning is not supported for a given system type, the applicable eradication procedure shall define the alternative validation method.
- The assigned technician shall rotate, revoke, or replace all identified compromised credentials.
- The assigned technician shall remove all identified persistence mechanisms, including unauthorized services, scheduled tasks, registry modifications, startup items, and unauthorized user accounts.
- The assigned technician shall patch all identified exploited vulnerabilities or implement documented compensating controls approved by the IC.

- The assigned technician shall update CI records for all eradication-driven configuration changes per **Policy 3.08**, or confirm that pending CI updates are within the applicable documentation window with assigned owners.
- The assigned technician shall complete all catch-up RFC documentation for eradication-phase Emergency Changes, or confirm that pending RFC items are within the twenty-four (24) hour documentation window with assigned owners.

The IC shall document the eradication-complete determination with explicit reference to each mandatory verification condition and shall identify the eradication procedures that were invoked along with confirmation that their scenario-specific verification criteria were satisfied.

Upon eradication-complete determination, the incident transitions to the recovery phase governed by **Policy 4.05**. The eradication-complete determination is the primary criterion for initiating recovery. The IC remains in command through the recovery phase until Operational Handback is declared under **Policy 4.05**.

6.5 Eradication Procedure Governance

Policy 4.04 mandates the existence of a governed library of eradication procedures. For purposes of this policy, the "scenario guides" referenced in the policy title and in the **Policy 4.01** Chapter 4 roadmap are the governed eradication procedures maintained in Redmine. Eradication procedures are maintained as Knowledge Base artifacts in the System of Engagement (Redmine) per **Policy 3.13** and formatted per **Policy 1.04** (Policy and Documentation Formatting Standards).

The procedure library shall be sufficient to address eradication requirements across all six (6) Layer 1 Indicator of Compromise (IoC) categories (A through F) defined in **Policy 4.02**. The IT Director shall determine what procedures are required and shall authorize the creation of new procedures when operational needs or post-incident findings identify coverage gaps.

The containment playbooks maintained under **Policy 4.03** shall reference the applicable eradication procedures in their Eradication Handoff Criteria element. When a containment playbook identifies eradication procedures for a given incident type, the IC shall invoke those procedures at the time of eradication unless the IC determines and documents that a different procedure set is required based on conditions discovered during containment.

The Assistant IT Director owns eradication procedure maintenance under standing authority. The Assistant IT Director shall review each procedure no less than annually, upon closure of any incident that invoked it, and upon any change to the ECIO environment classified as a Significant or Emergency Change under **Policy 3.09** that is relevant to that procedure's technical scope.

Each eradication procedure shall contain, at minimum, the following seven (7) elements:

- **Scenario Description:** A characterization of the threat type and the circumstances under which this procedure is invoked.
- **Applicability Criteria:** The conditions that determine when this procedure applies, including Layer 1 IoC category mapping and any environmental or system-specific preconditions.
- **Required Tools and Access:** The tools, elevated permissions, and system access required to execute the procedure.
- **Eradication Steps:** Step-by-step technical instructions for threat removal, organized in executable sequence.
- **CJIS Considerations:** Specific forensic preservation and documentation obligations applicable when CJI involvement is confirmed or cannot be ruled out.
- **Verification Criteria:** Scenario-specific criteria that the assigned technician shall satisfy before the IC includes this procedure's scope in the eradication-complete determination. These criteria supplement the mandatory minimum verification conditions established in Section 6.4 of this policy. The Verification Criteria element shall define the authorized detection or validation method for systems within

this procedure's scope, including the alternative validation method for system types where automated scanning is not supported.

- **Documentation Checkpoints:** What the assigned technician shall document in the work order Notes and Chapter 4 checklist at each stage of procedure execution.

6.6 False Positive Disposition During Eradication

If a declared incident resolves as a false positive during eradication, the false positive disposition process in **Policy 4.02** Section 6.1 governs indicator review. The IC shall direct reversal of all eradication actions taken, unless the action constituted a Destructive Eradication action as defined in Section 6.2, in which case reversal is not possible and restoration shall proceed through the recovery process under **Policy 4.05**. The assigned technician shall reverse Non-Destructive Eradication and Credential and Access Remediation actions, including restoration of disabled accounts, reinstallation of removed software confirmed to be legitimate, and rollback of credential rotations where the original credentials were not compromised. The assigned technician shall create catch-up RFC documentation for any reversed Emergency Changes per **Policy 3.09**. The IC shall document the false positive determination and all reversal actions in the work order Notes. Operational jurisdiction may return to **Policy 3.06** (Operational Incident Management Policy) per the IC's direction.

For Destructive Eradication actions that have already been executed, the affected systems shall be restored through the recovery process under **Policy 4.05**. The IC shall document the false positive determination, including the justification for the original eradication action, for inclusion in the postmortem under **Policy 4.07**.

4.05 Recovery Operations and Restoration Prioritization

Effective: July 01, 2026 Version: 1.0

1. Purpose
2. Scope
3. Roles and Responsibilities
4. Compliance and Exceptions
5. References
6. Policy Statement

4.06 Communication Protocols and Partner Integration

Effective: July 01, 2026 Version: 1.0

1. Purpose
2. Scope
3. Roles and Responsibilities
4. Compliance and Exceptions
5. References
6. Policy Statement

4.07 Postmortem Review and Lessons Learned

Effective: July 01, 2026 Version: 1.0

1. Purpose

2. Scope

3. Roles and Responsibilities

4. Compliance and Exceptions

5. References

6. Policy Statement

4.08 Incident Response Roles and Contact Directory

Effective: July 01, 2026 Version: 1.0

1. Purpose
2. Scope
3. Roles and Responsibilities
4. Compliance and Exceptions
5. References
6. Policy Statement

5. Compliance and Oversight

5.01 Policy Implementation, Enforcement, and Legal Alignment

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the enforcement framework, corrective action authority, formal sanctions process, legal and regulatory alignment mechanism, exception governance, and record retention requirements that operationalize the Elko County Information Operations Policy Manual.

2. Scope

This policy applies to all personnel, systems, and entities subject to the ECIO Policy Manual, including Information Operations personnel, non-IT County employees, appointed and elected officials, and contractors and vendors who access, administer, or support County information systems, infrastructure, or data governed by the Information Operations Department.

- **In Scope**:
  - Enforcement authority and IT-administrative corrective actions.
  - Formal sanctions process and Criminal Justice Information Services (CJIS) notification requirements.
  - Policy implementation, dissemination, and acknowledgment tracking.
  - Legal and regulatory alignment.
  - Exception management.
  - Enforcement record retention.
- **Out of Scope**:
  - Policy review cadence and lifecycle management: **Policy 1.05**.
  - Service delivery grievances and dispute resolution for enforcement actions: **Policy 3.04**.
  - Internal audit procedures and control testing: **Policy 5.02**.
  - Vendor compliance and third-party assurance: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the enforcement authority for the ECIO Policy Manual across all population classes defined in Section 6.4.
  - Shall maintain independent authority over the County's information technology infrastructure, including the authority to take immediate system-level action to protect County assets, reduce liability, or manage operational and compliance risk.
  - Shall initiate IT-administrative corrective actions in accordance with Section 6.3.
  - Shall document enforcement decisions in the Department's system of record within twenty-four (24) hours of the action.

  - Shall refer matters to the appropriate personnel authority or legal process when the non-compliance warrants action beyond the IT Director's IT-administrative authority.
  - Shall serve as the Local Agency Security Officer (LASO) for CJIS notification purposes under the formal sanctions process defined in Section 6.5.
  - Shall maintain awareness of legal and regulatory changes affecting the manual and initiate event-driven reviews in accordance with **Policy 1.05** (Policy Review and Update Procedures).
  - Shall approve policy exceptions in accordance with the exception management framework defined in Section 6.6 and within delegated authority under **Policy 1.08** (Delegation of Authority and Decision Rights), except where this policy requires County Manager approval or where the exception exceeds delegated authority.
- **County Manager**:
  - Shall serve as the escalation authority for enforcement disputes that cannot be resolved at the IT Director level.
  - Shall receive written notification from the IT Director when IT-administrative enforcement actions are taken against appointed or elected officials.
  - Shall approve formal policy exceptions that exceed the IT Director's delegated authority in accordance with **Policy 1.08**.
- **Human Resources (HR)**:
  - Shall serve as the process owner for personnel-disciplinary actions initiated through the applicable labor agreement, County Personnel Policies, or employment contract.
  - Shall receive referrals from the IT Director when IT-administrative corrective actions escalate to the personnel-disciplinary track.
  - Shall maintain sanctions documentation and personnel records in accordance with applicable retention requirements.
- **District Attorney's Office**:
  - Shall receive referrals from the IT Director when non-compliance involves suspected criminal activity, potential liability to the County, or circumstances requiring immediate legal guidance.
  - Shall determine next steps in coordination with HR when emergency protective actions are taken against appointed officials.
- **Department Heads**:
  - Shall receive written notification from the IT Director when IT-administrative enforcement actions are taken against personnel under their supervision.
  - Shall initiate personnel-disciplinary action through the applicable process when referred by the IT Director.
  - Shall direct disputes regarding IT enforcement actions through the service grievance pathway established in **Policy 3.04** (Service Delivery Feedback and Grievance Policy) or through the risk acceptance process established in **Policy 1.09** (Risk Management Policy) where the dispute concerns a compliance standard.
- **All County Personnel and Contractors**:
  - Shall comply with the policies, standards, and procedures established in the ECIO Policy Manual.
  - Shall complete required policy acknowledgments within the timeframes defined in Section 6.2.
  - Shall cooperate with IT-administrative enforcement actions and investigations.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all personnel, entities, and systems within the scope of the ECIO Policy Manual.

- **Assessment**: Compliance with the enforcement, acknowledgment, and exception management requirements of this policy shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance with the requirements of this policy — including failure to complete required acknowledgments, failure to cooperate with IT-administrative enforcement actions, or failure to document and route enforcement actions as required — shall be addressed through the corrective action framework defined in Section 6.3 of this policy.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the County Manager in accordance with **Policy 1.08**. Oral exceptions are not valid. Exceptions to this policy shall not be approved by the IT Director alone, as the IT Director is both the enforcement authority and a subject of this policy.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205 (Computer Crimes)
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records Management Program)
- NRS 242.171 (Responsibilities of Office/Director)
- NRS 244 (Counties: Government)
- NRS 281A (Ethics in Government)
- NRS 603A (Security of Personal Information)

- NAC 239.155 (Adoption of Records Retention Schedule)
- CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions)
- NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions)

Framework Alignment:

- NIST CSF 2.0: GV.OC-03 (Legal, Regulatory, and Contractual Requirements)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: GV.PO-02 (Policy Review)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: PL-1 (Planning Policy and Procedures)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: SI-12 (Information Management and Retention)
- COBIT 2019: APO01.01 (Design the Management System for Enterprise I&T)
- COBIT 2019: APO01.09 (Define and Communicate Policies and Procedures)
- COBIT 2019: MEA03 (Managed Compliance with External Requirements)
- ITIL v4: Continual Improvement Practice

6. Policy Statement

The ECIO Policy Manual is an enforceable governance instrument, not an aspirational document. Every directive expressed in mandatory compliance language ("shall" or "must") across the manual is an auditable obligation backed by the corrective action framework defined in this policy. This policy provides the operational mechanism through which non-compliance is identified, documented, escalated, and resolved — and through which the manual's alignment with applicable law is maintained.

For purposes of this policy, references to the Department's system of record refer to the designated operational recordkeeping system for enforcement actions, acknowledgments, and exception records. This is distinct from the Authoritative System of Record maintained under **Policy 1.04**, which governs policy text.

6.1 Policy Implementation and Dissemination

The IT Director shall ensure that all policies within the ECIO Policy Manual are operationalized through the following implementation requirements.

- **Publication**: Upon approval of a new or revised policy, the IT Director shall publish the updated policy to the Departmental Knowledge Base in accordance with **Policy 3.13** (Knowledge Management Policy). The LyX master record and its compiled PDF remain the legally authoritative source in accordance with **Policy 1.04** (Policy and Documentation Formatting Standards); the Knowledge Base publication constitutes the operational distribution mechanism.
- **Constructive Notice**: Publication of a policy in the Knowledge Base constitutes constructive notice to all Information Operations personnel. The IT Director shall issue a written notification to all Department personnel upon publication of any new or substantively revised policy. For non-IT County personnel, constructive notice is established through the acknowledgment and training mechanisms defined in Section 6.2 and **Policy 2.03** (Security Awareness and Training Policy).
- **Documentation as Standard**: Material operational actions, security-relevant actions, service-affecting changes, enforcement actions, and decisions that establish direction, approval, or disposition shall be documented in the designated System of Engagement within twenty-four (24) hours of completion,

except during active incident response where documentation shall occur during incident closure in accordance with **Policy 4.01** (Incident Response Policy Overview). Dependence on memory, verbal direction, or informal communication as a substitute for written documentation is prohibited. Failure to document required actions constitutes non-compliance with this policy.

- **Coordination with Review Lifecycle**: Implementation of policies shall be coordinated with the review lifecycle defined in **Policy 1.05**. Event-driven reviews triggered by enforcement actions, legal changes, or audit findings shall follow the procedures established in that policy.

6.2 Policy Acknowledgment and Awareness

The IT Director shall maintain a policy acknowledgment program to ensure all personnel within scope are aware of their obligations under the ECIO Policy Manual.

- **Information Operations Personnel**: All Information Operations personnel shall acknowledge receipt and understanding of the ECIO Policy Manual upon hire, upon any substantive revision to a policy within their scope of responsibility, and annually thereafter. Acknowledgments shall be documented and retained in the Department's system of record.
- **Non-IT County Personnel**: Acknowledgment requirements for non-IT County personnel are established through the acceptable use acknowledgment process defined in **Policy 2.01** (Acceptable Use of Information Technology Resources Policy) and the security awareness and training program defined in **Policy 2.03**. The IT Director shall coordinate with HR to ensure acknowledgment completion is tracked.
- **Contractors and Vendors**: Contractors and vendors shall acknowledge applicable ECIO policies as a condition of access provisioning in accordance with **Policy 1.14** (Stakeholder Engagement and Communications Policy) and **Policy 2.01**.
- **Lapsed Acknowledgment**: The IT Director shall withhold or suspend system access for any individual whose required policy acknowledgment is overdue by more than thirty (30) calendar days. Access shall be reinstated upon completion of the outstanding acknowledgment. This suspension is an IT-administrative action under Section 6.3, not a personnel-disciplinary action.
- **Completion Tracking**: Acknowledgment completion rates shall be reported as part of the annual policy review and maturity scoring process defined in **Policy 5.07**.

6.3 Enforcement Authority and IT-Administrative Actions

The IT Director maintains independent authority over the County's information technology infrastructure. This authority includes the right to take immediate system-level action to protect County assets, reduce liability, or manage operational and compliance risk. This authority exists regardless of the position, department, or employment classification of the affected party.

IT-administrative actions are distinct from personnel-disciplinary actions. IT-administrative actions are imposed by the IT Director under management authority over the technology infrastructure. Personnel-disciplinary actions are governed by the applicable labor agreement, County Personnel Policies, or employment contract and are processed through the appropriate personnel authority. This policy governs IT-administrative actions directly and defines the referral mechanism for personnel-disciplinary actions.

The following IT-administrative actions are available to the IT Director. This list constitutes the governed set of actions; the IT Director may also impose other operationally appropriate restrictions within the IT Director's management authority over the County's information technology infrastructure to protect County assets, reduce liability, or manage operational and compliance risk.

- **System-Level Actions (applicable to all population classes)**:
  - Access suspension (temporary revocation of logical access to one or more County systems).
  - Privilege revocation (removal of elevated or specialized permissions).

  - Network isolation (disconnection of a device, system, or network segment).
  - Asset confiscation (physical removal of County-owned IT assets from the individual's possession).
  - Forced credential reset (mandatory password change or re-authentication).
  - Account lockout (disabling an account pending investigation or remediation).
  - Increased audit frequency (enhanced monitoring of the affected account, system, or network segment).
  - Mandatory retraining as a prerequisite for access reinstatement.
- **Supervisory Actions (applicable only to Information Operations personnel)**:
  - Documented coaching and counseling.
  - Formal written performance deficiency notice.
  - Tier reassignment (temporary or permanent reassignment to a lower operational tier as defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework)).
  - Removal from on-call, standby, or specialized duty rotations.
  - Referral to the HR and/or County Manager process for formal discipline under the applicable labor agreement or County Personnel Policies.

Corrective action may begin at any level depending on the severity of the non-compliance, the frequency of the occurrence, the risk to County assets or operations, and the cumulative effect of prior non-compliance. The IT Director is not required to follow a sequential escalation path.

The IT Director shall document all IT-administrative enforcement actions in the Department's system of record within twenty-four (24) hours of the action. Documentation shall include the nature of the non-compliance, the enforcement action taken, the affected individual or system, and the notification provided to the appropriate parties.

IT-administrative actions shall remain in effect during any dispute resolution process unless the County Manager directs otherwise or a court order requires it. The dispute resolution pathways defined in Section 6.4 determine whether an action was justified; they do not automatically stay the action.

6.4 Enforcement by Population Class

The IT Director's enforcement authority and notification obligations vary based on the affected party's relationship to the County. The following population classes define the enforcement posture, notification chain, and dispute resolution routing for each class.

- **Information Operations Personnel**:
  - **Enforcement Posture**: The IT Director may impose any IT-administrative action defined in Section 6.3, including both system-level and supervisory actions.
  - **Notification**: No external notification is required for IT-administrative actions within the IT Director's supervisory authority. When the IT Director refers a matter to the personnel-disciplinary track, the IT Director shall provide written documentation of the non-compliance and the IT-administrative actions already taken to HR and/or the County Manager.
  - **Personnel-Disciplinary Referral**: Formal discipline beyond the IT Director's supervisory authority shall be initiated through the applicable labor agreement (Article 9, Disciplinary Action) or County Personnel Policies. The IT Director shall provide the written notice, supporting documentation, and evidence required by the applicable process.

  - **Dispute Resolution**: Internal disputes shall follow the Department's chain of command. Represented employees retain all rights under the applicable labor agreement, including grievance and arbitration rights.

- **Non-IT County Employees**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3. The IT Director shall not impose supervisory actions on personnel outside the Information Operations Department.
  - **Notification**: The IT Director shall provide written notification to the affected employee's department head within one (1) business day of any IT-administrative enforcement action. The notification shall identify the non-compliance, the action taken, and the policy basis for the action.
  - **Personnel-Disciplinary Referral**: Where the IT Director determines that the non-compliance warrants personnel-disciplinary action, the IT Director shall refer the matter in writing to the affected employee's department head and/or HR. The department head shall initiate action through the applicable labor agreement or personnel process.
  - **Dispute Resolution**: Department heads who dispute an IT-administrative enforcement action shall direct the dispute through the service grievance pathway established in **Policy 3.04**. Requests to relax or waive the underlying compliance standard shall be directed through the risk acceptance process established in **Policy 1.09**. These pathways are the exclusive channels for resolving enforcement disputes; informal or lateral communications that attempt to circumvent them shall be redirected to the appropriate channel.
- **Appointed and Elected Officials**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3.
  - **Notification**: The IT Director shall provide written notification to the County Manager within one (1) business day of any IT-administrative enforcement action taken against an appointed or elected official.
  - **Emergency Protective Action**: Where the IT Director identifies an immediate threat to County assets, evidence of a bad act, or conditions requiring immediate protective action, the IT Director shall take immediate system-level action and shall notify the County Manager, HR, and the District Attorney's Office immediately, providing the reasoning for the action. The appropriate authority shall determine next steps. The IT Director shall document the emergency protective action and the notifications provided in the Department's system of record within twenty-four (24) hours, consistent with the documentation requirement in Section 6.3.
  - **Dispute Resolution**: Appointed and elected officials who dispute an IT-administrative enforcement action shall direct the dispute through the service grievance pathway established in **Policy 3.04**, which provides for escalation to the County Manager. Requests to relax or waive the underlying compliance standard shall be directed through the risk acceptance process established in **Policy 1.09**.
- **Contractors and Vendors**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3. Access revocation for contractors and vendors is immediate and does not require prior approval from the contract administrator.
  - **Notification**: The IT Director shall provide written notification to the responsible contract administrator and to the vendor compliance process established in **Policy 5.06** (Vendor Compliance and Third-Party Assurance) within one (1) business day of any IT-administrative enforcement action.

- **Contract Remedies**: Where non-compliance by a contractor or vendor constitutes a breach of contractual obligations, the IT Director shall refer the matter to the contract administrator and County legal counsel for contract remedies. The IT Director's authority to revoke or restrict system access is independent of the contract remedy process.
- **Dispute Resolution**: Contractors and vendors shall direct disputes through the contract administrator. The service grievance pathway in **Policy 3.04** is available to the extent the contractor or vendor is a recipient of IT services.

6.5 Formal Sanctions Process and CJIS Notification

The Department shall employ a formal sanctions process for individuals who fail to comply with the policies and procedures established in the ECIO Policy Manual. This process is consistent with applicable County HR policies, labor agreements, and NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions).

- **Initiation**: The IT Director initiates the formal sanctions process by documenting the non-compliance, the IT-administrative actions taken, and a recommendation for formal discipline. The IT Director shall refer the documented matter to HR and/or the County Manager for processing through the applicable personnel framework.
- **Process Ownership**: The formal sanctions process is governed by the applicable labor agreement, County Personnel Policies, or employment contract — not by this policy. This policy defines the trigger conditions, the documentation the IT Director provides, and the CJIS notification obligation. It does not define the investigation, notice, response, or appeal procedures, which are established in the applicable personnel framework.
- **CJIS Notification Requirement**: In accordance with CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions) and NIST SP 800-53 Rev. 5: PS-8, when a formal sanctions process is initiated against any individual with access to Criminal Justice Information (CJI), the IT Director (as LASO) shall notify the appropriate Information Security Officer (ISO), HR representative, and System or Network Administrator within twenty-four (24) hours. The notification shall identify the individual sanctioned and the reason for the sanction, unless County legal counsel determines a different timing is legally required.
- **Legal Referral**: Where non-compliance involves suspected criminal activity — including but not limited to violations of NRS 205 (Computer Crimes) or unauthorized access to CJI — the IT Director shall refer the matter to the District Attorney's Office and, where applicable, to the appropriate law enforcement authority. Legal referral does not preclude concurrent IT-administrative action; the IT Director shall take immediate system-level protective action as warranted.

6.6 Exception Management

All policies within the ECIO Policy Manual are subject to a uniform exception management framework. Exceptions to any policy requirement shall be governed by the following requirements.

- **Written Documentation**: All exceptions shall be documented in writing prior to implementation. The documentation shall include the specific policy requirement from which the exception is sought, the business justification, the proposed duration, the compensating controls (if any), and the residual risk accepted.
- **Approval Authority**: Exceptions shall be approved in writing by the IT Director within delegated authority under **Policy 1.08**. Exceptions that exceed the IT Director's delegated authority shall be approved by the County Manager. Oral exceptions are not valid.
- **Policy-Specific Requirements**: Where a policy's Section 4 establishes exception requirements that are stricter than this general framework, the stricter requirement governs. Exceptions to this policy (**Policy 5.01**) are subject to the approval requirements in Section 4, which require County Manager approval; the IT Director shall not approve exceptions to this policy acting alone.

- **CJI Exceptions**: Exceptions to any policy requirement that governs the handling, storage, transmission, or access to CJI shall require explicit written approval of the IT Director (as LASO) and, where applicable, written approval by the CJIS Systems Agency (CSA), CJIS Systems Officer (CSO), or other governing authority required by applicable CJIS agreements. All such approvals shall be retained for audit.
- **Risk Recording**: All approved exceptions shall be recorded in the central Risk Register maintained under **Policy 1.09**. The risk entry shall reference the exception documentation and shall be reviewed during the annual policy review cycle defined in **Policy 5.07**.
- **Duration and Review**: Exceptions shall specify a duration. Open-ended exceptions are prohibited. The IT Director shall review all active exceptions during each annual policy review cycle and shall close, renew, or escalate each exception based on current risk conditions.
- **Retroactive Exceptions**: Retroactive exceptions — documenting a deviation after the fact — shall be documented as a non-compliance event under Section 6.3 and evaluated for corrective action. A retroactive exception does not constitute a defense to an enforcement action already initiated.

6.7 Legal and Regulatory Alignment

The ECIO Policy Manual operates within and supports compliance with applicable federal, state, and local law. The IT Director shall maintain awareness of legal and regulatory changes that affect the manual's obligations and shall ensure the manual remains aligned with current requirements.

- **Monitoring Responsibility**: The IT Director shall monitor changes to the Nevada Revised Statutes, the Nevada Administrative Code, the CJIS Security Policy, and applicable federal law and regulation that affect the manual's scope. The IT Director may designate qualified personnel to assist with monitoring but retains accountability for the alignment determination.
- **Event-Driven Review**: When a legal or regulatory change is identified that affects one or more policies in the manual, the IT Director shall initiate an event-driven review in accordance with **Policy 1.05**. The review shall assess the impact of the change, identify the affected policies, and produce the necessary updates.
- **Order of Precedence**: Where a conflict between the ECIO Policy Manual and a legal or regulatory requirement is identified, the legal requirement prevails. The order of authority established in the Compliance Alignment & Order of Precedence section of the Manual Executive Summary governs the resolution hierarchy. The IT Director shall update the affected policy within the next scheduled review cycle, or sooner if the conflict creates immediate compliance risk.
- **Statutory Awareness (Non-Exhaustive)**: The following statutes and regulations are of primary relevance to the manual's enforcement and compliance obligations. This list is maintained for operational awareness and does not constitute a comprehensive legal analysis. NRS 205 (Computer Crimes), NRS 239 (Public Records), NRS 239.125 (Local Government Records Management Program), NRS 242.171 (Responsibilities of Office/Director), NRS 244 (Counties: Government), NRS 281A (Ethics in Government), NRS 603A (Security of Personal Information), and the CJIS Security Policy as published by the FBI Criminal Justice Information Services Division.

6.8 Enforcement Record Retention

The IT Director shall ensure that all records generated under this policy are classified, retained, and disposed of in accordance with **Policy 1.11** (Data Governance and Classification Policy), NRS 239.125 (Local Government Records Management Program), NAC 239.155 (Adoption of Records Retention Schedule), and the applicable series within the Nevada Local Government Records Retention Schedule.

- **Corrective Action Records**: Documentation of IT-administrative enforcement actions, including the nature of the non-compliance, the action taken, notification records, and any remediation completed, shall be retained for a minimum period consistent with the applicable retention schedule series for personnel security and disciplinary records.

- **Sanctions Documentation**: Records of formal sanctions referrals, including CJIS PS-8 notification records, shall be retained in coordination with HR and in accordance with the applicable retention schedule.
- **Exception Records**: Approved exception documentation, risk register entries, and renewal or closure records shall be retained for the duration of the exception plus the applicable retention period.
- **Acknowledgment Records**: Policy acknowledgment records shall be retained for a minimum of seven (7) years following separation of employment or contract termination, consistent with the retention requirements established in **Policy 2.01** and the applicable CJIS requirements.
- **Legal Referral Records**: Records of referrals to the District Attorney's Office or law enforcement shall be retained in accordance with the applicable retention schedule and in coordination with the receiving authority.
- **Public Records Status**: All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. The classification and handling of enforcement records shall comply with **Policy 1.11**.

5.02 Internal Audits, Self-Assessment, and Control Testing

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the internal audit program, self-assessment procedures, and control testing methodology that the Information Operations Department uses to evaluate the implementation, operating effectiveness, and continued adequacy of controls, processes, and obligations defined throughout the ECIO Policy Manual.

2. Scope

This policy applies to all policies, controls, processes, and systems governed by the ECIO Policy Manual.

- **In Scope**:
  - Internal audit planning, scheduling, and execution.
  - Self-assessment procedures and process-owner evaluations.
  - Control testing and validation methodology.
  - Audit and assessment documentation, evidence handling, and record retention.
  - Deficiency identification, classification, and routing.
- **Out of Scope**:
  - Policy lifecycle management and version control: **Policy 1.05**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Corrective action plan development, tracking, and closure: **Policy 5.03**.
  - Security control authorization decisions: **Policy 5.05**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the audit authority for the ECIO Policy Manual.
  - Shall approve the Annual Audit Plan defined in Section 6.1.
  - Shall receive and review all audit summary reports and deficiency notifications produced under this policy.
  - Shall authorize unplanned audits when circumstances require assessment outside the approved schedule.
  - Shall ensure that audit activities maintain sufficient objectivity as defined in Section 6.4.
  - Shall evaluate the need for external assessment services when internal objectivity cannot be achieved for Criminal Justice Information Services (CJIS) relevant controls, consistent with CJIS Security Policy v6.0: CA-2(1) (Independent Assessors) and CA-7(1) (Independent Assessment).

- **Assistant IT Director**:
  - Shall develop the draft Annual Audit Plan for IT Director approval.
  - Shall execute or coordinate the execution of all internal audits, self-assessments, and control tests scheduled under this policy.
  - Shall maintain audit records and evidence in the System of Engagement (Redmine).
  - Shall ensure that audit-derived evidence is protected against unauthorized modification or deletion in accordance with CJIS Security Policy v6.0: AU-9 (Protection of Audit Information).
  - Shall prepare audit summary reports for IT Director review.
  - Shall classify findings and route deficiencies in accordance with Section 6.5.
  - Shall conduct or coordinate the quarterly self-assessments defined in Section 6.2.
  - Shall maintain the Control Testing Register defined in Section 6.3.
- **All Information Operations Personnel**:
  - Shall cooperate fully with internal audit and control testing activities, including providing access to systems, records, and documentation within their operational responsibility.
  - Shall conduct self-assessments of controls within their assigned operational areas when directed by the Assistant IT Director.
  - Shall not obstruct, delay, or withhold information from audit or assessment activities.
- **Department Heads (Non-IT County Departments)**:
  - Shall cooperate with audit and assessment activities that evaluate controls applicable to their personnel or systems, including access reviews, acceptable use compliance, and training verification.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all personnel within scope, in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Assessment**: Compliance with audit planning, execution, documentation, and reporting obligations shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to execute scheduled audits, failure to document audit findings, failure to route deficiencies as required, or obstruction of audit activities shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification, identification of residual risk, and any compensating measures. Exceptions affecting audit scope minimums, CJIS testing cadences, or the objectivity safeguards established in Section 6.4 shall be approved by the County Manager in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights) and the exception management framework established in **Policy 5.01**. All other exceptions shall be approved by the IT Director in accordance with **Policy 1.08** and **Policy 5.01**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.05: Security Control Assessment and Authorization
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- CJIS Security Policy v6.0: AU-9 (Protection of Audit Information)
- CJIS Security Policy v6.0: CA-1 (Assessment, Authorization, and Monitoring Policy and Procedures)
- CJIS Security Policy v6.0: CA-2 (Control Assessments)
- CJIS Security Policy v6.0: CA-7 (Continuous Monitoring)
- NIST CSF 2.0: ID.IM-01 (Improvements are identified from evaluations)
- NIST CSF 2.0: ID.IM-02 (Improvements are identified from security tests and exercises)
- NIST SP 800-53 Rev. 5: CA-2 (Control Assessments)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)

Framework Alignment:

- COBIT 2019: MEA02 (Managed System of Internal Control)
- ITIL v4: Continual Improvement Practice

6. Policy Statement

6.1 Audit Planning and Annual Schedule

The IT Director shall approve an Annual Audit Plan no later than thirty (30) calendar days after the beginning of each fiscal year. The Assistant IT Director shall prepare the draft plan and submit it to the IT Director for review.

The Annual Audit Plan shall identify, at minimum: the policies, controls, and processes to be assessed during the fiscal year; the assessment method for each item (internal audit, self-assessment, or control test); the planned quarter of execution; and the personnel or role responsible for conducting each assessment.

Audit scope shall be determined on a risk-informed basis. The following factors shall inform prioritization: the results of the previous year's audit and assessment cycle, the risk ratings maintained under **Policy 1.09** (Risk Management Policy), any open deficiencies tracked under **Policy 5.03** (Compliance Monitoring and Corrective Action), changes to the regulatory or threat environment, and the results of any external audits or assessments conducted during the prior period.

Every policy in the ECIO Policy Manual shall be assessed through at least one of the three mechanisms defined in this policy — internal audit, self-assessment, or control test — within each annual cycle. Policies governing controls subject to CJIS Security Policy obligations shall be assessed no less than annually through internal audit or control testing; self-assessment alone does not satisfy the CJIS assessment requirement.

The Annual Audit Plan is a planning instrument; it does not prevent the IT Director from authorizing additional assessments during the fiscal year. The IT Director may initiate unplanned audits in response to

cybersecurity incidents, enforcement actions, external audit findings, regulatory changes, or risk conditions identified under **Policy 1.09**. The Assistant IT Director shall document unplanned audits in the System of Engagement with the same rigor as planned audits.

6.2 Self-Assessment Procedures

Self-assessments are process-owner evaluations that determine whether the controls assigned to a given operational area are implemented, are operating as intended, and are producing the expected outcome. Self-assessments supplement — but do not replace — the internal audit and control testing activities defined in Sections 6.1 and 6.3.

The Assistant IT Director shall conduct or coordinate self-assessments on a quarterly cadence. Each quarterly self-assessment cycle shall cover the policies and controls designated in the Annual Audit Plan for that quarter. Where the Annual Audit Plan designates a policy for self-assessment rather than internal audit, the quarterly self-assessment constitutes the annual assessment obligation for that policy.

Each self-assessment shall evaluate, at minimum: whether the required controls are documented and current, whether the controls have been executed within the cadences defined in the governing policy, and whether evidence of control execution exists in the System of Engagement or the applicable system of record.

The Assistant IT Director shall document self-assessment results in a work order in the System of Engagement in accordance with **Policy 3.13** (Knowledge Management Policy). Each self-assessment record shall include: the policy or control area assessed, the assessment date, the controls evaluated, the determination for each control (conforming, observation, or deficiency as defined in Section 6.5), and any recommended actions.

Where a self-assessment reveals a condition that requires deeper evaluation, the Assistant IT Director shall escalate the finding to the IT Director with a recommendation to initiate an unplanned internal audit or control test of the affected area.

6.3 Control Testing and Validation

Control testing validates that a specific technical or procedural control produces its intended security or operational outcome when exercised. Control testing goes beyond self-assessment by directly exercising the control mechanism rather than evaluating documentation and evidence of prior execution.

The Assistant IT Director shall maintain a Control Testing Register in the System of Engagement. The register shall list each testable control, the governing policy, the testing method, the testing cadence, and the date and result of the most recent test. The register is a living instrument; the Assistant IT Director shall update it as policies are added, revised, or retired under **Policy 1.05** (Policy Review and Update Procedures).

The Assistant IT Director shall select testing methods appropriate to the control being tested. Testing methods shall include one or more of the following: examination of documentation, records, or configuration artifacts; interview of personnel responsible for the control's operation; and direct testing through observation, execution, or simulation of the control mechanism.

Each control test shall document: the control tested and the governing policy reference, the testing method used, the expected outcome, the actual outcome, the pass or fail determination, and any anomalies or observations noted during the test.

Testing cadence shall be risk-informed and shall comply with the following minimum frequencies:

- Controls implementing CJIS Security Policy requirements shall be tested no less than annually.
- Controls identified as high-risk under **Policy 1.09** shall be tested no less than annually.
- All other controls shall be tested no less than once every twenty-four (24) months.

The IT Director may establish more frequent testing cadences for specific controls based on risk conditions, regulatory changes, or prior test failures.

Where a control test results in a failure, the Assistant IT Director shall classify the finding per Section 6.5 and route it accordingly. The Assistant IT Director shall retest a failed control after remediation is complete; the retest result shall be documented in the same work order chain as the original test.

6.4 Audit Execution and Documentation

The Assistant IT Director shall conduct internal audits in accordance with the Annual Audit Plan or under IT Director authorization for unplanned assessments. Each internal audit shall follow a consistent methodology comprising four stages: scoping, evidence collection, analysis, and reporting.

- **Scoping**: The auditor shall define the controls under assessment, the assessment criteria, the evidence to be collected, and the systems or records to be examined. The auditor shall retain the scoping document with the audit record.
- **Evidence Collection**: The auditor shall gather sufficient evidence to support a determination of control effectiveness. Evidence may include system configurations, log records, work order histories, training records, policy acknowledgment records, and direct observation of operational procedures.
- **Analysis**: The auditor shall evaluate collected evidence against the requirements of the governing policy and applicable framework controls to determine whether each assessed control is conforming, warrants an observation, or constitutes a deficiency.
- **Reporting**: The auditor shall prepare an audit summary that documents the scope, methodology, evidence collected, findings by control, and recommended actions. The auditor shall submit the audit summary to the IT Director within fifteen (15) business days of the completion of evidence collection.

Objectivity is a core requirement of the audit function. Personnel shall not serve as the primary auditor for controls they materially implement, administer, or routinely operate. Where staffing constraints make full independence impractical, the IT Director shall document the constraint and ensure that audit results receive independent review. For the purposes of this policy, independent review means review by a person who did not participate in the implementation, operation, or assessment of the controls under evaluation.

The IT Director shall evaluate the need for external assessment services when internal objectivity cannot be achieved for CJIS-relevant controls, consistent with CJIS Security Policy CA-2(1) and CA-7(1).

The Assistant IT Director shall maintain all audit documentation — scoping documents, evidence artifacts, working papers, and audit summaries — in the System of Engagement and shall classify audit records in accordance with **Policy 1.11** (Data Governance and Classification Policy). Audit records may be subject to disclosure under NRS 239 unless protected by a specific statutory exemption; classification and handling shall follow **Policy 1.11**.

6.5 Findings, Classification, and Routing

The Assistant IT Director shall classify audit findings, self-assessment results, and control test outcomes using a three-tier scheme.

- **Conforming**: The assessed control is implemented correctly, is operating as intended, and is producing the desired outcome. Conforming findings shall be recorded in the Control Testing Register and shall contribute to the maturity scoring process under **Policy 5.07**.
- **Observation**: A minor gap, inconsistency, or area for improvement that does not constitute a material failure of the control's protective or operational function. The Assistant IT Director shall document and track observations. The Assistant IT Director shall reclassify observations that recur across two (2) or more consecutive assessment cycles as deficiencies.
- **Deficiency**: The control is not implemented, is not operating as intended, or is not producing the desired outcome, and the gap creates material risk to the security, compliance, or operational posture

of the Department. The Assistant IT Director shall route deficiencies to **Policy 5.03** for corrective action plan development within ten (10) business days of classification.

When a deficiency affects a control implementing a CJIS Security Policy requirement, the IT Director shall evaluate whether the deficiency constitutes a reportable condition under the applicable CJIS notification obligations and shall act accordingly.

When an audit or assessment reveals that non-compliance by an individual has occurred, the Assistant IT Director shall route the finding to the IT Director for evaluation under the enforcement framework established in **Policy 5.01**. The audit function identifies the condition; enforcement authority remains with the IT Director under **Policy 5.01**.

The Assistant IT Director shall prepare a consolidated Annual Audit Summary Report at the conclusion of each annual audit cycle. The report shall document: the total number of assessments conducted by type (internal audit, self-assessment, and control test); the number and distribution of findings by classification tier; the policies and controls with open deficiencies; trend data comparing current-year results to prior-year results; and recommendations for the next annual cycle. The Assistant IT Director shall submit the Annual Audit Summary Report to the IT Director and shall make it available as an input to the annual policy review and maturity scoring process under **Policy 5.07**.

6.6 Audit Record Retention

The Assistant IT Director shall retain audit records, self-assessment documentation, control test results, evidence artifacts, and audit summary reports in the System of Engagement in accordance with **Policy 1.11** and the applicable Nevada Local Government Records Retention Schedule. Where multiple retention requirements apply, the longest applicable period shall govern. Audit records shall be retained for a minimum of three (3) years from the date of the assessment where no longer retention period is specified by an applicable schedule.

5.03 Compliance Monitoring and Corrective Action

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy governs the development, approval, tracking, and closure of Corrective Action Plans and establishes the compliance monitoring function that verifies the Department's ongoing adherence to its statutory and regulatory notification obligations.

2. Scope

This policy applies to all deficiencies, control failures, and compliance gaps identified through the assessment, audit, and operational monitoring functions of the ECIO Policy Manual that require documented remediation.

- **In Scope**:
  - Corrective Action Plan development, content requirements, and approval.
  - Corrective Action Plan tracking, milestone management, and closure.
  - Verification of remediation effectiveness.
  - Compliance monitoring of incident reporting and breach notification obligations.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Service level target-setting and SLA deviation thresholds: **Policy 3.01** and **Policy 3.02**.
  - Enforcement actions against individuals and formal sanctions: **Policy 5.01**.
  - Audit planning, assessment execution, and deficiency classification: **Policy 5.02**.
  - Vendor compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall approve all Corrective Action Plans prior to execution.
  - Shall approve Corrective Action Plan closures upon receipt of verification evidence.
  - Shall evaluate whether a deficiency affecting a control implementing a Criminal Justice Information Services (CJIS) Security Policy requirement, or any statutory breach notification obligation, triggers external or interagency reporting requirements.
  - Shall ensure that required notifications are executed in accordance with **Policy 4.02** (Identification and Reporting Procedures) and **Policy 4.06** (Communication Protocols and Partner Integration) when reporting is required.
  - Shall authorize exceptions to this policy in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Assistant IT Director**:

  - Shall develop the Corrective Action Plan for each deficiency routed to this policy within the timeframes defined in Section 6.2.
  - Shall maintain all open Corrective Action Plans in the System of Engagement (Redmine).
  - Shall review all open Corrective Action Plans no less than monthly and shall update milestone status as material progress occurs.
  - Shall request verification assessments through the mechanisms defined in **Policy 5.02** upon completion of remediation activities.
  - Shall ensure that each Corrective Action Plan is linked to the corresponding entry in the Risk Register maintained under **Policy 1.09**.
  - Shall conduct the compliance monitoring reviews defined in Section 6.5.
  - Shall report open Corrective Action Plans and their current status as part of the reporting cadences defined in **Policy 3.02** and **Policy 5.04** (Performance Metrics and Operational KPIs).
- **All Information Operations Personnel**:
  - Shall execute remediation tasks assigned under an approved Corrective Action Plan within the milestone timelines established in the plan.
  - Shall document remediation actions in the System of Engagement (Redmine) as they are completed.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in deficiency remediation, compliance monitoring, or Corrective Action Plan management.

- **Assessment**: Adherence to Corrective Action Plan development timelines, milestone tracking, verification requirements, and compliance monitoring obligations shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to develop required Corrective Action Plans within the timelines defined in Section 6.2, failure to maintain milestone tracking, or failure to conduct required compliance monitoring reviews shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment

- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: CA-5 (Plan of Action and Milestones)
- CJIS Security Policy v6.0: CA-7 (Continuous Monitoring)
- CJIS Security Policy v6.0: IR-6 (Incident Reporting)
- NIST CSF 2.0: ID.IM-01 (Improvements Are Identified from Evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements Are Identified from Execution of Operational Processes)
- NIST SP 800-53 Rev. 5: CA-5 (Plan of Action and Milestones)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-4 (Plan of Action and Milestones Process)

Framework Alignment:

- COBIT 2019: MEA01.05 (Ensure the Implementation of Corrective Actions)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Problem Management Practice

6. Policy Statement

6.1 Scope and Intake Sources

This policy governs two functions. First, it defines the lifecycle for Corrective Action Plans (CAPs) — the documented remediation instruments used to correct deficiencies, control failures, and compliance gaps identified across the ECIO Policy Manual. Second, it establishes the compliance monitoring function that verifies the Department's adherence to its incident reporting and breach notification obligations. These functions are connected: gaps identified through compliance monitoring enter the same CAP lifecycle as deficiencies from any other intake source.

Corrective Action Plans constitute the Department's implementation of NIST SP 800-53 Rev. 5: CA-5 (Plan of Action and Milestones) and CJIS Security Policy v6.0: CA-5. All remediation tracking instruments within the ECIO Policy Manual — regardless of the label used in the originating policy — shall follow the lifecycle defined in this policy.

The Assistant IT Director shall initiate CAPs from the following intake sources. This policy does not redefine the triggers or thresholds that generate these inputs; it receives them and governs what happens next.

- **Audit-Derived Deficiencies**: Deficiencies classified under **Policy 5.02** Section 6.5 and routed to this policy for corrective action plan development.
- **Service Level Corrective Action**: Corrective Action Plans triggered by the sustained non-compliance threshold defined in **Policy 3.02** Section 6.3.
- **Risk Response Remediation**: Remediation actions identified through the risk response process defined in **Policy 1.09** that require documented tracking with milestones.
- **Compliance Monitoring Findings**: Gaps identified through the compliance monitoring function defined in Section 6.5 of this policy.

The boundary between this policy and its adjacent policies is as follows. **Policy 5.02** identifies deficiencies through audit, self-assessment, and control testing; this policy develops and manages the remediation. **Policy 5.01** enforces consequences against individuals for non-compliance; this policy remediates the process or control that failed. **Policy 1.09** maintains the Risk Register and defines when a risk response is needed; this policy governs the remediation lifecycle once that response requires tracked corrective action.

6.2 Corrective Action Plan Content and Approval

The Assistant IT Director shall develop a CAP for each deficiency routed to this policy. Development shall be completed within ten (10) business days of receipt from the originating source. When a deficiency is routed from **Policy 5.02**, the ten (10) business day development window begins on the date of classification under **Policy 5.02** Section 6.5.

Each CAP shall be documented in the System of Engagement (Redmine) and shall include, at minimum, the following content:

- **Deficiency Description**: A clear statement of the control failure, compliance gap, or process breakdown, including the originating source and the affected policy or control.
- **Root Cause**: The identified or probable cause of the deficiency. Where the root cause cannot be determined within the development window, the CAP shall state that root cause analysis is ongoing and shall include a milestone for completing it.
- **Remediation Actions**: The specific actions required to correct the deficiency, stated with sufficient precision that completion is objectively verifiable.
- **Milestones**: Each CAP shall include one or more defined milestones with target completion dates. Milestones shall represent measurable interim checkpoints — not a single end-state target. The milestone structure shall be sufficient to enable progress tracking and early detection of delays.
- **Verification Criteria**: The standard by which remediation will be confirmed complete. Verification criteria shall identify the assessment method (control re-test, self-assessment, or audit) and the expected evidence of remediation.
- **Responsible Role**: The role assigned to execute remediation actions. Assignment shall follow the role definitions established in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
- **Risk Register Linkage**: The Risk ID of the corresponding entry in the Risk Register maintained under **Policy 1.09**. When a deficiency does not yet have a Risk Register entry, the Assistant IT Director shall create one at the time of CAP development.
- **CJIS Impact Indicator**: A determination of whether the deficiency affects a control implementing a CJIS Security Policy requirement. When the indicator is affirmative, the IT Director shall evaluate whether the deficiency triggers external or interagency reporting requirements and shall ensure that required notifications are executed in accordance with **Policy 4.02** and **Policy 4.06**.

The IT Director shall review and approve each CAP prior to execution. Approval constitutes authorization to begin remediation activities and acceptance of the proposed milestones and timeline. The IT Director may direct modifications to the remediation approach, milestones, or timeline prior to approval.

6.3 Tracking and Update Cadence

The Assistant IT Director shall maintain all open CAPs in the System of Engagement (Redmine). The Assistant IT Director shall review all open CAPs no less than monthly and shall update milestone status upon the completion of any milestone, upon discovery of a delay, or no less than monthly. Each monthly review shall document: milestone completion status, any changes to the remediation approach or timeline, and an assessment of whether the CAP remains on track for closure within its approved timeline.

The Assistant IT Director shall update CAPs whenever new information becomes available from control assessments, independent audits or reviews, or continuous monitoring activities, consistent with CJIS Security Policy v6.0: CA-5, which requires updates at least every six (6) months or when new information is available. The monthly review cadence established in this policy meets and exceeds this minimum.

The Assistant IT Director shall report open CAPs through the existing reporting structures established in the manual. Open CAPs and their current status shall be included in the monthly performance summary defined in **Policy 3.02** Section 6.4. Open CAPs shall be available as an input to the annual policy review and maturity scoring process under **Policy 5.07**. This policy does not establish separate reporting cadences or standalone CAP status reports.

When a CAP milestone target date is missed, the Assistant IT Director shall document the reason for the delay and establish a revised target date. When two (2) or more milestones within a single CAP are missed, the Assistant IT Director shall escalate the CAP to the IT Director for review. The IT Director shall determine whether the CAP requires revision, additional resources, or risk acceptance for the underlying deficiency in accordance with **Policy 1.09**.

6.4 Verification and Closure

The Assistant IT Director shall verify remediation before a CAP is closed. The Assistant IT Director shall request verification through the assessment mechanisms defined in **Policy 5.02** — control re-test, self-assessment, or audit — appropriate to the nature of the original deficiency. This policy does not establish a separate verification methodology; it uses the assessment infrastructure that **Policy 5.02** already provides.

The verification assessment shall confirm that the remediation actions have been implemented, are operating as intended, and are producing the desired outcome — the same standard used for the "Conforming" classification in **Policy 5.02** Section 6.5.

A CAP shall not be closed solely on the basis of task completion. Closure requires documented verification that the remediation achieved the stated control, process, or compliance outcome.

Upon receipt of a conforming verification result, the Assistant IT Director shall prepare the CAP for closure and submit it to the IT Director with the verification evidence. The IT Director shall approve the closure. Upon closure, the Assistant IT Director shall update the corresponding Risk Register entry under **Policy 1.09** to reflect the resolved status.

When verification reveals that remediation was not effective, the Assistant IT Director shall not close the CAP. The Assistant IT Director shall revise the remediation approach, establish new milestones, and resubmit the revised CAP to the IT Director for approval.

6.5 Compliance Monitoring

The Department maintains statutory and regulatory obligations for incident reporting and breach notification that are operationally executed by other policies in the manual. CJIS Security Policy v6.0: IR-6 (Incident Reporting) establishes the incident reporting obligation; its operational execution is governed by **Policy 4.02** and **Policy 4.06**. NRS 603A.220 establishes the breach notification obligation; its operational execution is also governed by **Policy 4.06**. This section establishes the compliance monitoring function that verifies whether those obligations are being met. Gaps identified through this function constitute a CAP intake source under Section 6.1 and enter the same remediation lifecycle as deficiencies from any other source.

The Assistant IT Director shall review, no less than annually, whether the Department's incident reporting and breach notification processes are being executed in accordance with the requirements defined in **Policy 4.02** and **Policy 4.06**. The review shall evaluate, at minimum:

- Whether incidents meeting the CJIS IR-6 reporting criteria were reported within the required timelines.
- Whether breach notifications required by NRS 603A.220 were issued within the timeframes mandated by that statute.
- Whether the documentation requirements established in **Policy 4.02** and **Policy 4.06** were satisfied.

The Assistant IT Director shall treat gaps identified through the compliance monitoring review as deficiencies and shall route them into the CAP lifecycle defined in Sections 6.2 through 6.4 of this policy. When a compliance monitoring review identifies a gap in a CJIS-reportable process, the IT Director shall evaluate whether the gap itself triggers external or interagency reporting requirements and shall ensure that required notifications are executed in accordance with **Policy 4.02** and **Policy 4.06**.

The compliance monitoring review may be conducted as part of the annual audit cycle under **Policy 5.02** or as a standalone review. Regardless of the mechanism, the Assistant IT Director shall document the results and retain them in the System of Engagement (Redmine).

6.6 Record Retention

The Assistant IT Director shall retain all CAP records — including the CAP documentation, milestone tracking updates, verification evidence, and closure approvals — in the System of Engagement (Redmine) in accordance with **Policy 1.11** (Data Governance and Classification Policy) and the applicable Nevada Local Government Records Retention Schedule under NRS 239.125. Where multiple retention requirements apply, the longest applicable period shall govern.

The Assistant IT Director shall retain compliance monitoring review records under the same framework. All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. Classification and handling shall follow **Policy 1.11**.

5.04 Performance Metrics and Operational KPIs

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the governance framework for defining, reviewing, and acting upon departmental performance metrics and operational key performance indicators (KPIs) used by the Elko County Information Operations Department to evaluate service performance, operational resilience, security posture, and organizational sustainability.

2. Scope

This policy applies to all Information Operations personnel involved in KPI definition, data aggregation, performance review, or executive reporting.

- **In Scope**:
  - Departmental KPI taxonomy and domain coverage requirements.
  - KPI definition, approval, and threshold governance.
  - Quarterly KPI review and recordkeeping.
  - Underperformance pattern identification and routing.
  - Annual executive performance reporting.
- **Out of Scope**:
  - Individual personnel performance evaluations: **Policy 1.07**.
  - SLA target definition: **Policy 3.01**.
  - In-flight service level measurement and operational reporting: **Policy 3.02**.
  - Service improvement intake and triage: **Policy 3.16**.
  - Internal audit and control testing mechanics: **Policy 5.02**.
  - Corrective Action Plan lifecycle: **Policy 5.03**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall approve the KPI domain structure, initial KPI selection, and material threshold changes.
  - Shall review the Quarterly KPI Review Summary prepared by the Assistant IT Director and document review acknowledgment.
  - Shall determine whether a single-period deviation is sufficiently severe to require immediate escalation despite the absence of a consecutive miss.
  - Shall approve the annual executive KPI summary prior to issuance.
  - Shall incorporate aggregate service level performance and key operational metrics into the Monthly Executive Report delivered to the County Manager in accordance with **Policy 1.14** (Stakeholder Engagement and Communications Policy).
- **Assistant IT Director**:

  - Shall maintain the live KPI register in the System of Engagement (Redmine) as the authoritative operational catalog of KPI definitions, calculation methods, targets, and current status.
  - Shall validate source data practicality and record integrity for each KPI maintained in the register.
  - Shall coordinate quarterly KPI review preparation, incorporating formal feeder summaries produced under source policies.
  - Shall prepare the Quarterly KPI Review Summary and the annual executive KPI summary.
  - Shall route qualifying underperformance patterns to the Service Improvement Register under **Policy 3.16** (Service Improvement and Continual Improvement Plan) or the Corrective Action Plan lifecycle under **Policy 5.03** (Compliance Monitoring and Corrective Action) as required by Section 6.6.
  - Shall propose KPI additions, removals, or material threshold changes to the IT Director for approval.
- **All Information Operations Personnel**:
  - Shall provide requested source data accurately and within requested timeframes.
  - Shall participate in improvement activity arising from KPI review where assigned.
  - Shall maintain process records required by the source policies that feed the KPI framework.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in KPI governance, data aggregation, performance review, or executive reporting.

- **Assessment**: Adherence to KPI governance obligations, review cadences, and routing requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain required KPI records, conduct required reviews, or route qualifying underperformance issues in accordance with this policy may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment). KPI deviations requiring improvement intake or formal remediation shall be routed through the existing mechanisms defined in **Policy 3.16** and **Policy 5.03**. Parallel improvement logs, corrective-action trackers, or memo-only review processes shall not be created under this policy.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.11: Capacity and Availability Management Policy

- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071558 (Activity Reports)

Framework Alignment:

- NIST CSF 2.0: PR.AT-03 (Information Security Performance Is Measured and Evaluated)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-6 (Measures of Performance)
- COBIT 2019: MEA01 (Managed Performance and Conformance Monitoring)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Measurement and Reporting Practice

6. Policy Statement

This policy governs the Department's KPI framework at the scorecard and governance level. It defines what qualifies as a KPI, the required domains of KPI coverage, the recordkeeping and review cadence, and the routing rules for performance results that require action. Operational data collection remains governed by the source policies identified in the KPI register; corrective action follows the lifecycle defined in **Policy 5.03**; and improvement intake follows the routing defined in **Policy 3.16**.

6.1 KPI Qualification Criteria

A measure shall qualify as a KPI under this policy only when it meets all of the following conditions:

1. It is reviewed at the IT Director or Assistant IT Director quarterly governance level
2. It reflects departmental outcome, control health, or operational resilience
3. It is stable enough to trend across review periods
4. It is capable of triggering a governance response.

Measures that do not meet this threshold remain supporting metrics owned by their source policies.

6.2 Required KPI Domains

The Department shall maintain KPI coverage across, at minimum, the following domains:

- **Financial Stewardship**: Budget-to-actual performance, cost stewardship, and financially meaningful ratios supporting procurement, budgeting, and sustainability decisions. Source data governed by **Policy 1.10** (IT Financial Management and Procurement Policy) and **Policy 1.12** (IT Asset Management Policy).

- **Service Delivery**: Quarterly service-level KPIs sourced from the service management stack, including SLA compliance rate, Recurring Ticket Ratio, Mean Time to Repair/Recovery, and first contact resolution rate. Source data governed by **Policy 3.02** (Service Level Management and Metrics Reporting).
- **Reliability and Availability**: Measures reflecting core service continuity and operational resilience. Source data governed by **Policy 3.11** (Capacity and Availability Management Policy) and the monitoring function under **Policy 3.12** (Monitoring and Event Management Policy).
- **Security and Control Health**: Measures reflecting security hygiene and control effectiveness. Source data governed by the applicable Chapter 2 policies and **Policy 3.12**.
- **Organizational Health**: Aggregate sustainability indicators addressing workforce readiness, delivery capacity, critical role coverage, or succession fragility. Source data drawn from existing HR and departmental records.
- **Improvement and Remediation**: Measures reflecting whether adverse signals are translating into tracked improvement activity and corrective action. Source data governed by **Policy 3.16** and **Policy 5.03**.
- **Project Delivery**: On-time, on-budget, and on-scope performance for initiatives meeting the project designation threshold defined in **Policy 3.14** (IT Project Management Policy). Source data governed by **Policy 3.14**.
- **Vendor Performance**: Supplier and service-provider measures affecting county service reliability, contractual accountability, or renewal decisions. Source data governed by **Policy 3.02** Section 6.5 and **Policy 5.06** (Vendor Compliance and Third-Party Assurance).

Not every domain must contain the same number of KPIs. The KPI register shall remain deliberately limited and shall prioritize measures that are decision-useful at the departmental governance level.

6.3 KPI Register and Definition Requirements

The Assistant IT Director shall maintain a live KPI register in the System of Engagement (Redmine). The KPI register is the authoritative operational catalog for KPI definitions and current status. The policy manual defines governance requirements; the KPI register carries current formulas, targets, and statuses.

Each KPI record in the register shall include, at minimum:

- KPI title.
- Assigned domain.
- Source policy or source system.
- Calculation method or formula.
- Review cadence.
- Target value.
- Warning threshold, where used.
- Critical threshold, where used.
- Trend direction convention.
- Expected routing action when performance falls outside approved tolerances.

Initial KPI selection and all target or threshold changes shall be proposed by the Assistant IT Director and approved by the IT Director before becoming active. No KPI shall be added to, removed from, or redefined within the register without IT Director approval.

6.4 Data Sourcing

All KPI data shall be sourced exclusively from existing authoritative systems and the data collection processes governed by the source policies identified in the KPI register. Personnel shall not create manual tracking spreadsheets, shadow databases, or parallel data collection pipelines for KPIs where system-generated reporting is technically feasible. The Quarterly Service Level Performance Summary required by **Policy 3.02** Section 6.4, the project performance data feed required by **Policy 3.14** Section 6.8, and other formal feeder summaries produced under source policies shall be incorporated into the KPI review process rather than duplicated.

6.5 Quarterly KPI Review

No later than fifteen (15) business days following the close of each calendar quarter, the Assistant IT Director shall prepare a Quarterly KPI Review Summary for IT Director review. The IT Director shall review the summary and document review acknowledgment. The Quarterly KPI Review Summary shall be maintained in the System of Engagement (Redmine) as the authoritative internal record of quarterly KPI governance review.

The Quarterly KPI Review Summary shall include, at minimum:

- The quarter covered.
- The KPIs reviewed.
- Current status and trend direction for each KPI.
- Any single-period misses requiring monitoring.
- Any underperformance patterns requiring intake under **Policy 3.16**.
- Any deviations requiring Corrective Action Plan development under **Policy 5.03**.
- Approved target or threshold changes.
- Assigned follow-up actions.
- IT Director review acknowledgment.

6.6 Underperformance Thresholds and Routing

- **Single-Period Miss**: A KPI single-period miss exists when a KPI falls below its approved target or outside its approved tolerance during one quarterly review period. A single-period miss shall be documented in the Quarterly KPI Review Summary and monitored during the next review cycle.
- **Underperformance Pattern**: A KPI underperformance pattern exists when either: (a) the same KPI records two consecutive quarterly misses; or (b) the IT Director determines that a single deviation is sufficiently severe, persistent, or strategically significant to require tracked improvement despite the absence of a second consecutive miss.
- **Routing**: Upon identification of a KPI underperformance pattern, the Assistant IT Director shall log a Service Improvement Register entry in accordance with **Policy 3.16** unless the issue instead requires direct routing into the Corrective Action Plan lifecycle under **Policy 5.03**. Where KPI deviation reflects a control deficiency, compliance gap, sustained policy nonconformance, or other condition requiring formal remediation with milestones, the Assistant IT Director shall initiate or update a Corrective Action Plan in accordance with **Policy 5.03**. This policy does not create a separate remediation tracker.
- **Pattern Analysis**: Recurring Ticket Ratio and similar pattern-based KPIs shall be reviewed for evidence of documentation weakness, training need, recurring failure mode, or process design deficiency. Where the analysis identifies a systemic improvement opportunity, the Assistant IT Director shall route the issue through the Service Improvement Register.

6.7 Organizational Health Boundary

Organizational Health KPIs shall be limited to indicators that affect workforce sustainability, delivery capacity, succession fragility, or operational overdependence on specific personnel. Such indicators shall be reviewed primarily in aggregate. This policy shall not be used as an employee ranking or disciplinary scorecard. Individual personnel actions arising from organizational health review shall be handled through normal supervisory and HR processes, not through the KPI governance process defined in this policy.

6.8 Executive Reporting

The IT Director shall extract a targeted subset of the KPI taxonomy to fulfill the Monthly Executive Report obligation established in **Policy 1.14** Section 6.2. The Monthly Executive Report content is the IT Director's executive communication derivative; it draws from, but does not replace, the quarterly governance record.

No later than the end of the first calendar quarter following year-end, the Assistant IT Director shall prepare an annual KPI and operational performance summary for IT Director approval. This summary may be incorporated into the Department's annual reporting or other executive communication issued through County leadership channels.

6.9 Records Retention

The Quarterly KPI Review Summary is the authoritative record of KPI governance review. Annual executive summaries are derivative communication artifacts and do not replace the quarterly record.

Quarterly KPI Review Summaries shall be maintained in the System of Engagement (Redmine) and retained in accordance with the Nevada Local Government Records Retention Schedule under NRS 239.125, for a minimum of three (3) years from the date of production unless a longer period is required by another applicable authority: LRDA 20071558 (Activity Reports).

Where annual executive summaries are issued as formal reports or memoranda, they shall be retained in accordance with the applicable County records-management practice for the record series under which they are filed.

5.05 Security Control Assessment and Authorization

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the authorization decision process by which the IT Director, as the designated Authorizing Official, reviews security control assessment results and renders formal authorization decisions for County information systems and controls governed by the ECIO Policy Manual.

2. Scope

This policy applies to all information systems, controls, and assets governed by the ECIO Policy Manual that require formal authorization to operate within the County production environment.

- **In Scope**:
  - Review of assessment results and audit findings for authorization decisions.
  - Formal authorization, conditional authorization, or denial decisions.
  - Documentation and retention of authorization decision records.
  - Risk-informed conditions attached to conditional authorizations.
  - Reauthorization determinations following changes to system boundary, risk profile, or control posture.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Control testing, self-assessment, and internal audit mechanics: **Policy 5.02**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the Authorizing Official for all County information systems and controls, consistent with the designation established in **Policy 1.09** (Risk Management Policy).
  - Shall review assessment results delivered under **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and render formal authorization decisions.
  - Shall attach risk-based conditions or require compensating controls when granting conditional authorization.
  - Shall ensure that each authorization decision is documented in an authorization decision record and retained in accordance with **Policy 3.13** (Knowledge Management Policy).

  - Shall evaluate whether denial of authorization for a system processing Criminal Justice Information Services (CJIS) data affects active CJIS compliance obligations and, when warranted, shall ensure that appropriate operational, service-restriction, or partner-notification steps are taken through the applicable policies: **Policy 5.03** (Compliance Monitoring and Corrective Action), **Policy 4.02** (Identification and Reporting Procedures), and **Policy 4.06** (Communication Protocols and Partner Integration).

- **Assistant IT Director**:
  - Shall compile the decision inputs for each authorization review by assembling the current **Policy 5.02** assessment results, the **Policy 1.09** risk ratings and security categorization documentation, and the status of any open Corrective Action Plans under **Policy 5.03**.
  - Shall present the compiled decision inputs to the IT Director with a risk summary and a recommendation.
  - Shall document the IT Director's authorization decision in the System of Engagement (Redmine) and maintain the authorization decision record.
  - Shall route deficiencies identified through a denial decision to **Policy 5.03** for Corrective Action Plan development.
  - Shall update the corresponding Risk Register entry under **Policy 1.09** to reflect the authorization status following each decision.
- **All Department Personnel**:
  - Shall provide requested evidence or clarification during the authorization review process when directed by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in authorization decision preparation, review, or documentation.

- **Assessment**: Adherence to authorization decision documentation, retention, and routing requirements shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Deployment of any information system to the County production network without a valid authorization, or failure to document authorization decisions as required by this policy, may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration

- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)

Framework Alignment:

- CJIS Security Policy v6.0: CA-1 (Assessment, Authorization, and Monitoring Policy and Procedures)
- NIST CSF 2.0: ID.RA-06 (Risk Responses)
- NIST SP 800-37 Rev. 2: (Risk Management Framework for Information Systems and Organizations)
- NIST SP 800-53 Rev. 5: CA-6 (Authorization)
- COBIT 2019: MEA02 (Managed System of Internal Control)
- ITIL v4: Risk Management Practice

6. Policy Statement

6.1 Authorization Decision Process

No County information system shall process production data or maintain persistent connectivity to the County production network without a valid authorization decision rendered by the IT Director. This policy implements the Authorize step of the NIST Risk Management Framework lifecycle adopted in **Policy 1.09** Section 6.1.

Authorization decisions shall be made solely on the basis of assessment results and audit findings delivered under **Policy 5.02**, current risk ratings and security categorization documentation maintained under **Policy 1.09**, and the status of any open Corrective Action Plans tracked under **Policy 5.03**. No separate or parallel testing, assessment, or evidence-collection activity shall be performed under this policy. Where the IT Director determines that existing assessment coverage is insufficient to support an authorization decision, the IT Director shall direct the Assistant IT Director to schedule supplemental assessment activity through the mechanisms defined in **Policy 5.02**.

The Assistant IT Director shall compile the decision inputs and present them to the IT Director with a risk summary that identifies: the system or control under review, the security categorization, the assessment results and any open deficiencies, the current risk rating, and a recommendation. The IT Director shall review the compiled inputs and render one of the decision outcomes defined in Section 6.2.

6.2 Decision Outcomes

The IT Director shall render one of the following decisions for each system or control submitted for authorization review.

- **Authorization to Operate**: Issued when **Policy 5.02** assessment results verify that controls are implemented correctly, operating as intended, and producing the desired outcome, and residual risk is within the risk tolerance defined in the Risk Management Strategy maintained under **Policy 1.09**. The system is approved for production operation.
- **Conditional Authorization**: Issued when residual risk exceeds tolerance but can be managed through documented compensating controls or time-bound conditions. The authorization decision record shall identify each condition, the compensating control or remediation action required, and the timeframe for resolution. When a conditional authorization depends on acceptance of residual risk above tolerance, the condition shall be supported by a Risk Acceptance Memo under **Policy 1.09** and documented in the Risk Register. Conditions shall be tracked through the Corrective Action Plan lifecycle under

Policy 5.03 when they require milestone-based remediation. The IT Director may revoke a conditional authorization at any time if conditions are not met within the specified timeframe or if the risk posture deteriorates.

- **Denial of Authorization**: Issued when controls are inadequate and residual risk exceeds tolerance without acceptable compensating controls. A denial prohibits the system from operating in the production environment. The Assistant IT Director shall route the underlying deficiencies to **Policy 5.03** for Corrective Action Plan development. A system that has been denied authorization may be resubmitted for review after remediation is verified through the assessment mechanisms defined in **Policy 5.02**.

6.3 Authorization Decision Record

Each authorization decision shall be documented in the System of Engagement (Redmine) as an authorization decision record. The record shall include, at minimum: the system or control name and identifier, the security categorization, the decision outcome, the assessment results summary relied upon, the risk rationale supporting the decision, any conditions attached to a conditional authorization, and the IT Director's approval. The Assistant IT Director shall maintain authorization decision records in accordance with **Policy 3.13** and the Nevada Local Government Records Retention Schedule under NRS 239.125, for a minimum of three (3) years from the date of the decision unless a longer period is required by another applicable authority.

6.4 Reauthorization and Revocation

Authorization decisions remain valid until a subsequent event requires the IT Director to render a new decision. The following events shall trigger a reauthorization review:

- The annual assessment cycle conducted under **Policy 5.02** produces findings that change the risk posture of an authorized system.
- A change to the system boundary, architecture, data classification, or control posture that alters the system's risk profile occurs.
- The IT Director determines that a change in the threat environment, regulatory landscape, or operational context warrants reauthorization.
- A Corrective Action Plan associated with a conditional authorization fails to achieve closure within the approved timeframe.

The IT Director shall render a new authorization decision following the same process defined in Sections 6.1 and 6.2. The new decision shall supersede the prior authorization decision record. The prior record shall be retained in accordance with Section 6.3.

The IT Director may revoke an existing authorization at any time when the risk posture requires immediate action, without waiting for a reauthorization trigger. A revocation shall be documented as a new authorization decision record with Denial of Authorization as the outcome and shall include the risk rationale for immediate action.

6.5 CJIS-Specific Considerations

For systems processing Criminal Justice Information Services (CJIS) data, authorization decisions shall incorporate the CJIS-specific assessment frequency and independent-assessor requirements already defined in **Policy 5.02**. This policy does not establish separate CJIS assessment mechanics; it consumes the CJIS-relevant assessment results that **Policy 5.02** produces. Denial or revocation of authorization for any system processing CJIS data shall trigger the IT Director's evaluation of whether the system's inability to operate affects active CJIS compliance obligations, and when warranted, the IT Director shall ensure that appropriate operational and notification steps are taken through **Policy 5.03**, **Policy 4.02**, and **Policy 4.06**.

5.06 Vendor Compliance and Third-Party Assurance

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the ongoing compliance monitoring, third-party assurance evaluation, and vendor remediation framework for vendors, contractors, and third-party service providers engaged with Elko County information systems.

2. Scope

This policy applies to all active vendor, contractor, and third-party service provider relationships that fall within the scope of **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance).

- **In Scope**:
  - Vendor compliance monitoring and review.
  - Third-party assurance evidence collection and evaluation.
  - Criminal Justice Information Services (CJIS) vendor compliance assessment.
  - Vendor enforcement notification intake from **Policy 5.01**.
  - Vendor remediation and Corrective Action Plan routing.
  - Contract action recommendations based on sustained non-compliance.
  - Vendor compliance data feed to the KPI framework in **Policy 5.04**.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Vendor onboarding, contracting, and pre-engagement controls: **Policy 1.13**.
  - Vendor SLA performance measurement and operational reporting: **Policy 3.02**.
  - IT-administrative enforcement actions and formal sanctions: **Policy 5.01**.
  - Internal audit mechanics and control testing methodology: **Policy 5.02**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Security control authorization decisions: **Policy 5.05**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for all vendor compliance review outcomes and contract action recommendations produced under this policy.
  - Shall exercise the contractual audit and inspection rights established in **Policy 1.13** Section 6.3, including the authority to initiate triennial audits and unannounced security inspections of vendors with access to Criminal Justice Information (CJI).

  - Shall authorize unscheduled vendor compliance reviews when enforcement notification patterns, assurance evidence deficiencies, or other risk conditions warrant assessment outside the standard cadence.
  - Shall determine whether vendor compliance findings constitute risk-relevant inputs requiring referral to the Risk Register maintained under **Policy 1.09** (Risk Management Policy). This policy identifies and routes risk-relevant findings; **Policy 1.09** governs risk scoring, acceptance, and Risk Register maintenance.
  - Shall approve deviations from the approved assurance evidence types defined in Section 6.4.
- **Assistant IT Director**:
  - Shall maintain the Vendor Compliance Record for each vendor within scope, in the System of Engagement (Redmine), in accordance with **Policy 3.13** (Knowledge Management Policy) and Section 6.1 of this policy.
  - Shall conduct or coordinate all scheduled and unscheduled vendor compliance reviews defined in Section 6.2.
  - Shall prepare pre-renewal compliance evaluations and submit them to the IT Director in accordance with Section 6.3.
  - Shall collect, catalog, and evaluate third-party assurance evidence in accordance with Section 6.4.
  - Shall prepare vendor compliance data for integration with the Vendor Performance KPI domain defined in **Policy 5.04** (Performance Metrics and Operational KPIs).
  - Shall route vendor compliance deficiencies requiring formal remediation to the Corrective Action Plan lifecycle governed by **Policy 5.03** (Compliance Monitoring and Corrective Action) in accordance with Section 6.6.
  - Shall document contract action recommendations for IT Director review in accordance with Section 6.7.
- **Requesting Department Head**:
  - Shall cooperate with vendor compliance reviews by providing business-side performance information, contract deliverable status, and vendor relationship context when requested by the Assistant IT Director.
  - Shall notify the Assistant IT Director of vendor performance concerns, missed deliverables, or contractual disputes that may affect the vendor's compliance posture.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in vendor compliance monitoring, review, or reporting.

- **Assessment**: Adherence to vendor compliance review cadences, Vendor Compliance Record maintenance, assurance evidence collection, and reporting obligations shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to conduct required vendor compliance reviews, failure to maintain Vendor Compliance Records, failure to collect or evaluate required assurance evidence, or failure to act on enforcement notifications received under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment) shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01**.

- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Exceptions affecting CJIS vendor compliance assessment cadences, CJIS Security Addendum verification requirements, or the exercise of contractual audit rights for vendors with access to CJI shall require County Manager approval in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights). No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline. No exception shall be granted that would place County systems or CJI out of compliance with applicable CJIS Security Policy obligations.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.17: System Maintenance and Vendor Repairs
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.05: Security Control Assessment and Authorization
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071300 (Vendor Performance Case Files)
- CJIS Security Policy v6.0: Section CA-2 (Control Assessments)
- CJIS Security Policy v6.0: Section CA-2(1) (Independent Assessors)
- CJIS Security Policy v6.0: Section SA-9 (External System Services)
- CJIS Security Policy v6.0: Section SR-8 (Notification Agreements)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SR-6 (Supplier Assessments and Reviews)

Framework Alignment:

- NIST CSF 2.0: GV.SC-06 (Cybersecurity Supply Chain Risk Management)
- NIST SP 800-37 Rev. 2: (Risk Management Framework for Information Systems and Organizations)
- COBIT 2019: APO10 (Manage Vendors)
- ITIL v4: Supplier Management Practice

6. Policy Statement

Policy 1.13 governs the engagement, onboarding, and contracting of third-party service providers. This policy governs what happens after a vendor is active: the ongoing evaluation of whether vendors continue to meet the security, compliance, and performance standards that justified their engagement. This policy consumes operational data produced by the service management function (**Policy 3.01** and **Policy 3.02**), enforcement data produced by the compliance function (**Policy 5.01**), and assurance evidence provided by the vendors themselves. It produces compliance posture assessments and contract action recommendations that feed back into governance decisions under **Policy 1.09**, enforcement decisions under **Policy 5.01**, corrective action under **Policy 5.03**, and the Vendor Performance KPI domain under **Policy 5.04**.

6.1 Vendor Compliance Record

The Assistant IT Director shall establish and maintain a Vendor Compliance Record for each vendor, contractor, or third-party service provider within scope of this policy. The Vendor Compliance Record shall be maintained in the System of Engagement (Redmine) in accordance with **Policy 3.13** and shall serve as the consolidated, authoritative record of the vendor's compliance posture across all assets, contracts, and service relationships.

- **Record Content**: Each Vendor Compliance Record shall include, at minimum:
  - The vendor name and all associated contracts or service agreements.
  - The asset support classifications (IT-Managed, IT-Supported, or Vendor-Managed) applicable to the vendor's services as defined in **Policy 1.12** (IT Asset Management Policy).
  - The data classification tier of data the vendor accesses or processes as defined in **Policy 1.11** (Data Governance and Classification Policy).
  - Whether the vendor has logical or physical access to Criminal Justice Information (CJI).
  - The current CJIS Security Addendum status, where applicable.
  - The vendor SLA performance data maintained under **Policy 3.02** Section 6.5.
  - All enforcement notifications received from **Policy 5.01**.
  - All third-party assurance evidence received and evaluated under Section 6.4.
  - The outcome of each vendor compliance review conducted under Section 6.2.
  - The status of any active Corrective Action Plan (CAP) associated with the vendor under **Policy 5.03**.
- **Work Order Linkage**: The Vendor Compliance Record shall reference the work orders associated with vendor-related events including SLA breaches recorded under **Policy 3.02** Section 6.5, enforcement actions received under **Policy 5.01** Section 6.4, and maintenance events recorded under **Policy 3.17** (System Maintenance and Vendor Repairs). The work order system is the operational evidence base; the Vendor Compliance Record is the compliance summary layer.
- **Enforcement Notification Intake**: When the IT Director provides written notification to the vendor compliance process under **Policy 5.01** Section 6.4 (Contractors and Vendors), the Assistant IT Director shall log the notification in the applicable Vendor Compliance Record within two (2) business days of receipt. The log entry shall document the date the notification was received to establish the logging deadline.
- **Notification Log Content**: The log entry shall include:
  - The date of the enforcement action
  - The non-compliance identified
  - The IT-administrative action taken

  - The policy basis
  - The affected County systems or services
  - The responsible contract administrator.
- **Review Integration**: Enforcement notifications shall be considered in the next scheduled vendor compliance review.
- **Unscheduled Review Trigger**: Where two (2) or more enforcement notifications are received for the same vendor within any rolling twelve (12) month period, or where a single notification involves a Critical-severity incident or CJI exposure, the Assistant IT Director shall recommend to the IT Director that an unscheduled vendor compliance review be initiated.

6.2 Annual Vendor Compliance Review

The Assistant IT Director shall conduct or coordinate a vendor compliance review for each vendor within scope no less than annually. The annual vendor compliance review establishes the minimum review floor; pre-renewal reviews under Section 6.3 and unscheduled reviews triggered under Section 6.1 or Section 6.5 are additional and do not reset the annual cycle.

- **Review Inputs**: Each vendor compliance review shall evaluate, at minimum:
  - Vendor SLA performance data for the review period, sourced from the Vendor Compliance Record and the vendor SLA performance tracking maintained under **Policy 3.02** Section 6.5.
  - Enforcement notifications received during the review period.
  - The currency and sufficiency of third-party assurance evidence under Section 6.4.
  - CJIS Security Addendum compliance status, where applicable.
  - The status of any open Corrective Action Plan associated with the vendor.
  - Any vendor-related incidents, findings, or risk conditions identified during the review period.
- **Review Output**: The Assistant IT Director shall document each vendor compliance review in the Vendor Compliance Record. The review record shall include the date, the period covered, the data sources evaluated, a compliance determination for each evaluation criterion, an overall vendor compliance posture assessment, and any recommended actions. The compliance posture assessment shall use one of the following determinations: Compliant, Compliant with Observations, Non-Compliant — Remediation Required, or Non-Compliant — Contract Action Recommended.
- **Routing**: A determination of Non-Compliant — Remediation Required shall initiate the vendor remediation and Corrective Action Plan routing defined in Section 6.6. A determination of Non-Compliant — Contract Action Recommended shall initiate the escalation process defined in Section 6.7. Observations identified under a Compliant with Observations determination shall be documented in the Vendor Compliance Record, communicated to the vendor in writing, and evaluated during the next scheduled vendor compliance review. Compliance review outcomes that constitute risk-relevant findings shall be referred to the IT Director for consideration as inputs to the Risk Register under **Policy 1.09**.
- **Unscheduled Reviews**: The IT Director may authorize an unscheduled vendor compliance review at any time based on enforcement notification patterns, assurance evidence deficiencies, security incidents involving vendor systems or personnel, or other risk conditions. Unscheduled reviews shall follow the same input, output, and routing requirements as annual reviews.

6.3 Pre-Renewal Compliance Evaluation

No later than ninety (90) calendar days prior to the expiration or renewal date of any contract with a vendor within scope of this policy, the Assistant IT Director shall prepare a pre-renewal compliance evaluation

and submit it to the IT Director for review. This evaluation aligns with and incorporates the vendor SLA performance summary required by **Policy 3.01** (Service Catalog and SLA Policy) Section 6.5.

- **Evaluation Content**: The pre-renewal compliance evaluation shall include, at minimum:
  - The complete Vendor Compliance Record history for the current contract period.
  - A summary of the vendor's SLA performance across the contract period, sourced from **Policy 3.02** Section 6.5.
  - A summary of enforcement notifications received during the contract period.
  - The status and outcome of all third-party assurance evidence evaluations during the contract period.
  - The status and outcome of any Corrective Action Plans associated with the vendor during the contract period.
  - CJIS compliance status, where applicable.
  - A compliance posture recommendation for the IT Director's consideration in the renewal decision.
- **IT Director Action**: The IT Director shall review the pre-renewal compliance evaluation and document a renewal recommendation. The renewal recommendation shall be one of the following: Renew Without Conditions, Renew With Conditions (specifying the conditions), Do Not Renew, or Escalate to Contract Administrator and Legal Counsel. The documented renewal recommendation shall be provided to the Requesting Department Head identified in **Policy 1.13** Section 3.
- **Contracts Without Defined Renewal Dates**: For evergreen contracts or contracts with automatic renewal provisions, the Assistant IT Director shall conduct the pre-renewal compliance evaluation annually, aligned with the annual vendor compliance review, and shall note the evaluation as serving both the annual review and the pre-renewal function.

6.4 Third-Party Assurance Evidence

For vendors whose services involve access to County data classified as Confidential or Restricted under **Policy 1.11**, or whose services involve access to CJI, the Information Operations Department shall maintain an ongoing program of third-party assurance evidence collection and evaluation.

- **Assurance Evidence Types**: Acceptable assurance evidence shall be restricted to the following approved artifact types:
  - Service Organization Control (SOC) reports (SOC 1, SOC 2 Type I, SOC 2 Type II).
  - Independent security assessments or penetration test summaries.
  - Completed security questionnaires using County-defined or industry-standard formats.
  - Certifications or attestation letters from recognized bodies (e.g., ISO 27001).
  - CJIS Security Addendum Certifications required by **Policy 1.13** Section 6.3.
  - Any deviation from or substitution for these approved artifact types shall require documented IT Director approval.
- **Collection Cadence**: The Assistant IT Director shall request updated assurance evidence from each vendor subject to this section no less than annually, or upon the issuance of new SOC reports or the renewal of relevant certifications. For CJIS vendors, the CJIS Security Addendum Certification and supporting CJIS compliance documentation shall be verified no less than annually and following any change in vendor personnel with CJI access.
- **Evaluation**: The Assistant IT Director shall review each piece of assurance evidence received and document the evaluation in the Vendor Compliance Record. The evaluation shall note whether the evidence is current, whether it covers the services provided to the County, whether it identifies control

deficiencies relevant to County risk, and whether any exceptions, qualifications, or findings in the evidence require County follow-up. Where assurance evidence reveals control deficiencies affecting County data or systems, the Assistant IT Director shall notify the IT Director and recommend whether the deficiency warrants a Corrective Action Plan under **Policy 5.03**, a contract action recommendation under Section 6.7, or an unscheduled vendor compliance review.

- **Failure to Provide**: Where a vendor fails to provide requested assurance evidence within thirty (30) calendar days of the request, the Assistant IT Director shall escalate to the IT Director. The IT Director shall determine whether the failure constitutes a compliance concern warranting further action, including initiation of a Corrective Action Plan under **Policy 5.03** or exercise of contractual audit rights.

6.5 CJIS Vendor Compliance

For vendors with logical access to CJI, or unescorted access to physically secure locations where CJI is processed, the following CJIS-specific compliance obligations apply in addition to the general requirements of this policy. These obligations operationalize the contractual audit and oversight rights established in **Policy 1.13** Section 6.3 and the control assessment requirements of CJIS Security Policy v6.0: Section CA-2 (Control Assessments). This policy governs the County's ongoing monitoring of CJIS vendor compliance after activation; it does not create, modify, or weaken the underlying contractual requirements established in **Policy 1.13** Section 6.3.

- **Triennial Assessment**: The IT Director shall ensure that each CJIS vendor undergoes a compliance assessment no less than once every three (3) years, consistent with CJIS Security Policy v6.0: Section CA-2. The assessment shall evaluate the vendor's implementation and operating effectiveness of controls applicable to CJI protection. The IT Director shall determine whether the assessment is conducted by Information Operations personnel, by an independent assessor, or through a combination of both, considering the objectivity requirements of CJIS Security Policy v6.0: Section CA-2(1) (Independent Assessors) and the assessment resources available. Where internal personnel are utilized, the IT Director shall ensure the selected assessors possess organizational independence from the vendor management activities being assessed, consistent with the objectivity safeguards established in **Policy 5.02** Section 6.4.
- **Unannounced Inspections**: The IT Director retains the authority to conduct unannounced security inspections of CJIS vendor operations, as provided by the contractual terms established under **Policy 1.13** Section 6.3. The IT Director shall exercise this authority when risk conditions, enforcement notification patterns, or assurance evidence deficiencies indicate that a planned assessment may not provide sufficient assurance.
- **Security Addendum Verification**: The Assistant IT Director shall verify, no less than annually, that all CJIS vendor personnel with access to CJI have executed current CJIS Security Addendum Certifications as required by **Policy 1.13** Section 6.3. Any gap in Security Addendum coverage shall be treated as a compliance deficiency and logged in the Vendor Compliance Record.
- **Notification Agreements**: Consistent with CJIS Security Policy v6.0: Section SR-8 (Notification Agreements) and NIST SP 800-53 Rev. 5: SA-9 (External System Services), the IT Director shall verify that each CJIS vendor's contract includes the incident notification and cooperation provisions required by **Policy 1.13** Section 6.3. Where a CJIS vendor fails to meet the notification timelines established in **Policy 1.13**, the failure shall be documented in the Vendor Compliance Record and treated as a compliance deficiency.
- **Findings Routing**: CJIS assessment findings that constitute control deficiencies shall be routed to **Policy 5.03** for Corrective Action Plan development. CJIS assessment findings that affect the authorization posture of a system processing CJI shall be provided to the IT Director for consideration under **Policy 5.05** (Security Control Assessment and Authorization). CJIS assessment results shall be documented in the Vendor Compliance Record.

6.6 Vendor Remediation and Corrective Action Routing

When a vendor compliance review under Section 6.2 produces a determination of Non-Compliant — Remediation Required, or when the IT Director determines that a vendor's cumulative compliance posture warrants formal remediation, the identified deficiencies shall be routed to the Corrective Action Plan (CAP) lifecycle governed by **Policy 5.03**. This policy defines the vendor-specific triggers and referral content; **Policy 5.03** governs CAP development, tracking, and closure.

- **CAP Referral Content**: The Assistant IT Director shall prepare the CAP referral and submit it to the IT Director for approval. The referral shall include:
  - The vendor name and applicable contracts.
  - The specific compliance deficiencies or performance failures that triggered the referral.
  - The affected County systems or services.
  - The contract administrator responsible for the vendor relationship.
  - Any interim risk mitigation measures in effect.
- **Vendor Notification**: Upon IT Director approval of the CAP referral, the Assistant IT Director shall provide written notification to the vendor and to the Requesting Department Head. The notification shall identify the deficiencies, the required remediation outcomes, and the CAP timeline established under **Policy 5.03**. Vendor notification is an operational communication; it does not require vendor agreement or acceptance to take effect.
- **Monitoring**: The Assistant IT Director shall update the Vendor Compliance Record with the CAP reference and shall monitor vendor-related CAP progress as part of each subsequent scheduled vendor compliance review.
- **Closure or Escalation**: Where the vendor achieves the required remediation outcomes within the CAP timeline, the Assistant IT Director shall document the resolution in the Vendor Compliance Record. Where a vendor-related CAP fails to achieve closure within the approved timeline, or where the vendor's compliance posture deteriorates during the CAP period, the Assistant IT Director shall recommend escalation to contract action under Section 6.7.
- **Clarification**: Observations that do not meet the threshold for formal CAP development shall be documented in the Vendor Compliance Record and communicated to the vendor in writing. The observations shall be evaluated during the next scheduled vendor compliance review.

6.7 Escalation and Contract Action Recommendations

When a vendor compliance review under Section 6.2 produces a determination of Non-Compliant — Contract Action Recommended, or when a vendor-related Corrective Action Plan under Section 6.6 fails to achieve closure, the Assistant IT Director shall prepare a formal contract action recommendation for IT Director review.

- **Recommendation Content**: The contract action recommendation shall include, at minimum:
  - A summary of the vendor's compliance history from the Vendor Compliance Record.
  - The specific compliance deficiencies or CAP failures that support the recommendation.
  - The recommended action (which may include contract modification, contract non-renewal, contract termination for cause, or other contractual remedy as applicable).
  - The potential operational impact of the recommended action on County services.
- **IT Director Action**: The IT Director shall review the contract action recommendation and determine the appropriate course of action. Where the IT Director concurs with the recommendation, the IT Director shall refer the matter to the contract administrator and County legal counsel for contract remedies, consistent with the referral pathway established in **Policy 5.01** Section 6.4 (Contractors

and Vendors). The IT Director's authority to revoke or restrict system access under **Policy 5.01** is independent of the contract remedy process and may be exercised at any point.

- **Documentation**: All contract action recommendations, IT Director determinations, and referrals shall be documented in the Vendor Compliance Record and retained in accordance with Section 6.9.

6.8 Vendor Performance Data Feed

This policy serves as a source data provider for the Vendor Performance KPI domain established in **Policy 5.04** Section 6.2. The Assistant IT Director shall ensure that vendor compliance review outcomes, CAP status, assurance evidence currency, and CJIS compliance status are available for incorporation into the Quarterly KPI Review Summary prepared under **Policy 5.04** Section 6.5. This data feed supplements the vendor SLA performance data provided by **Policy 3.02** Section 6.5 and shall not duplicate data already captured in the service level management function.

6.9 Record Retention

Records generated under this policy shall be retained in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule.

- **Vendor Compliance Records**: Vendor Compliance Records, including all compliance review records, assurance evidence evaluations, enforcement notification logs, CAP referrals, and contract action recommendations, shall be retained in the System of Engagement (Redmine) for six (6) calendar years after the record is closed, in accordance with LRDA 20071300 (Vendor Performance Case Files). A Vendor Compliance Record is closed when the vendor no longer provides services to the County and all open compliance actions, Corrective Action Plans, and contract action recommendations associated with the vendor have been resolved or formally closed.
- **CJIS Assessment Records**: For vendors with access to CJI, assessment records shall be retained for the greater of the LRDA 20071300 retention period or the CJIS-required retention period applicable at the time of the assessment.
- **Litigation and Legal Holds**: The IT Director shall ensure that retention and disposition actions are suspended during litigation holds, public records preservation requirements, or other legal hold events.
- **Public Records**: All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. Disclosure determinations for vendor compliance records containing security findings, assurance evidence, or CJIS-related materials shall be made in coordination with the County's public records process and legal counsel, consistent with applicable exemptions and the data classification requirements of **Policy 1.11**.

5.07 Annual Policy Review and Maturity Scoring

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the annual policy review process, maturity scoring methodology, and executive reporting requirements that the Information Operations Department uses to evaluate the implementation effectiveness and operational maturity of the ECIO Policy Manual.

2. Scope

This policy applies to all policies and governed appendices within the ECIO Policy Manual.

- **In Scope**:
  - Annual review of each policy for implementation effectiveness, operational relevance, and regulatory alignment.
  - Maturity scoring of each policy using the NIST Cybersecurity Framework 2.0 Tier model.
  - Annual review of governed appendices for currency and accuracy.
  - Evaluation of audit program effectiveness.
  - Preparation and submission of the Annual Policy Review Report.
  - Executive reporting to the County Manager.
- **Out of Scope**:
  - Policy lifecycle management, version control, and change control workflow: **Policy 1.05**.
  - Internal audit planning, assessment execution, and deficiency classification: **Policy 5.02**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Performance metric governance and KPI catalog maintenance: **Policy 5.04**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Standard Operating Procedures, playbooks, and operational documentation maintained in the System of Engagement: **Policy 1.04** and **Policy 3.13**.

3. Roles and Responsibilities

- **County Manager**:
  - Shall receive and review the Annual Policy Review Report submitted by the IT Director.
  - Shall provide written acknowledgment of receipt and review within thirty (30) calendar days of submission.
  - Shall direct the IT Director to address specific concerns, conduct additional analysis, or revise maturity tier assignments when the County Manager determines that documented justification warrants such direction.
  - Shall approve exceptions to this policy that would materially affect the annual review, as defined in Section 4.

- **IT Director**:
  - Shall conduct the annual policy review and maturity scoring process defined in this policy.
  - Shall assign a maturity tier to each policy in the ECIO Policy Manual in accordance with the methodology defined in Section 6.3.
  - Shall evaluate the effectiveness of the internal audit program defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) in accordance with Section 6.4.
  - Shall prepare and submit the Annual Policy Review Report to the County Manager in accordance with Section 6.5.
  - Shall route findings to the remediation pathways defined in Section 6.7.
  - Shall complete the annual policy review within the timeline defined in Section 6.1.
- **Assistant IT Director**:
  - Shall compile the assessment inputs defined in Section 6.2.
  - Shall present compiled inputs to the IT Director prior to the start of the review.
  - Shall produce the annual improvement summary under **Policy 3.16** (Service Improvement and Continual Improvement Plan) for inclusion as an input to the review process.
  - Shall maintain all review records and scoring documentation in the System of Engagement.
  - Shall update the Policy Matrix (**Appendix 6.02**) to reflect current maturity tier assignments following IT Director approval.
- **All Information Operations Personnel**:
  - Shall provide requested evidence, documentation, or operational context during the annual policy review process when directed by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in the annual policy review, maturity scoring, or executive reporting process.

- **Assessment**: Compliance with the review cadence, scoring methodology, report preparation, and submission requirements of this policy shall be assessed through the internal audit process defined in **Policy 5.02**. The County Manager's review of the Annual Policy Review Report, as defined in Section 6.6, provides independent oversight of this policy's execution.
- **Enforcement**: Failure to conduct the annual policy review within the required timeframe, failure to prepare or submit the Annual Policy Review Report, or failure to route findings to the required remediation pathways may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification. Exceptions that would materially affect the annual review — including extension or waiver of the submission deadline, suppression or omission of required report content, alteration of the scoring methodology, or omission of the audit program effectiveness evaluation defined in Section 6.4 — shall be approved by the County Manager in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights) and the exception management framework established in **Policy 5.01**. All other exceptions shall be approved by the IT Director in accordance with **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan
- ECIO Policy 4.07: (Postmortem Review and Lessons Learned)
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Appendix 6.02: Policy Matrix
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071256 (Quality Assurance Review Audits and Reports)

Framework Alignment:

- CJIS Security Policy v6.0: CA-1 (Assessment, Authorization, and Monitoring Policy and Procedures)
- NIST CSF 2.0: GV.PO-02 (Policy Review)
- NIST CSF 2.0: ID.IM-01 (Improvements Are Identified from Evaluations)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-6 (Measures of Performance)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- COBIT 2019: MEA03 (Monitor, Evaluate and Assess Compliance with External Requirements)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Measurement and Reporting Practice

6. Policy Statement

The ECIO Policy Manual is a living governance instrument. The policies within it are not static artifacts; they are operational controls that the Department shall evaluate annually for continued relevance, implementation effectiveness, and alignment with the regulatory and operational environment. This policy establishes the structured methodology for that evaluation and the reporting mechanism that delivers accountability to County leadership.

This policy does not govern the policy change control lifecycle — that function belongs to **Policy 1.05**. This policy does not conduct audits, self-assessments, or control tests — those functions belong to **Policy 5.02**. This policy consumes the outputs of both and produces the annual maturity assessment and executive

report that neither can produce independently. The annual policy review conducted under this policy operationalizes the annual internal review referenced in **Policy 1.05** Section 6.1 and does not alter the review cadence, approval chain, or change control workflow established there.

6.1 Review Scope and Cadence

The IT Director shall conduct the annual policy review and maturity scoring process once per fiscal year. The IT Director shall complete the review and submit the Annual Policy Review Report to the County Manager no later than ninety (90) calendar days after the conclusion of each fiscal year.

The review shall encompass every policy in the ECIO Policy Manual. The IT Director shall evaluate each policy for:

- **Implementation status**: whether the policy's directives are implemented and producing the intended outcomes.
- **Control effectiveness**: whether the controls defined in the policy are operating as designed, informed by the assessment results produced under **Policy 5.02**.
- **Operational relevance**: whether the policy's scope, directives, and controls remain appropriate given changes in the regulatory, technological, or operational environment since the prior review.
- **Workforce awareness**: whether personnel subject to the policy demonstrate awareness of and adherence to its requirements, informed by training and acknowledgment records maintained under **Policy 5.01**.
- **Regulatory alignment**: whether the policy's framework mappings and statutory citations remain current and accurate.

The review shall also encompass all appendices within Chapter 6 of the ECIO Policy Manual. The IT Director shall evaluate each appendix for currency and accuracy — whether its content reflects the current state of the policies, roles, frameworks, and operational structures it supports. Appendices do not receive maturity tier assignments; they are reference artifacts, not operational controls.

- **Clarification**: Standard Operating Procedures, playbooks, and other operational documentation maintained in the System of Engagement are not within the scope of this review. The currency of those documents is governed by **Policy 1.04** (Policy and Documentation Formatting Standards) and **Policy 3.13** (Knowledge Management Policy); their adequacy is tested through **Policy 5.02**.

The IT Director may delegate data compilation and preliminary analysis to the Assistant IT Director. The IT Director shall not delegate the maturity tier assignments or the preparation of the final Annual Policy Review Report.

6.2 Assessment Inputs

The IT Director shall base the annual policy review on the following governed set of inputs. The Assistant IT Director shall compile these inputs and present them to the IT Director prior to the commencement of the review.

- **Policy 5.07 Annual Audit Summary Report**: the consolidated results of all internal audits, self-assessments, and control tests conducted during the fiscal year, including conforming findings, observations, and deficiencies classified under Policy 5.02 Section 6.5.
- **Policy 5.04 annual KPI data**: the performance metrics and operational KPI results produced during the fiscal year, including any qualifying underperformance patterns identified under Policy 5.04.
- **Policy 3.16 annual improvement summary**: the summary of Service Improvement Register activity, triage decisions, and completed improvement actions produced under Policy 3.16.

- **Policy 5.03 open Corrective Action Plan status**: the current inventory of open Corrective Action Plans, their milestone status, and any plans that failed to achieve closure within the approved timeframe.
- **Policy 1.09 Risk Register status**: the current risk ratings, risk treatment decisions, and any risk posture changes recorded during the fiscal year.
- **Policy 5.01 enforcement and acknowledgment records**: the summary of enforcement actions taken during the fiscal year and the current status of policy acknowledgment compliance across all population classes.
- **Ad hoc inputs**: **Policy 4.07** (Postmortem Review and Lessons Learned) incident postmortem findings, external audit results, regulatory changes, and any other material that the IT Director determines is relevant to the review.

When an input defined above is not available at the time of review — for example, because a source policy has not yet been operationalized — the IT Director shall document the absence and note the impact on the maturity assessment for affected policies.

6.3 Maturity Scoring Methodology

The IT Director shall assign a maturity tier to each policy in the ECIO Policy Manual using criteria derived from the NIST Cybersecurity Framework (CSF) 2.0 Tier model. NIST CSF 2.0 defines Tiers as a characterization of the rigor of an organization's cybersecurity risk governance and management practices at the organizational level. This policy applies the Tier criteria as an internal scoring rubric for per-policy implementation effectiveness — an operational derivative, not a claim that NIST defines Tiers at individual-policy granularity.

The four (4) tiers, as adapted for per-policy maturity assessment, are:

- **Tier 1 — Partial**: The policy exists but its implementation is ad hoc, inconsistent, or reactive. Controls defined in the policy are not consistently applied. Assessment evidence under **Policy 5.02** is absent, incomplete, or shows material deficiencies. Personnel awareness is limited.
- **Tier 2 — Risk-Informed**: The policy is implemented with management awareness and risk-informed practices, but execution is not standardized across all areas within scope. Assessment evidence exists but reveals observations or inconsistencies. Corrective Action Plans under **Policy 5.03** may be in progress for controls governed by the policy.
- **Tier 3 — Repeatable**: The policy is consistently implemented across all areas within scope. Controls produce reliable, documented outcomes. Assessment evidence under **Policy 5.02** shows predominantly conforming results. The policy is reviewed and updated through the lifecycle process defined in **Policy 1.05**.
- **Tier 4 — Adaptive**: The policy implementation continuously improves based on audit findings, incident lessons learned, KPI data, and operational experience. Practices adapt proactively to changes in the threat environment, regulatory landscape, or operational context. Improvement activity under **Policy 3.16** is linked to the policy. Trend data shows sustained or improving maturity across two (2) or more consecutive review periods.

The IT Director shall document the rationale for each tier assignment. The rationale shall reference specific assessment inputs from Section 6.2 that support the determination.

- **Constraint**: The maturity tier assigned to a policy reflects the assessed state of implementation during the review period. It is not a target, a requirement, or a compliance standard. Tier assignment does not create an obligation to achieve a higher tier in the subsequent period. The IT Director may establish target tiers as a planning tool, but target tiers are advisory and do not carry enforcement consequences.

- **Clarification**: A policy that has been recently adopted or substantially revised may appropriately receive a Tier 1 or Tier 2 assignment in its first review cycle. A lower-tier assignment for a newly adopted policy does not constitute a deficiency.

6.4 Audit Program Effectiveness Review

As part of the annual policy review, the IT Director shall evaluate whether the internal audit program defined in **Policy 5.02** is being executed as designed.

The IT Director shall assess, at minimum:

- Whether the Annual Audit Plan was approved and executed within the cadences and scope requirements defined in **Policy 5.02** Section 6.1.
- Whether every policy in the ECIO Policy Manual received at least one (1) assessment — internal audit, self-assessment, or control test — during the fiscal year, as required by **Policy 5.02**.
- Whether policies governing controls subject to Criminal Justice Information Services (CJIS) Security Policy obligations received assessment through internal audit or control testing — not self-assessment alone — as required by **Policy 5.02**.
- Whether quarterly self-assessments were conducted on the cadence defined in **Policy 5.02** Section 6.2.
- Whether the control testing methodology defined in **Policy 5.02** Section 6.3 was applied consistently and produced documented results.
- Whether audit findings were classified and routed in accordance with **Policy 5.02** Section 6.5.
- Whether the objectivity safeguards defined in **Policy 5.02** Section 6.4 were maintained.

The IT Director shall document the results of this evaluation in the Annual Policy Review Report. The IT Director shall route deficiencies in the audit program in accordance with Section 6.7.

- **Rationale**: **Policy 5.02** cannot serve as its own assessment mechanism. This section provides the independent evaluation of the audit program that **Policy 5.02** Section 4 references through this policy.

6.5 Annual Policy Review Report

The IT Director shall prepare the Annual Policy Review Report as a single consolidated document following the conclusion of the annual review process. The IT Director shall document the report in the System of Engagement and classify it in accordance with **Policy 1.11**.

The Annual Policy Review Report shall contain, at minimum:

- The maturity tier assigned to each policy, with supporting rationale.
- Year-over-year tier comparison identifying policies that improved, maintained their tier, or regressed.
- A summary of the appendix currency and accuracy review, identifying any appendices requiring update.
- A summary of the audit program effectiveness review conducted under Section 6.4.
- The total number and classification of deficiencies identified during the review period, with current remediation status under **Policy 5.03**.
- A summary of open Corrective Action Plans and their impact on affected policy maturity assessments.
- A summary of regulatory, technological, or operational changes that affected or should affect policy content during the next review period.
- Recommendations for policy revisions to be initiated under **Policy 1.05**.
- Recommendations for the next annual audit cycle under **Policy 5.02**.

- Improvement candidates to be routed to the Service Improvement Register under **Policy 3.16**.

6.6 Executive Review

The IT Director shall submit the Annual Policy Review Report to the County Manager through the strategic reporting cadence established in **Policy 1.14** (Stakeholder Engagement and Communications Policy). The IT Director shall present the report during the Monthly Briefing following its completion and shall retain the report as an attachment to the corresponding Monthly Executive Report.

The County Manager shall provide written acknowledgment of receipt and review within thirty (30) calendar days of submission. The County Manager's review provides independent oversight of the annual review process and of the IT Director's execution of this policy. The County Manager may direct the IT Director to address specific concerns, conduct additional analysis, or revise maturity tier assignments with documented justification.

6.7 Findings Routing and Remediation

The IT Director shall route all actionable findings from the annual policy review through existing remediation and improvement pathways. This policy does not establish parallel tracking mechanisms, corrective action processes, or improvement registers.

- The IT Director shall route deficiencies in policy implementation or control effectiveness to **Policy 5.03** for Corrective Action Plan development.
- The IT Director shall initiate policy revisions identified through the review through the change control process defined in **Policy 1.05**.
- The IT Director shall route improvement opportunities that do not constitute deficiencies to the Service Improvement Register under **Policy 3.16**.
- The IT Director shall ensure that risk posture changes identified through the review are reflected in the Risk Register maintained under **Policy 1.09**.
- The IT Director shall route deficiencies in the audit program identified under Section 6.4 to **Policy 5.03** for Corrective Action Plan development and shall communicate those deficiencies to the County Manager in the Annual Policy Review Report.

6.8 Record Retention

The Assistant IT Director shall retain all annual policy review records — including scoring documentation, input summaries, working papers, the Annual Policy Review Report, and County Manager acknowledgment records — in the System of Engagement in accordance with **Policy 1.11** and the applicable Nevada Local Government Records Retention Schedule. Where multiple retention requirements apply, the longest applicable period shall govern.

The Assistant IT Director shall retain annual policy review records for a minimum of three (3) calendar years from the end of the calendar year to which they pertain, where no longer retention period is specified by an applicable schedule.

6. Appendices

6.01 Glossary and Definitions

6.02 Policy Matrix

Governance and Strategic Framework						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
1.01						
1.02						
1.03						
1.04						
1.05						
1.06						
1.07						
1.08						
1.09						
1.10						
1.11						
1.12						
1.13						
1.14						

Information Security						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
2.01						
2.02						
2.03						
2.04						
2.05						
2.06						
2.07						
2.08						
2.09						
2.10						
2.11						
2.12						
2.13						
2.14						
2.15						

Service Management and Operations						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
3.01						
3.02						
3.03						
3.04						
3.05						
3.06						
3.07						

Service Management and Operations						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
3.08						
3.09						
3.10						
3.11						
3.12						
3.13						
3.14						
3.15						
3.16						
3.17						

Incident Response						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
4.01						
4.02						
4.03						
4.04						
4.05						
4.06						
4.07						
4.08						

Compliance and Oversight						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
5.01						
5.02						
5.03						
5.04						
5.05						
5.06						
5.07						

Table 2 — Policy Dependency and Integration Matrix.

The governance flow map. Rows are ECIO policies, columns are Feeds, Defers To, and Receives From. A policy author asking "if I amend Policy 3.06, what else do I need to review?" scans the row and sees every downstream policy that receives from it. An IT Director asking "what is the full jurisdictional chain for a ransomware event?" traces the Feeds column from 3.12 through to 4.08. This table is an internal instrument — it lives in the document but is clearly labeled as internal governance reference, not the compliance artifact.

Governance and Strategic Framework				
ID	Policy Title	Feeds	Defers To	Receives From
1.01				

Governance and Strategic Framework				
ID	Policy Title	Feeds	Defers To	Receives From
1.02				
1.03				
1.04				
1.05				
1.06				
1.07				
1.08				
1.09				
1.10				
1.11				
1.12				
1.13				
1.14				

Information Security				
ID	Policy Title	Feeds	Defers To	Receives From
2.01				
2.02				
2.03				
2.04				
2.05				
2.06				
2.07				
2.08				
2.09				
2.10				
2.11				
2.12				
2.13				
2.14				
2.15				

Service Management and Operations				
ID	Policy Title	Feeds	Defers To	Receives From
3.01				
3.02				
3.03				
3.04				
3.05				
3.06				
3.07				
3.08				
3.09				
3.10				
3.11				

Service Management and Operations				
ID	Policy Title	Feeds	Defers To	Receives From
3.12				
3.13				
3.14				
3.15				
3.16				
3.17				

Incident Response				
ID	Policy Title	Feeds	Defers To	Receives From
4.01				
4.02				
4.03				
4.04				
4.05				
4.06				
4.07				
4.08				

Compliance and Oversight				
ID	Policy Title	Feeds	Defers To	Receives From
5.01				
5.02				
5.03				
5.04				
5.05				
5.06				
5.07				

6.03 Workforce Roles STAK Matrix

IT Trainee (Tier L0) *Focus: Learning & Assimilation*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Technical Literacy	Identify basic hardware and software components of IT systems.	Apply foundational IT concepts under supervision.	Computer hardware, operating systems, file systems.	CompTIA A+, SFIA ITOP 1
Troubleshooting	Assist with diagnosing and resolving common user issues.	Follow step-by-step guides and ask clarifying questions.	Basic diagnostic tools, error codes, support documentation.	CompTIA A+, SFIA USUP 1
Ticketing	Log basic user requests and document actions taken.	Use templates and follow format guidelines accurately.	Service desk ticketing systems, terminology standards.	Internal SOP, SFIA USUP 1
Professional Conduct	Demonstrate workplace etiquette, communication, and dress code adherence.	Follow department norms and seek feedback proactively.	Departmental ethos, communication protocols.	Internal Policy, SFIA METL 2
Security Awareness	Identify common security threats and acceptable use violations.	Report suspicious activity and avoid unsafe behavior.	CJIS Security Awareness (Level 2), Phishing, AUP.	CJIS 5.2, SFIA SCTY 2
Workflow	Participate in structured task rotations with Support and Admin teams.	Observe, document, and follow instructions across tasks.	Basic IT operations, workflow diagrams, tool usage norms.	Internal SOP, SFIA USUP 1
Certification	Study for and pass CompTIA A+ and Network+ within 12-month program.	Follow a learning plan, complete practice exams.	A+ exam domains and objectives.	CompTIA Learning Objectives

Administrative Assistant (Tier L1) *Focus: Process & Logistics*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Visitor Mgmt	Greet visitors to the IT department and verify identity as needed.	Follow visitor procedures and validate credentials confidently.	Visitor policy, ID types, physical access protocols.	Internal Policy, SFIA SCTY 2
Communication	Receive, direct, and document incoming calls and messages.	Communicate clearly and route requests to appropriate personnel.	Departmental structure, communication etiquette.	Internal SOP, SFIA CSMG 2
Documentation	Assist with formatting and distributing IT communica-tions.	Use templates and maintain consistent document structure.	Style guides, document handling protocols.	Policy 1.04, SFIA ADMN 2
Scheduling	Coordinate meetings, reserve rooms, and manage calendars.	Use scheduling tools and communicate availability accurately.	Calendar software, internal scheduling policies.	SFIA ADMN 2
Onboarding	Prepare materials and coordinate logistics for new IT staff onboarding.	Assemble packets and liaise with HR and mentors.	Onboarding checklist, training materials.	SFIA ADMN 2
Inventory	Receive and track basic IT inventory deliveries.	Check items against invoices and update inventory records.	Receiving processes, asset tags, inventory system.	SFIA ASMG 2
Credential Support	Assist with basic password resets (Non-Privileged Only).	MUST verify identity per **Policy 2.05** prior to any reset.	Password policy, social engineering indicators.	NIST IA-2, SFIA USUP 2

Support Specialist (Tier L2) *Focus: Service & Resolution*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Endpoint Support	Diagnose and resolve issues with desktops, laptops, and mobile devices.	Apply structured troubleshooting methods.	Windows/macOS, drivers, BIOS, performance tools.	NICE IO-WRL-007, SFIA ITOP 3
Peripheral Config	Install and configure local and networked print-ers/scanners.	Troubleshoot connectivity and driver-related issues.	Print spoolers, network shares, vendor support tools.	NICE IO-WRL-007, SFIA ITOP 3
App Support	Configure and troubleshoot common software (Email, Office, PDF).	Assist users with usage errors and patches.	Outlook, Microsoft Office, Adobe tools, user profiles.	NICE IO-WRL-007, SFIA CSMG 3
User Support	Interact with end-users to understand, resolve, or escalate issues.	Listen actively, communicate clearly, and remain professional.	Service culture, escalation triggers, empathy principles.	NICE IO-WRL-007, SFIA CSMG 3
Identity Mgmt	Reset passwords and verify user identity across systems.	Follow documented verification and reset procedures.	Authentication policies, MFA workflows.	NICE IO-WRL-007, SFIA SCAD 3
Asset Deployment	Provision, label, and deploy new IT assets to users.	Follow imaging checklists and ensure successful deployment.	Imaging tools, inventory control, naming conventions.	NICE IO-WRL-007, SFIA HSIN 3
Ticketing	Log all work performed in the service management system.	Use clear, structured language and document resolution.	Service desk taxonomy, change history recording.	NICE IO-WRL-007, SFIA ASUP 3
Escalation	Escalate issues appropriately when outside Tier 1 authority.	Recognize issue boundaries and route to the correct tier.	Escalation policies, troubleshooting boundaries.	NICE IO-WRL-007, SFIA USUP 3
Security Check	Verify antivirus, patches, and device encryption on devices.	Use tools to check compliance and document findings.	AV software, update tools, Bit-Locker/FileVault.	NICE IO-WRL-007, SFIA SCTY 3

Network Administrator (Tier L3) *Focus: Connectivity & Boundary Defense*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Net Architecture	Design and document LAN, WAN, and wireless topologies.	Develop scalable, fault-tolerant network designs.	IP subnetting, VLANs, routing protocols, topology models.	NICE IO-WRL-004, SFIA NTDS 5
Device Config	Configure routers, switches, firewalls, and wireless controllers.	Apply configurations using CLI and GUI tools per standards.	IOS/CLI, DHCP, DNS, NAT, VLAN tagging.	NICE IO-WRL-004, SFIA ITOP 4
Firewall Mgmt	Implement and audit firewall rule sets and ACLs.	Balance functionality and security based on least privilege.	Firewall zones, rule ordering, logging, VPN passthrough.	NICE PD-WRL-004, SFIA SCTY 5
Monitoring	Monitor traffic, performance, and respond to anomalies.	Use SNMP, syslog, and flow tools to identify root causes.	SNMP, NetFlow, ping/traceroute, log correlation.	NICE IO-WRL-004, SFIA NTAS 4
VPN/Remote	Deploy and manage secure remote access tunnels.	Configure site-to-site and client VPNs with authentication.	IPSec, SSL VPNs, RADIUS, MFA integrations.	NICE IO-WRL-004, SFIA NTAS 5
Security Compliance	Enforce and verify compliance with network security standards.	Audit configurations and isolate insecure behaviors.	NIST 800-53 AC/SC, CJIS encryption standards.	NICE PD-WRL-004, SFIA SCTY 5
Change Mgmt	Submit and execute approved changes to live configurations.	Prepare rollback plans and follow documentation procedures.	CAB process, change forms, outage notification steps.	NICE OG-WRL-002, SFIA CHMG 4
Risk Audit	Conduct self-audits of networking systems and identify risks.	Map risks to controls and support mitigation planning.	CIS Controls, NIST CSF, CJIS 5.9.	NICE OG-WRL-012, SFIA AUDT 4

Systems Administrator (Tier L3) *Focus: Server Infrastructure & Data Integrity*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Server Provisioning	Build and configure physical and virtual servers.	Install OS, configure baseline, and join to directory.	Hyper-V/VMware, Windows/Linux, Active Directory.	NICE IO-WRL-005, SFIA ITOP 4
Database Mgmt	Maintain integrity, backups, and encryption (TDE) of SQL.	Ensure availability and CJIS-compliant storage.	SQL, Oracle, CJIS 5.10, Backup strategies.	NICE IO-WRL-002, SFIA DBAD 4
Identity Mgmt	Create, manage, and audit user accounts and permissions.	Apply RBAC and enforce least-privilege principles.	Active Directory, GPOs, NTFS permissions, LDAP.	NICE IO-WRL-005, SFIA SCAD 4
Patch Mgmt	Apply OS and application patches according to policy.	Use automated tools to deploy and verify patches.	WSUS/SCCM, CVSS scoring, patch windows.	NICE IO-WRL-005, SFIA VUAS 4
System Monitoring	Monitor and optimize system health and performance.	Interpret logs, counters, and alerts to maintain uptime.	Event Viewer, Performance Monitor, SNMP traps.	NICE IO-WRL-005, SFIA ASUP 4
Backup & Recovery	Configure, monitor, and test system backups/DR.	Perform restorations to verify data integrity.	Veeam/Altaro, RTO/RPO, DR planning.	NICE IO-WRL-005, SFIA STMG 4
Config Mgmt	Document and manage baseline configura-tions/changes.	Maintain golden images and enforce approved changes.	CMDB, configuration scripts, version control tools.	NICE IO-WRL-005, SFIA CFMG 4
Security Hardening	Apply security policies and controls to managed systems.	Disable unnecessary services, enforce baselines, audit logs.	CIS Benchmarks, STIGs, NIST AC & SC families.	NICE IO-WRL-006, SFIA SCTY 5
Scripting	Write scripts to automate administration tasks.	Use Power-Shell/Bash to streamline repeatable operations.	PowerShell syntax, Bash scripting, task scheduling.	NICE IO-WRL-005, SFIA PROG 3
Audit Support	Produce system data and evidence during audits.	Export logs, review access, and respond to findings.	CJIS 5.9, NIST 800-53, audit log tools.	NICE OG-WRL-012, SFIA AUDT 4

Assistant IT Director (Tier L4) *Focus: Operations & Governance Execution*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Ops Oversight	Supervise day-to-day operations of support/infra teams.	Coordinate workstreams and monitor SLA adherence.	ITIL service management, workflows, escalation paths.	NICE OG-WRL-010, SFIA ITMG 5
Project Mgmt	Manage the departmental IT project portfolio.	Track milestones, allocate resources, resolve conflicts.	Project lifecycle models, PM tools, resource balancing.	NICE OG-WRL-011, SFIA POMG 5
Vendor Mgmt	Oversee IT vendor contracts and SLAs.	Negotiate terms, assess performance, manage renewals.	Procurement policy, SLA frameworks, vendor scorecards.	NICE OG-WRL-009, SFIA SUPP 5
Policy Enforcement	Ensure compliance with internal IT policies and regulations.	Conduct reviews and implement corrective actions.	Departmental policies, NIST 800-53, CJIS 5.9.	NICE OG-WRL-002, SFIA BURM 5
Staff Dev	Lead performance management and career planning.	Conduct evaluations, set goals, provide feedback.	HR frameworks, coaching methods, performance tracking.	NICE OG-WRL-003, SFIA PDSV 5
Budget Control	Support financial planning and cost monitoring.	Develop budgets, track spend, optimize expenses.	Public budgeting standards, procurement systems.	NICE OG-WRL-010, SFIA FMIT 5
Incident Escalation	Serve as escalation authority for major incidents.	Coordinate response teams and ensure resolution.	Incident response plans, service continuity procedures.	NICE PD-WRL-003, SFIA USUP 5
Change Leadership	Oversee and authorize operational changes.	Evaluate change impact and ensure communication.	Change Advisory Board (CAB) process.	NICE OG-WRL-002, SFIA CHMG 5

IT Director (Tier L5) *Focus: Strategy, Risk & Executive Leadership*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Strategic Planning	Develop and maintain multi-year IT strategy.	Synthesize input from departments into strategic goals.	COBIT, NIST CSF, public sector planning cycles.	NICE OG-WRL-007, SFIA ITSP 6
Governance	Define and oversee implementation of IT governance.	Evaluate frameworks and tailor controls to needs.	COBIT 2019, CJIS Security Policy, NIST 800-53.	NICE OG-WRL-007, SFIA GOVN 6
Executive Mgmt	Represent IT in executive meetings and collaborations.	Communicate IT initiatives in terms of strategic impact.	Government budgeting processes, dependencies.	NICE OG-WRL-007, SFIA RLMT 6
Risk Mgmt	Oversee IT risk management (CISO function).	Evaluate risk posture and approve mitigation strategies.	CJIS 5.9, NIST RMF, risk register maintenance.	NICE OG-WRL-007, SFIA BURM 6
Policy Approval	Approve department-level IT policies.	Authorize and delegate policy enforcement.	Policy development lifecycle, governance standards.	NICE OG-WRL-002, SFIA GOVN 6
Budget Oversight	Develop and manage the annual IT budget.	Balance strategic initiatives with operational needs.	Capital and operational budgeting, procurement.	NICE OG-WRL-007, SFIA FMIT 6
Innovation	Evaluate emerging technologies for strategic adoption.	Facilitate pilot programs and implementation strategies.	Tech scanning, cost-benefit analysis, change leadership.	NICE OG-WRL-007, SFIA INOV 6
Leadership	Provide leadership to the Assistant Director and staff.	Set vision, model expectations, guide culture.	Organizational development, public accountability.	NICE OG-WRL-003, SFIA PEMT 6

6.04 Revision History and Version Control